Verification Security Application Standard

5.0.0 Version



2025 May

ف‌ه‌رس‌ت

ص‌ف‌ح‌ه اص‌ل‌ی 7
درب‌اره ای‌ن اس‌ت‌ان‌دارد 7
ک‌پ‌ی‌رای‌ت و م‌ج‌وز 7
س‌رپ‌رس‌ت‌ان پ‌روژه 7
گ‌روه ک‌اری 7
س‌ای‌ر ه‌م‌ک‌اران اص‌ل‌ی 7
م‌ش‌ارک‌ت‌ک‌ن‌ن‌د‌گ‌ان و ب‌ازب‌ی‌ن‌ه‌ای د‌ی‌گ‌ر 8

پ‌ی‌ش‌گ‌ف‌ت‌ار **8**
م‌ق‌دم‌ه 8
اص‌ول ک‌ل‌ی‌د‌ی ن‌س‌خ‌ه ۵.۰ 8
چ‌ش‌م‌ان‌داز آ‌ی‌ن‌ده 9

ASVS چ‌ی‌س‌ت؟ **9**
دام‌ن‌ه ASVS 9
Application 10
ام‌ن‌ی‌ت 10
ت‌أ‌ی‌ی‌د 10
اس‌ت‌ان‌دارد 10
ال‌زام (Requirement) 11
ت‌ص‌م‌ی‌م‌ات ام‌ن‌ی‌ت‌ی م‌س‌ت‌ن‌د‌ش‌ده 11
س‌ط‌وح ت‌أ‌ی‌ی‌د ام‌ن‌ی‌ت ب‌رن‌ام‌ه‌ه‌ای ک‌ارب‌ردی 12
ارزی‌اب‌ی س‌ط‌وح 12
س‌ط‌ح ۱ 13
س‌ط‌ح ۲ 13
س‌ط‌ح ۳ 13
ک‌دام س‌ط‌ح را ان‌ت‌خ‌اب ک‌ن‌ی‌م 14
چ‌گ‌ون‌ه از ASVS اس‌ت‌ف‌اده ک‌ن‌ی‌م 14
س‌اخ‌ت‌ار ASVS 14
strategy Release 14
ان‌ع‌ط‌اف‌پ‌ذ‌ی‌ری در اس‌ت‌ف‌اده از ASVS 15
ن‌ح‌وه ارج‌اع ب‌ه ال‌زام‌ات ASVS 15
ف‌ورک ک‌ردن (Forking) ASVS 16
م‌وارد اس‌ت‌ف‌اده از ASVS 16
ب‌ه‌ع‌ن‌وان راه‌ن‌م‌ای د‌ق‌ی‌ق م‌ع‌م‌اری ام‌ن‌ی‌ت‌ی 16
ب‌ه‌ع‌ن‌وان م‌رج‌ع ت‌خ‌ص‌ص‌ی ب‌رای ب‌رن‌ام‌ه‌ن‌وی‌س‌ی ام‌ن 16
ب‌ه‌ع‌ن‌وان راه‌ن‌م‌ای آ‌زم‌ون‌ه‌ای واح‌د و ی‌ک‌پ‌ارچ‌ه‌س‌ازی خ‌ود ک‌ار 16
ب‌رای آ‌م‌وزش ت‌وس‌ع‌ه ام‌ن 17
ب‌ه‌ع‌ن‌وان چ‌ارچ‌وب‌ی ب‌رای راه‌ن‌م‌ای‌ی در خ‌ری‌د ن‌رم‌اف‌زار ام‌ن 17
ک‌ارب‌رد ع‌م‌ل‌ی ASVS 17

ارزیابی و صدور گواهی **17**
دیدگاه OWASP در مورد گواهی‌نامه‌ها و نشان‌های اعتماد ASVS 17
نحوه تأیید انطباق با ASVS 18
گزارش‌گیری ارزیابی 18
دامنه ارزیابی 18
روش‌های ارزیابی 18

تغییرات نسبت به نسخه 4.x **20**
مقدمه 20
فلسفه الزامات 20
دامنه و تمرکز. 20
تمرکز بر اهداف امنیتی به‌جای سازوکارها 20
تصمیم‌مات امنیتی مستند 20
تغییرات ساختاری و فصل‌های جدید 21
حذف نگاشت مستقیم با استانداردهای دیگر 22
کاهش وابستگی به دستورالعمل‌های هویت دیجیتال NIST 22
فاصله گرفتن از نگاشت CWE 22
بازنگری در تعریف سطوح (Levels) 22
ورود ساده‌تر به سطح اول 22
افسانه قابلیت آزمون‌پذیری 23
فقط ریسک مطرح نیست 23

Sanitization and Encoding V1 **23**
هدف 23
V1.1 ساختار Sanitization and Encoding 24
V1.2 پیشگیری از تزریق 24
V1.3 پاکسازی (Sanitization) 26
V1.4 حافظه، رشته و کد بدون مدیریت (Memory, String, and Unmanaged Code) 27
V1.5 سریال‌زدایی ایمن (Safe Deserialization) 28
References 29

Logic Business and Validation V2 **29**
هدف 29
V2.1 مستندات اعتبارسنجی و منطق کسب‌وکار (Business Logic and Validation Documentation) 30
V2.2 اعتبارسنجی ورودی (Input Validation) 30
V2.3 امنیت منطق کسب‌وکار (Business Logic Security) 31
V2.4 مقابله با خودکارسازی (Anti-automation) 32
References 33

V3 امنیت رابط کاربری وب (Web Frontend Security) **33**
هدف کنترلی 33
V3.1 مستندسازی امنیت رابط کاربری وب (Web Frontend Security Documentation) 33

34 . . . . . V3.2 تف‌سی‌ر ناخواسته محتوا Interpretation) Content (Unintended
34 . . . . . V3.3 پی‌ کی‌ربندی کوکی Setup) (Cookie
35 . . . . . V3.4 هدره‌ای مکانی‌زم‌ه‌ای امنیتی مرورگر Headers) Mechanism Security (Browser
37 . . . . . V3.5 تف کی‌ ک مبدا توسط مرورگر Separation) Origin (Browser
38 . . . . . V3.6 ی ک‌پارچ گی منابع خارجی Integrity) Resource (External
39 . . . . . V3.7 سای‌ر ملاحظات امنیتی مرورگر Considerations) Security Browser (Other
39 . . . . . References

40 Service Web and API V4

40 . . . . . هدف
40 . . . . . Security Service Web Generic V4.1
41 . . . . . Validation Structure Message HTTP V4.2
42 . . . . . GraphQL V4.3
42 . . . . . WebSocket V4.4
43 . . . . . References

43 Handling File V5

43 . . . . . هدف
44 . . . . . Documentation Handling File V5.1
44 . . . . . Content and Upload File V5.2
45 . . . . . Storage File V5.3
45 . . . . . Download File V5.4
46 . . . . . References

46 Authentication V6

46 . . . . . Objective Control
47 . . . . . Documentation Authentication V6.1
47 . . . . . Security Password V6.2
48 . . . . . Security Authentication General V6.3
50 . . . . . Recovery and Lifecycle Factor Authentication V6.4
51 . . . . . requirements authentication Multi-factor General V6.5
52 . . . . . mechanisms authentication Out-of-Band V6.6
53 . . . . . mechanism authentication Cryptographic V6.7
54 . . . . . Provider Identity an with Authentication V6.8
55 . . . . . References

55 Management Session V7

55 . . . . . هدف
56 . . . . . Documentation Management Session V7.1
57 . . . . . Security Management Session Fundamental V7.2
57 . . . . . Timeout Session V7.3
58 . . . . . Termination Session V7.4

59 . . . . . Abuse Session Against Defenses V7.5
59 . . . . . Re-authentication Federated V7.6
60 . . . . . References

60 Authorization V8
60 . . . . . هدف
60 . . . . . Documentation Authorization V8.1
61 . . . . . Design Authorization General V8.2
62 . . . . . Authorization Level Operation V8.3
62 . . . . . Considerations Authorization Other V8.4
63 . . . . . References

63 Tokens Self-contained V9
63 . . . . . هدف
63 . . . . . integrity and source Token V9.1
64 . . . . . content Token V9.2
65 . . . . . References

65 OIDC and OAuth V10
65 . . . . . هدف
67 . . . . . Security OIDC and OAuth Generic V10.1
68 . . . . . Client OAuth V10.2
69 . . . . . Server Resource OAuth V10.3
70 . . . . . Server Authorization OAuth V10.4
72 . . . . . Client OIDC V10.5
73 . . . . . Provider OpenID V10.6
73 . . . . . Management Consent V10.7
74 . . . . . References

75 Cryptography V11
75 . . . . . هدف
75 . . . . . Documentation and Inventory Cryptographic V11.1
76 . . . . . Implementation Cryptography Secure V11.2
77 . . . . . Algorithms Encryption V11.3
78 . . . . . Functions Hash-based and Hashing V11.4
79 . . . . . Values Random V11.5
79 . . . . . Cryptography Key Public V11.6
80 . . . . . Cryptography Data In-Use V11.7
80 . . . . . References

81 Communication Secure V12
81 . . . . . هدف
81 . . . . . Guidance Security TLS General V12.1

82 . . . . . Services Facing External with Communication HTTPS V12.2
82 . . . . . Security Communication Service to Service General V12.3
83 . . . . . References

83 Configuration V13
83 . . . . . هدف
83 . . . . . Documentation Configuration V13.1
84 . . . . . Configuration Communication Backend V13.2
85 . . . . . Management Secret V13.3
86 . . . . . Leakage Information Unintended V13.4
87 . . . . . References

87 Protection Data V14
87 . . . . . هدف
87 . . . . . Documentation Protection Data V14.1
88 . . . . . Protection Data General V14.2
89 . . . . . Protection Data Client-side V14.3
90 . . . . . References

90 Architecture and Coding Secure V15
90 . . . . . Objective Control
90 . . . . . Documentation Architecture and Coding Secure V15.1
91 . . . . . Dependencies and Architecture Security V15.2
92 . . . . . Coding Defensive V15.3
93 . . . . . Concurrency Safe V15.4
94 . . . . . References

94 Handling Error and Logging Security V16
94 . . . . . هدف
95 . . . . . Documentation Logging Security V16.1
95 . . . . . Logging General V16.2
96 . . . . . Events Security V16.3
97 . . . . . Protection Log V16.4
97 . . . . . Handling Error V16.5
98 . . . . . References

98 WebRTC V17
98 . . . . . هدف
99 . . . . . Server TURN V17.1
100 . . . . . Media V17.2
101 . . . . . Signaling V17.3
102 . . . . . References

102 Glossary A: Appendix

108 References B: Appendix
109 . . . . . Projects Core OWASP
109 . . . . . project Series Sheet Cheat OWASP
109 . . . . . Projects Related Security Mobile
109 . . . . . projects related Things of Internet OWASP
109 . . . . . projects Serverless OWASP
109 . . . . . Others

110 Standards Cryptography C: Appendix
110 . . . . . Documentation and Inventory Cryptographic
110 . . . . . Parameters Cryptographic of Strengths Equivalent
111 . . . . . Values Random
112 . . . . . Algorithms Cipher
113 . . . . . Modes Cipher AES
114 . . . . . Wrapping Key
114 . . . . . Encryption Authenticated
115 . . . . . Functions Hash
115 . . . . . Cases Use General for Functions Hash
116 . . . . . Storage Password for Functions Hash
117 . . . . . (KDFs) Functions Derivation Key
117 . . . . . Functions Derivation Key General
117 . . . . . Functions Derivation Key Password-based
118 . . . . . Mechanisms Exchange Key
118 . . . . . Schemes KEX
118 . . . . . groups Diffie-Hellman
119 . . . . . (MAC) Codes Authentication Message
120 . . . . . Signatures Digital
120 . . . . . Standards Encryption Post-Quantum

121 Recommendations D: Appendix
121 . . . . . Introduction
121 . . . . . mechanisms in-scope Recommended,
121 . . . . . principles Security Software
122 . . . . . processes Security Software

123 Contributors - E Appendix

صفحه اصلی

درباره این استاندارد

استاندارد تأیید امنیت نرم‌افزار (ASVS)، فهرستی از الزامات امنیتی برای نرم‌افزارهاست که مهم‌اران، توسعه‌دهندگان، آزمون‌گران، متخصصان امنیت، فروشندگان ابزار و مصرف‌کنندگان می‌توانند از آن برای تعریف، ساخت، آزمون و تأیید امنیت برنامه‌های نرم‌افزاری استفاده کنند.

کپی‌رایت و مجوز

2025 May 5.0.0, Version



شکل 1: license

Foundation. OWASP The 2008-2025 © Copyright

این سند تحت مجوز Creative Commons Attribution-ShareAlike 4.0 International License منتشر شده است.

در هرگونه بازنشر یا توزیع، باید شرایط این مجوز را به‌روشنی به دیگران اعلام نمایید.

سرپرستان پروژه

Josh C Grossman Elar Lang

Daniel Cuthbert Jim Manico

گروه کاری

Corona Gabriel Armstrong Ryan Sharafaldin Iman Prutchi Shanni Andalis Ralph Ahnoff Tobias Jacquot Meghan Yardeni Eden

سایر همکاران اصلی

Isaac Lewis Sjoerd Langkemper

Mark Carney Sandro Gauci

مشارکت کنندگان و بازبینه‌ای دیگر

فهرست سایر مشارکت کنندگان در ضمیمه E درج شده است.

در صورتی که نام فردی در فهرست اعتبارهای نسخه x.5 ذکر نشده باشد، لطفاً با ثبت تی کت در گیتهاب، نسبت به شناساندن ایشان در به‌روزرسانی‌های آتی نسخه x.5 اقدام فرمایید.

استاندارد ASVS بر پایه‌ی تلاش‌های افراد درگیر در نسخه‌های ۱.۰ (۲۰۰۸) تا ۴.۰ (۲۰۱۹) بنا شده است. بسیاری از ساختارها و اقلام تأییدی که امروزه در ASVS باقی مانده‌اند، در ابتدا توسط Andrew van der Williams Jeff Boberski، Mike Stock، و Wichers Dave نوشته شده‌اند، در کنار بسیاری دیگر از مشارکت-کنندگان. از همه کسانی که در گذشته مشارکت داشته‌اند صمیمانه سپاسگزاریم. برای مشاهده فهرست کامل مشارکت کنندگان پیشین، لطفاً به هر نسخه‌ی قبلی مراجعه نمایید.

پیشگفتار

به نسخه ۵.۰ استاندارد تأییدی امنیت نرم‌افزار (ASVS) خوش آمدید.

مقدمه

استاندارد ASVS که در سال ۲۰۰۸ و از طریق همکاری یک جامعه جهانی راه‌اندازی شد، ASVS مجموعه‌ای جامع از الزامات امنیتی برای طراحی، توسعه و آزمون برنامه‌ها و خدمات وب مدرن تعریف می‌کند.

پس از انتشار نسخه ۴.۰ در سال ۲۰۱۹ و به‌روزرسانی جزئی آن (نسخه ۴.۰.۳ در سال ۲۰۲۱)، نسخه ۵.۰ یک نقطه‌ی عطف مهم به شمار می‌آید—این نسخه برای همراستایی با آخرین پیشرفت‌ها در حوزه‌ی امنیت نرم‌افزار، به‌روزرسانی و مدرن‌سازی شده است.

نسخه ۵.۰ نتیجه‌ی مشارکت گسترده سرپرستان پروژه، اعضای گروه کاری و جامعه بزرگ OWASP در راستای به‌روزرسانی و ارتقای این استاندارد مهم است.

اصول کلیدی نسخه ۵.۰

این بازنگری عمده با چند اصل کلیدی طراحی و توسعه یافته است:

- حوزه و تمرکز دقیق‌تر: این نسخه از استاندارد به گونه‌ای طراحی شده تا همراستا با ارکان اصلی موجود در نام آن باشد: برنامه کاربردی، امنیت، تأیید و استاندارد. الزامات به گونه‌ای بازنویسی شده‌اند که پیشگیری از نقص‌های امنیتی را در اولویت قرار دهند، نه الزام به پیاده‌سازی‌های فنی خاص. متن الزامات به‌صورت خودتوضیحی نگاشته شده‌اند تا چرایی وجود هر مورد را روشن کنند.

- پشتیبانی از تصمیمات مستند امنیتی: نسخه ۵.۰ الزامات جدیدی برای مستندسازی تصمیمات کلیدی امنیتی معرفی کرده است. این اقدام موجب افزایش قابلیت ردیابی شده و پیادهسازیهای متناسب با زمینه (context) را پشتیبانی میکند، به سازمانها اجازه میدهد تا موضع امنیتی خود را با نیازها و ریسکهای خاص خود تطبیق دهند.
- سطوح بهروزشده :درحالیکه مدل سهسطحی ASVS حفظ شده است، تعاریف سطحها بازطراحی شدهاند تا پذیرش آن سادهتر گردد. سطح ۱ بهعنوان گام آغازین برای پذیرش ASVS طراحی شده و لایهی نخست دفاعی را فراهم میآورد. سطح ۲ نمایانگر دیدی جامع از رویههای استاندارد امنیتی است. سطح ۳ به نیازهای پیشرفته و با تضمین بالا میپردازد.
- محتوای بازآراییشده و گستردهشدهتر: نسخه ۵.۰ شامل حدود ۳۵۰ الزام در قالب ۱۷ فصل است. فصلها بهمنظور وضوح بیشتر و سهولت استفاده، بازسازماندهی شدهاند. نگاشتی دوسویه بین نسخههای ۴.۰ و ۵.۰ نیز ارائه شده تا فرآیند مهاجرت را تسهیل نمایند.

چشمانداز آینده

همانطورکه تأمین امنیت یک نرمافزار هرگز نقطهی پایان ندارد، ASVS نیز بهعنوان یک استاندارد همواره در حال توسعه است. گرچه نسخه ۵.۰ یک انتشار عمده بهشمار میآید، اما روند توسعه ادامه خواهد داشت. این نسخه، همزمان با فراهمسازی دسترسی جامعه وسیعتری به بهبودها و افزودههای صورت-گرفته، بستری برای ارتقاهای آینده نیز فراهم میکند. از جمله این موارد، میتوان به تلاشهای جامعهمحور برای ایجاد راهنمای پیادهسازی و تأیید بر پایهی مجموعه الزامات اصلی اشاره کرد.

ASVS 5.0 بهمنظور فراهمسازی یک پایهی قابلاعتماد برای توسعهی نرمافزار امن طراحی شده است. ما از جامعه دعوت میکنیم تا این استاندارد را بپذیرند، در آن مشارکت کنند و بر پایهی آن، اقدامات بیشتری انجام دهند؛ تا بهصورت جمعی، وضعیت امنیت برنامههای نرمافزاری را ارتقا دهیم.

ASVS چیست؟

استاندارد تأیید امنیت نرمافزار (ASVS) مجموعهای از الزامات امنیتی برای برنامهها و خدمات وب تعریف میکند و منبعی ارزشمند برای تمامی افرادی است که قصد دارند برنامههای ایمن طراحی، توسعه یا نگهداری کنند یا امنیت آنها را ارزیابی نمایند.

این فصل به جنبههای اساسی استفاده از ASVS ، از جمله دامنه کاربرد، ساختار سطوح اولویت-بندیشده، و موارد اصلی استفاده از این استاندارد میپردازد.

دامنه ASVS

دامنه استاندارد ASVS از نام آن الهام گرفته شده است: برنامه کاربردی(Application)، امنیت(Security)، تأیید(Verification) و استاندارد(Standard). این دامنه مشخص میکند که چه الزامی گنجانده یا مستثنی شده است و هدف اصلی آن، شناسایی اصول امنیتیای است که باید محقق شوند. دامنه همچنین الزامات مستندسازی را نیز در بر میگیرد که پایههای برای الزامات پیادهسازی محسوب میشود.

برای مهاجمان، چیزی به نام «دامنه» معنا ندارد؛ بنابراین الزامات ASVS باید در کنار راهنماهایی برای سایر جنبه‌های چرخه عمر نرم‌افزار، مانند فرآیندهای CI/CD، میزبانی و عملیات اجرایی مورد ارزیابی قرار گیرد.

Application

ASVS، "برنامه" را به‌عنوان محصول نرم‌افزاری در حال توسعه تعریف می‌کند که کنترل‌های امنیتی باید درون آن گنجانده شود. ASVS فعالیت‌های چرخه عمر توسعه یا نحوه ساخت برنامه از طریق فرآیند CI/CD را تجویز نمی‌کند، بلکه بر نتایج امنیتی مورد انتظار درون خود محصول تمرکز دارد.

اجزایی مانند load balancer WAF، یا پراکسی‌هایی که ترافیک HTTP را پردازش، اصلاح یا اعتبارسنجی می‌کنند، ممکن است به‌منظور خاصی بخشی از برنامه تلقی شوند، زیرا برخی کنترل‌های امنیتی مستقیماً به آن‌ها وابسته هستند یا از طریق آن‌ها پیاده‌سازی می‌شوند. این اجزا باید در الزاماتی که مرتبط با Response Cache، Rate Limite، یا کنترل ارتباطات ورودی و خروجی بر اساس مبدا و مقصد در نظر گرفته شوند.

در مقابل، ASVS به‌طور کلی الزاماتی را که مستقیماً مرتبط با برنامه نیستند یا پیکربندی آن‌ها خارج از حوزه مسئولیت برنامه است، مستثنی می‌کند. به‌عنوان مثال، مسائل مرتبط با DNS معمولاً توسط تیم یا واحدی مجزا مدیریت می‌شود.

به‌طور مشابه، اگرچه برنامه مسئول نحوه دریافت ورودی و تولید خروجی است، ولی اگر یک فرآیند خارجی با برنامه یا داده‌های آن تعامل داشته باشد، خارج از دامنه ASVS محسوب می‌شود. به‌عنوان نمونه، پشتیبان‌گیری از برنامه یا داده‌های آن، عموماً برعهده یک فرآیند خارجی است و در کنترل برنامه یا توسعه‌دهندگان آن قرار ندارد.

امنیت

هر الزام باید تأثیری قابل اندازه‌گیری بر امنیت داشته باشد. عدم وجود یک الزام باید منجر به ناامن‌تر شدن برنامه شود و پیاده‌سازی آن الزام باید احتمال وقوع یا تأثیر یک ریسک امنیتی را کاهش دهد.

سایر ملاحظات مانند جنبه‌های عملکردی، سبک کدنویسی یا الزامات سیاستی خارج از دامنه ASVS هستند.

تأیید

هر الزام باید قابل تأیید باشد و نتیجه تأیید باید منجر به تصمیم "موفق" یا "ناموفق" گردد.

استاندارد

ASVS مجموعه‌ای از الزامات امنیتی است که برای انطباق با استاندارد باید پیاده‌سازی شوند. به همین دلیل، الزامات به تعریف هدف امنیتی‌ای محدود می‌شوند که باید محقق گردد. اطلاعات جانبی

می‌توانند بر پایه ASVS ساخته شود یا از طریق نگاشت به آن متصل گردد.

به‌طور خاص، OWASP دارای پروژه‌های متعددی است و ASVS به‌صورت آگاهانه از تکرار محتوای سایر پروژه‌ها اجتناب کرده است. به‌عنوان مثال، اگر توسعه‌دهنده‌ای بپرسد "چگونه باید فلان الزام را در فناوری خاص خود پیاده‌سازی کنم"، این سؤال در حوزه پروژه Series Sheet Cheat قرار می‌گیرد. اگر ارزیاب بپرسد "چگونه بایدِ این الزام را در این محیط آزمون کنم"، پاسخ آن در پروژه Security Web Guide Testing یافت می‌شود

در حالی که ASVS فقط برای استفاده متخصصان امنیت طراحی نشده، انتظار می‌رود که خواننده دانش فنی کافی برای درک محتوا یا توانایی جست‌وجو درباره مفاهیم خاص را داشته باشد.

الزام (Requirement)

واژه "الزام" در ASVS دقیقاً برای توصیف آنچه باید برای تأمین امنیت انجام شود به‌کار می‌رود. ASVS فقط شامل الزامات (must) است و توصیه‌ها (should) را به‌عنوان شرط اصلی شامل نمی‌شود.

به‌عبارت دیگر، توصیه‌هایی که ممکن است فقط یکی از راه‌حل‌های ممکن یا ملاحظات سبک کنونی باشند، در تعریف "الزام" نمی‌گنجند.

الزامات ASVS برای پاسخ‌گویی به اصول امنیتی خاص طراحی شده‌اند، بدون آنکه به روش پیاده‌سازی یا فناوری خاصی وابسته باشند، و در عین حال به گونه‌ای نوشته شده‌اند که خودبه‌خود دلیل وجودشان را توضیح دهند. این بدین معناست که الزامات مبتنی بر یک روش تأیید یا پیاده‌سازی خاص نیستند.

تصمیمات امنیتی مستندشده

در امنیت نرم‌افزار، طراحی و مشخص کردن سازوکارهای امنیتی به موقع منجر به پیاده‌سازی‌ای منسجم‌تر و قابل‌اعتمادتر در محصول نهایی یا ویژگی موردنظر می‌شود.

علاوه بر این، برخی الزامات به گونه‌ای هستند که پیاده‌سازی آن‌ها بسیار خاص و وابسته به زیازه‌ای هر برنامه است. برای مثال، کنترل مجوزها، اعتبارسنجی ورودی‌ها و کنترل‌های محافظتی بر روی سطوح مختلف داده‌ای حساس.

برای حل این موضوع، به‌جای بیانه‌ای کلی مثل "تمام داده‌ها باید رمزگذاری شوند" یا تلاش برای پوشش همه موارد ممکن در قالب یک الزام، الزامات مستندسازی در نظر گرفته شده‌اند که توسعه‌دهنده را ملزم می‌سازند نحوه پیاده‌سازی و پیکربندی این نوع کنترل‌ها را به‌صورت مستند ارائه دهد. این مستندات سپس می‌توانند از نظر تناسب مورد بازبینی قرار گرفته و پیاده‌سازی واقعی با مستندات مقایسه شود تا میزان انطباق بررسی گردد.

این الزامات برای ثبت تصمیماتی طراحی شده‌اند که سازمان توسعه‌دهنده درباره نحوه پیاده‌سازی الزامات امنیتی اتخاذ کرده است.

الزامات مستندسازی همواره در بخش اول هر فصل قرار دارند (هرچند همه فصل‌ها چنین الزامی ندارند) و همواره با یک الزام پیاده‌سازی مرتبط هستند، جایی که تصمیمات مستندسازی‌شده باید عملاً پیاده‌سازی شوند. نکته اینجاست که بررسی مستندات و بررسی پیاده‌سازی واقعی، دو فعالیت مستقل هستند.

دو عامل اصلی برای گنجاندن این الزامات وجود دارد. اولین الزام این است که بسیاری از الزامات امنیتی شامل تعریف قوانین خاصی هستند. مانند انواع فایله‌ایی که مجاز به آپلود هستند، کنترله‌ای کسب و کاری مورد نیاز، یا کاراکتره‌ای مجاز برای یک فیلد خاص. این قوانین در هر برنامه متفاوت است، بنابراین ASVS نمی‌تواند به‌صورت امری آنها را تعیین کند، و حتی Cheat sheet یا پاسخ مفصل هم در این موارد کمک نخواهد کرد. بدون هستند بودن این تصمیمات، تأیید پیاده‌سازی آنها ممکن نخواهد بود.

دومین عامل این است که توسعه دهندگان نرم‌افزار در انتخاب برخی الزامات آزادی عمل داشته باشند. برای مثال، در نسخه‌های پیشین ASVS، قواعد مربوط به پایان جلسه (session timeout) بسیار امری بودند. ولی بسیاری از برنامه‌ها، به‌ویژه برنامه‌های مشتری‌محور، قواعدی آسان‌گیرانه‌تر را ترجیح می‌دهند و از کنترله‌ای جایگزین استفاده می‌کنند. به همین دلیل، الزامات مربوط به هستندسازی به‌صورت صریح اجازه‌ی چنین انعطافی را فراهم می‌کنند.

بدیهی است که انتظار نمی‌رود توسعه‌دهندگان به‌صورت فردی این تصمیمات را بگیرند و هستند کنند، بلکه این وظیفه‌ی سازمان است که تصمیم‌گیری کرده، آنها را هستند کرده و به توسعه‌دهندگان منتقل کند تا در کنوی‌سی لحاظ شوند.

در توسعه نرم‌افزار، همانطور که برای طراحی ویژگی‌ها و ظاهر برنامه چارچوب‌ها، راهنماها و مؤلفه‌های مشخصی وجود دارد و انتظار می‌رود که توسعه‌دهندگان از آنها پیروی کنند، در مورد امنیت هم بایید همین روی کرد وجود داشته باشد. یعنی امنیت نباید چیزی باشد که هر توسعه‌دهنده بنا به سلیقه خود تصمیم بگیرد، بلکه باید از استانداردها، ابزارها و طراحی‌های مشخصی تبعیت نمایید.

همچنین، نحوه هستندسازی نیز انعطاف‌پذیر است. تصمیمات امنیتی می‌توانند در قالب یک سند رسمی نوشته شده باشند که توسعه‌دهندگان به آن مراجعه می‌کنند، یا این تصمیمات می‌توانند به‌صورت کد در یک کتابخانه مشترک پیاده‌سازی شده باشند که استفاده از آن برای همه توسعه‌دهندگان الزامی است. در هر دو حالت، هدف نهایی محقق می‌شود.

سطوح تأیید امنیت برنامه‌های کاربردی

ASVS سه سطح تأیید امنیت تعریف می‌کند که با افزایش سطح، عمق و پیچیدگی الزامات امنیتی نیز افزایش می‌یابد. هدف کلی این است که سازمان‌ها از سطح اول شروع کرده و همت‌رین دغدغه‌های امنیتی را برطرف کنند، و سپس متناسب با نیازهای سازمان و برنامه، به سطوح بالاتر حرکت کنند. در استاد و متن الزامات، این سطوح با نماده‌ای L1، L2 و L3 نمایش داده می‌شوند.

هر سطح از ASVS بیانگر الزامات امنیتی‌ای است که بایید در آن سطح محقق شود؛ الزامات سطوح بالاتر به‌عنوان توصیه در نظر گرفته می‌شوند.

به‌منظور جلوگیری از تکرار الزامات یا گنجاندن الزامات نامربوط در سطوح بالاتر، برخی الزامات فقط در یک سطح مشخص اعمال می‌شوند اما در سطوح بالاتر شرایط سخت‌گیرانه‌تری دارند.

ارزیابی سطوح

سطوح ASVS بر پایه‌ی اولویت‌بندی الزامات و بر اساس تجربه‌ی پیاده‌سازی و آزمون آنها تعیین شده‌اند. تمرکز اصلی بر مقایسه‌ی کاهش ریسک در برابر هزینه‌ی پیاده‌سازی الزام است. عامل کلیدی دیگر، سهولت در ورود و پذیرش استاندارد است.

کاهش ریسک به میزان کاهش ریسک امنیتی در برنامه توجه دارد و عوامل سنتی مانند محرمانگی(Confidentiality)، یکپارچگی (Integrity)، دسترس‌پذیری و(Availability) همچنین لایه دفاع اولیه یا دفاع در عمق بودن الزام را در نظر می‌گیرد.

بحث‌های دقیق درباره معیارها و تصمیم‌گیری سطح‌بندی منجر به توزیع‌ی شده که در بیشتر موارد قابل اعتماد است، هرچند ممکن است برای همه موارد ۱۰۰٪ مناسب نباشد. در نتیجه، ممکن است سازمان‌ها تصمیم بگیرند برخی الزامات سطوح بالاتر را زودتر و بر اساس تحلیل ریسک خود در اولویت قرار دهند.

انواع الزامات در هر سطح را می‌توان به‌صورت زیر توصیف کرد.

سطح ۱

این سطح حداقل الزامات برای ایمن‌سازی برنامه را شامل می‌شود و نقطه شروعی حیاتی محسوب می‌شود. حدود ۲۰٪ از کل الزامات ASVS در این سطح قرار دارد. هدف این سطح، داشتن کمترین تعداد الزامات برای سهولت در ورود و پذیرش استاندارد است.

این الزامات عموماً حیاتی یا پایه‌ای هستند و اولین خط دفاعی در برابر حملات رایج محسوب می‌شوند، حملاتی که برای بهره‌برداری از آن‌ها به آسیب‌پذیری یا پیش‌شرط دیگری نیاز نیست.

همچنین برخی الزامات مثل موارد مربوط به گذرواژه‌ها در سطح ۱ اهمیت بیشتری دارند، زیرا در سطوح بالاتر استفاده از احراز هویت چندمرحله‌ای مطرح می‌شود.

سطح ۱ الزاماً از طریق آزمون نفوذ خارجی و بدون دسترسی به کد یا مستندات (مانند آزمون جعبه‌سیاه) قابل ارزیابی نیست، ولی تعداد کمتر الزامات آن فرآیند تأیید را ساده‌تر می‌کند.

سطح ۲

بیشتر برنامه‌ها باید به‌دنبال دستیابی به این سطح از امنیت باشند. حدود ۵۰٪ از الزامات ASVS در سطح ۲ هستند، و بنابراین یک برنامه باید حدود ۷۰٪ از الزامات ASVS (یعنی تمام الزامات L1 و L2) را برای انطباق با این سطح پیاده‌سازی کند.

این الزامات معمولاً به حملات کمتر رایج یا دفاع‌های پیچیده‌تر در برابر حملات رایج مرتبط هستند. ممکن است این الزامات همچنان دفاع اولیه باشند، یا برای بهره‌برداری نیاز به پیش‌شرط‌های داشته باشند.

سطح ۳

این سطح باید هدف برنامه‌هایی باشد که می‌خواهند بالاترین سطح امنیت را اثبات کنند و شامل حدود ۳۰٪ نهایی الزامات است.

الزامات این سطح عمدتاً شامل مکانیزم‌های دفاع در عمق یا کنترل‌های پیچیده و دشوار برای پیاده‌سازی هستند.

کدام سطح را انتخاب کنیم

سطوح اولویت‌بندی‌شده ASVS برای نشان دادن بلوغ امنیتی برنامه و سازمان طراحی شده‌اند. به‌جای آنکه ASVS الزام کند که یک برنامه باید در چه سطحی باشد، این مسئولیت بر عهده‌ی سازمان است که با تحلیل ریسک، و با توجه به حساسیت برنامه و انتظارات کاربران، سطح مناسب را انتخاب کند.

برای نمونه، یک استارتاپ نوپا که فقط مقدار محدودی از داده‌ای حساس را جمع‌آوری می‌کند، ممکن است تصمیم بگیرد سطح ۱ را برای اهداف اولیه امنیتی انتخاب کند؛ اما یک بانک برای برنامه بانکی آنلاین خود، به‌سختی می‌تواند چیزی کمتر از سطح ۳ را به مشتریانش توجیه کند.

چگونه از ASVS استفاده کنیم

ساختار ASVS

ASVS شامل حدود ۳۵۰ الزام امنیتی است که در قالب ۱۷ فصل دسته‌بندی شده‌اند. هر فصل نیز به بخش‌های کوچک‌تر تقسیم شده است.

هدف از این تقسیم‌بندی فصل‌ها و بخش‌ها، ساده‌سازی انتخاب یا فیلتر کردن موارد مرتبط با برنامه‌ی خاص است. برای مثال، در یک API ماشین‌به‌ماشین، الزامات فصل V3 که مربوط به Frontend است، کاربردی نخواهد داشت. اگر از OAuth یا WebRTC استفاده نشده، آن فصل‌ها نیز می‌توانند نادیده گرفته شوند.

strategy Release

انتشاره‌ای ASVS از الگوی "Major.Minor.Patch" پیروی می‌کنند که این سه عدد، نوع تغییرات را نشان می‌دهند، در یک Major، عدد اول تغییر می‌کند، در Minor، عدد دوم تغییر می‌کند، و در Patch، عدد سوم تغییر می‌کند.

- Major) :(release بازسازمان‌دهی کامل؛ ممکن است تقریباً همه چیز از جمله شماره‌های الزامات تغییر کند. ارزیابی مجدد برای انطباق لازم است. مثال: 4.0.3 → 5.0.0
- Minor) :(release ممکن است الزامات جدیدی اضافه یا حذف شوند، اما شماره‌گذاری کلی حفظ می‌شود. ارزیابی مجدد لازم است، ولی ساده‌تر خواهد بود. مثال: 5.0.0 → 5.1.0
- Patch) :(release ممکن است الزامات تکراری یا منسوخ حذف شوند یا سخت‌گیری آن‌ها کاهش یابد، ولی برنامه‌ای که با نسخه قبلی انطباق داشته، با نسخه وصله‌شده نیز انطباق خواهد داشت.مثال: 5.0.0 → 5.0.1

نکته: آنچه در بالا آمد، صرفاً مربوط به الزامات ASVS است. تغییرات متنی در بخش‌های جانبی یا ضمائم، به‌عنوان تغییرات بنیادی در نظر گرفته نمی‌شوند.

انعطاف‌پذیری در استفاده از ASVS

برخی از موارد پیش‌گفته، مانند الزامات مستندسازی و سازوکار سطوح، این امکان را فراهم می‌کنند که از ASVS به‌صورت انعطاف‌پذیرتر و متناسب با نیازهای هر سازمان استفاده شود.

علاوه بر این، قویاً توصیه می‌شود که سازمان‌ها یک نسخه شخصی‌سازی‌شده از ASVS ایجاد کنند که الزامات را با توجه به ویژگی‌ها و سطح ریسک برنامه‌های خود تنظیم نمایند. با این حال، حفظ قابلیت ره‌گیری (traceability) الزامی است؛ به‌گونه‌ای که مثلاً گنجاندن الزام 4.1.1 در تمام نسخه‌ها معنای یکسانی داشته باشد.

در حالت ایده‌آل، هر سازمان باید نسخه اختصاصی ASVS خود را ته‌یه کند و بخش‌های نامربوط مانند GraphQL، WebSockets یا SOAP (در صورت عدم استفاده) را حذف نماید. چنین نسخه‌ای همچنین محل مناسبی برای افزودن راهنمایی‌های خاص سازمان، مانند کتابخانه‌ها یا منابع توصیه‌شده برای پیاده‌سازی الزامات، خواهد بود.

نحوه ارجاع به الزامات ASVS

هر الزام دارای شناسه‌ای با قالب `<chapter>.<section>.<requirement>` است که هر بخش یک عدد می‌باشد. برای مثال :1.11.3.

- مقدار `<chapter>` نشان‌دهنده فصل الزام است؛ برای نمونه، تمام الزامات `1.#.#` متعلق به فصل "رمزگذاری و پاک‌سازی" هستند.
- مقدار `<section>` نشان‌دهنده بخش درون آن فصل است؛ مثلاً تمام الزامات `1.2.#` در بخش "پیش‌گیری از تزریق" فصل رمزگذاری و پاک‌سازی قرار دارند.
- مقدار `<requirement>` بیان‌گر شماره الزام خاص درون فصل و بخش است؛ مثلاً `1.2.5` که در نسخه 5.0.0 چنین تعریف شده است:

> تأیید شود که برنامه از injection Command OS محافظت کند و فراخوانی‌های سیستم‌عامل از پرس‌وجوی پارامتری با Encoding مناسب استفاده نماید.

از آنجاکه شناسه‌ها ممکن است بین نسخه‌های مختلف تغییر کنند، توصیه می‌شود که در استناد، گزارش‌ها یا ابزارها از قالب زیر استفاده شود: `v<version>-<chapter>.<section>.<requirement>` که در آن version نشان دهنده برچسب نسخه ASVS می‌باشد. برای مثال: `v5.0.0-1.2.5` به‌صورت دقیق به الزام پنجم از بخش « Prevention Injection » در فصل « Sanitization» and Encoding در نسخه 5.0.0 اشاره دارد. (این قالب را می‌توان به‌صورت خلاصه‌شده به شکل `v<version>-<requirement_identifier>` نمایش داد.)

نکته: حرف v پیش از شماره نسخه باید همواره با حروف کوچک نوشته شود.

اگر شناسه‌ها بدون عنصر `v<version>` استفاده شوند، باید فرض شود که به آخرین محتوای ASVS اشاره دارند. با گسترش و تغییر استانداردها، این کار مشکل‌ساز می‌شود؛ به همین دلیل توصیه می‌شود نویسندگان و توسعه‌دهندگان همواره نسخه را نیز ذکر کنند.

فهرست الزامات ASVS در قالب‌های مانند CSV،JSON و سایر فرمت‌ها نیز برای ارجاع یا استفاده برنامه‌نویسی در دسترس است.

فورک کردن ASVS (Forking)

سازمان‌ها می‌توانند با انتخاب یکی از سه سطح یا ایجاد نسخه فورک‌شده‌ی دامنه‌محور، از مزای‌ای ASVS به‌رهمند شوند. این نسخه فورک‌شده می‌تواند الزامات را بر اساس سطح ریسک برنامه تنظیم کند. این اقدام تشویق می‌شود، مشروط بر آنکه قابلیت ره‌گیری حفظ شود (یعنی مثلاً الزام 4.1.1 در همه نسخه‌ها معنای یکسانی داشته باشد).

در حالت ایده‌آل، هر سازمان باید نسخه‌ای متناسب با نیازهای خود از ASVS تهیه کند و بخش‌های غیرمرتبط (مانند GraphQL، SOAP Websockets در صورتی که مورد استفاده قرار نمی‌گیرند) را حذف نماید. ایجاد نسخه‌ی اختصاصی (forking) باید با سطح ۱ ASVS به‌عنوان پایه آغاز شود و سپس بر اساس سطح ریسک برنامه، به سطوح ۲ یا ۳ ارتقاء یابد.

موارد استفاده از ASVS

ASVS می‌تواند برای ارزیابی امنیت یک برنامه کاربردی مورد استفاده قرار گیرد. که این موضوع در فصل بعد با جزئیات بیشتری بررسی خواهد شد. با این حال، موارد استفاده‌ی دیگری نیز برای ASVS (یا نسخه‌های فورک‌شده آن) شناسایی شده‌اند.

به‌عنوان راهنمای دقیق معماری امنیتی

یکی از رایج‌ترین کاربردهایASVS، استفاده از آن به‌عنوان مرجعی برای معماران امنیتی است. منابع محدودی برای نحوه طراحی معماری ایمن برای برنامه‌های مدرن وجود دارد ASVS می‌تواند خلأ موجود را با ارائه کنترل‌های مناسب برای چالش‌های رایج، مانند الگوهای حفاظت از داده‌ها یا استراتژی‌های اعتبارسنجی ورودی، پر کند. الزامات مربوط به معماری و مستندسازی در این زمینه به‌وی‌ژه مفید خواهند بود.

به‌عنوان مرجع تخصصی برای برنامه‌نویسی امن

ASVS می‌تواند به‌عنوان مبنایی برای تهیه مرجع برنامه‌نویسی امن در طول توسعه نرم‌افزار مورد استفاده قرار گیرد و به توسعه‌دهندگان کمک کند تا در حین ساخت نرم‌افزار، امنیت را به‌طور مستمر مدنظر داشته باشند. اگرچه ASVS می‌تواند پایه‌ی این مرجع باشد، اما توصیه می‌شود سازمان-ها راهنمای اختصاصی خود را تهیه کنند—راهنمایی که شفاف، یک‌پارچه، و ترجیحاً با مشارکت مهندسان امنیت یا معماران امنیتی تدوین شده باشد.به‌عنوان مکمل این راهنما، به سازمان‌ها تاکید می‌شود تا در صورت امکان، سازوکارها و کتابخانه‌های امنیتی تأییدشده‌ای تهیه کنند که در راهنما معرفی شده و توسعه‌دهندگان در پروژه‌های خود از آن‌ها استفاده نمایند.

به‌عنوان راهنمای آزمون‌های واحد و یک‌پارچه‌سازی خودکار

ASVS به‌گونه‌ای طراحی شده که بسیار قابل آزمون باشد. برخی از الزامات ماهیتی فنی دارند، در حالی‌که برخی دیگر(مانند الزامات معماری یا مستندسازی) نیاز به بررسی مستندات یا بازبینی معماری دارند. با طراحی آزمون‌های واحد و یک‌پارچه‌سازی که آسیب‌پذیری‌ها و سوءاستفاده‌های خاص

مرتبط با الزامات قابل‌تأیید را بررسی و fuzz می‌کنند، می‌توان اطمینان یافت که این کنترل‌ها در هر نسخه از برنامه (build) به‌درستی عمل می‌کنند. برای نمونه، می‌توان تست‌های اضافی‌ای به مجموعه تست‌ها برای یک کنترلر ورود login) (controller افزود که پارامتر نام کاربری (username) را از نظر مواردی مثل نام‌های کاربری پیش‌فرض رایج، تشخیص وجود حساب (account)، enumeration)، حملات brute force، تزریق LDAP و SQL، و XSS بررسی کنند. به‌صورت مشابه، تست پارامتر رمز عبور (password) نیز باید شامل بررسی رمزهای رایج، طول رمز عبور، تزریق null byte، حذف پارامتر، XSS، و موارد دیگر رباشد.

برای آموزش توسعه امن

ASVS می‌تواند برای تعریف ویژگی‌های نرم‌افزار ایمن نیز مورد استفاده قرار گیرد. بسیاری از دوره‌های "برنامه‌نویسی امن" در واقع صرفاً دوره‌های هک اخلاقی هستند که نکاتی جزئی در مورد کدنویسی امن به آن‌ها اضافه شده است. و این لزوماً به به‌بود مهارت توسعه‌دهندگان در نوشتن کد امن کمک نمی‌کند.درعوض، دوره‌های آموزش توسعه امن می‌توانند با محوریت ASVS و تمرکز قوی بر سازوکارهای مثبت و کاربردی آن طراحی شوند، نه صرفاً تمرکز بر فهرست Top 10 آسیب‌پذیری‌ها یا کارهایی که نباید انجام داد. ساختار ASVS همچنین یک چارچوب منطقی برای مرور گام‌به‌گام موضوعات مختلف مرتبط با ایمن‌سازی برنامه فراهم می‌کند.

به‌عنوان چارچوبی برای راهنمایی در خرید نرم‌افزار امن

ASVS یک چارچوب عالی برای کمک به خرید نرم‌افزار امن یا خدمات توسعه اختصاصی امن است. خریدار می‌تواند به‌سادگی مشخص کند که نرم‌افزاری که قصد تهیه آن را دارد، باید مطابق با سطح X از ASVS توسعه یافته باشد و از فروشنده بخواهد اثبات کند که نرم‌افزار با آن سطح از استانداردASVS منطبق است.

کاربرد عملی ASVS

تهدیدهای مختلف، انگیزه‌های متفاوتی دارند. برخی صنایع دارای دارایی‌های اطلاعاتی و فناوری منحصربه‌فرد، و همچنین الزامات انطباق قانونی خاصِ حوزه‌ی خود هستند.

به سازمان‌ها تاکید می‌شود که با توجه به ماهیت کسب‌وکار خود، ویژگی‌های خاص ریسک‌های خود را عمیقاً بررسی کنند و بر اساس این تحلیل، سطح مناسب ASVS را که با نیازهای کسب‌وکارشان مطابقت دارد، تعیین نمایند.

ارزیابی و صدور گواهی

دیدگاه OWASP در مورد گواهی‌نامه‌ها و نشانه‌ای اعتماد ASVS

OWASP به‌عنوان یک سازمان غیرانتفاعی و بی‌طرف از نظر تجاری، هیچ فروشنده، ارزیاب یا نرم‌افزاری را گواهی نمی‌کند. هرگونه ادعا مبنی بر گواهی‌بودن ،ASVS ارائه نشان اعتماد یا تضمین

انطباق با ASVS توسط اشخاص ثالث، به‌ویژه تأیید رسمی OWASP نیست. از این‌رو، سازمان‌ها باید نسبت به چنین ادعاهایی با احتیاط عمل کنند.

البته سازمان‌ها می‌توانند خدمات تضمین امنیت ارائه دهند، مشروط بر آنکه ادعای دریافت گواهی رسمی از سوی OWASP نداشته باشند.

نحوه تأیید انطباق با ASVS

ASVS به‌طور عام‌دانه جزئیات چگونگی ارزیابی انطباق در سطحی مانند یک راهنمای تست را تجویز نمی‌کند، اما تأکید بر برخی نکات کلیدی اهمیت دارد.

گزارش‌گیری ارزیابی

گزارش‌های سنتی تست نفوذ تنها به ارائه "موارد استثناء" می‌پردازند و صرفاً شکست‌ها را فهرست می‌کنند. اما گزارش گواهی‌نامه ASVS باید شامل موارد دامنه ارزیابی(Scope)، خلاصه‌ای از تمام الزامات بررسی‌شده، الزامات دارای استثناء یا عدم انطباق و راهنمایی برای رفع مشکلات شناسایی‌شده. برخی الزامات ممکن است به‌دلایل فنی یا عملکردی، قابل اعمال نباشند (مثلاً مدیریت نشست در هایAPI بدون وضعیت) که در این صورت، باید در گزارش ذکر شود.

دامنه ارزیابی

سازمانی که یک نرم‌افزار را توسعه می‌دهد، معمولاً همه الزامات ASVS را پیاده‌سازی نمی‌کند، زیرا برخی الزامات ممکن است برای آن نرم‌افزار خاص نامربوط یا کم‌اهمیت باشند. بنابراین، ارزیاب باید دامنه بررسی را به‌روشنی مشخص کند؛ از جمله اینکه سازمان در پی دستیابی به کدام سطح (Level) است و کدام الزامات را شامل کرده است. این شفاف‌سازی باید بر اساس آنچه در گزارش گنجانده شده انجام گیرد، نه آنچه حذف شده است. همچنین ارزیاب باید نظر خود را در مورد دلایل مستند حذف یا پیاده‌سازی‌نشدن الزامات خاص ارائه دهد.

این موضوع به مصرف‌کننده گزارش کمک می‌کند تا زمینه ارزیابی را به‌تر درک کرده و در مورد میزان اعتماد به نرم‌افزار، تصمیم آگاهانه‌تری بگیرد.

سازمان‌هایی که گواهی صادر می‌کنند می‌توانند روش‌های مختلفی برای آزمون انتخاب کنند، اما باید این روش‌ها را در گزارش خود به‌طور شفاف ذکر کنند و به‌تر است این روش‌ها قابل تکرار باشند. بسته به نوع نرم‌افزار و نیازهای آن، ممکن است برای بررسی مواردی مانند اعتبارسنجی ورودی، از روش‌هایی مثل تست نفوذ دستی یا تحلیل کدمنبع استفاده شود.

روش‌های ارزیابی

تکنیکی‌های مختلفی برای تأیید الزامات خاص ASVS ممکن است مورد نیاز باشند. علاوه بر تست نفوذ (با استفاده از اعتبارنامه‌های مختلف برای پوشش کامل برنامه)، تأیید الزامات ASVS ممکن است به دسترسی به مستندات، کدمنبع، پیکربندی، و افراد درگیر در فرآیند توسعه نیاز داشته باشد؛ به‌ویژه برای تأیید الزامات سطح ۲ (L2) و سطح ۳ (L3) ارائه شواهد مستند و قوی از

یافت‌ه‌ها با مست‌ندسازی دقیق، از جمله اوراق کاری، تصاویر صفحه (اسکری‌نشات)، اسکری‌پت‌ها و لاگ‌های تست، یک روی‌ه استاندارد محسوب می‌شود. اجرای صرف یک ابزار خودکار بدون انجام تست‌های دقیق، برای دریافت گواهی‌نامه کافی نیست؛ چراکه هر الزام باید به‌طور قابل تأیید بررسی و آزموده شود.

استفاده از ابزاره‌ای خودکار برای تأیید الزامات ASVS همواره موضوعی مورد توجه بوده است. بنابراین، مهم است که نکاتی در مورد تست خودکار و تست جعبه سیاه (black box testing) روشن و شفاف بیان شوند.

نقش ابزاره‌ای خودکار امنیتی زمانی که ابزاره‌ای خودکار تست امنیتی مانند DAST (تست امنیتی پویا) و SAST (تست امنیتی ایستا) به‌درستی در خط ساخت (build pipeline) پیاده‌سازی شوند، ممکن است بتوانند برخی از مشکلات امنیتی را شناسایی کنند که اصولاً نباید وجود داشته باشند. با این حال، اگر این ابزاره‌ا به‌دقت پیکربندی و تنظیم نشوند، پوشش لازم را فراهم نخواهند کرد و حجم زیاد هشداره‌ای نادرست (noise) باعث می‌شود مشکلات امنیتی واقعی قابل شناسایی و رفع نباشند.

در حالی که این ابزاره‌ا ممکن است برخی از نیازمندی‌های فنی ساده‌تر مانند کدگذاری خروجی یا پاکسازی (sanitization) را پوشش دهند، نکته بسیار مهم این است که نمی‌توانند بسیاری از الزامات پیچیده‌تر ASVS (استاندارد تأیید امنیت نرم‌افزار) را، به‌ویژه آن‌های که به منطق تجاری یا کنترل دسترسی مربوط می‌شوند، به‌طور کامل بررسی کنند.

برای نیازمندی‌های که ساده نیستند، همچنان می‌توان از خودکارسازی استفاده کرد، اما باید بررسی‌های خاص برای هر نرم‌افزار نوشته شود تا این الزامات پوشش داده شوند. این بررسی‌ها می‌توانند شبیه به تست‌های واحد (unit test) یا تست‌های یکپارچه‌سازی (integration test) باشند که ممکن است قبلاً در سازمان وجود داشته باشند. بنابراین ممکن است بتوان از زیرساخت فعلی تست خودکار برای نوشتن تست‌های مخصوص ASVS استفاده کرد. اگرچه انجام این کار در کوتاه‌مدت نیاز به سرمایه‌گذاری دارد، اما مزایای بلندمدت آن در امکان بررسی مستمر الزامات امنیتی ASVS بسیار قابل توجه خواهد بود.

به طور خلاصه قابل تست بودن از طریق خودکارسازی به این معنا نیست که می‌توان صرفاً یک ابزار آماده را اجرا کرد.

نقش تست نفوذ در نسخه 4.0، سطح L1 برای انجام تست نفوذ «جعبه سیاه» (بدون دسترسی به مستندات یا کمی) بهینه‌سازی شده بود، اما حتی در آن نسخه نیز تأکید شده بود که این روش نباید به‌عنوان فعالیت اصلی تضمین امنیتی تلقی شود و باید از آن پرهیز کرد.

تست بدون دسترسی به اطلاعات تکمیلی، شیوه‌ای ناکارآمد و ضعیف برای ارزیابی امنیت است، چراکه فرصت بررسی کدمنبع، شناسایی ته‌دیده‌ها، کشف کنترل‌های ناقص و انجام تست جامع‌تر در زمان کمتر را از بین می‌برد.

به‌طور جدی توصیه می‌شود که از روش‌های ترکیبی (Hybrid) برای تست نفوذ استفاده شود، یعنی تست‌های که با دسترسی کامل به مستندات، کد و توسعه‌دهندگان انجام می‌شوند؛ زیرا چنین سطحی از دسترسی برای ارزیابی دقیق بسیاری از الزامات ASVS ضروری خواهد بود.

تغییرات نسبت به نسخه 4.x

مقدمه

کاربرانی که با نسخه x.4 این استاندارد آشنایی دارند، ممکن است مرور تغییرات کلیدی معرفی‌شده در نسخه 5.0 را مفید بیابند؛ تغییراتی که شامل به‌روزرسانی‌های در محتوا، دامنه و فلسفه زیربنایی استاندارد هستند.

از میان 286 الزام موجود در نسخه ،4.0.3 تنها 11 مورد بدون تغییر باقی مانده‌اند و ۱۵ مورد صرفاً اصلاحات جزئی گرامری داشته‌اند که معنای آن‌ها را تغییر نداده است. در مجموع، 109 الزام (معادل 38%) در نسخه 5.0 دیگر به‌صورت الزامات جداگانه وجود ندارند؛ که از این میان، 50 مورد حذف شده‌اند، 28 مورد به‌عنوان موارد تکراری حذف شده‌اند و 31 مورد در الزامات دیگر ادغام شده‌اند. مابقی الزامات نیز به‌نوعی مورد بازنگری قرار گرفته‌اند. حتی الزامات تغییریافته‌ای که از لحاظ محتوایی تغییر زیادی نداشته‌اند نیز به‌دلیل بازآرایی یا بازساختاردهی، شناسه‌ای متفاوتی دارند.

برای تسهیل پذیرش نسخه ،5.0 اسنادی برای نگاشت الزامات ارائه شده‌اند تا به کاربران کمک کنند نحوه تطابق الزامات نسخه x.4 با نسخه 5.0 را دنبال کنند. این نگاشت‌ها به نسخه انتشار خاصی وابسته نیستند و در صورت لزوم به‌روزرسانی یا شفاف‌سازی خواهند شد.

فلسفه الزامات

دامنه و تمرکز

در نسخه x.4 الزامات متعددی گنجانده شده بودند که با دامنه مورد نظر این استاندارد همراستا نبودند؛ این موارد حذف شده‌اند. همچنین، الزاماتی که با معیارهای دامنه نسخه 5.0 سازگار نبودند یا قابلیت ارزیابی نداشتند نیز کنار گذاشته شده‌اند.

تمرکز بر اهداف امنیتی به‌جای سازوکارها

در نسخه 4.x بسیاری از الزامات بر سازوکارهای خاصی متمرکز بودند و نه بر اهداف زیربنایی امنیتی. در نسخه ،5.0 تمرکز الزامات بر اهداف امنیتی است و تنها در مواردی که یک سازوکار خاص تنها راه‌حل عملی است، به آن اشاره شده یا به‌عنوان نمونه یا راه‌نمایی مکمل آورده شده است.

این رویکرد به رسمیت می‌شناسد که روش‌های متعددی ممکن است برای رسیدن به یک هدف امنیتی وجود داشته باشند و از تجویزهای غیرضروری که می‌توانند انعطاف‌پذیری سازمان‌ها را محدود کنند، اجتناب می‌کند.

همچنین، الزامات مرتبط با یک دغدغه امنیتی واحد، در صورت لزوم با هم ادغام شده‌اند.

تصمیمات امنیتی مستند

هرچند مفهوم تصمیمات امنیتی مستند ممکن است در نسخه 5.0 جدید به‌نظر برسد، در واقع ادامه و تکامل الزاماتی در نسخه 4.0 است که به تحلیل سیاست‌ها و مدل‌سازی تهدید اشاره داشتند.

در گذشته، برخی الزامات به‌طور ضمنی نیازمند تحلیل برای پیاده‌سازی کنترل‌های امنیتی بودند، مانند تعیین اتصالات شبکه مجاز.

به‌منظور اطمینان از در دسترس بودن اطلاعات لازم برای اجرا و ارزیابی، این انتظارات اکنون به‌طور صریح به‌عنوان الزامات مستندسازی تعریف شده‌اند تا شفاف، قابل اجرا و قابل ارزیابی باشند.

تغییرات ساختاری و فصل‌های جدید

چند فصل در نسخه 5.0 محتوای کاملاً جدیدی را معرفی کرده‌اند:

- OAuth وOIDC: با توجه به رواج گسترده این پروتکل‌ها برای واگذاری دسترسی و ورود یکپارچه ،(SSO) الزامات اختصاصی برای این حوزه تعریف شده‌اند تا سناریوهای متنوعی که توسعه‌دهندگان مکن است با آن‌ها مواجه شوند، پوشش داده شود. این حوزه مکن است در آینده به استانداردی مستقل تبدیل شود(مشابه آنچه برای حوزه موبایل و IoT در نسخه‌های قبلی رخ داد).
- :WebRTC با توجه به رشد سریع این فناوری، ملاحظات و چالش‌های امنیتی خاص آن اکنون در بخش‌ی اختصاصی پوشش داده شده‌اند.

همچنین، تلاش شده ساختار فصل‌ها به‌گونه‌ای تنظیم شود که مجموعه‌های منسجم و مرتبطی از الزامات را در کنار هم قرار دهد.

این بازسازماندهی منجر به ایجاد فصل‌های جدیدی نیز شده است:

- توکن‌های مستقل(Tokens): Self-contained که پیش‌تر زیرمجموعه مدیریت نشست بودند، اکنون به‌عنوان یک سازوکار مستقل شناخته می‌شوند و یکی از عناصر بنیادی در ارتباطات بدون وضعیت (stateless) مانند OAuth و OIDC به‌شمار می‌روند. به‌دلیل پیامدهای امنیتی خاص این نوع توکن‌ها، در نسخه x.5 یک فصل اختصاصی به آن‌ها اختصاص داده شده و برخی الزامات جدید نیز در این زمینه معرفی شده‌اند.
- امنیت فرانت‌اند وب: با توجه به پیچیدگی فزاینده برنامه‌های تحت مرورگر و معماری‌های مبتنی بر ،API الزامات امنیتی فرانت‌اند به فصل مستقلی منتقل شده‌اند.
- کدنویسی و معماری ایمن: الزاماتی که به شیوه‌های کلی امنیت مربوط می‌شدند ولی در فصل‌های قبلی جای نمی‌گرفتند، در این بخش جمع‌آوری شده‌اند.

سایر تغییرات ساختاری در نسخه 5.0 به‌منظور شفاف‌سازی مقصود اعمال شده‌اند. برای مثال، الزامات مربوط به اعتبارسنجی ورودی به‌جای قرارگیری در کنار پاک‌سازی و کدگذاری، در کنار منطق تجاری قرار داده شده‌اند تا نقش آن‌ها در اجرای قوانین تجاری را بهتر نشان دهند.

فصل قبلی با عنوان معماری V1 به‌طور کامل حذف شده است. بخش ابتدایی آن شامل الزاماتی بود که خارج از محدوده موضوعی قرار داشتند، در حالی که بخش‌های بعدی به فصل‌های مرتبط منتقل شده‌اند و الزامات نیز در صورت لزوم بازنگری، شفاف‌سازی و حذف موارد تکراری شده‌اند.

حذف نگاشت مستقیم با استانداردهای دیگر

نگاشت مستقیم با استانداردهای دیگر از متن اصلی استانداردحذف شده است. هدف آن است که نگاشتی با پروژه OWASP Common CRE (Requirement Enumeration) ارائه شود که به‌نوبه خود ASVS را به طیفی از پروژه‌های OWASP و استانداردهای خارجی متصل کند.

نگاشت مستقیم با CWE و NIST دیگر حفظ نمی‌شود، که در ادامه توضیح داده شده است.

کاهش وابستگی به دستورالعمل‌های هویت دیجیتال NIST

دستورالعمل‌های هویت دیجیتال NIST SP 800-63 (Digital Identity Guidelines) مدت‌ها به‌عنوان مرجع برای کنترل‌های احراز هویت و مجوزدهی استفاده می‌شدند. در نسخه x.4 برخی فصل‌ها با ساختار و واژگان NIST همراستا بودند.

با آنکه این دستورالعمل‌ها همچنان مرجع مهمی محسوب می‌شوند، این همراستایی سخت‌گیرانه چالش‌های ایجاد کرده بود؛ از جمله واژگان کمتر شناخته‌شده، تکرار الزامات مشابه، و نگاشت‌های ناقص. نسخه 5.0 از این روی کرد فاصله گرفته تا وضوح و ارتباط مؤثرتر را ارتقا دهد.

فاصله گرفتن از نگاشت CWE

Common Weakness Enumeration (CWE) طبقه‌بندی مفیدی از ضعف‌های امنیتی نرم‌افزار ارائه می‌دهد. با این حال، چالش‌هایی مانند هایCWE که فقط شامل دسته‌بندی هستند، دشواری در نگاشت دقیق الزامات به یک CWE خاص، و نگاشت‌های نامشخص در نسخه x.4 باعث شد تصمیم گرفته شود که در نسخه 5.0 نگاشت مستقیم با CWE حذف شود.

بازنگری در تعریف سطوح (Levels)

نسخه x.4 سطوح امنیتی را به‌صورت L1 (“حداقلی”)، L2 (“استاندارد”) و L3 (“پیشرفته”) تعریف می‌کرد و تلویحاً بیان می‌کرد که تمام برنامه‌هایی که با داده‌های حساس سروکار دارند باید حداقل به سطح L2 برسند.

نسخه 5.0 به چندین ایراد در این روی کرد پرداخته است که در پاراگراف‌های ذیل آمده است:

از لحاظ عملی برخلاف نسخه x.4 که از علامت تیک (✓) برای نمایش سطح استفاده می‌کرد، نسخه x.5 از عدد ساده در تمام قالب‌های سند (شامل markdown، PDF، DOCX، JSON، CSV و XML) استفاده می‌کند. برای حفظ سازگاری با نسخه‌های قبلی، خروجی‌های قدیمی JSON، CSV و XML با علامت تیک نیز تولید می‌شوند.

ورود ساده‌تر به سطح اول

بازخوردها نشان دادند که تعداد بالای الزامات سطح اول 120) مورد) و این‌که این سطح به‌عنوان حداقل اما ناکافی معرفی شده بود، موجب کاهش تمایل به استفاده می‌شد. نسخه ۵.۰ تلاش کرده این مانع را با تعریف سطح L1 حول الزامات لایه اول دفاعی کاهش دهد؛ نتیجه این کار الزامات کمتر و روشن‌تر

در ای‌ن س‌طح اس‌ت. ب‌رای م‌قای‌س‌ه ع‌ددی: در ن‌س‌خ‌ه 4.0.3 ت‌ع‌داد 128 ال‌زام L1 از م‌ج‌م‌وع 278(م‌ع‌ادل (46% وج‌ود داش‌ت، ام‌ا در ن‌س‌خ‌ه 5.0.0 ای‌ن ت‌ع‌داد ب‌ه 70 ال‌زام از م‌ج‌م‌وع 345 (م‌ع‌ادل (20% ک‌اه‌ش ی‌اف‌ت‌ه اس‌ت.

اف‌س‌ان‌ه ق‌اب‌ل‌ی‌ت آزم‌ون‌پ‌ذی‌ری

در ن‌س‌خ‌ه x.4 ی‌ک‌ی از م‌ع‌ی‌ارهای اص‌ل‌ی ان‌ت‌خ‌اب ال‌زام‌ات س‌طح 1، ق‌اب‌ل‌ی‌ت ارزی‌اب‌ی آن‌ه‌ا از ط‌ری‌ق ت‌س‌ت ن‌ف‌وذ خ‌ارج‌ی ب‌ه‌ص‌ورت "ج‌ع‌ب‌ه س‌ی‌اه" ب‌ود. ام‌ا ای‌ن روی‌ک‌رد ب‌ا ه‌دف واق‌ع‌ی س‌طح 1 (ح‌داق‌ل ک‌ن‌ت‌رل‌ه‌ای ام‌ن‌ی‌ت‌ی) ه‌م‌خ‌وان‌ی ک‌ام‌ل ن‌داش‌ت. ب‌رخ‌ی ک‌ارب‌ران م‌ع‌ت‌ق‌د ب‌ودن‌د س‌طح 1 ب‌رای ت‌أم‌ی‌ن ام‌ن‌ی‌ت ک‌اف‌ی ن‌ی‌س‌ت، و ب‌رخ‌ی دی‌گ‌ر آن را ب‌ی‌ش از ح‌د س‌خ‌ت ب‌رای آزم‌ون ت‌ل‌ق‌ی م‌ی‌ک‌ردن‌د.

ات‌ک‌ا ب‌ه ق‌اب‌ل‌ی‌ت آزم‌ون‌پ‌ذی‌ری ب‌ه‌ع‌ن‌وان م‌ع‌ی‌ار، روی‌ک‌ردی ن‌س‌ب‌ی و گ‌اه گ‌م‌راه‌ک‌ن‌ن‌ده اس‌ت؛ چ‌را ک‌ه آزم‌ون‌پ‌ذی‌ر ب‌ودن ال‌زام ل‌زوماً ب‌ه م‌ع‌ن‌ای س‌ه‌ول‌ت ی‌ا ام‌ک‌ان خ‌ودک‌ارس‌ازی آزم‌ون آن ن‌ی‌س‌ت. ه‌م‌چ‌ن‌ی‌ن ال‌زام‌ات آس‌ان‌ت‌ر ب‌رای آزم‌ون ل‌زوماً پ‌راث‌رت‌ری‌ن ی‌ا آس‌ان‌ت‌ری‌ن گ‌زی‌ن‌ه‌ا ب‌رای اج‌را ن‌ی‌س‌ت‌ن‌د.

ب‌ن‌اب‌رای‌ن در ن‌س‌خ‌ه 5.0، ت‌ص‌م‌ی‌م‌گ‌ی‌ری در م‌ورد س‌طوح ع‌م‌دتاً ب‌ر اس‌اس ک‌اه‌ش ری‌س‌ک انج‌ام ش‌ده و م‌ی‌زان ت‌لاش م‌وردن‌ی‌از ب‌رای پ‌ی‌اده‌س‌ازی ن‌ی‌ز در ن‌ظر گ‌رف‌ت‌ه ش‌ده اس‌ت.

ف‌ق‌ط ری‌س‌ک م‌ط‌رح ن‌ی‌س‌ت

اس‌ت‌ف‌اده از س‌طوح ن‌س‌خ‌ه‌ای و م‌ب‌ت‌ن‌ی ب‌ر ری‌س‌ک ک‌ه ال‌زام س‌طح خ‌اص‌ی را ب‌رای ب‌رن‌ام‌ه‌ه‌ا ت‌ج‌وی‌ز م‌ی‌ک‌ن‌ن‌د، در ع‌م‌ل ب‌ی‌ش از ح‌د خ‌ش‌ک و ان‌ع‌ط‌اف‌ن‌اپ‌ذی‌ر ب‌وده اس‌ت. در واق‌ع، اول‌وی‌ت‌ب‌ن‌دی و پ‌ی‌اده‌س‌ازی ک‌ن‌ت‌رل‌ه‌ای ام‌ن‌ی‌ت‌ی ب‌ه ع‌وام‌ل م‌ت‌ع‌ددی ب‌س‌ت‌گ‌ی دارد، از ج‌م‌ل‌ه ک‌اه‌ش ری‌س‌ک و م‌ی‌زان ت‌لاش اج‌رای‌ی.

ب‌ن‌اب‌رای‌ن ت‌وص‌ی‌ه م‌ی‌ش‌ود س‌ازم‌ان‌ه‌ا س‌طح‌ی از ASVS را ان‌ت‌خ‌اب ک‌ن‌ن‌د ک‌ه م‌ت‌ن‌اس‌ب ب‌ا ب‌ل‌وغ ام‌ن‌ی‌ت‌ی آن‌ه‌ا و پ‌ی‌ام‌ی ک‌ه م‌ی‌خ‌واه‌ن‌د ب‌ه ک‌ارب‌ران خ‌ود م‌ن‌ت‌ق‌ل ک‌ن‌ن‌د، ب‌اش‌د.

Sanitization and Encoding V1

ه‌دف

ای‌ن ف‌ص‌ل ب‌ه ض‌ع‌ف‌ه‌ای رای‌ج ام‌ن‌ی‌ت‌ی در ب‌رن‌ام‌ه‌ه‌ای وب م‌ی‌پ‌ردازد ک‌ه ن‌اش‌ی از پ‌ردازش ن‌اام‌ن داده‌ه‌ای غ‌ی‌رق‌اب‌ل‌اع‌ت‌م‌اد اس‌ت. چ‌ن‌ی‌ن ض‌ع‌ف‌ه‌ای‌ی م‌م‌ک‌ن اس‌ت م‌ن‌ج‌ر ب‌ه آس‌ی‌ب‌پ‌ذی‌ری‌ه‌ای ف‌ن‌ی م‌خ‌ت‌ل‌ف‌ی ش‌ون‌د، در ش‌رای‌ط‌ی ک‌ه داده‌ه‌ای غ‌ی‌رق‌اب‌ل‌اع‌ت‌م‌اد، م‌ط‌اب‌ق ب‌ا دس‌ت‌ور زب‌ان م‌ف‌س‌ر م‌رب‌وط‌ه ت‌ف‌س‌ی‌ر م‌ی‌ش‌ون‌د.

در ب‌رن‌ام‌ه‌ه‌ای وب م‌درن، ه‌م‌واره ب‌ه‌ت‌ری‌ن ک‌ار اس‌ت‌ف‌اده از ه‌ایAPI ام‌ن‌ت‌ر م‌ان‌ن‌د parameterized، auto- queries escaping ی‌ا templating frameworks اس‌ت. در غ‌ی‌ر ای‌ن ص‌ورت، اج‌رای دق‌ی‌ق و م‌ح‌ت‌اط‌ان‌ه‌ی encoding، escaping ی‌ا sanitization ب‌رای ام‌ن‌ی‌ت ب‌رن‌ام‌ه ح‌ی‌ات‌ی خ‌واه‌د ب‌ود.

اع‌ت‌ب‌ارس‌ن‌ج‌ی ورودی ب‌ه‌ع‌ن‌وان م‌ک‌ان‌ی‌زم «دف‌اع در ع‌م‌ق» ع‌م‌ل م‌ی‌ک‌ن‌د و از ورود م‌ح‌ت‌وای غ‌ی‌رم‌ن‌ت‌ظ‌ره ی‌ا خ‌ط‌رن‌اک ج‌ل‌وگ‌ی‌ری م‌ی‌ک‌ن‌د. ب‌ا ای‌ن ح‌ال، از آن‌ج‌اک‌ه ه‌دف اص‌ل‌ی آن ت‌ط‌اب‌ق م‌ح‌ت‌وا ب‌ا ال‌زام‌ات ع‌م‌ل‌ک‌ردی و ت‌ج‌اری اس‌ت، ال‌زام‌ات م‌رت‌ب‌ط ب‌ا آن در ف‌ص‌ل «اع‌ت‌ب‌ارس‌ن‌ج‌ی و م‌ن‌ط‌ق ک‌س‌ب‌وک‌ار» آم‌ده اس‌ت.

V1.1 ساخت‌ار Sanitization and Encoding

در بخش‌های زیر، الزامات مختص سورس کدی‌ا مختص مفسر برای پردازش امن داده‌های ناامن به‌منظور جلوگیری از آسیب‌پذیری‌های امنیتی ارائه شده‌اند. این الزامات، تررتیب انجام این پردازش و محل مناسب اجرای آن را پوشش می‌دهند. همچنین، هدف آن‌ها این است که هنگام ذخیره‌سازی داده، محتوا در حالت اولیه خود باقی بمانند و به‌صورت encoded یا escaped (مثلاً HTML encoding) ذخیره نشود تا از بروز مشکلات ناشی از رمزگذاری دوگانه (double encoding) جلوگیری شود.

#	Description	Level
1.1.1	ورودی فقط یک‌بار به فرم است‌اندارد decoded یا unescaped شود، و این تنها زمانی انجام شود که انتظار می‌رود داده واقعاً در آن قالب رمزگذاری‌شده دریافت شده باشد. این فرآیند باید قبل از هرگونه پردازش بعدی روی ورودی انجام شود، و به‌هیچ‌وجه نباید پس از اعتبارسنجی یا پاک‌سازی انجام گیرد.	2
1.1.2	برنامه فرآیند encode و escape خروجی را به‌عنوان آخرین مرحله انجام می‌دهد؛ به‌گونه‌ای که این عملیات یا دقیقاً پیش از استفاده داده در مفسر مربوطه انجام شود، یا اینکه خود مفسر به‌طور داخلی این کار را انجام دهد.	2

V1.2 پیشگیری از تزریق

encode و escape خروجی‌ها زمان دریافت ورودی‌های حساس که ممکن است منجر به تزریق شوند، برای امنیت برنامه حیاتی است. معمولاً این encode و escape خروجی ذخیره نمی‌شوند، بلکه صرفاً برای ایمن‌سازی نمایش در همان لحظه در مفسر استفاده می‌شوند. انجام زودهنگام این عملیات ممکن است باعث خرابی محتوا یا بی‌اثر شدن فرایند encoding و escaping شود.

در بسیاری از موارد، کتابخانه‌های نرم‌افزاری توابع امن یا امنتری را برای انجام خودکار این کار ارائه می‌دهند، با این حال باید اطمینان حاصل شود که برای زمینه (context) موردنظر صحیح هستند.

#	Description	Level
1.2.1	encoding خروجی برای پاسخ HTTP، سند HTML یا سند XML با زمینه‌ای که داده در آن استفاده می‌شود باید متناسب باشد؛ برای مثال، در رمزگذاری کاراکترهای مربوط به عناصر HTML، صفات HTML، توضیحات HTML، CSS یا فیلدهای هدر HTTP به‌گونه‌ای عمل شود که ساختار پیام یا سند تغییر نکند.	1
1.2.2	هنگام ساخت پویا آدرس‌های URL، داده‌های غیرقابل‌اعتماد باید متناسب با زمینه استفاده‌شان رمزگذاری شوند (مثلاً Encoding URL یا base64url برای پارامترهای کوئری یا مسیر) همچنین اطمینان حاصل شود که فقط پروتکل‌های امن در URL مجاز باشند (برای نمونه، استفاده از JavaScript: یا data: ممنوع شود)	1

#	Description	Level
1.2.3	هن‌گام تولی‌د پ‌وی‌ا مح‌ت‌وای JavaScript (از ج‌م‌لهJSON)، از encoding ی‌ا escaping خ‌روج‌ی اس‌ت‌فاده ش‌ود ت‌ا از ت‌غ‌ی‌ی‌ر س‌اخ‌ت‌ار پ‌ی‌ام ی‌ا س‌ند ج‌لوگ‌ی‌ری گ‌ردد (و از ح‌م‌لات ت‌زری‌ق JavaScript ی‌ا JSON پ‌ی‌ش‌گ‌ی‌ری ش‌ود).	1
1.2.4	در ان‌ت‌خ‌اب داده ی‌ا اج‌رای ک‌وئ‌ری‌ه‌ای پ‌ای‌گ‌اه داده (م‌انند SQL، NoSQL HQL،...)، از parameterized، queries، ORMاه‌ی Framework Entity ی‌ا اس‌ت‌فاده ش‌ود ی‌ا ب‌ه روش‌ه‌ای دی‌گ‌ر، ب‌رنام‌ه در ب‌راب‌ر ت‌زری‌ق SQL و س‌ای‌ر ح‌م‌لات ت‌زری‌ق‌ی پ‌ای‌گ‌اه داده ای‌م‌ن ش‌ده ب‌اش‌د. ای‌ن م‌وض‌وع ه‌ن‌گ‌ام ن‌وش‌ت‌ن procedure storedاه‌ا ن‌ی‌ز ص‌دق م‌ی‌ک‌ن‌د.	1
1.2.5	ب‌رنام‌ه در ب‌راب‌ر ت‌زری‌ق دس‌ت‌ورات س‌ی‌س‌ت‌م‌ع‌ام‌ل OS) command injection) مح‌اف‌ظ‌ت ش‌ده اس‌ت و در ف‌راخ‌وان‌ی‌ه‌ای س‌ی‌س‌ت‌م‌ع‌ام‌ل، از ک‌وئ‌ری‌ه‌ای پ‌ارام‌ت‌ری‌ش‌ده س‌ی‌س‌ت‌م‌ع‌ام‌ل ی‌ا Encoding خ‌روج‌ی دس‌ت‌ورات س‌ی‌س‌ت‌م‌ع‌ام‌ل‌ی اس‌ت‌فاده م‌ی‌ش‌ود.	1
1.2.6	ب‌رنام‌ه در ب‌راب‌ر آس‌ی‌ب‌پ‌ذی‌ری‌ه‌ای ت‌زری‌ق LDAP مح‌اف‌ظ‌ت ش‌ده اس‌ت، ی‌ا ای‌ن‌ک‌ه ک‌ن‌ت‌رل‌ه‌ای ام‌ن‌ی‌ت‌ی م‌ش‌خ‌ص‌ی ب‌رای ج‌لوگ‌ی‌ری از ت‌زری‌ق LDAP پ‌ی‌اده‌س‌ازی ش‌ده‌ان‌د.	2
1.2.7	ب‌رنام‌ه در ب‌راب‌ر ح‌م‌لات ت‌زری‌قXPath، ب‌ه‌وس‌ی‌ل‌ه‌ی اس‌ت‌فاده از ک‌وئ‌ری‌ه‌ای پ‌ارام‌ت‌ری‌ش‌ده ی‌ا ک‌وئ‌ری‌ه‌ای از پ‌ی‌ش ک‌ام‌پ‌ای‌ل‌ش‌ده مح‌اف‌ظ‌ت ش‌ده ب‌اش‌د.	2
1.2.8	پ‌ردازش گ‌ره‌ای LaTeX ب‌ه‌ص‌ورت ام‌ن پ‌ی‌ک‌ربن‌دی ش‌ده‌ان‌د (ب‌رای ن‌م‌ون‌ه ب‌ا ع‌دم اس‌ت‌فاده از گ‌زی‌ن‌ه‌ی shell-escape– (و از ف‌ه‌رس‌ت م‌جاز دس‌ت‌ورات (allowlist) ب‌رای ج‌لوگ‌ی‌ری از ح‌م‌لات ت‌زری‌ق LaTeX اس‌ت‌فاده ش‌ده اس‌ت.	2
1.2.9	ب‌رنام‌ه ک‌اراک‌ت‌ره‌ای وی‌ژه در ع‌ب‌ارات Regex را escape م‌ی‌ک‌ند (مع‌م‌ولاً ب‌ا اس‌ت‌فاده از ،(ت‌ا ای‌ن ک‌اراک‌ت‌ره‌ا ب‌ه‌اش‌ت‌ب‌اه ب‌ه‌ع‌ن‌وان مت‌اک‌اراک‌ت‌ر ت‌ف‌س‌ی‌ر ن‌ش‌وند.	2
1.2.10	ب‌رنام‌ه در ب‌راب‌ر ح‌م‌لات ت‌زری‌ق CSV و ف‌رم‌ول Formula) (Injection مح‌اف‌ظ‌ت ش‌ده اس‌ت. ب‌رنام‌ه ب‌ای‌د ه‌ن‌گ‌ام خ‌روج‌ی گ‌رف‌ت‌ن ف‌ای‌ل‌ه‌ای ،CSV از ق‌وان‌ی‌ن escape ت‌ع‌ی‌ی‌ن‌ش‌ده در ب‌خ‌ش‌ه‌ای ۲.۶ و ۲.۷ اس‌ت‌ان‌دارد RFC 4180 پ‌ی‌روی ک‌ند. ه‌م‌چ‌ن‌ی‌ن، ه‌ن‌گ‌ام خ‌روج‌ی گ‌رف‌ت‌ن ب‌ه ف‌رمت CSV ی‌ا س‌ای‌ر ف‌رمت‌ه‌ای ص‌ف‌ح‌ه گ‌س‌ت‌رده (م‌انند XLSX XLS، ی‌ا ODF)، اگ‌ر ک‌اراک‌ت‌ره‌ای وی‌ژه‌ای م‌انند ‘=’، ‘+’، ‘-’، ‘@’، \t (tab) و 0 Null) character) در اب‌ت‌دای م‌ق‌دار ی‌ک ف‌ی‌ل‌د ق‌رار داش‌ت‌ه ب‌اش‌ن‌د، ب‌ای‌د ب‌ا ی‌ک ت‌ک ک‌وت‌ی‌ش‌ن (’) escape ش‌ون‌د.	3

ن‌ک‌ت‌ه: اس‌ت‌فاده از ک‌وئ‌ری‌ه‌ای پ‌ارام‌ت‌ری‌ش‌ده Parameterized) (Queries ی‌ا داده‌Escapingاه‌ا در SQL ه‌م‌ی‌ش‌ه ب‌ه‌ت‌ن‌ه‌ای‌ی ک‌اف‌ی ن‌ی‌س‌ت. ب‌خ‌ش‌ه‌ای‌ی از ک‌وئ‌ری م‌ث‌ل ن‌ام ج‌دول‌ه‌ا و س‌ت‌ون‌ه‌ا (از ج‌م‌لهٔ ن‌ام س‌ت‌ون‌ه‌ای‌ی ک‌ه در دس‌ت‌ور BY ORDER اس‌ت‌فاده ش‌ده‌ان‌د) را ن‌م‌ی‌ت‌وان ب‌ا escape ک‌ردن ام‌ن ک‌رد .اگ‌ر داده‌ه‌ای‌ی ک‌ه ک‌ارب‌ر وارد ک‌رده (ح‌ت‌ی ب‌ع‌د از escape ک‌ردن) در ای‌ن ب‌خ‌ش‌ه‌ا اس‌ت‌فاده ش‌ون‌د، م‌م‌ک‌ن اس‌ت:ک‌وئ‌ری ب‌ه‌درس‌ت‌ی اج‌را ن‌ش‌ود (خ‌طای SQL ب‌ده)، ی‌ا ب‌اع‌ث ح‌م‌له‌ی Injection SQL ش‌ود.

V1.3 پاک‌سازی (Sanitization)

ای‌ده‌آل‌تری‌ن روش محافظت در برابر استفاده از محتوای غیرقابل اعتماد در ی‌ک بستر ناامن، استفاده از encoding ی‌ا escaping متناسب با همان بستر است؛ روشی‌که معنای اصلی محتوای ناامن را حفظ می‌کند اما آن را برای استفاده در همان زمینه ای‌من می‌سازد — همان‌طورکه در بخش قبلی به‌تفصیل توضیح داده شد.

اما اگر ای‌ن امکان وجود نداشته باشد، باید از sanitization (پاک‌سازی) استفاده شود؛ یعنی حذف کاراکترها ی‌ا بخش‌های‌ی از محتواکه ممکن است خطرناک باشند. در برخی موارد، ای‌ن کار ممکن است باعث تغییر معنای ورودی شود، اما از منظر امنیتی، چاره‌ای جز ای‌ن وجود ندارد.

#	Description	Level
1.3.1	تمام ورودی‌های HTML غیرقابل اعتماد (مثلاً از طریق ویرایش‌گرهای WYSIWYG ی‌ا ابزارهای مشابه)، با استفاده از ی‌ک کتابخانه ی‌ا قابلیت امن و معتبر sanitization (پاک‌سازی) شوند.	1
1.3.2	برنامه استفاده از تابع eval ی‌ا سایر قابلیت‌های اجرای پویا (dynamic) کد مانند Language Expression Spring ،(SpEL) اجتناب کند. در مواردی‌که استفاده از ای‌ن قابلیت‌ها اجتناب‌ناپذیر است، ورودی‌های کاربرکه در اجرای کد گنجانده می‌شوند باید پیش از اجرا، به‌طور کامل پاک‌سازی (sanitized) شوند.	1
1.3.3	بخش‌های حائز اهمیت‌که احتمال وقوع حملات ناشی از ورودی‌های کاربر در آن‌ها بالاست؛ باید پیش‌اپیش عملیاتSanitization جهت اقدامات ایمنی روی داده‌ها انجام شود؛ برای مثال، تنها کاراکترهای‌ی‌که برای آن محتوا ایمن محسوب می‌شوند مجاز باشند، و ورودی‌های بی‌شازحد بلند نیز کوتاه (trim) شوند.	2
1.3.4	محتوای اس‌کریپت‌پذیر (scriptable) فایل‌های SVG که توسط کاربر ارائه می‌شود، مورد اعتبارسنجی ی‌ا پاک‌سازی (sanitization) قرار گرفته باشد تا فقط شامل تگ‌ها و ویژگی‌های‌ی (attributes) باشد که برای برنامه ایمن هستند؛ برای مثال، از درج اس‌کریپت‌ها و عناصر خطرناک مانند foreignObject جلوگیری شده باشد.	2
1.3.5	برنامه محتوای زبان‌های قالب‌نویسی ی‌ا اس‌کریپت‌پذیر ارائه‌شده توسط کاربر، مانند Markdown ،CSS ی‌ا استایل‌شیت‌های XSL ،BBCode ی‌ا موارد مشابه را پاک‌سازی (sanitize) کرده ی‌ا غیرفعال کرده باشد.	2
1.3.6	برنامه در برابر حملات جعل درخواست سمت سرور (SSRF) محافظت شده باشد؛ به ای‌ن صورت‌که داده‌های غیرقابل اعتماد را در برابر ی‌ک لیست مجاز از پروتکل‌ها، دامنه‌ها، مسیرها و پورت‌ها اعتبارسنجی کرده و کاراکترهای بالقوه خطرناک را پیش از استفاده از داده برای فراخوانی سرویس دیگر پاک‌سازی (sanitize) می‌کند.	2

#	Description	Level
1.3.7	برنامه در برابر حملات تزریق قالب (Template Injection) محافظت شده باشد؛ به این صورت که ساخت قالب‌ها بر پایه داده‌های غیرقابل اعتماد مجاز نباشد. در صورتی که هیچ راه‌حل جایگزینی وجود نداشته باشد، هرگونه ورودی غیرقابل اعتماد که به‌صورت پویا در فرآیند ایجاد قالب وارد می‌شود، باید پیش از استفاده یا پاک‌سازی (sanitize) شود یا به‌صورت سخت‌گیرانه اعتبارسنجی (validate) گردد.	2
1.3.8	برنامه، ورودی غیرقابل اعتماد را پیش از استفاده در کوئری‌های Naming Java and Directory Interface (JNDI) به‌درستی پاک‌سازی (sanitize) می‌کند و همچنین اطمینان حاصل شود که پیکربندی JNDI به‌گونه‌ای امن انجام شده تا از برون حملات تزریق JNDI جلوگیری شود.	2
1.3.9	برنامه، محتوا را پیش از ارسال به memcache پاک‌سازی (sanitize) می‌کند تا از حملات تزریق (injection attacks) جلوگیری شود.	2
1.3.10	رشته‌های قالب‌بندی (format strings) که ممکن است هنگام استفاده، به‌شکلی ناخواسته یا مخرب تفسیر شوند، پیش از پردازش پاک‌سازی (sanitize) شوند.	2
1.3.11	برنامه ورودی‌های کاربر را پیش از ارسال به سامانه‌های ایمیل (مانند SMTP یا IMAP) پاک‌سازی (sanitize) کند تا از حملات تزریق در SMTP یا IMAP جلوگیری شود.	2
1.3.12	عبارات منظم (Regular Expressions) عاری از اجزایی هستند که باعث بازگشت‌پذیری نمایی (exponential backtracking) می‌شوند، و همچنین ورودی‌های غیرقابل اعتماد به‌درستی پاک‌سازی (sanitize) شوند تا از حملات ReDoS (انکار سرویس با استفاده از عبارات منظم) یا Regex Runaway جلوگیری گردد.	3

V1.4 حافظه، رشته و کد بدون مدیریت (Memory, String and Unmanaged Code)

الزامات زیر به ریسک‌های ناشی از استفاده ناایمن از حافظه می‌پردازند، که معمولاً در شرایطی مطرح هستند که برنامه از زبان‌های سیستمی یا کدهای مدیریت‌نشده (unmanaged code) استفاده می‌کند.

در برخی موارد، می‌توان با تنظیم پرچم‌های کامپایلر (compiler flags) به این هدف دست یافت؛ مانند فعال‌سازی محافظت‌ها و هشدارهای مربوط به سرریز بافر (buffer overflow)، تصادفی‌سازی پشته (stack randomization)، جلوگیری از اجرای داده‌ها (DEP) و همچنین توقف فرایند ساخت (build) در صورت شناسایی عملیات ناایمن روی اشاره‌گرها، حافظه، رشته‌های قالب‌بندی، اعداد صحیح یا رشته‌های متنی.

#	Description	Level
1.4.1	برنامه از رشته‌های ایمن از نظر مدیریت حافظه، کپی حافظه‌ای ایمن‌تر و حساب‌گری ایمن‌تر روی اشاره‌گرها استفاده می‌کند تا از سرریز پشته (stack overflow)، سرریز بافر (buffer overflow) یا سرریز حافظه پویای (heap overflow) جلوگیری کرده یا آن‌ها را شناسایی کند.	2
1.4.2	از تکنیک‌های اعتبارسنجی علامت (sign validation)، محدوده (range validation) و ورودی (input validation) استفاده شده است تا از بروز سرریز عدد صحیح (integer overflow) جلوگیری شود.	2
1.4.3	حافظه و منابعی که به‌صورت پویا تخصیص داده شده‌اند، به‌درستی آزاد (release) می‌شوند و همچنین ارجاع‌ها یا اشاره‌گرها (pointers) به حافظه آزادشده حذف یا به null تنظیم می‌شوند تا از اشاره‌گرهای معلق (dangling pointers) و آسیب‌پذیری‌های استفاده پس از آزادسازی (use-after-free) جلوگیری شود.	2

V1.5 سریال‌زدایی ایمن (Safe Deserialization)

تبدیل داده‌ها از یک قالب ذخیره‌شده یا انتقال‌یافته به یک object واقعی برنامه(فرایند -dese rialization) در گذشته منبع بسیاری از آسیب‌پذیری‌های تزریق کد بوده است. بنابراین، انجام این فرایند باید با دقت و به‌صورت ایمن صورت گیرد تا از بروز چنین مشکلاتی جلوگیری شود.

به‌ویژه، برخی از روش‌های deserialization طبق مستندات زبان‌های برنامه‌نویسی یا چارچوب‌ها به‌عنوان ناایمن شناخته شده‌اند و نمی‌توانند هنگام کار با داده‌های غیرقابل‌اعتماد به‌صورت ایمن استفاده شوند. برای هر مکانیزم مورداستفاده، باید بررسی دقیق و مسئولانه (due diligence) انجام شود.

#	Description	Level
1.5.1	برنامه، Parserهای XML را به‌گونه‌ای پیکربندی کرده باشد که از تنظیمات محدودکننده استفاده کنند، و ویژگی‌های ناایمنی مانند resolve کردن موجودیت‌های خارجی (external entities) غیرفعال شده باشند تا از حملات XML External Entity (XXE) جلوگیری شود.	1
1.5.2	فرآیند deserialization داده‌های غیرقابل‌اعتماد، با اجرای مدیریت ایمن ورودی‌ها همراه باشد، برای مثال، استفاده از لیست مجاز (allowlist) انواع objectها یا محدود کردن انواع تعریف‌شده توسط کلاینت برای جلوگیری از حملات deserialization. همچنین، مکانیزم‌های deserialization که به‌طور صریح به‌عنوان ناایمن شناخته شده‌اند، نباید با داده‌های غیرقابل‌اعتماد مورد استفاده قرار گیرند.	2

#	Description	Level
1.5.3	Parser های مختلفی که در برنامه برای یک نوع داده مشخص استفاده می‌شوند (برای مثال: Parser های JSON، XML یا URL) رفتار تحلیلی یکسانی دارند و از مکانیزم یکسانی برای encoding کاراکترها استفاده می‌کنند، تا از بروز مشکلاتی مانند آسیب‌پذیری در سازگاری JSON (JSON Interoperability) یا تفاوت در نحوه تحلیل URI یا مسیر فایلی که ممکن است در حملات RFI یا SSRF سوءاستفاده شود، جلوگیری شود.	3

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- OWASP Injection LDAP Prevention Cheat Sheet
- OWASP Cross Site Scripting Prevention Cheat Sheet
- OWASP DOM based Cross Site Scripting Prevention Cheat Sheet
- OWASP XML External Entity Prevention Cheat Sheet
- OWASP Web Security Testing Guide: Testing Client-Side
- OWASP Java Encoding Project
- HTML Client-side Sanitization Library - DOMPurify
- RFC4180 - Common Format and MIME Type for Comma-Separated Values (CSV) Files

برای اطلاعات بیشتر، به‌ویژه در مورد مشکلات deserialization یا parsing، لطفاً مراجعه کنید به:

- OWASP Deserialization Cheat Sheet
- An Exploration of JSON Interoperability Vulnerabilities
- Orange Tsai - A New Era of SSRF - Exploiting URL Parser in Trending Programming Languages

Logic Business and Validation V2

هدف

یک برنامه مورد تائید باید الزامات سطح بالا را به شرح زیر برآورده سازد:

- داده‌های دریافتی برنامه با الزامات تجاری یا عملکردی مطابقت داشته باشد.
- منطق تجاری (Business Logic) دارای جریان ترتیبی بوده، به‌صورت گام‌به‌گام پردازش شود و قابل دور زدن نباشد.
- منطق تجاری شامل محدودیت‌ها و کنترل‌های برای شناسایی و جلوگیری از حملات خودکار است؛ مانند انتقال‌های مکرر با مبالغ کم یا اضافه کردن می‌لی‌ون‌ها دوست به‌صورت تک-تک.

- در طراحی و پیاده‌سازی جریان‌های منطق تجاری با ارزش بالا، سناریوهای سوءاستفاده و کاربران مخرب در نظر گرفته شود و تدابیری نظیر محافظت در برابر جعل هویت (Spoof-ing)، دستکاری (Tampering)، افشای اطلاعات و ارتقای سطح دسترسی (Privilege Escalation) اتخاذ شده باشد.

V2.1 مستندات اعتبارسنجی و منطق کسب‌وکار (Business and Validation Logic Documentation)

مستندات اعتبارسنجی و منطق تجاری باید به‌روشنی محدودیت‌های منطق کسب و کار، قوانین اعتبارسنجی و سازگاری مناسب بین داده‌های ترکیب شده (از نظر مفهومی و متنی) را تعریف کنند، تا مشخص باشد چه مواردی باید در برنامه پیاده‌سازی شوند.

#	Description	Level
2.1.1	قوانین اعتبارسنجی ورودی‌های برنامه (مندرج در مستندات برنامه) باید چگونگی بررسی صحت داده‌ها را مطابق با ساختار مورد انتظار مشخص نمایند. این ساختارها می‌توانند شامل فرمت‌های رایج داده مانند شماره کارت اعتباری، آدرس ایمیل، شماره تلفن یا یک قالب داده‌ای داخلی باشد.	1
2.1.2	قوانین اعتبارسنجی ورودی‌های برنامه (مندرج در مستندات برنامه) باید چگونگی بررسی سازگاری مناسب بین داده‌های ترکیب شده (از نظر مفهومی و متنی) را مشخص نمایند؛ مانند تطبیق کدپستی با نام محله.	2
2.1.3	انتظارات مربوط به محدودیت‌ها و اعتبارسنجی‌های منطق کسب و کار مستند شده باشند؛ این مستندات باید شامل محدودیت‌ها در سطح هر کاربر و محدودیت‌های عمومی در سطح برنامه باشند.	2

V2.2 اعتبارسنجی ورودی (Input Validation)

کنترل‌های مؤثر در اعتبارسنجی ورودی، انتظارات کسب و کار یا عملکردی مرتبط با نوع داده‌ای که برنامه باید دریافت کند را اعمال می‌کنند. این کار منجر به کیفیت بهتر داده‌ها و کاهش دامنه حمله (Attack Surface) می‌شود. با این حال، اعتبارسنجی ورودی جایگزین استفاده از encoding ، پارامتری‌سازی یا پاک‌سازی داده‌ها هنگام استفاده از داده در سایر بخش‌های برنامه یا هنگام نمایش درخروجی نمی‌باشد.

در این زمینه، «ورودی» می‌تواند از منابع متنوعی دریافت شود، از جمله: فیلدهای فرم ،HTML درخواست‌های ،REST پارامترهای ،URL فیلدهای هدر کوکی،HTTPها، فایل‌های ذخیره‌شده در دیسک، پایگاه‌های داده، هایAPI خارجی.

یک کنترل منطق کسب و کاری ممکن است بررسی کند که مقدار ورودی، عددی کمتر از 100 است.یک انتظار عملکردی ممکن است بررسی کند که یک عدد (که تعیین می‌کند یک حلقه چند بار اجرا شود تا پردازش بیش از حد و در نتیجه وضعیت انکار سرویس(DoS) اتفاق نیافتد) از یک آستانه‌ی خاص کمتر باشد.

با این‌که اعتبارسنجی بر پایه Schema الزام صریح ندارد، ولی این روش می‌تواند مؤثرتری‌ن راه‌کار برای پوشش کامل اعتبارسنجی در هایHTTP API یا سایر واسطه‌ای‌که از JSON یا XML استفاده می‌کنند باشد.

نکات مهم درباره اعتبارسنجی بر اساس :Schema

- "نسخه منتشرشده" از مشخصات Schema JSON، Validation برای استفاده در محیط تولید مناسب تلقی می‌شود، نه لزوما پایدار(Stable). هنگام استفاده از این نوع اعتبارسنجی، باید اطمینان حاصل شود که هیچ مغایرتی با الزامات زیر وجود ندارد.
- در صورت نیاز پس از رسمی و نهایی شدن استاندارد، تمامی کتابخانه‌های مورد استفاده برای Schema JSON بایدValidation به‌صورت مستمر پایش و به‌روزرسانی شوند.
- اعتبارسنجی DTD نباید مورد استفاده قرار گیرد و ارزیابی DTD در فریم‌ورک‌ها باید غیرفعال شود، تا از حملات XXE مرتبط با DTD جلوگیری شود.

#	Description	Level
2.2.1	ورودی‌ها باید به‌منظور اعمال انتظارات کسب و کار یا عملکردی مرتبط با آن‌ها اعتبارسنجی شوند.این اعتبارسنجی باید یکی از این دو روش زیر را داشته باشد، استفاده از اعتبارسنجی مثبت (Positive Validation) مبتنی بر فهرست مجاز از مقادیر، الگوها یا بازه‌های قابل قبول و تطبیق با سناریوهای مورد انتظار و محدودیت‌های منطقی، بر اساس قوانینی از پیش تعریف‌شده. برای سطح 1 ،(L1) تمرکز می‌تواند بر ورودی‌هایی باشد که در تصمیم‌گیری‌های خاص تجاری یا امنیتی استفاده می‌شوند. برای سطح 2 و بالاتر، این اعتبارسنجی باید شامل تمام ورودی‌ها باشد.	1
2.2.2	برنامه به‌گونه‌ای طراحی شود که اعتبارسنجی ورودی را در لایه قابل اعتمادی از سرویس (Trusted Service Layer) اعمال کند. هرچند اعتبارسنجی سمت کلاینت (Client-side Validation) باعث بهبود تجربه کاربری می‌شود و توصیه می‌گردد، اما نباید به‌عنوان یک کنترل امنیتی اتکا شود.	1
2.2.3	برنامه باید اطمینان حاصل نماید که ترکیب داده‌های مربوطه با توجه به قوانین از پیش تعریف‌شده معقول و منطقی باشد.	2

V2.3 امنیت منطق کسب‌وکار (Business Logic Security)

این بخش به الزامات کلیدی می‌پردازد که هدف آن‌ها اطمینان از پیاده سازی صحیح منطق کسب و کاری برنامه است و برنامه در برابر حملات مربوط به کسب و کار، مصون است.

#	Description	Level
2.3.1	اطمی‌نان حاصل شود که برنامه فقط جری‌انه‌ای منطق تجاری را برای همان کاربر و طبق ترتی‌ب گام‌به‌گام از پی‌ش تع‌ی‌ی‌ن شده و مورد انتظار پردازش می‌کند و امکان رد کردن مراحل (Skipping Steps) وجود ندارد.	1
2.3.2	اطمی‌نان حاصل شود که محدودی‌ت‌ه‌ای منطق تجاری مطابق با مس‌ت‌ندات برنامه پی‌اده‌س‌ازی شده‌اند، تا از س‌وءاس‌ت‌فاده از نقص‌ه‌ای منطقی جل‌وگی‌ری شود.	2
2.3.3	تراکن‌ش‌ه‌ای س‌طح منطق کس‌ب‌وکار (business logic) بای‌د به‌گون‌ه‌ای اس‌ت‌فاده شوند که یا ی‌ک عمل‌ی‌ات منطق کس‌ب‌وکار به‌طور کامل با موفقی‌ت انجام شود، یا در صورت بروز خطا، به حالت صحی‌ح قبل‌ی بازگردد(rollback) شود.	2
2.3.4	در منطق کس‌ب‌وکار (business logic) بای‌د از مکان‌ی‌زم‌ه‌ای قفل‌گذاری (locking) اس‌ت‌فاده شده باشد تا اطمی‌نان حاصل شود که منابع محدود (مانند صندلی‌ه‌ای س‌ی‌نما یا بازه‌ه‌ای زمانی تح‌وی‌ل)، قابل رزرو دوباره (double-booked) از طری‌ق دست‌کاری منطق برنامه نباشند.	2
2.3.5	اطمی‌نان حاصل شود که جری‌انه‌ای منطق کس‌ب و کاری با ارزش بالا نی‌ازمند تای‌ی‌د چند کاربره (Multi-user Approval) هس‌تند تا از اقدامات غی‌رمجاز یا تص‌ادفی جل‌وگی‌ری شود. این موارد می‌توانند شامل - اما نه محدود به - انتق‌ال‌ه‌ای مالی بزرگ، تای‌ی‌د قراردادها، دست‌رسی به اطلاعات طبق‌ه‌بن‌ده شده، یا غی‌رفع‌ال‌س‌ازی‌ه‌ای ای‌منی در محی‌ط‌ه‌ای تول‌ی‌د صنع‌تی باشد.	3

V2.4 مقابله با خودکارسازی (Anti-automation)

این بخش شامل کنترل‌ه‌ای ضد خودکارسازی است تا تعاملات انسانی‌مانند الزامی شود و از درخواست‌ه‌ای خودکار بی‌ش‌ازحد جل‌وگی‌ری گردد.

#	Description	Level
2.4.1	کنترل‌ه‌ای ضد خودکارسازی (Anti-Automation) در س‌ی‌س‌تم پی‌اده‌س‌ازی شده باشند تا از س‌وءاس‌ت‌فاده‌ای‌ی مانند فراخوانی بی‌ش از حد توابع برنامه جل‌وگی‌ری شود؛ چراکه این نوع حمل‌ات می‌توانند منجر به اس‌تخراج غی‌رمجاز داده‌ها، تول‌ی‌د داده‌ای زائد، مصرف کامل س‌ه‌می‌ه‌ها، عبور از محدودی‌ت‌ه‌ای نرخ (Rate Limit)، ایجاد اخت‌لال در سرویس (DoS) یا اس‌ت‌فاده بی‌ش از حد از منابع گران‌ق‌ی‌مت شوند.	2

#	Description	Level
2.4.2	بررسی کنید که جریان‌های منطق کسب‌وکار (Business Logic) به گونه‌ای طراحی شده باشند که نیازمند زمان‌بندی واقعی انسان باشند، و از ارسال سریع و غیرطبیعی تراکنش‌ها (Transaction Submissions) جلوگیری کنند.	3

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- Testing Validation Input Guide: Testing Security Web OWASP
- Testing Logic Business Guide: Testing Security Web OWASP
- جلوگیری از خودکارسازی (Anti-automation) را می‌توان به روش‌های مختلفی انجام داد، از جمله با استفاده از OWASP Applications Web to Threats Automated
- Sheet Cheat Validation Input OWASP
- Schema JSON

V3 امنیت رابط کاربری وب (Web Security) Frontend

هدف کنترلی

این دسته از الزامات بر روی محافظت در برابر حملاتی تمرکز دارد که از طریق رابط وب (Web Frontend) برنامه اجرا می‌شوند. این الزامات برای راه‌کارهایی از نوع ماشین-به-ماشین (Machine-to-Machine) کاربردی ندارند.

V3.1 مستندسازی امنیت رابط کاربری وب (Web Frontend Security Documentation)

این بخش ویژگی‌های امنیتی مرورگر را که باید در مستندات برنامه مشخص شوند، توضیح می‌دهد.

#	Description	Level
3.1.1	در مس‌تندات برنامه بای‌د وی‌ژگی‌های امنی‌تی مربوط به مرورگری که برنامه را اجرا می‌کند مشخص شده باشد (نظیر استفاده از HTTPS، پشتی‌بانی از HTTP Strict Security Transport (HSTS)، اجرای Content Security Policy (CSP) و سایر مکانیزم‌های امنی‌تی مرتبط با HTTP). همچنین در مس‌تندات بای‌د مشخص شود مرورگر در صورت عدم دس‌ترسی به این وی‌ژگی‌ها چه رفت‌اری بای‌د داشته باشد. (برای مثال: نمایش هشدار به کاربر یا ممانعت از دس‌ترسی به برنامه).	3

V3.2 تفسیر ناخواسته محتوا (Unintended Content Interpretation)

پردازش محتوا یا عملکرد مربوط به آن در یک شرایط زمینه‌ای نادرست می‌تواند منجر به اجرای یا نمایش محتوای مخرب برای کاربر شود.

#	Description	Level
3.2.1	کنترل‌های امنی‌تی متناسب با مرورگرها در هنگام پردازش پاسخ‌های HTTP به منظور جلوگیری از پردازش محتوا یا عملکرد مربوط به آن در شرایط زمینه‌ای نادرست بای‌د بکارگرفته شود. (برای مثال، زمانی که یک یAPI یک فایل بارگذاری‌شده توسط کاربر یا هر منبع دیگری به‌طور مس‌تقیم درخواست می‌شود). کنترل‌های ممکن می‌توانند شامل این موارد باشند: عدم پردازش محتوا مگر در صورت وجود هدرهای متناسب با درخواست‌های HTTP (مانند Sec-Fetch-* به منظور اطمی‌نان از صحی‌ح بودن پردازش محتوا یا عملکرد مربوط به . استفاده از عبارت sandbox در هدر Content-Security-Policy یا استفاده از نوعattachment در هدر Content-Disposition .	1
3.2.2	اطمی‌نان حاصل شود که محتوای‌ی که برای نمایش به‌صورت متن طراحی شده نه برای پردازش به صورتHTML ، با استفاده از توابع امن نظیر CreateTextNode یا textContent به منظور جلوگیری از اجرای ناخواسته محتوای‌ی مانند HTML یا JavaScript پردازش شود.	1
3.2.3	برنامه هنگام استفاده از جاواسکری‌پت سمت کاربر (Client-Side JavaScript)، با استفاده از اعلام متغی‌رها به‌صورت صری‌ح، انجام بررسی نوع به‌صورت سخت‌گی‌رانه، اجتناب از ذخی‌ره‌سازی متغی‌رهای سراسری بر روی شیء document، و پی‌اده‌سازی ایزولاسی‌ون فضای نام (namespace isolation)، وقوع Clobbering DOM جلوگی‌ری می‌کند.	3

V3.3 پی‌کربندی کوکی (Cookie Setup)

این بخش الزامات مربوط به پی‌کربندی ایمن کوکی‌های حساس را تشری‌ح می‌کند تا سطح بالاتری از اطمی‌نان نسبت به این‌که آن‌ها توسط خود برنامه ایجاد شده‌اند فراهم شود و همچنین

از نشت محتوای آن‌ها یا تغییر نام‌های جلوگیری گردد.

#	Description	Level
3.3.1	اطمینان حاصل شود که کوکی‌ها دارای ویژگی 'Secure' هستند. در صورتی که از پیشوند '__Host-' برای نام کوکی استفاده نمی‌شود، باید پیشوند __Secure- در نام کوکی لحاظ شده باشد.	1
3.3.2	اطمینان حاصل شود که مقدار ویژگی SameSite برای هر کوکی، متناسب با هدف آن کوکی تنظیم شده باشد تا میزان آسیب‌پذیری در برابر حملات فریب سمت کلاینت نظیر CSRF کاهش یابد.	2
3.3.3	اطمینان حاصل شود که کوکی‌ها از پیشوند __Host- در نام خود استفاده می‌کنند، مگر در مواردی که کوکی به‌طور مشخص برای اشتراک‌گذاری بین چند دامنه (Hosts) طراحی شده باشد.	2
3.3.4	اطمینان حاصل شود که اگر مقدار کوکی (مثلاً توکن نشست) نباید برای اسکریپت‌های سمت کلاینت در دسترس باشد، ویژگی HttpOnly باید برای آن کوکی فعال شده باشد، و همچنین مقدار کوکی (مثلاً همان توکن نشست) تنها از طریق هدر Set-Cookie به کلاینت ارسال شود.	2
3.3.5	اطمینان حاصل شود که حداکثر مجموع نام و مقدار کوکی از ۴۰۹۶ بایت تجاوز نکند. کوکی‌هایی که بیش از این مقدار باشند توسط مرورگر ذخیره نخواهند شد، و بنابراین در درخواست‌ها ارسال نمی‌شوند؛ موضوعی که ممکن است باعث شود عملکردهایی از برنامه که به آن کوکی وابسته‌اند، غیرفعال یا مختل شوند.	3

V3.4 هدرهای مکانیزم‌های امنیتی مرورگر (Browser Security Mechanism Headers)

این بخش مشخص می‌کند که کدام هدرهای امنیتی باید در پاسخ‌های HTTP تنظیم شوند، تا هنگام پردازش پاسخ توسط مرورگر، ویژگی‌ها و محدودیت‌های امنیتی مرورگر فعال گردند.

#	Description	Level
3.4.1	اطمینان حاصل شود که در تمامی پاسخ‌های HTTP، هدر Strict-Transport-Security وجود دارد تا سیاست Transport Strict (HTTP HSTS Security) اعمال شود. حداقل مقدار max-age باید برابر با یک سال باشد. برای برنامه‌های سطح 2 (L2) و بالاتر، این سیاست باید برای تمام زیردامنه‌ها (subdomains) نیز اعمال شود.	1

#	Description	Level
3.4.2	اطمی‌نان حاصل شود که هدرAccess-Control-Allow-Origin مربوط به ،(CORS) دارای ی ک مقدار ثابت و مشخص توسط برنامه باشد یا اگر هدر Origin در درخواست مورد استفاده قرار می گیرد باید با فهرستی از مبدأهای مورد اعتماد (Allowlist) اعتبارسنجی شود. در صورتی که استفاده از مقدار * در Access-Control-Allow-Origin تنظیم شده باشد، اطمی‌نان حاصل شود که هیچ اطلاعات حساسی در پاسخ قرار ندارد.	1
3.4.3	اطمی‌نان حاصل شود که تمامی پاسخ‌های HTTP شامل هدر Content-Security-Policy باشند تا ری‌سک اجرای اسکریپت‌های مخرب (مانند JavaScript) مخرب کاهش یابد. دستورهای object-src ‘none’ و base-uri ‘none’ الزامی هستند .برای برنامه‌های سطح 3 ،(L3) بایدسی‌است CSP به‌صورت اختصاصی برای هر پاسخ(Per-response Policy) و مبتنی بر nonce یا hash تعریف شده باشد.	2
3.4.4	اطمی‌نان حاصل شود که تمامی پاسخ‌ها شامل هدر :X-Content-Type-Options nosniff باشند، این (هدر) به مرورگرها دستور می‌دهد که برای پاسخ دریافتی از Sniffing Content یا حدس‌زدن نوع محتوا (MIME Type (Guessing استفاده نکنند و آن‌ها را ملزم می کنند که نوع محتوای واقعی را دقیقاً مطابق مقدار هدر Content-Type در درخواست/پاسخ در نظر بگیرند.برای مثال، پاسخ به ی ک درخواست برای ی ک فایل استایل (CSS) تنها در صورتی پذیرفته می‌شود که مقدار Content-Type در پاسخ ’text/css‘ باشد.این کار همچنین ام کان استفاده از قابلیت مس‌دودسازی خواندن منابع از مبدا متفاوت Blocking Read Cross-Origin یا (CORB) توسط مرورگر را فراهم می‌سازد.	2
3.4.5	برنامه بایدی (وب‌سایت یا اپلیکیشن) ی ک “Referrer Policy” (سیاست ارجاع) تنظیم کرده باشد تا از نشت اطلاعات حساس از طریق هدر HTTP به نام Referer به سرویس‌های شخص ثالث جلوگیری شود. این کار را می‌توان از طریق هدر پاسخ HTTP به نام Referrer-Policy یا با استفاده از ویژگی‌های درعنا‌صر HTML انجام داد.اطلاعات حساس ممکن است شامل مسیر (Path) و داده‌های کوئری (Query) در آدرس URL باشد، و در مورد برنامه‌های داخلی و غیرعمومی، حتی نام میزبان (hostname) نیز می‌تواند جزو اطلاعات حساس محسوب شود.	2
3.4.6	برنامه بایدی از frame-ancestors در هدر Content-Security-Policy (CSP) برای تمام پاسخ‌های HTTP استفاده کند،تا به‌صورت پیش‌فرض، اجازه‌ی نمایش سایت در قالب iframe داده نشود، و فقط در صورت نیاز، نمایش منابع خاص (specific resources) در iframe مجاز باشد.به این نکته توجه کنید که هدر X-Frame-Options با اینکه هنوز توسط برخی مرورگرها پشتیبانی می‌شود، اما قدیمی (obsolete) است و نباید به آن تکیه کرد.	2
3.4.7	هدر Content-Security-Policy (CSP) بایدی شامل ی ک آدرس برای گزارش (Report violation) باشد.	3

#	Description	Level
3.4.8	تمام پاسخ‌های HTTP که باعث رندر (نمایش) یک سند می‌شوند مانند (پاسخ‌های با نوع محتوا text/html) باید شامل هدر Cross-Origin-Opener-Policy با دستور same-origin یا same-origin-allow-popups باشند (بنا به نیاز). این کار از حملات جلوگیری می‌کند که از دست‌رسی مشترک به اشیای Window سوءاستفاده می‌کنند، مانند حملات tabnabbing و frame counting.	3

V3.5 تفکیک مبدا توسط مرورگر (Browser Origin (Separation

وقتی یک درخواست برای انجام عملکرد حساس در سمت سرور پذیرفته می‌شود، برنامه باید اطمینان حاصل کند که این درخواست واقعاً از طرف خود برنامه یا یک منبع مورد اعتماد ارسال شده و توسط مهاجم جعل نشده است.

عملکرد حساس در این زمینه می‌تواند شامل مواردی مانند ارسال فرم‌ها برای کاربران تأییدشده یا تأییدنشده (مثلاً درخواست احراز هویت)، عملیات تغییر وضعیت (state-changing operations)، یا عملکردهایی که منابع زیادی مصرف می‌کنند (مانند خروجی گرفتن از داده‌ها) باشد.

مکانیزم‌های کلیدی برای محافظت در برابر چنین حملاتی شامل سیاست‌های امنیتی مرورگرها مانند Same Origin Policy برای جاوااسکریپت و همچنین منطق SameSite برای کوکی‌ها هستند. یکی دیگر از روش‌های رایج برای محافظت، مکانیزم preflight CORS است. این مکانیزم به‌ویژه برای اندپوینت‌هایی که قرار است از یک مبدأ متفاوت فراخوانی شوند حیاتی است، اما حتی برای اندپوینت‌هایی که نباید از مبدأهای دیگر فراخوانی شوند نیز می‌توانند به‌عنوان یک لایه محافظتی مؤثر در برابر جعل درخواست Forgery Request عمل کنند.

#	Description	Level
3.5.1	برنامه باید از مکانیزم Preflight در CORS برای جلوگیری از درخواست‌های cross-origin به عملکردهای حساس استفاده نمی‌کنند، این درخواست‌ها به گونه‌ای اعتبارسنجی شوند که فقط از مبدأ اصلی برنامه ارسال شده باشند. این اعتبارسنجی می‌تواند با استفاده از توکن‌های (anti-forgery tokens) یا الزام به ارسال هدرهای HTTP اضافی انجام شود که در لیست هدرهای مجاز CORS (CORS-safelisted) قرار ندارند. این اقدام برای محافظت در برابر حملات جعل درخواست از طریق مرورگر، که با نام CSRF (Cross-Site Request Forgery) شناخته می‌شوند، ضروری است.	1
3.5.2	اگر برنامه برای جلوگیری از استفاده غیرمجاز cross-origin از عملکردهای حساس، به مکانیزم Preflight در CORS متکی است، باید امکان فراخوانی این عملکردها با درخواست‌هایی که باعث ایجاد Preflight نمی‌شوند، وجود نداشته باشد. برای تحقق این هدف ممکن است لازم باشد مقدار هدرهای Origin و Content-Type بررسی شوند یا از هدر اضافی استفاده شود که در لیست هدرهای مجاز CORS قرار ندارد.	1

#	Description	Level
3.5.3	برنامه‌ای درخواست‌های HTTP که به عمل کرده‌ای حساس از متده‌ای مناسب مانند POST، PUT PATCH یا DELETE استفاده می‌کنند، و نه از متده‌ای که در استاندارد HTTP به‌عنوان "ایمن" تعریف شده‌اند، مانند GET، HEAD یا OPTIONS. به عنوان جایگزینی یا مکمل، می‌توان از بررسی سخت‌گیرانه هدرهای Sec-Fetch-* استفاده کرد تا اطمینان حاصل شود که درخواست از منبع نامناسبی مثل بارگذاری تصویر، ناوبری صفحه یا فراخوانی cross-origin ارسال نشده است.	1
3.5.4	برنامه‌های مجزا باید روی نام‌های دامنه (hostname) متفاوت میزبانی شده‌اند تا از محدودیت‌های ارائه‌شده توسط Same-Origin Policy) (به‌رسمیت شوند. این شامل کنترل تعاملات اسناد یا اسکریپت‌های بارگذاری‌شده از یک مبدأ با منابع مبدأ دیگر و اعمال محدودیت بر اساس دامنه برای کوکی‌ها می‌شود.	2
3.5.5	برنامه باید پیام‌های دریافت‌شده از طریق رابط postMessage در صورتی که مبدأ پیام مورد اعتماد نباشد یا ساختار پیام نامعتبر باشد، نادیده گرفته می‌شوند.	2
3.5.6	هیچ‌جای برنامه از قابلیت JSONP استفاده نشود تا از حملات Cross-Site Inclusion Script (XSSI) جلوگیری شود.	3
3.5.7	داده‌هایی که نیاز به احراز هویت دارند، در پاسخ‌های مربوط به منابع اسکریپت‌ی(مانند فایل‌های JavaScript) نباید قرار بگیرند تا از حملات XSSI جلوگیری شود.	3
3.5.8	اطمینان حاصل کنید که منابع احراز هویت‌شده (مانند تصاویر، ویدیوها، اسکریپت‌ها و سایر اسناد) فقط در مواقعی که هدف آن است، قابل بارگذاری یا جاسازی توسط کاربر باشند. این کار را می‌توان با اعتبارسنجی دقیق هدرهای HTTP مانند Sec-Fetch-* انجام داد تا اطمینان حاصل شود که درخواست از یک منبع غیرمجاز ارسال نشده است، یا با تنظیم هدر Cross-Origin-Resource-Policy برای محدود کردن دسترسی مرورگر به محتوا.	3

V3.6 یکپارچگی منابع خارجی (External Integrity) Resource

این بخش، راهنمایی‌هایی برای میزبانی ایمن محتوا در سایت‌های شخص ثالث (Third-party) ارائه می‌دهد.

#	Description	Level
3.6.1	منابع سمت کلای‌نت مانند کتابخانه‌های جاواسکریپت، فای‌ل‌های CSS، یا فونت‌های وب، تنها در صورتی به‌صورت خارجی (مثلاً از طریق شبکه تحویل محتوا - CDN می‌زبانی شوند که آن منابع: استاتیک (تغییرناپذیر) باشند، نسخه‌گذاری‌شده (versioned) باشند و یکپارچگی آن‌ها با استفاده از Integrity Subresource (SRI) بررسی شود. اگر این موارد امکان‌پذیر نیست، باید برای هر منبع، یک تصمیم امنیتی مستند وجود داشته باشد که توجیه کند چرا این منبع به این شکل بارگذاری می‌شود.	3

V3.7 سایر ملاحظات امنیتی مرورگر (Other Browser Security Considerations)

این بخش شامل مجموعه‌ای از کنترل‌های امنیتی و ویژگی‌های امنیتی مدرن مرورگر است که برای افزایش امنیت در سمت کلای‌نت (مرورگر کاربر) توصیه می‌شوند.

#	Description	Level
3.7.1	برنامه صرفا باید از فناوری‌های سمت کلای‌نتی استفاده کند که همچنان پشتیبانی می‌شوند و از نظر امنیتی قابل اعتماد هستند.مثال‌هایی از فناوری‌هایی که این الزام را برآورده نمی‌کنند عبارتند از NSAPI NACL،Silverlight،ActiveX،Shockwave،Flash،Plugins و هایApplet جاوا در سمت کلای‌نت	2
3.7.2	برنامه فقط زمانی کاربر را به دامنه‌ها یا هایhostname دیگر(که تحت کنترل برنامه نیستند) به صورت خودکار هدایت می‌کند، که آن مقصد در یک فهرست مجاز (allowlist) قرار داشته باشد.	2
3.7.3	برنامه باید هنگام ریدایرکت کاربر به یک URL که خارج از کنترل برنامه است، یک پیام هشدار نشان می‌دهد و امکان لغو آن را به کاربر می‌دهد.	3
3.7.4	باید دامنه اصلی برنامه، مثلاً (site.tld) به فهرست preload عمومی HSTS اضافه شده باشد.	3
3.7.5	اگر مرورگر کاربر از ویژگی‌های امنیتی مورد انتظار برنامه پشتیبانی نمی‌کند، برنامه رفتار مناسبی داشته باشد، مثل هشدار دادن به کاربر یا مسدود کردن دسترسی.	3

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- details prefix __Host- Set-Cookie

- Sheet Cheat Policy Security Content OWASP
- Project Headers Secure OWASP
- Sheet Cheat Prevention Forgery Request Cross-Site OWASP
- form submission List Preload Browser HSTS
- Sheet Cheat Prevention Clobbering DOM OWASP

Service Web and API V4

هدف

برخی ملاحظات امنیتی صرفا برای برنامه‌هایی که هایAPI را برای استفاده توسط مرورگرهای وب یا مصارف دیگر(معمولاً مبتنی بر XML, JSON GraphQl می باشند(ارائه می‌دهند، مطرح می‌شوند. این فصل شامل پیکربندی‌ها و مکانیزم‌های امنیتی مرتبطی است که باید به این نوع برنامه‌ها اعمال شوند.

توجه کنید نگرانی‌های عمومی امنیتی مانند احراز هویت، مدیریت نشست و اعتبارسنجی ورودی‌ها که در فصل‌های دیگر مطرح شده‌اند، در مورد هاAPI نیز صدق می‌کنند. بنابراین این فصل نباید به صورت جداگانه یا خارج از زمینه کلی استاندارد، بررسی یا آزموده شود.

Security Service Web Generic V4.1

این بخش به ملاحظات کلی امنیت سرویس‌های وب می‌پردازد و در نتیجه بر رعایت استانداردهای اولیه و اصول به‌داشتی امنیتی در طراحی و پیاده‌سازی سرویس‌های وب تأکید دارد.

#	Description	Level
4.1.1	اطمینان حاصل شود که در هر پاسخ HTTP که شامل Body می باشد، هدر Content-Type وجود داشته باشد که نوع آن، با محتوای پاسخ دریافتی از سرور مطابقت داشته باشد. این هدر باید شامل پارامتر charset نیز باشد تا رمزگذاری کاراکتر ایمن (مانند UTF-8 یا ISO-8859-1) را مشخص کند. این مقادیر باید مطابق با استاندارد Types Media IANA باشند؛ برای مثال، انواعی مانند ،"text/" "xml+/" و "xml/" را در بر می‌گیرند.	1
4.1.2	اطمینان حاصل شود که تنها نقاط پایانی که برای استفاده کاربرنهایی از طریق مرورگر طراحی شده‌اند (User-Facing Endpoints) به‌صورت خودکار از HTTP به HTTPS هدایت شوند، سایر سرویس‌ها یا نقاط پایانی نباید (ریدایرکت شفاف، Transparent Redirect) داشته باشند. این اقدام برای جلوگیری از وضعیتی است که در آن یک کلاینت به اشتباه درخواست‌های رمزنگاری‌نشده (HTTP) ارسال می‌کند، اما چون این درخواست‌ها به‌طور خودکار به HTTPS ریدایرکت می‌شوند، نشت احتمالی داده‌های حساس پنهان خواهد ماند.	2

#	Description	Level
4.1.3	اطمی‌نان حاصل شود که هدره‌ای HTTP که در برنامه استفاده می شود و توسط ی ک لایه واسطه، مانند ی کbalancer load ، ی ک پروکسی وب یا ی ک سرویس backend-for-frontend تنظیم شده است نمی‌تواند توسط کاربر نهایی بازنویسی شود. هدره‌ای نمونه ممکن است شامل X-Real-IP، X-Forwarded-* یا X-User-ID باشند.	2
4.1.4	اطمی‌نان حاصل شود که فقط متدهای HTTP که صریحاً توسط برنامه یا API آن پشتیبانی می‌شوند (از جمله OPTIONS در درخواست‌های preflight) می‌توانند مورد استفاده قرار گیرند و متدهای استفاده نشده مسدود شوند.	3
4.1.5	اطمی‌نان حاصل شود که برای درخواست‌ها یا تراکنش‌هایی که بسیار حساس هستند یا از چندین سامانه عبور می کنند، از امضاهای دیجیتال در سطح پیام استفاده شود تا اطمی‌نان امنیتی بیشتری علاوه بر محافظت‌های سطح انتقال (مانند TLS فراهم گردد.	3

Validation Structure Message HTTP V4.2

این بخش به‌صورت دقیق مشخص می کند که ساختار و هدره‌ای درخواست HTTP باید چگونه اعتبارسنجی شوند تا از حملاتی مانند Request HTTP، response Smuggling، injection header splitting و service of denial از طریق ی ک پیام طولانی HTTP جلوگیری شود.

این الزامات برای پردازش و تولید کلی پیام‌های HTTP اهمیت دارند، اما به‌ویژه هنگام تبدیل پیام‌های HTTP بین نسخه‌های مختلف HTTP مهم هستند.

#	Description	Level
4.2.1	اطمی‌نان حاصل شود که تمامی اجزای برنامه)از جمله لود بالانسرها، فایروال‌ها و سروره‌ای اپلی کیشن(مرزهای پیام‌های HTTP ورودی را با استفاده از مکانیزم مناسب نسخه های HTTP تعیین می کنند تا از حملات HTTP smuggling request جلوگیری شود. در HTTP/1.x اگر هدر Transfer-Encoding وجود داشته باشد، هدر Content-Length باید مطابق RFC 2616 نادیده گرفته شود. در مقابل، هنگام استفاده از HTTP/2 یا HTTP/3، اگر هدر Content-Length وجود داشته باشد، گیرنده باید اطمی‌نان حاصل کند که این مقادیر با طول فریم‌های DATA سازگار می‌باشد.	2
4.2.2	اطمی‌نان حاصل شود که هنگام تولید پیام‌های HTTP، هدر Content-Length با طول محتوای ی که توسط چارچوب‌بندی پروتکل HTTP تعیین می‌شود، تداخل نداشته باشد تا از حملات smuggling request جلوگیری شود.	3
4.2.3	اطمی‌نان حاصل شود برنامه، پیام‌های HTTP/2 یا HTTP/3 با هدره‌ای connection-specific مانند Transfer-Encoding را به منظور جلوگیری از حملات splitting response یا injection header ارسال یا قبول نمی کنند.	3

#	Description	Level
4.2.4	اطمی‌نان حاصل شود برنامه تنها درخواست های HTTP/2 and HTTP/3 که هدرها و مقادیر آن شامل هیچ توالی \r(CR),\n(LF),\n\r(CRLF) نباشد را می پذیرد تا از حملات injection header جلوگیری کند.	3
4.2.5	اطمی‌نان حاصل کنی‌د که اگر برنامه (Frontend or (Backend اقدام به ساخت و ارسال درخواست‌های HTTP می کند از مکانیزم های validation ، sanitization یا سایر مکانیزم‌ها استفاده کند تا از ایجاد هاURI (مانند فراخوانیAPI (یا فیلده‌ای هدر درخواست HTTP (مانند Authorization یا(Cookie که بیش از حد مجاز، طولانی هستند، جلوگیری شود که منجر به عدم پذیرش درخواست توسط مولفه دریافت کننده(هر بخشی از زیرساخت یا سامانه که درخواست HTTP را دریافت و پردازش می کند) شود. عدم رعایت این موضوع می تواند باعث وقوع حمله Service of Danial شود، ارسال یک درخواست بیش از حد طولانی (مانند یک فیلد هدر کوکی طولانی) باعث می شود سرور همواره با وضعیت خطا پاسخ دهد.	3

GraphQL V4.3

GraphQL به‌طور فزاینده‌ای در حال تبدیل شدن به روشی رایج برای توسعه‌ی کلاینت‌های داده‌محور است، که به‌صورت مستقیم به چندین سرویس مختلف در backend وابسته نیستند. این بخش به ملاحظات امنیتی ویژه مربوط به استفاده از GraphQL می‌پردازد.

#	Description	Level
4.3.1	اطمی‌نان حاصل شود یکی از مکانیزم ها برای جلوگیری از حملات انکار سرویس (DoS) درلایه GraphQL یا لایه داده استفاده شده است. این مکانیزم‌ها عبارتند از استفاده از فهرست مجاز کوئری‌ها (Query ،(Allowlist محدودسازی عمق کوئری‌ها Depth) محدودسازی،(Limiting تعداد یا حجم داده(Amount (Limiting و تحلیل هزینه کوئری Cost) (Query Analysis). این اقدامات، به منظور مقابله با درخواست های پیچیده، تو در تو یا کوئری‌های پرهزینه که می توانند موجب مصرف بیش از حد منابع و اختلال در سرویس دهی شوند ضروری است.	2
4.3.2	اطمی‌نان حاصل شود که قابلیت Introspection در GraphQL در محیط تولید (Production) غیرفعال شده‌است، مگرAPI مبتنی بر GraphQL به‌صورت صریح برای استفاده توسط اشخاص یا سامانه های ثالث (Third Parties) طراحی شده باشد.	2

WebSocket V4.4

WebSocket یک پروتکل ارتباطی است که امکان ارتباط دوطرفه همزمان را از طریق یک اتصال TCP فراهم می کند. این پروتکل در سال ۲۰۱۱ توسط IETF در قالب RFC 6455 استانداردسازی شد.

اگ‌رچه WebSocket برای کار کردن از طریق پورت‌های رایج HTTP یعنی پورت 443 (HTTPS) و پورت 80 (HTTP) طراحی شده، اما پروتکل‌های مجزا از HTTP محسوب می‌شود.

این بخش به الزامات کلیدی امنیتی می‌پردازد که برای جلوگیری از حملاتی طراحی شده‌اند که از طریق این کانال ارتباطی بلادرنگ، به‌ویژه در حوزه‌های امنیت ارتباطات و مدیریت نشست انجام می‌گیرند.

#	Description	Level
4.4.1	اطمینان حاصل شود که تمامی ارتباطات WebSocket از طریق پروتکل TLS (WSS) برقرار می‌شوند.	1
4.4.2	اطمینان حاصل شود که در هنگام Handshake اولیه‌ی HTTP برای WebSocket، مقدار هدر Origin بررسی شود و در صورتی که با لیست از مبداهای مجاز (allowed origins) برای برنامه مطابقت داشته باشد، اتصال پذیرفته می‌شود.	2
4.4.3	اطمینان حاصل شود که در صورتی که امکان استفاده از مکانیزم استاندارد مدیریت نشست برنامه وجود نداشته باشد، از توکن‌های اختصاصی (Duplicated Tokens) برای این منظور استفاده شود که با الزامات امنیتی مدیریت نشست به طور کامل مطابقت داشته باشند.	2
4.4.4	اطمینان حاصل شود که توکن‌های اختصاصی مدیریت نشست WebSocket در هنگام انتقال از یک نشست HTTPS موجود به کانالWebSocket، از طریق نشست HTTPS احراز هویت‌شده قبلی، دریافت یا اعتبارسنجی می‌شوند.	2

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- OWASP REST Security Cheat Sheet
- Resources on GraphQL Authorization from Apollo and graphql.org.
- OWASP Web Security Testing Guide: Testing GraphQL
- OWASP Web Security Testing Guide: Testing WebSockets

Handling File V5

هدف

استفاده از فایل‌ها می‌تواند انواع مختلفی از ریسک‌ها را برای برنامه ایجاد کند، از جمله حملات انکار سرویس (DOS)، دسترسی غیرمجاز به اطلاعات، پر شدن فضای ذخیره‌سازی. این فصل شامل مجموعه‌ای از الزامات امنیتی برای مقابله با این تهدیدات است.

Documentation Handling File V5.1

این بخش شامل الزاماتی است که بیان می کنند ویژگی‌های مورد انتظار برای فایل‌های‌ی که توسط برنامه پذیرفته می‌شوند باید مستندسازی شوند. این مستندسازی پیش‌نیازی ضروری برای طراحی و بررسی کنترل‌های امنیتی مرتبط با بارگذاری فایل‌ها است.

#	Description	Level
5.1.1	مستندات نوع فایل‌های مجاز، پسوندهای مورد انتظار، و حداکثر اندازه هر فایل (شامل اندازه پس از استخراج) را برای هر قابلیت بارگذاری مشخص کرده باشد. همچنین، مستندات توضیح می‌دهند چگونه فایل‌ها برای دانلود و پردازش توسط کاربران نهایی ایمن‌سازی می‌شوند؛ برای مثال، رفتار برنامه هنگام شناسایی یک فایل مخرب چگونه خواهد بود.	2

Content and Upload File V5.2

قابلیت بارگذاری فایل یکی از منابع اصلی ورود فایل‌های غیرقابل اعتماد به سامانه می‌باشد. این بخش الزامات لازم را برای اطمینان از اینکه وجود، حجم یا محتوای این فایل‌ها نمی‌توانند به برنامه آسیب برسانند، تشریح می کنند.

#	Description	Level
5.2.1	برنامه تنها فایل‌های با حجم مشخص، که قادر به پردازش آن است را می‌پذیرد تا از کاهش عملکرد یا حملات انکار سرویس (DoS) جلوگیری شود.	1
5.2.2	هنگام پذیرش فایل توسط برنامه، چه به صورت مستقیم و چه به صورت یک آرشیو مانند فایل‌zip پسوند فایل با پسوند مورد انتظار مطابقت داشته باشد و اعتبارسنجی محتوای فایل صورت گیرد تا ایمن شود محتوای فایل با نوع تعریف‌شده توسط پسوند مخوانی دارد. این فرآیند می تواند شامل موارد بررسی بایت‌های ابتدایی (magic bytes) فایل، انجام بازنویسی تصاویر برای حذف ساختارها و اطلاعات ناخواسته و استفاده از کتابخانه‌های تخصصی برای اعتبارسنجی کامل محتوای فایل باشد اما محدود به آنها نیست. در سطح L1، کافی است این بررسی‌ها فقط بر روی فایل‌های‌ی که در فرآیند تجاری یا امنیتی خاص استفاده می‌شوند متمرکز باشد. در سطح L2 و بالاتر، این فرآیند باید برای تمامی فایل‌های ورودی برنامه اجرا شود.	1
5.2.3	برنامه باید پیش از استخراج محتوای فایل‌های فشرده (مانند zip، gz، docx، odt)، آنها را از نظر حداکثر اندازه مجاز پس از استخراج و همچنین حداکثر تعداد فایل‌های درون آن بررسی می کنند.	2

#	Description	Level
5.2.4	برنامه فضای مشخصی برای اندازه فایل و تعداد فایل‌های مجاز برای هر کاربر اعمال می‌کند تا از این طریق، یک کاربر نتواند با بارگذاری تعداد زیادی فایل یا فایل‌های بیش از حد بزرگ، فضای ذخیره‌سازی را پر کند.	3
5.2.5	برنامه اجازه بارگذاری فایل‌های فشرده که حاوی لینک های نمادین (symlinks) هستند را نمی‌دهد، مگر اینکه این رفتار به طور مشخص مورد نیاز باشد. در چنین شرایطی باید یک فهرست مجاز (allowlist) از مسیرها یا فایل‌هایی که می توانند برای آن‌ها لینک نمادین ایجاد شود، اعمال و اعتبارسنجی گردد.	3
5.2.6	برنامه تصاویر بارگذاری‌شده با اندازه پیکسلی بزرگتر از حد مجاز را رد کند تا از حملات flood pixel attacks جلوگیری شود.	3

Storage File V5.3

این بخش شامل الزامات جلوگیری از اجرای غیرمجاز فایل‌ها پس از بارگذاری، شناسایی محتوای خطرناک و جلوگیری از استفاده از داده‌های غیرمعتبر برای کنترل مکان ذخیره‌سازی فایل‌ها است.

#	Description	Level
5.3.1	فایل هایی که از ورودی های غیرمعتبر بارگذاری یا تولید می شوند و در پوشه های عمومی قرار می گیرند، هنگام دسترسی مستقیم از طریق یک درخواست HTTP، به عنوان کدهای سمت سرور اجرا نشوند.	1
5.3.2	هنگام ایجاد مسیره‌ای فایل برای عملیات مختلف، به جای استفاده از نام فایل‌های ارسال شده توسط کاربر، از داده‌های تولید شده داخلی یا منابع مورد اعتماد استفاده شود. و در صورتی که استفاده از نام فایل‌ها یا متادیتای ارسالی توسط کاربر ضروری باشد، می بایست validation و Sanitization اعمال شود. این کار برای جلوگیری از حملاتی مانند Path Traversal، Inclusion(LFI, File Remote or Local (RFI و Request Server-Side Forgery(SSRF) می‌باشد.	1
5.3.3	پردازش فایل‌های سمت سرور، مانند استخراج فایل‌های فشرده، اطلاعات مسیر ارائه شده توسط کاربر را نادیده می گیرد تا از آسیب‌پذیری‌های مانند zip slip جلوگیری شود.	3

Download File V5.4

این بخش شامل الزامات برای کاهش ریسک‌ها هنگام ارائه فایل‌ها برای دانلود است، از جمله حملاتPath Traversal و حملات Injection می باشد. همچنین اطمینان حاصل می‌شود که فایل‌ها حاوی محتوای خطرناک

نباشند.

#	Description	Level
5.4.1	برنامه نام فایل ارسال‌شده توسط کاربر را چه در قالب JSON، JSONP یا پارامتر URL، اعتبارسنجی می‌کند یا نادیده می‌گیرد، و در پاسخ HTTP، نام فایل را به‌طور صریح در فیلد Content-Disposition هدر مشخص می‌نماید.	2
5.4.2	نام‌های فایل‌های ارائه شده (مانند فیلدهای هدر پاسخ HTTP یا پیوست‌های ایمیل)، به‌درستی encoded یا sanitized شده‌اند (مطابق RFC 6266)، تا ساختار سند حفظ شده و از حملات تزریق جلوگیری شود.	2
5.4.3	فایل‌های دریافت شده از منابع غیرقابل اعتماد توسط آنتی ویروس اسکن شود تا از ارائه محتوای مخرب شناخته‌شده جلوگیری شود.	2

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- OWASP File Upload Cheat Sheet
- Example of using arbitrary file read for symlinks
- "Magic of Explanation" from Bytes Wikipedia

Authentication V6

Objective Control

احراز هویت فرآیند تأیید یا اثبات اصالت یک فرد یا دستگاه می‌باشد. این فرآیند شامل بررسی صحت ادعاهای ارائه شده توسط یک شخص یا یک دستگاه بوده به‌گونه‌ای که در برابر جعل هویت مقاوم باشد و از بازیابی یا رهگیری گذرواژه‌ها جلوگیری کند.

استاندارد NIST SP 800-63 یک استاندارد مدرن و مبتنی بر شواهد است که برای سازمان‌های سراسر جهان ارزشمند محسوب می‌شود و برای سازمان‌های دولتی ایالات متحده و نهادهایی که با این سازمان‌ها تعامل دارند، اهمیت ویژه‌ای دارد.

اگرچه بسیاری از الزامات مطرح شده در این فصل بر اساس بخش دوم این استاندارد (با عنوان NIST SP 800-63B تحت عنوان «راهنمای هویت دیجیتال – احراز هویت و مدیریت چرخه عمر») بنا شده اند، تمرکز این فصل بر تهدیدات رایج و ضعف‌های پرتکرار در احراز هویت می‌باشد. این فصل تلاشی برای پوشش جامع تمامی نکات استاندارد نمی‌کند. در مواردی که رعایت کامل استاندارد NIST SP 800-63 ضروری باشد، لطفاً به متن کامل این استاندارد مراجعه فرمایید.

همچنین، ممکن است اصطلاحات به‌کاررفته در NIST SP 800-63 با اصطلاحات عمومی‌تر تفاوت داشته باشد؛ به همین دلیل، این فصل عمدتاً از واژگان رایج‌تر و قابل فهم‌تر استفاده می‌کند تا وضوح مطلب افزایش یابد.

یکی از ویژگی‌های رایج در سامانه‌های پیشرفته‌تر، تطبیق‌پذیری مراحل احراز هویت با توجه به عوامل مختلف ریسک است. این ویژگی در فصل Authorization مورد بررسی قرار می‌گیرد، چرا که این مکانیزم‌ها باید در تصمیم‌گیری‌های مربوط به Authorization نیز لحاظ شوند.

Documentation Authentication V6.1

این بخش شامل الزامات مربوط به مستندسازی احراز هویت است که باید برای یک برنامه کاربردی نگه‌داری شود. این مستندسازی برای پیاده‌سازی و ارزیابی نحوه پیکربندی کنترل‌های مرتبط با احراز هویت از اهمیت بالایی برخوردار است.

#	Description	Level
6.1.1	مستندات برنامه، نحوه استفاده از کنترل هایی مانند محدودیت نرخ (Rate Limit)، مقابله با خودکارسازی (Anti-Automation) و پاسخ تطبیقی Adaptive (Response) را برای دفاع در برابر حملاتی مانند Credential Stuffing و حملات Force Brute Password به وضوح تعریف کرده باشد. مستندات باید به‌وضوح نحوه پیکربندی این کنترل‌ها را تشریح کرده و نشان دهند که چگونه از قفل شدن مخرب حساب‌های کاربری جلوگیری می‌شود.	1
6.1.2	یک لیست از کلمات خاص مرتبط با زمینه سازمانی (Context-Specific) مستندسازی شود تا از بکارگیری آن‌ها در رمزهای عبور جلوگیری شد. این فهرست می‌تواند شامل نام سازمان، نام محصول، شناسه سامانه، نام کدپروژه، نام دپارتمان یا نقش های سازمانی و موارد مشابه باشد.	2
6.1.3	در صورت وجود مسیرهای متعدد احراز هویت در برنامه کاربردی، تمامی این مسیرها به همراه کنترل‌های امنیتی و سطح قدرت احراز هویت مورد نیاز، مستندسازی شده‌اند. لازم است این کنترل‌ها به‌صورت یکسان و سازگار در تمامی مسیرهای احراز هویت اجرا شوند.	2

Security Password V6.2

کلمات عبور، که توسط NIST SP 800-63 به عنوان "رمزهای به خاطر سپرده شده" (Memorized Secrets) شناخته می‌شوند، شامل کلمات عبور، عبارت‌های عبور، کدهای PIN، الگوهای بازگشایی unlock)، Patterns) انتخاب تصویر صحیح (مثلاً انتخاب بچه گربه صحیح از میان چند تصویر) هستند. این‌ها معمولاً به عنوان "چیزی که شما می‌دانید" در نظر گرفته می‌شوند و اغلب به عنوان یک مکانیزم احراز هویت تک‌عاملی استفاده می‌شوند.

بر این اساس، این بخش شامل الزامات و توصیه‌های برای ایجاد و مدیریت امن کلمات عبور می‌باشد. بی‌شتر این الزامات در سطح L1 مطرح شده‌اند، چرا که در این سطح نقش کلیدی دارند. از سطح L2 به بعد، استفاده از احراز هویت چندعاملی الزامی می‌باشد، که در آن گذواژه می‌تواند یکی از عوامل تشکیل‌دهنده باشد.

الزامات این بخش عمدتا به بند § 5.1.1.2 از راهنمایی‌های NIST's Guidance می‌باشد.

#	Description	Level
6.2.1	کلمات عبور تنظیم شده توسط کاربر حداقل ۸ کاراکتر طول داشته باشد. هرچند حداقل ۱۵ کاراکتر به شدت توصیه می‌شود.	1
6.2.2	کاربران قادر به تغییر گذرواژه خود باشند.	1
6.2.3	هنگام تغییر کلمه عبور، گذرواژه فعلی و گذرواژه جدید توسط کاربر تکمیل شود.	1
6.2.4	کلمات عبوری که در حین ثبت‌نام حساب کاربری یا تغییر کلمه عبور ارسال می شوند با یک فهرست در دست‌رس از حداقل ۳۰۰۰ کلمه عبور رایج که) با سیاست‌های کلمه عبور برنامه (مانند حداقل طول) سازگاری دارند) بررسی شوند.	1
6.2.5	کلمات عبور با هر ترکیبی قابل استفاده باشند، بدون اینکه قوانینی برای محدودکردن نوع کاراکترهای مجاز وجود داشته باشد. نبایدهیچ گونه الزامی برای تعداد حداقل کاراکترهای حروف بزرگ یا کوچک، اعداد یا کاراکترهای خاص وجود داشته باشد.	1
6.2.6	فیلدهای ورودی کلمه عبور از نوع "type=password" استفاده می کنند تا ورودی‌ها پنهان شوند. برنامه‌ها می‌توانند به کاربر این امکان را بدهند که موقتاً کلمه عبور کامل یا آخرین کاراکتر تایپ شده را مشاهده کند.	1
6.2.7	عمل کرد "چسباندن"، (paste) ابزاره‌ای کمکی گذرواژه مرورگر و مدیریت کننده‌های گذرواژه خارجی مجاز باشند.	1
6.2.8	برنامه کلمه عبور کاربر را دقیقاً همانطورکه از کاربر دریافت شده است، بدون هیچ گونه تغییراتی مانند کوتاه‌سازی(truncation) یا تبدیل حروف بزرگ و کوچک (case)، transformation) بررسی کند.	1
6.2.9	استفاده از گذرواژه‌های با حداقل طول ۶۴ کاراکتر مجاز باشد.	2
6.2.10	کلمه عبور کاربر تا زمانی که مشخص شود که به خطر افتاده است یا کاربر آن را تغییر دهد، معتبر باقی بماند. برنامه نباید الزام به تغییر دوره‌ای گذرواژه‌ها را داشته باشد.	2
6.2.11	فهرست مسدود شده ای از کلمات خاص مرتبط با زمینه سازمانی برای جلوگیری از ایجاد کلمات عبور آسان قابل حدس، مورد استفاده قرار گیرد.	2
6.2.12	کلمات عبور وارد شده در حین ثبت‌نام حساب کاربری یا تغییر کلمه عبور با مجموعه‌ای از کلمات عبور افشا شده بررسی شوند.	2

Security Authentication General V6.3

این بخش شامل الزامات عمومی برای امنیت مکانیزم‌های احراز هویت و همچنین تعیین انتظارات مربوط به سطوح مختلف امنیتی می‌باشد. در سطح L2، سامانه‌ها باید الزاماً از احراز هویت چندعاملی (MFA) استفاده کنند. در سطح L3، استفاده از احراز هویت مبتنی بر سخت‌افزار الزامی می‌باشد

که بای‌د درون ی‌ک مح‌ی‌ط اج‌رای م‌ورد اع‌ت‌م‌اد و ق‌اب‌ل گ‌واه‌ی Environment Execution (Trusted – (TEE انج‌ام ش‌ود. ای‌ن م‌ی‌ت‌وان‌د ش‌ام‌ل ک‌ل‌ی‌ده‌ای ع‌ب‌ور واب‌س‌ت‌ه ب‌ه دس‌ت‌گ‌اه (Device-Bound ،(Passkeys اح‌رازک‌ن‌ن‌ده-ه‌ای ب‌ا س‌طح اط‌م‌ی‌ن‌ان ب‌الا م‌طاب‌ق ب‌ا اس‌ت‌ان‌دارد eIDAS (س‌طح LoA ،(High اح‌رازک‌ن‌ن‌ده‌ه‌ای دارای س‌طح اط‌م‌ی‌ن‌ان AAL3 ط‌ب‌ق اس‌ت‌ان‌دارد ،NIST ی‌ا م‌ک‌ان‌ی‌زم‌ه‌ای م‌ع‌ادل دی‌گ‌ر ب‌اش‌د.

اگ‌رچ‌ه ای‌ن ال‌زام‌ات در م‌ق‌ای‌س‌ه ب‌ا ب‌س‌ی‌اری از چ‌ارچ‌وب‌ه‌ای دی‌گ‌ر، روی‌ک‌ردی س‌خ‌ت‌گ‌ی‌ران‌ه ن‌س‌ب‌ت ب‌ه MFA دارن‌د، ام‌ا ای‌ن س‌خ‌ت‌گ‌ی‌ری ب‌رای ارت‌ق‌ای س‌طح ام‌ن‌ی‌ت ک‌ارب‌ران ح‌ی‌ات‌ی م‌ی‌ب‌اش‌د. ه‌ر گ‌ون‌ه ت‌لاش ب‌رای ک‌اه‌ش ای‌ن ال‌زام‌ات ب‌ای‌د ب‌ا ی‌ک ب‌رن‌ام‌ه ش‌ف‌اف و دق‌ی‌ق ب‌رای ک‌اه‌ش ری‌س‌ک‌ه‌ای م‌رت‌ب‌ط ب‌ا اح‌راز ه‌وی‌ت م‌راه ب‌اش‌د، ب‌ه‌ط‌وری‌ک‌ه راه‌ن‌م‌ای‌ه‌ا و پ‌ژوه‌ش‌ه‌ای ارائ‌ه‌ش‌ده ت‌وس‌ط NIST ن‌ی‌ز در آن ل‌ح‌اظ ش‌ده ب‌اش‌د.

ت‌وج‌ه داش‌ت‌ه ب‌اش‌ی‌د ک‌ه در زم‌ان ان‌ت‌ش‌ار ای‌ن س‌ن‌د، اس‌ت‌ان‌دارد NIST SP 800-63 اس‌ت‌ف‌اده از ای‌م‌ی‌ل را ب‌ه ع‌ن‌وان ی‌ک م‌ک‌ان‌ی‌زم اح‌راز ه‌وی‌ت ق‌اب‌ل ق‌ب‌ول ن‌م‌ی‌دان‌د).copy archived.(

ال‌زام‌ات ای‌ن ب‌خ‌ش ب‌ه ب‌خ‌ش‌ه‌ای م‌خ‌ت‌ل‌ف‌ی از راه‌ن‌م‌ای Guidance NIST's م‌رب‌وط م‌ی‌ش‌ون‌د، از ج‌م‌ل‌ه ب‌ن‌ده‌ای § 4.2.1، § 4.3.1، § 5.2.2 و § 6.1.2.

#	Description	Level
6.3.1	ک‌ن‌ت‌رل‌ه‌ای ل‌ازم ب‌رای ج‌ل‌وگ‌ی‌ری از ح‌م‌لات‌ی م‌ان‌ن‌د Stuffing Credential و force brute password ط‌ب‌ق م‌س‌ت‌ن‌دات ام‌ن‌ی‌ت‌ی ب‌رن‌ام‌ه پ‌ی‌اده‌س‌ازی ش‌ون‌د.	1
6.3.2	ح‌س‌اب‌ه‌ای ک‌ارب‌ری پ‌ی‌ش‌ف‌رض (م‌ان‌ن‌د "admin"، "root" ی‌ا "sa") در ب‌رن‌ام‌ه وج‌ود ن‌داش‌ت‌ه ب‌اش‌ن‌د ی‌ا غ‌ی‌رف‌ع‌ال ش‌ده ب‌اش‌ن‌د.	1
6.3.3	ب‌رای دس‌ت‌رس‌ی ب‌ه ب‌رن‌ام‌ه، از ی‌ک م‌ک‌ان‌ی‌زم اح‌راز ه‌وی‌ت چ‌ن‌دع‌ام‌ل‌ی (MFA) ی‌ا ت‌رک‌ی‌ب‌ی از م‌ک‌ان‌ی‌زم‌ه‌ای اح‌راز ه‌وی‌ت ت‌ک‌ع‌ام‌ل‌ی اس‌ت‌ف‌اده ش‌ود. ب‌رای س‌طح L3، ح‌داق‌ل ی‌ک‌ی از ع‌وام‌ل اح‌راز ه‌وی‌ت ب‌ای‌د م‌ب‌ت‌ن‌ی ب‌ر س‌خ‌ت‌اف‌زار ب‌اش‌د در ب‌راب‌ر ح‌م‌لات ف‌ی‌ش‌ی‌ن‌گ، م‌ق‌اوم‌ت در ب‌راب‌ر ن‌ف‌وذ و ج‌ع‌ل ه‌وی‌ت را ف‌راه‌م ک‌ن‌د، در ح‌ال‌ی‌ک‌ه ب‌ا اق‌دام آگ‌اه‌ان‌ه ک‌ارب‌ر (م‌ان‌ن‌د ف‌ش‌ردن د ک‌م‌ه روی ک‌ل‌ی‌د س‌خ‌ت‌اف‌زاری FIDO ی‌ا ت‌ل‌ف‌ن ه‌م‌راه) ق‌ص‌د ک‌ارب‌ر ب‌رای اح‌راز ه‌وی‌ت را ن‌ی‌ز ت‌أی‌ی‌د ن‌م‌ای‌د. ه‌ر گ‌ون‌ه ت‌س‌ه‌ی‌ل ی‌ا ت‌ع‌دی‌ل در ای‌ن ال‌زام، م‌س‌ت‌ل‌زم ارائ‌ه دل‌ای‌ل م‌س‌ت‌ن‌د و م‌ج‌م‌وع‌ه‌ای ج‌ام‌ع از ک‌ن‌ت‌رل‌ه‌ای ج‌ب‌ران‌ی اس‌ت.	2
6.3.4	ت‌أی‌ی‌د ک‌ن‌ی‌د ک‌ه در ص‌ورت وج‌ود م‌س‌ی‌ره‌ای م‌ت‌ع‌دد اح‌راز ه‌وی‌ت در ب‌رن‌ام‌ه، ه‌ی‌چ م‌س‌ی‌ر اح‌راز ه‌وی‌تِ م‌س‌ت‌ن‌دس‌ازی‌ن‌ش‌ده‌ای وج‌ود ن‌داش‌ت‌ه ب‌اش‌د و ک‌ن‌ت‌رل‌ه‌ای ام‌ن‌ی‌ت‌ی و س‌طح ق‌درت اح‌راز ه‌وی‌ت در ت‌م‌ام‌ی م‌س‌ی‌ره‌ا ب‌ه‌ص‌ورت ی‌ک‌س‌ان و س‌ازگ‌ار اع‌م‌ال ش‌ون‌د.	2
6.3.5	ک‌ارب‌ران از ت‌لاش‌ه‌ای م‌ش‌ک‌وک ب‌رای اح‌راز ه‌وی‌ت (م‌وف‌ق ی‌ا ن‌ام‌وف‌ق) م‌ط‌ل‌ع ش‌ون‌د. ای‌ن اط‌لاع‌رس‌ان‌ی م‌ی‌ت‌وان‌د ش‌ام‌ل ت‌لاش ب‌رای اح‌راز ه‌وی‌ت از م‌وق‌ع‌ی‌ت م‌ک‌ان‌ی ی‌ا ک‌ل‌ای‌ن‌ت غ‌ی‌رم‌ع‌م‌ول، اح‌راز ه‌وی‌ت ن‌اق‌ص (ت‌ن‌ه‌ا م‌وف‌ق‌ی‌ت ی‌ک‌ی از ع‌وام‌ل)، ت‌لاش ب‌رای اح‌راز ه‌وی‌ت پ‌س از ی‌ک دوره ط‌ول‌ان‌ی ع‌دم ف‌ع‌ال‌ی‌ت، ی‌ا اح‌راز ه‌وی‌ت م‌وف‌ق پ‌س از چ‌ن‌دی‌ن ت‌لاش ن‌ام‌وف‌ق ب‌اش‌د.	3
6.3.6	ای‌م‌ی‌ل ب‌ه‌ع‌ن‌وان م‌ک‌ان‌ی‌زم اح‌راز ه‌وی‌ت، چ‌ه ب‌ه‌ص‌ورت ت‌ک‌ع‌ام‌ل‌ی و چ‌ه ب‌ه‌ع‌ن‌وان ی‌ک‌ی از ع‌وام‌ل اح‌راز ه‌وی‌ت چ‌ن‌دع‌ام‌ل‌ی، اس‌ت‌ف‌اده ن‌م‌ی‌ش‌ود.	3

#	Description	Level
6.3.7	کاربران پس از به‌روزرسانی اطلاعات احراز هویت خود، مانند بازنشانی گذرواژه یا تغییر نام کاربری یا آدرس ایمیل، مطلع شوند.	3
6.3.8	با توجه به پیامهای خطا، کدهای پاسخ HTTP یا تفاوت در زمان پاسخدهی، نتوان کاربران مجتبر را از طریق تلاشهای ناموفق احراز هویت شناسایی کرد. همچنین، عملکردهای ثبتنام و بازیابی گذرواژه نیز باید از این نوع افشای اطلاعات محافظت شده باشند.	3

Recovery and Lifecycle Factor Authentication V6.4

عوامل احراز هویت میتوانند شامل کلمه عبور، توکنهای نرمافزاری، توکنهای سختافزاری و دستگاههای بیومتریک باشند. مدیریت امن چرخه عمر این مکانیزمها برای حفظ امنیت برنامه اهمیت بسیاری دارد و این بخش شامل الزامات مرتبط با این موضوع میباشد.

الزامات این بخش عمدتاً مربوط به بندهای § 5.1.1.2 و § 6.1.2.3 از راهنمای Guidance NIST's میباشد.

#	Description	Level
6.4.1	کلمه عبور اولیه یا کدهای فعالسازی تولید شده توسط سیستم، بهصورت تصادفی و ایمن تولید شوند، با سیاست فعلی رمزعبور مطابقت دارند، و پس از مدت زمان کوتاهی یا پس از اولین استفاده منقضی میشوند. این رمزهای اولیه نباید به عنوان رمزعبور بلندمدت مورد استفاده قرار گیرند.	1
6.4.2	راهنمای کلمه عبور یا احراز هویت مبتنی بر دانش (که به عنوان "سؤالات امنیتی" شناخته میشوند) در سیستم وجود ندارد.	1
6.4.3	فرآیند امنی برای بازنشانی کلمه عبور فراموششده پیادهسازی شده است که هیچیک از مکانیزمهای احراز هویت چندعاملی فعال را دور نزند.	2
6.4.4	در صورت از دست رفتن یکی از عوامل احراز هویت چندعاملی، فرآیند اثبات هویت با همان سطحی که در زمان ثبتنام انجام شده است، اجرا شود.	2
6.4.5	دستورالعملهای تمدید مکانیزمهای احراز هویت دارای تاریخ انقضا برای کاربران به موقع ارسال میشود تا پیش از انقضای مکانیزم فعلی فرصت کافی برای تمدید وجود داشته باشد، و در صورت لزوم، یادآورهای خودکار نیز تنظیم و ارسال شده باشند.	3
6.4.6	کاربران ادمین میتوانند فرآیند بازنشانی کلمه عبور را برای کاربران عادی آغاز کنند، اما اجازه تغییر مستقیم یا انتخاب رمزعبور برای کاربر را ندارند. این کنترل برای جلوگیری از دسترسی ادمین به رمزعبور کاربران طراحی شده است.	3

requirements authentication Multi-factor General V6.5

ای‌ن بخ‌ش راه‌نم‌ای‌ی‌ه‌ای ک‌لی ارائ‌ه م‌ی‌دهد ک‌ه ب‌رای انواع م‌خ‌ت‌لف م‌ک‌انی‌زم‌ه‌ای اح‌راز ه‌وی‌ت چ‌ندع‌ام‌لی (MFA) ق‌اب‌ل اس‌ت‌ف‌اده اس‌ت.

م‌ک‌انی‌زم‌ه‌ای ب‌ررس‌ی‌ش‌ده ش‌ام‌ل م‌وارد زی‌ر ه‌س‌ت‌ن‌د:

- Secrets Lookup (ف‌رای‌ن‌د ی‌اف‌ت‌ن ی‌ا ب‌ازی‌اب‌ی اط‌لاع‌ات م‌ح‌رمان‌ه)
- رم‌زه‌ای ع‌ب‌ور ی‌ک‌ب‌ار م‌ص‌رف م‌ب‌ت‌نی ب‌ر زم‌ان (TOTPs)
- م‌ک‌انی‌زم‌ه‌ای خ‌ارج از ب‌ان‌د Mechanisms) (Out-of-Band

Secret Lookup ک‌ه‌ای‌ی ه‌س‌ت‌ن‌د ک‌ه ب‌ه‌ص‌ورت از پ‌ی‌ش ت‌ول‌ی‌دش‌ده ارائ‌ه م‌ی‌ش‌ون‌د و م‌ش‌اب‌ه ب‌ا ک‌ه‌ای م‌ج‌وز ت‌راک‌ن‌ش ،(TAN) ک‌ه‌ای ب‌ازی‌اب‌ی ح‌س‌اب‌ه‌ای ش‌ب‌ک‌ه‌ه‌ای اج‌ت‌م‌اع‌ی ی‌ا ش‌ب‌ک‌ه‌ای از م‌ق‌ادی‌ر ت‌ص‌ادف‌ی م‌ی‌-ب‌اش‌ن‌د. ای‌ن ن‌وع م‌ک‌انی‌زم ب‌ه‌ع‌ن‌وان "چ‌ی‌زی ک‌ه در اخ‌ت‌ی‌ار دار‌ی‌د" در ن‌ظر گ‌رف‌ت‌ه م‌ی‌ش‌ود، زی‌را ک‌ه‌ا ع‌م‌داً غ‌ی‌رق‌اب‌ل ح‌ف‌ظ ک‌ردن ه‌س‌ت‌ن‌د و ن‌ی‌از ب‌ه ذخ‌ی‌ره‌س‌ازی دارن‌د.

رم‌زه‌ای ی‌ک‌ب‌ار م‌ص‌رف چ‌ندع‌ام‌لی Multi-factor) (TOTPs م‌ش‌اب‌ه رم‌زه‌ای ی‌ک‌ب‌ار م‌ص‌رف ت‌ک‌ع‌ام‌لی ه‌س‌ت‌ن‌د، ام‌ا ب‌رای ای‌ج‌اد رم‌ز ن‌ه‌ای‌ی ،(OTP) ن‌ی‌از ب‌ه وارد ک‌ردن ک‌د PIN م‌ع‌ت‌ب‌ر، ب‌ازک‌ردن ب‌ا ب‌ی‌وم‌ت‌ری‌ک، وارد ک‌ردن USB ی‌ا ج‌ف‌ت‌س‌ازی ،NFC ی‌ا م‌ق‌دار اض‌اف‌ی دی‌گ‌ری (م‌ان‌ند م‌اش‌ی‌ن‌ح‌س‌اب‌ه‌ای ام‌ض‌ای ت‌راک‌ن‌ش) دارن‌د.

ج‌زئ‌ی‌ات م‌رب‌وط ب‌ه م‌ک‌انی‌زم‌ه‌ای خ‌ارج از ب‌ان‌د (Out-of-Band) در ب‌خ‌ش ب‌ع‌دی ارائ‌ه خ‌واه‌د ش‌د.

ال‌زام‌ات م‌وج‌ود در ای‌ن ب‌خ‌ش‌ه‌ا ع‌م‌دت‌اً م‌رب‌وط ب‌ه ب‌ن‌ده‌ای § 5.1.2، § 5.1.3، § 5.1.4.2، § 5.1.5.2، § 5.2.1 و § 5.2.3 از راه‌نم‌ای Guidance NIST's م‌ی‌ب‌اش‌ن‌د.

#	Description	Level
6.5.1	Secrets Lookup درخ‌واس‌ت‌ه‌ا ی‌ا ک‌ه‌ای اح‌راز ه‌وی‌ت خ‌ارج از ب‌ان‌د (Out-of-Band) و رم‌زه‌ای ی‌ک‌ب‌ار م‌ص‌رف م‌ب‌ت‌نی ب‌ر زم‌ان (TOTP) ت‌نه‌ا ی‌ک‌ب‌ار ق‌اب‌ل اس‌ت‌ف‌اده ب‌اش‌ن‌د و پ‌س از اس‌ت‌ف‌اده م‌وف‌ق، م‌ج‌دداً ق‌اب‌ل اس‌ت‌ف‌اده ن‌ب‌اش‌ن‌د.	2
6.5.2	در ص‌ورت ذخ‌ی‌ره‌س‌ازی Secrets Lookup در س‌م‌ت Backend ب‌رن‌ام‌ه، اگ‌ر م‌ق‌دار آنت‌روپ‌ی ک‌م‌ت‌ر از ۱۱۲ ب‌ی‌ت ب‌اش‌ن‌د (م‌ع‌ادل ۱۹ ک‌اراک‌ت‌ر ت‌ص‌ادف‌ی ال‌ف‌ب‌ای‌ی-ع‌ددی ی‌ا ۳۴ رق‌م ت‌ص‌ادف‌ی)، ب‌ای‌د ب‌ا ی‌ک ال‌گ‌وری‌ت‌م ت‌ای‌ی‌د ش‌ده ب‌رای ذخ‌ی‌ره رم‌زع‌ب‌ور و ب‌ا اس‌ت‌ف‌اده از ی‌ک Salt ت‌ص‌ادف‌ی ۳۲ ب‌ی‌ت‌ی ه‌ش ش‌ون‌د. در ص‌ورت‌ی ک‌ه آنت‌روپ‌ی ک‌د ۱۱۲ ب‌ی‌ت ی‌ا ب‌ی‌ش‌ت‌ر ب‌اش‌د، م‌ی‌ت‌وان از ی‌ک ت‌اب‌ع ه‌ش اس‌ت‌ان‌دارد ب‌رای ذخ‌ی‌ره س‌ازی اس‌ت‌ف‌اده ک‌رد.	2
6.5.3	Secrets Lookup ک‌ه‌ای اح‌راز ه‌وی‌ت خ‌ارج از ب‌ان‌د (out of band) و ت‌ول‌ی‌د رم‌زه‌ای ی‌ک‌ب‌ار م‌ص‌رف م‌ب‌ت‌نی ب‌ر زم‌ان(TOTP) ه‌م‌گ‌ی ب‌ا اس‌ت‌ف‌اده از ی‌ک ت‌ول‌ی‌د ک‌ن‌ن‌ده ع‌دد ش‌ب‌ه ت‌ص‌ادف‌ی رم‌زن‌گ‌اری‌ش‌ده (CSPRNG) ت‌ول‌ی‌د ش‌ده ب‌اش‌ن‌د ت‌ا از ت‌ول‌ی‌د م‌ق‌ادی‌ر ق‌اب‌ل پ‌ی‌ش‌ب‌ی‌ن‌ی ج‌ل‌وگ‌ی‌ری ش‌ود.	2

#	Description	Level
6.5.4	Secrets Lookup و کدهای احراز هویت خارج از باند (out of band) حداقل دارای ۲۰ بیت آنتروپی باشند (معمولاً ۴ کاراکتر تصادفی الفبایی-عددی یا ۶ رقم تصادفی برای رسیدن به این میزان آنتروپی کافی است).	2
6.5.5	درخواستها، کدها یا توکنهای احراز هویت خارج از باند (Out-of-Band) و همچنین رمزهای عبور یکبار مصرف مبتنی بر زمان (TOTP) دارای طول عمر مشخص باشند. حداکثر طول عمر برای درخواستهای خارج از باند باید ۱۰ دقیقه و برای TOTP حداکثر ۳۰ ثانیه باشد.	2
6.5.6	امکان لغو (Revoke) هر عامل احراز هویت، از جمله دستگاههای فیزیکی، در صورت سرقت یا مفقود شدن وجود داشته باشد.	3
6.5.7	مکانیزمهای احراز هویت بیومتریک فقط بهعنوان عامل دوم و در کنار یکی از عوامل «چیزی که در اختیار دارید» یا «چیزی که کاربر می داند» مورد استفاده قرار می گیرند.	3
6.5.8	اعتبارسنجی رمزهای یکبار مصرف مبتنی بر زمان (TOTP) بر اساس منبع زمانی از یک سرویس قابل اعتماد انجام میشود و نه بر اساس زمان ارائهشده توسط کلاینت یا منابع غیرقابل اعتماد.	3

mechanisms authentication Out-of-Band V6.6

این نوع احراز هویت معمولاً شامل ارتباط سرور احراز هویت با یک دستگاه فیزیکی از طریق یک کانال ثانویه امن است. بهعنوان مثال، ارسال Notifications Push به دستگاههای تلفن همراه. این نوع از مکانیزم احراز هویت بهعنوان "چیزی که در اختیار دارید" در نظر گرفته میشود.

مکانیزمهای ناامن احراز هویت خارج از باند نظیر ایمیل و VOIP مجاز نیستند. همچنین، احراز هویت از طریق خطوط تلفن عمومی (PSTN) و پیامک (SMS) در حال حاضر توسط NIST بهعنوان مکانیزمهای"محدودشده")"restricted" mechanisms authentication(دستهبندی شدهاند و باید به تدریج با مکانیزمهایی مانند رمز یکبار مصرف مبتنی بر زمان) مکانیزمهای رمزنگاریشده یا روشهای مشابه امنتر جایگزین شوند. استانداردNIST SP 800-63B در بند § 5.1.3.3 توصیه میکند که در صورت ضرورت پشتیبانی از احراز هویت خارج از باند تلفنی یا پیامکی، بایدریسکهای مانند تعویض دستگاه، تغییر سیمکارت، انتقال شماره یا رفتارهای غیرعادی دیگرمدنظر قرار گیرد. هرچند این بخش از چارچوب ASVS الزام صریحی برای رعایت این موارد ندارد، اما عدم توجه به این ملاحظات امنیتی در یک اپلیکیشن حساس با سطح امنیتی L2 یا L3 بایدبهعنوان یک علامت هشدار جدی تلقی شود.

توجه داشته باشید که NIST اخیراً راهنماییهای ارائه کرده است که استفاده از Notifications Push را نامطلوب میداند. هرچند این بخش از ASVS به این موضوع اشاره نکرده است، آگاهی از خطرات ناشی از حمله Bombing Push اهمیت بالایی دارد.

#	Description	Level
6.6.1	مکانیزم‌های احراز هویت مبتنی بر شبکه تلفن عمومی (PSTN) برای ارسال رمزهای یک‌بار مصرف (OTP) از طریق تماس تلفنی یا پیام‌کتن‌ها در صورتی که شماره تلفن قبلا اعتبارسنجی شده باشد، یا روش‌های جایگزین قوی‌تر (رمزهای عبور یک‌بار مصرف مبتنی بر زمان) در دسترس باشند ارائه می‌شوند و سرویس‌دهنده بایدکاربران را از ریسک‌های امنیتی این روش‌ها مطلع سازد. برای اپلیکیشن‌های سطح L3، استفاده از تماس تلفنی و پیام‌کبه‌عنوان گزینه، مجاز نیست.	2
6.6.2	درخواست‌ها، کدها یا توکن‌های احراز هویت خارج از باند (Out-of-Band) به درخواست احراز هویت اصلی که برای آن تولید شده‌اند متصل باشند و قابل استفاده برای درخواست‌های قبلی یا بعدی نباشند.	2
6.6.3	مکانیزم‌های احراز هویت خارج از باند (Out-of-Band) مبتنی بر کد در برابر حملات force brute از طریق اعمال کنترل محدودیت نرخ (Rate Limiting) محافظت شوند. همچنین، استفاده از کدی با حداقل ۶۴ بیت آنتروپی مدنظر(Entropy) قرار گیرد.	2
6.6.4	در صورت استفاده از Notifications Push جهت احراز هویت چند عاملی، محدودیت نرخ (Rate Limiting) به منظور جلوگیری از حملات Bombing Push اعمال شده باشد. استفاده از تطبیق عدد (Number Matching) نیز می‌تواند به کاهش این ریسک کمک کند.	3

mechanism authentication Cryptographic V6.7

مکانیزم‌های احراز هویت رمزنگاری‌شده شامل کارت‌های هوشمند یا کلیدهای FIDO هستند، که در آن‌ها کاربر باید دستگاه رمزنگاری را به رایانه متصل کرده یا با آن جفت کند تا فرآیند احراز هویت تکمیل شود. در این روش، سرور احراز هویت یک عدد تصادفی (Nonce) چالشی به دستگاه یا نرم‌افزار رمزنگاری ارسال می‌کند و دستگاه یا نرم‌افزار بر اساس کلید رمزنگاری securely ذخیره‌شده، پاسخی را محاسبه می‌کند. الزامات این بخش راهنمایی‌های خاص پیاده‌سازی این مکانیزم‌ها را ارائه می‌دهد و راهنمایی‌های مربوط به الگوریتم‌های رمزنگاری در فصل «رمزنگاری» آورده شده است.

در مواردی که کلیدهای مشترک یا کلیدهای محرمانه برای احراز هویت رمزنگاری‌شده مورد استفاده قرار می‌گیرند، لازم است این کلیدها به همان روشی که سایر اسرار سیستمی مدیریت می‌شوند، نگه‌داری شوند. همانطورکه در بخش Secret Management» «از فصل «Configuration» مستندسازی شده است.

الزامات این بخش عمدتاً مربوط به بند § 5.1.7.2 از راهنمای NIST's Guidance می‌باشد.

#	Description	Level
6.7.1	گواهی‌نامه‌های مورد استفاده برای تأیید ادعاهای احراز هویت رمزنگاری‌شده به گونه‌ای ذخیره شوند که از تغییر یا دستکاری آن‌ها محافظت شود.	3
6.7.2	مقدار چالش (Challenge) (Nonce حداقل ۶۴ بیت طول داشته باشد و از نظر آماری یکتا باشد یا حداقل در طول عمر دستگاه رمزنگاری منحصر به فرد باقی بماند.	3

Provider Identity an with Authentication V6.8

ارائه‌دهندگان هویت Providers (Identity یا (IdPs هویت فدرال شده برای کاربران فراهم می‌کنند. کاربران اغلب بیش از یک هویت با چندین ارائه‌دهنده هویت دارند، مانند هویت سازمانی که از طریق Azure، AD، Okta Ping Identity یا Google مدیریت می‌شود، یا هویت مصرف‌کننده که از طریق شبکه‌های اجتماعی مانند Facebook، Twitter Google یا WeChat ایجاد می‌شود. این فهرست تأیید یا احراز هویت از این شرکت‌ها یا خدمات نیست، بلکه صرفاً تشویقی برای توسعه‌دهندگان است تا واقعیت وجود چندین هویت برای بسیاری از کاربران را در نظر بگیرند. سازمان‌ها باید با توجه به پروفایل ریسک و قدرت اثبات هویت ارائه‌دهنده هویت، به ادغام با هویت‌های موجود کاربران کمک کنند. به عنوان مثال، سازمان‌های دولتی به‌احتمال زیاد هویت شبکه‌های اجتماعی را به‌عنوان روش ورود به سیستم‌های حساس قبول نمی‌کنند، زیرا ایجاد هویت‌های جعلی یا موقت در این فضا ساده است، در حالی که شرکت‌های فعال در حوزه بازی‌های موبایل ممکن است برای افزایش تعداد بازیکنان فعال خود نیاز به ادغام با پلتفرم‌های اصلی شبکه‌های اجتماعی داشته باشند.

استفاده از ارائه‌دهندگان هویت خارجی نیازمند پیکربندی و تأیید دقیق است تا از جعل هویت یا ادعاهای ساختگی جلوگیری شود. این بخش شامل الزامات لازم برای مقابله با این ریسک‌ها می‌باشد.

#	Description	Level
6.8.1	اگر برنامه از چند ارائه‌دهنده هویت (IdP) پشتیبانی می‌کند، مکانیزم جعل هویت کاربر از طریق یک ارائه‌دهنده هویت دیگر وجود نداشته باشد (برای مثال، با استفاده از شناسه کاربری یکسان). مکانیسم استاندارد برای جلوگیری از این تهدید، این است که برنامه، کاربران را با استفاده از ترکیب شناسه IdP (به‌عنوان فضای نام یا namespace) و شناسه کاربر در آن، IdP ثبت و شناسایی کند.	2
6.8.2	وجود و پیکربندی امضاهای دیجیتال بر روی تصدیق‌های (تقاضاها یا ادعاهای) احراز هویت برای مثال بر روی (توکن‌های JWT یا SAML assertions) همواره اعتبارسنجی می‌شود و هرگونه تصدیقی که فاقد امضا یا دارای امضای نامعتبر باشد، رد می‌گردد.	2

#	Description	Level
6.8.3	(تقاضاها یا ادعاهای) تصدیقهای SAML بهصورت منحصربهفرد پردازش شده و تنها یکبار در بازهی اعتبار خود استفاده میشوند تا از حملات بازپخش (Replay Attacks) جلوگیری گردد.	2
6.8.4	اگر برنامهای از یک ارائهدهنده هویت (IdP) جداگانه استفاده میکند و انتظار قدرت، روشها یا تازگی احراز هویت خاصی را برای عملکردهای خاص دارد، برنامه این موضوع را با استفاده از اطلاعات برگردانده شده توسط IdP تأیید میکند. بهعنوان مثال، اگر از OIDC استفاده شود، این کار میتواند با اعتبارسنجی ادعاهای (Claims) موجود در توکن شناسایی (ID Token) مانند «amr»، «acr» و «auth_time» (در صورت وجود) انجام شود. اگر ارائهدهنده هویت این اطلاعات را ارائه نکند، برنامه باید یک روش جایگزین مستندسازیشده داشته باشد که فرض میکند حداقل سطح احراز هویت استفاده شده است (مثلاً احراز هویت تکعاملی با نام کاربری و گذرواژه).	2

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- NIST SP 800-63 - Digital Identity Guidelines
- NIST SP 800-63B - Authentication and Lifecycle Management
- NIST SP 800-63 FAQ
- OWASP Web Security Testing Guide: Authentication for Testing
- OWASP Password Storage Cheat Sheet
- OWASP Password Forgot Cheat Sheet
- OWASP Questions Security Using and Choosing Cheat Sheet
- CISA Guidance on Number" "Matching
- FIDO Alliance on Details

Management Session V7

هدف

مکانیزمهای مدیریت نشست (Session Management Mechanisms) به برنامهها این امکان را میدهند که تعاملات کاربر و دستگاه را در طول زمان، حتی هنگام استفاده از پروتکلهای stateless (مانند HTTP)، با یکی گرمرتبط کنند. برنامههای مدرن معمولاً چندین توکن نشست از (Session Token-) با ویژگیها و اهداف متفاوت استفاده کنند. یک سیستم مدیریت نشست ایمن، سیستمی است که از بهدست آوردن، استفاده یا سوءاستفاده مهاجم از نشست قربانی جلوگیری میکند. برنامههایی که نشستها را نگهداری میکنند باید اطمینان حاصل کنند که الزامات سطحبالای زیر در مدیریت نشست رعایت شدهاند:

- نشست‌ها برای هر کاربر(شخص) منحصر به فرد هستند و نمی‌توان آن‌ها را حدس زد یا به اشتراک گذاشت.
- نشست‌ها زمانی که دیگر مورد نیاز نیستند، باطل می‌شوند و در دوره‌های عدم فعالیت، منقضی می‌گردند.

بسیاری از الزامات مطرح‌شده در این فصل به کنترل‌های انتخاب‌شده از دست‌ورالعمل‌های هویت دیجیتال SP NIST 800-63 مربوط می‌شوند و بر ته‌دیدات رایج و ضعف‌های متداول در احراز هویت که معمولاً مورد سوءاستفاده قرار می‌گیرند، تمرکز دارند.

توجه داشته باشید که الزامات مربوط به جزئیات پیاده‌سازی خاصِ برخی از مکانیزم‌های مدیریت نشست را می‌توان در منابع دیگری یافت:

- Cookie HTTPها یک مکانیزم مشترک برای امن سازی توکن‌های نشست هستند. الزامات امنیتی خاصی برای کوکی‌ها در بخش "Web Frontend Security" قرار داده شده است.
- توکن های Self-contained به عنوان روشی برای نگه‌داری نشست‌ها بطور مکرر مورد استفاده قرار می‌گیرند. الزامات امنیتی خاصی در بخش "Self-contained Tokens" قرار داده شده است.

Documentation Management Session V7.1

هیچ الگوی واحدی که برای تمامی برنامه‌های کاربردی مناسب باشد، وجود ندارد. بنابراین، تعریف مرزها و محدودیت‌های عمومی که برای تمامی موارد مناسب باشد غیر ممکن است. یک تحلیل ریسک با تصمیم‌مات امنیتی مستند شده مرتبط با مدیریت نشست باید به عنوان یک پیش نیاز برای پیاده سازی و ارزیابی انجام شود. این امر تضمین می کند که سیستم مدیریت نشست با الزامات خاص آن برنامه کاربردی طراحی شده است.

فارغ از این‌که از مکانیزم نشست stateful یا stateless استفاده شود، تحلیل باید به‌صورت کامل و مستند انجام شود تا نشان دهد راه‌حل انتخاب‌شده توانایی برآورده کردن تمامی الزامات امنیتی مرتبط را دارد. همچنین باید تعامل با هرگونه مکانیزم ورود یک‌پارچه Sign-On (Single یا SSO که در حال استفاده است، مورد توجه قرار گیرد.

#	Description	Level
7.1.1	بازه عدم فعالیت نشست کاربر و بیشینه طول عمر نشست قبل از احراز هویت مجدد، در ترکیب با سایر کنترل‌ها مستند و متناسب سازی شود. مستند سازی انجام شده باید شامل توجیه برای هر انحراف(نقض) از الزامات احراز هویت مجدد NIST SP 800-63B باشد.	2
7.1.2	در مستند باید تعداد نشست همزمان مجاز برای یک کاربر و همچنین رفتار و اعمال مناسب برای زمانی که این تعداد به حداکثر رسید مشخص شود.	2

#	Description	Level
7.1.3	تمام سیستم‌هایی که نشست‌های کاربر را به عنوان بخشی از یک اکوسیستم مدیریت هویت فدرال(مانند سیستم‌های SSO) ایجاد و مدیریت می‌کنند، باید در کنار سایر کنترل‌های مربوط به طول عمر نشست‌ها، خاتمه آن‌ها و هرگونه شرایط دیگری که نیاز به احراز هویت مجدد دارد، مستند شوند.	2

Security Management Session Fundamental V7.2

این بخش الزامات موردنیاز از نشست‌های امن را از طریق بررسی امنیت تولید و اعتبارسنجی توکن‌ها احصا می‌نماید.

#	Description	Level
7.2.1	برنامه کاربردی باید تمام بررسی‌های توکن نشست را با استفاده از یک سرویس backend مطمئن انجام دهد.	1
7.2.2	برنامه کاربردی که از هر یک از توکن‌های Self-Contained یا reference که به صورت پویا برای مدیریت نشست تولید شده‌اند استفاده کند اما از از کلیدهای API ثابت و کلیدها استفاده نکند.	1
7.2.3	در صورتی که برای نمایش نشست کاربر از توکن‌های reference استفاده می شود، این توکن‌ها منحصر به فرد بوده و با استفاده از یک تولید کننده عدد شبه تصادفی امن رمزنگاری(CSPRNG) که دارای انتروپی حداقل128 بیتی است تولید شوند.	1
7.2.4	برنامه کاربردی در هنگام احراز هویت کاربر یک توکن نشست جدید تولید نمایدکه شامل احراز هویت مجدد و ابطال توکن نشست کنونی است.	1

Timeout Session V7.3

مکانیزم های انقضای نشست به منظور به حداقل رساندن فرصت برای hijacking session و سایر روش‌های سواستفاده از نشست‌ها بکار می‌روند.

#	Description	Level
7.3.1	بر اساس تحلیل ریسک و تصمیمات امنیتی مستند شده، پس از گذشت مهلت زمانی عدم فعالیت، کاربر مجبور به احراز هویت مجدد گردد.	2

#	Description	Level
7.3.2	بر اساس تحلیل ریسک و تصمیمات امنیتی مستند شده، پس از گذشت بیشینه زمان مطلق طول عمر، کاربر مجبور به احراز هویت مجدد گردد.	2

Termination Session V7.4

ابطال نشست ممکن است توسط خود برنامه کاربردی و یا در صورتی که مکانیزم SSO برای مدیریت نشست مورد استفاده قرار گرفته است، توسط SSO به جای برنامه صورت پذیرد. ممکن است لازم باشد هنگام بررسی الزامات این بخش، تصمیم گرفته شود که آیا ارائه‌دهنده‌ی SSO در محدوده‌ی این الزامات قرار گیرد یا خیر، زیرا برخی از این هاSSO ممکن است توسط ارائه‌دهنده کنترل شوند.

ابطال نشست بایدمنجر به الزام کاربر به احراز هویت مجدد گردد و در سراسر برنامه، ورود یک‌پارچه (Federated) (Login و سایر بخش ها اثربخش باشد.

برای مکانیزم های نشست ،stateful ابطال عموما شامل نامعتبرسازی نشست در .استbackend در مواردی که توکن‌ها self-contained هستند، معیاره‌ای بیشتری به منظور ابطال یا بلاک کردن این توکن-ها مورد نیاز هستند؛ در غیر این صورت این توکن‌ها تا زمان منقضی شدن بصورت معتبر باقی می‌مانند.

#	Description	Level
7.4.1	در مواقعی که فرآیند خاتمه نشست کاربر فعال می‌شود (مانند خروج کاربر یا انقضای نشست)، برنامه اجازه هیچ فعالیتی را به آن نشست نمی‌دهد. برای tokens Reference یا stateful ،session این به معنی نامعتبرسازی اطلاعات نشست در برنامه Backend می‌باشد. برنامه‌هایی که از توکن‌های Self-contained استفاده می‌کنند نیاز به راه حل‌هایی نظیر نگه‌داری فهرستی از توکن‌های خاتمه‌یافته، عدم پذیرش توکن‌هایی که پیش از یک تاریخ و زمان مشخص برای هر کاربر تولید شده‌اند، یا چرخش کلید امضای مخصوص هر کاربر دارند.	1
7.4.2	برنامه کاربردی تمامی نشست‌های فعال را در زمانی که حساب کاربری غیرفعال یا حذف می‌شود را ابطال نماید. (مانند کارمندی که شرکت را ترک می‌کند)	1
7.4.3	برنامه کاربردی قابلیت ارائه گزینه ابطال تمامی نشست های فعال دیگر را پس از یک تغییر موفقیت آمیز یا حذف هریک از عوامل احراز هویت (نظیر تغییر پسورد از طریق ریست یا بازنشانی و در صورت وجود به روزرسانی تنظیمات MFA (را داشته باشد.	2
7.4.4	تمامی صفحاتی که نیازمند احراز هویت هستند دارای دسترسی آسان و مشخص به فرآیند خروج باشند.	2

#	Description	Level
7.4.5	مدیران برنامه کاربردی قادر به ابطال نشست‌های فعال برای یک شخص یا تمامی کاربران باشند.	2

Abuse Session Against Defenses V7.5

این بخش الزاماتی را برای کاهش ریسک‌های ناشی از نشست‌های فعال که می‌توانند از طریق وکت‌وره‌ای‌ی که مت‌کی بر وجود نشست‌های کاربر فعال و قابلیت‌های آن‌ها سوءت‌ند مورد سرقت و یا سوء استفاده قرار گیرند را ارایه می‌دهد. بطور مثال، با استفاده از اجرای محتواهای آلوده مرورگر احراز هویت شده قربانی را مجبور کنیم که یک عملی را با استفاده از نشست کاربر قربانی انجام دهد.

توجه داشته باشید که راهنمای سطح‌محور موجود در فصل «احراز هویت» بایدهنگام در نظر گرفتن الزامات این بخش مدنظر قرار گیرد.

#	Description	Level
7.5.1	برنامه کاربردی قبل از اعطای مجوز تغییر ویژگی‌های حساس حساب کاربری که بر روی احراز هویت تاثیر دارد نظیر آدرس ایمیل، شماره تلفن، تنظیمات MFA یا اطلاعات دیگرکه در بازگردانی حساب کاربری مورد استفاده قرار می‌گیرند، به احراز هویت مجدد کامل نیاز دارد.	2
7.5.2	حساب‌های کاربری قادر به دیدن(پس از احراز هویت مجدد با حداقل یک عامل) و ابطال یک یا همه نشست‌های فعال باشد.	2
7.5.3	برنامه کاربردی قبل از اجرای تراکنش‌ها یا عملیات‌های حساس نیازمند احراز هویت مجدد با حداقل یک عامل یا صحت سنجی ثانویه باشد.	3

Re-authentication Federated V7.6

این بخش مربوط به کسانی است که کدطرف اتکا (RP) یا ارائه دهنده هویت (IdP) را می‌نویسند. این الزامات از NIST SP 800-63C برای هویت اشتراکی و ادعاها گرفته شده است.

#	Description	Level
7.6.1	طول عمر و ابطال نشست بین RP و idp طبق سند- که نیازمند احرازهویت مجدد در زمان مورد نیاز مانند وقتی که بیشینه زمان بین رخداد احراز هویت idp رسیده باشد- انجام شود.	2

#	Description	Level
7.6.2	س‌اخت نش‌س‌ت‌ه‌ا نی‌از ب‌ه رض‌ای‌ت ک‌ارب‌ر ی‌ا ی‌ک اق‌دام ص‌ری‌ح دارد ک‌ه ب‌دی‌ن ص‌ورت از ای‌ج‌اد نش‌س‌ت‌ه‌ای ج‌دی‌د ب‌رن‌ام‌ه ب‌دون ت‌ع‌ام‌ل ک‌ارب‌ر ج‌ل‌وگ‌ی‌ری م‌ی‌ش‌ود.	2

References

ب‌رای اط‌لاع‌ات ب‌ی‌ش‌ت‌ر، ه‌م‌چ‌نی‌ن ب‌ه م‌ن‌اب‌ع زی‌ر م‌راج‌ع‌ه ک‌نی‌د:

- Testing Management Session Guide: Testing Security Web OWASP
- Sheet Cheat Management Session OWASP

Authorization V8

ه‌دف

م‌ج‌وز دس‌ت‌رس‌ی، ت‌ض‌م‌ی‌ن م‌ی‌ک‌ند ک‌ه دس‌ت‌رس‌ی‌ه‌ا ف‌ق‌ط در اخ‌ت‌ی‌ار م‌ص‌رف ک‌ن‌ن‌دگ‌ان م‌ج‌از (ک‌ارب‌ران،س‌رورها و س‌ای‌ر ک‌ل‌ای‌ن‌ت‌ه‌ا) ق‌رار گ‌ی‌رد. ب‌ه م‌ن‌ظور اع‌م‌ال اص‌ل ح‌داق‌ل دس‌ت‌رس‌ی(POLP)، ب‌رن‌ام‌ه‌ای ک‌ارب‌ردی م‌ورد ت‌ای‌ی‌د ب‌ای‌د ای‌ن ال‌زام‌ات س‌طح ب‌الا را اح‌ص‌اء نم‌ای‌ن‌د:

- ق‌وان‌ی‌ن ص‌دور م‌ج‌وزه‌ا ک‌ه ش‌ام‌ل ع‌وام‌ل دخ‌ی‌ل در ت‌ص‌م‌ی‌م گ‌ی‌ری و ع‌وام‌ل م‌ح‌ی‌ط‌ی اس‌ت را م‌س‌ت‌ن‌د س‌ازی نم‌ای‌ی‌د.
- دس‌ت‌رس‌ی م‌ص‌رف ک‌ن‌ن‌دگ‌ان ب‌ه م‌ن‌اب‌ع ب‌ای‌د ب‌ر اس‌اس ح‌ق‌وق ت‌ع‌ری‌ف ش‌ده آن‌ه‌ا م‌ج‌از ش‌م‌رده ش‌ود.

Documentation Authorization V8.1

م‌س‌ت‌ن‌د س‌ازی ج‌ام‌ع م‌ج‌وزه‌ا ب‌ه م‌ن‌ظور اط‌م‌ی‌ن‌ان از اع‌م‌ال پ‌ی‌وس‌ت‌ه، ق‌اب‌ل‌ی‌ت م‌م‌ی‌زی(Auditable) و ه‌م‌س‌و ب‌ودن ت‌ص‌م‌ی‌م‌ات ام‌ن‌ی‌ت‌ی ب‌ا س‌ی‌اس‌ت‌ه‌ای س‌ازم‌ان‌ی ض‌رور‌ی اس‌ت و ه‌م‌چ‌نی‌ن ب‌ا ش‌ف‌اف س‌ازی و اج‌رای‌ی ک‌ردن ال‌زام‌ات ام‌ن‌ی‌ت‌ی ب‌رای ت‌وس‌ع‌ه ده‌ن‌دگ‌ان، م‌دی‌ران س‌ی‌س‌ت‌م و آزم‌ون‌گ‌ره‌ای ری‌س‌ک دس‌ت‌رس‌ی غ‌ی‌ر م‌ج‌از را ک‌اه‌ش م‌ی‌ده‌د.

#	Description	Level
8.1.1	م‌س‌ت‌ن‌د اع‌ط‌ای م‌ج‌وز ب‌ای‌د ش‌ام‌ل ق‌وان‌ی‌ن‌ی ب‌ه م‌ن‌ظور م‌ح‌دودس‌ازی دس‌ت‌رس‌ی در س‌طح ع‌م‌ل‌ک‌رد و دس‌ت‌رس‌ی م‌ب‌ت‌ن‌ی ب‌ر داده ب‌ر اس‌اس م‌ج‌وزه‌ای ک‌ارب‌ران و وی‌ژگ‌ی‌ه‌ای م‌ن‌اب‌ع ب‌اش‌د.	1

#	Description	Level
8.1.2	مس‌تن‌د اع‌طای مج‌وز ب‌ای‌د ق‌وان‌ی‌نی را ب‌رای مح‌دودی‌ت‌ه‌ای دس‌ت‌رس‌ی در س‌طح Field ب‌ر اس‌اس مج‌وزه‌ای ک‌ارب‌ران و وی‌ژگ‌ی‌ه‌ای م‌ناب‌ع ت‌ع‌ری‌ف ن‌م‌ای‌د(ه‌ر دو دس‌ت‌رس‌ی خ‌وان‌دن و ن‌وش‌ت‌ن). ت‌وج‌ه داش‌ت‌ه ب‌اش‌ی‌د ک‌ه ای‌ن ق‌وان‌ی‌ن م‌م ک‌ن اس‌ت ب‌ه م‌ق‌ادی‌ر دی‌گ‌ر وی‌ژگ‌ی‌ه‌ای ش‌یء داده ی م‌رب‌وط‌ه Object) Data (Relevant ب‌س‌ت‌گ‌ی داش‌ت‌ه ب‌اش‌ن‌د، م‌ان‌ن‌د ح‌ال‌ت (state) ی‌ا وض‌ع‌ی‌ت .(status)	2
8.1.3	مس‌تن‌د ب‌رن‌ام‌ه ک‌ارب‌ردی ب‌ای‌د وی‌ژگ‌ی‌ه‌ای مح‌ی‌ط‌ی و زم‌ی‌ن‌ه‌ای (ش‌ام‌ل و ن‌ه مح‌دود ب‌ه زم‌ان روز، م‌ک‌ان، آدرس IP ی‌ا دس‌ت‌گ‌اه) ک‌ه در ب‌رن‌ام‌ه ک‌ارب‌ردی ب‌ه من‌ظ‌ور ات‌خ‌اذ ت‌ص‌م‌ی‌م‌ات ام‌ن‌ی‌ت‌ی (ن‌ظ‌ی‌ر آن دس‌ت‌ه از ت‌ص‌م‌ی‌م‌ات‌ی ک‌ه م‌رب‌وط ب‌ه اح‌راز ه‌وی‌ت و اع‌طای مج‌وز م‌ی ب‌اش‌د) را م‌ش‌خ‌ص ک‌ن‌د.	3
8.1.4	مس‌تن‌دات اح‌راز ه‌وی‌ت و اع‌طای مج‌وز، ع‌لاوه ب‌ر اع‌طای مج‌وز در س‌طح ،Field س‌طح ع‌م‌ل‌ک‌رد و داده‌ای خ‌اص، چ‌گ‌ون‌گ‌ی اس‌ت‌ف‌اده از ع‌وام‌ل مح‌ی‌ط‌ی و زم‌ی‌ن‌ه‌ای در ات‌خ‌اذ ت‌ص‌م‌ی‌م‌ات را م‌ش‌خ‌ص ن‌م‌ای‌د.	3

Design Authorization General V8.2

پ‌ی‌اده س‌ازی ک‌ن‌ت‌رل‌ه‌ای اع‌طای مج‌وز ج‌زئ‌ی‌در س‌طح ع‌م‌ل‌ک‌رد، داده و ف‌ی‌ل‌ده‌ا، ت‌ض‌م‌ی‌ن م‌ی‌ک‌ن‌د ک‌ه م‌ص‌رف ک‌ن‌ن‌د‌گ‌ان ف‌ق‌ط ق‌ادر ب‌ه دس‌ت‌رس‌ی ب‌ه آن چ‌ی‌زی ه‌س‌ت‌ن‌د ک‌ه ص‌ری‌ح‌ا ب‌ه آن‌ه‌ا دس‌ت‌رس‌ی داده ش‌ده اس‌ت.

#	Description	Level
8.2.1	ب‌رن‌ام‌ه ک‌ارب‌ردی ب‌ای‌د از مح‌دود ب‌ودن دس‌ت‌رس‌ی‌ه‌ای در س‌طح ع‌م‌ل‌ک‌رد ب‌ه م‌ش‌ت‌ری‌ان‌ی ک‌ه دارای دس‌ت‌رس‌ی ص‌ری‌ح ه‌س‌ت‌ن‌د اط‌م‌ی‌ن‌ان ح‌اص‌ل ن‌م‌ای‌د.	1
8.2.2	ب‌رن‌ام‌ه ک‌ارب‌ردی ب‌ای‌د از مح‌دود ب‌ودن دس‌ت‌رس‌ی‌ه‌ای در س‌طح داده ب‌ه م‌ش‌ت‌ری‌ان‌ی ک‌ه دارای دس‌ت‌رس‌ی ص‌ری‌ح ب‌ه اق‌ل‌ام داده‌ای خ‌اص ه‌س‌ت‌ن‌د اط‌م‌ی‌ن‌ان ح‌اص‌ل ن‌م‌ای‌د ت‌ا از ای‌ن ط‌ری‌ق خ‌ط‌ر آس‌ی‌ب پ‌ذی‌ری IDOR و level object broken authorization را ک‌اه‌ش ده‌د .	1
8.2.3	ب‌رن‌ام‌ه ک‌ارب‌ردی دس‌ت‌رس‌ی در س‌طح Field را ب‌ا م‌ج‌وزه‌ای ص‌ری‌ح ب‌ه Field ه‌ا ب‌رای م‌ص‌رف ک‌ن‌ن‌د‌گ‌ان ج‌ه‌ت ک‌اه‌ش خ‌ط‌ر level property object broken authorization (BOPLA) مح‌دود ک‌رده ب‌اش‌د.	2
8.2.4	ک‌ن‌ت‌رل‌ه‌ای ام‌ن‌ی‌ت‌ی ت‌ط‌ب‌ی‌ق‌ی ک‌ه ب‌ر اس‌اس وی‌ژگ‌ی‌ه‌ای مح‌ی‌ط‌ی و زم‌ی‌ن‌ه‌ای ک‌ارب‌ر (م‌ان‌ن‌د زم‌ان روز، م‌ک‌ان، آدرس IP ی‌ا دس‌ت‌گ‌اه) ه‌س‌ت‌ن‌د، ب‌رای ت‌ص‌م‌ی‌م‌گ‌ی‌ری‌ه‌ای اح‌راز ه‌وی‌ت (Authentication) و م‌ج‌وزده‌ی (Authorization) ط‌ب‌ق م‌س‌تن‌دات ب‌رن‌ام‌ه پ‌ی‌اده‌س‌ازی ش‌ده‌ان‌د. ای‌ن ک‌ن‌ت‌رل‌ه‌ا ب‌ای‌د ه‌م در زم‌ان ت‌ل‌اش ک‌ارب‌ر ب‌رای ش‌روع ی‌ک ن‌ش‌س‌ت (Session) ج‌دی‌د و ه‌م در ط‌ول ی‌ک ن‌ش‌س‌ت ف‌ع‌ال، اع‌م‌ال ش‌ون‌د.	3

Authorization Level Operation V8.3

اجرای فوری تغییرات در مجوزهای دسترسی در لایه مناسب از مهماری برنامه کاربردی به منظور جلوگیری از اقدامات غیرمجاز بویژه در محیط های پویا ضروری است.

#	Description	Level
8.3.1	برنامه کاربردی قوانین مجوزدهی را در یک لایه سرویس مهتبر اعمال نموده و بر آن دستهای از کنترلهایی که مصرف کنندگان نامعتبر قادر به دستکاری آنها هستند مکی نباشد. (نظیر جاوا اسکریپت سمت کاربر)	1
8.3.2	در مواقعی که امکان اعمال فوری تغییرات وجود ندارد (مثلاً وقتی که سیستم برای تصمیمگیری در مجوزدهی از توکنهای Self-Contained مثل JWT استفاده میکند که اطلاعات را داخل خود ذخیره کرده و تا زمان انقضا تغییر نمیکنند)، بایدکنترلهای جبرانی وجود داشته باشد. این کنترلها بایدبتوانند زمانی که کاربر عملی را انجام میدهد که دیگر مجاز به آن نیست، هشدار بدهند و تغییر را برگردانند. با این حال، توجه کنید که این راهکار جایگزین نمیتواند جلوی نشت اطلاعات را بگیرد.	3
8.3.3	دسترسی به یک object بر اساس مجوزهای کاربری شخص درخواست کننده(مثال: مصرف کننده) باشد نه بر اساس مجوزهای یک واسطه یا سرویسی که به نمایندگی از او عمل میکند. بطور مثال، در صورتی که یک مصرف کننده یک وب سرویس را با استفاده از یک توکن self-contained برای احراز هویت فراخوانی میکند و سپس آن سرویس اطلاعات را از یک سرویس دیگر درخواست میکند، سرویس دوم بایدهمان توکن مصرف کننده را استفاده کند، نه یک توکن سرویس-به-سرویس (Machine-to-Machine) (token که متعلق به سرویس اول است، تا تصمیمات مجوزدهی دقیقاً بر اساس مجوزهای کاربر گرفته شوند.	3

Considerations Authorization Other V8.4

ملاحظات اضافهتری برای مجوزدهی ، بویژه برای درگاههای مدیریتی و محیطهای چند کاربره(multi tenants) وجود دارد که برای جلوگیری از دسترسی غیر مجاز مفید هستند.

#	Description	Level
8.4.1	برنامه های کاربردی چند کاربره(multi tenants) از کنترل های cross-tenant به منظور تضمین این امر که عملیاتهای مصرف کنندگان هرگز کاربرانی (tenants) را که مجوز تعامل با آنها را ندارند را تحت تأثیر قرار نمیدهد.	2

#	Description	Level
8.4.2	دس‌ت‌رس‌ی ب‌ه درگ‌اه‌ه‌ای پ‌ی ک‌ربن‌دی ش‌امل چ‌ن‌دی‌ن ل‌ای‌ه ام‌ن‌ی‌ت‌ی از ق‌ب‌ی‌ل ت‌أی‌ی‌د م‌داوم ه‌وی‌ت م‌ص‌رف ک‌ن‌ن‌ده، ارزی‌اب‌ی وض‌ع‌ی‌ت ام‌ن‌ی‌ت‌ی دس‌ت‌گ‌اه و ت‌ح‌ل‌ی‌ل ری‌س‌ک زم‌ی‌ن‌ه‌ای ب‌اش‌د ت‌ا از ای‌ن طری‌ق اط‌م‌ی‌ن‌ان ح‌اص‌ل ش‌ود ک‌ه م‌وق‌ع‌ی‌ت ش‌ب‌ک‌ه‌ای ی‌ا ن‌ق‌اط پ‌ای‌ان‌ی م‌ع‌ت‌ب‌ر ت‌ن‌ه‌ا ع‌وام‌ل ب‌رای م‌ج‌وزه‌ی ن‌ی‌س‌ت‌ند اگ‌ر چ‌ه ک‌ه ای‌ن ع‌وام‌ل اح‌ت‌م‌ال دس‌ت‌رس‌ی غ‌ی‌رم‌ج‌از را ک‌اه‌ش م‌ی‌ده‌ند.	3

References

ب‌رای اط‌لاع‌ات ب‌ی‌ش‌ت‌ر، ه‌م‌چ‌ن‌ی‌ن ب‌ه م‌ن‌اب‌ع زی‌ر م‌راج‌ع‌ه ک‌ن‌ی‌د:

- Authorization Guide: Testing Security Web OWASP
- Sheet Cheat Authorization OWASP

Tokens Self-contained V9

ه‌دف

م‌ف‌ه‌وم ت‌وک‌ن self-contained در Oauth2 6749 RFC اص‌ل‌ی م‌رب‌وط ب‌ه س‌ال 2012 ذک‌ر ش‌ده اس‌ت. ای‌ن م‌ف‌ه‌وم ب‌ه ت‌وک‌ن‌ی اش‌اره دارد ک‌ه ش‌ام‌ل داده ی‌ا Claim اس‌ت ک‌ه ی‌ک س‌روی‌س گ‌ی‌رن‌ده ب‌رای ت‌ص‌م‌ی‌م‌گ‌ی‌ری‌-ه‌ای ام‌ن‌ی‌ت‌ی ب‌ه آن‌ه‌ا م‌ت‌ک‌ی خ‌واه‌د ب‌ود. از ای‌ن رو ب‌ای‌د آن‌ه‌ا را از ت‌وک‌ن‌ه‌ای س‌اده‌ای ک‌ه ف‌ق‌ط ح‌اوی ی‌ک ش‌ن‌اس‌ه ه‌س‌ت‌ند ک‌ه س‌روی‌س گ‌ی‌رن‌ده از آن‌ه‌ا ب‌رای ج‌س‌ت‌ج‌وی داده ب‌ص‌ورت م‌ح‌ل‌ی اس‌ت‌ف‌اده م‌ی‌-ک‌ند م‌ت‌م‌ای‌ز دان‌س‌ت. رای‌ج ت‌ری‌ن م‌ث‌ال‌ه‌ا از ت‌وک‌ن‌ه‌ای self-contained ه‌ا، JSON Tokens Web (JWTs) وSAML assertion ه‌س‌ت‌ند.

ک‌ارب‌رد ت‌وک‌ن‌ه‌ای self-contained ح‌ت‌ی خ‌ارج از ح‌وزه OAuth و OIDC ب‌س‌ی‌ار ف‌راگ‌ی‌ر ش‌ده اس‌ت. در ه‌م‌ی‌ن زم‌ان ام‌ن‌ی‌ت ای‌ن م‌ک‌ان‌ی‌زم ب‌ر ق‌اب‌ل‌ی‌ت اع‌ت‌ب‌ارس‌نج‌ی ی‌ک‌پ‌ارچ‌گ‌ی ت‌وک‌ن و ت‌ض‌م‌ی‌ن ای‌ن م‌س‌ال‌ه ک‌ه ای‌ن ت‌وک‌ن ب‌رای ی‌ک زم‌ی‌ن‌ه خ‌اص م‌ع‌ت‌ب‌ر اس‌ت اس‌ت‌وار اس‌ت. م‌وان‌ع زی‌ادی(چ‌ال‌ش‌ه‌ا) در ای‌ن ف‌رآی‌ن‌د وج‌ود دارد و ای‌ن ب‌خ‌ش ج‌زئ‌ی‌ات وی‌ژه‌ای از ای‌ن م‌ک‌ان‌ی‌زم‌ه‌ا را ارائ‌ه م‌ی‌ده‌د ک‌ه ب‌رن‌ام‌ه‌ه‌ا ب‌ای‌د ب‌ه م‌ن‌ظ‌ور ج‌ل‌وگ‌ی‌ری از ای‌ن چ‌ال‌ش‌ه‌ا، ارائ‌ه ده‌ند.

integrity and source Token V9.1

ای‌ن ب‌خ‌ش ش‌ام‌ل ال‌زام‌ات‌ی اس‌ت ک‌ه ت‌ض‌م‌ی‌ن م‌ی‌ک‌ند ک‌ه ت‌وک‌ن ت‌وس‌ط ب‌خ‌ش م‌ط‌م‌ئ‌ن(م‌ورد اع‌ت‌م‌اد) ت‌ول‌ی‌د ش‌ده اس‌ت و م‌ورد دس‌ت‌ک‌اری ق‌رار ن‌گ‌رف‌ت‌ه اس‌ت.

#	Description	Level
9.1.1	قبل از پذیرش محتوای توکن‌ها، آن‌ها را با استفاده از امضای دیجیتال یا MAC به منظور حفاظت در مقابل دستکاری‌ها مورد اعتبارسنجی قرار داده شود.	1
9.1.2	فقط الگوریتم‌های موجود در لیست مجاز قادر به استفاده در ساخت و صحت سنجی توکن‌های self-contained در یک زمینه مشخص باشند. این لیست مجاز باید در حالت ایده آل شامل هم الگوریتم‌های متقارن و هم نامتقارن‌ها باشد و نباید شامل الگوریتم‌های NONE باشد. در صورتی که هر دو الگوریتم‌های متقارن و نامتقارن مورد نیاز باشند کنترل‌های بیشتری باید به منظور جلوگیری از سردرگمی کلیدها(Confusion key) بکار گرفته شود.	1
9.1.3	به منظور جلوگیری از مشخص نمودن منابع غیر مطمئن و کلیدها توسط مهاجمین، موارد کلیدی که در اعتبارسنجی توکن‌های self-contained مورد استفاده قرار می گیرند، از منابع از پیش پیکربندی شده مطمئنی که برای صادر کننده توکن است تعیین شود. برای JWTs و سایر ساختارهای JWS ، هدرهای نظیر 'jku', 'x5u' و 'jwk' باید با یک لیست مجاز از منابع مطمئن مورد اعتبارسنجی قرار گیرند.	1

content Token V9.2

قبل از اتخاذ تصمیمات امنیتی براساس محتوای توکن ،self-contained ضروری است ابتدا بررسی شود که آیا توکن در دوره مهلت‌برخود و برای هدفی که توسط سرویس گیرنده درجهت کاربرد آن در نظر گرفته و ارائه شده است. این موضوع به منظور جلوگیری از استفاده متقابل نا امن بین سرویس‌های مختلف یا با انواع توکن‌های مختلف از صادرکننده مشابه است.

الزامات خاص برای OAuth و OIDC در این بخش مورد پوشش قرار گرفته شده‌اند.

#	Description	Level
9.2.1	اگر یک بازه زمانی مهلت‌بر در داده‌های توکن وجود داشته باشد، توکن و محتوای آن تنها در صورتی پذیرفته می‌شوند که زمان بررسی در این بازه زمانی مهلت‌بر باشد. به عنوان مثال، برای ،هاJWT ادعاهای 'nbf' و 'exp' باید تایید شوند.	1
9.2.2	سرویس‌هایی که یک توکن دریافت می کنند قبل از پذیرش محتوای آن، از لحاظ درستی نوع بررسی نموده و برای هدف مشخص شده در نظر گیرد. بطور مثال، فقط توکن‌های access می‌توانند به منظور تصمیمات مجوزی و فقط توکن های ID می‌توانند به منظور اثبات هویت کاربر مورد پذیرش قرار گیرند.	2

#	Description	Level
9.2.3	ی ک س رویس ف ق ط ت وک ن ه ای ی را ب پ ذی رد ک ه ب ه م ن ظ ور اس ت ف اده ت وس ط آن س رویس ه س ت ن د(audience).ب رای JWT ه ا،ای ن ام ر م ی ت وان د از ط ری ق اع ت ب ارس ن ج ی ادع ای 'aud' ب ا ی ک ل ی س ت م ج از ت ع ری ف ش ده در س رویس ص ورت پ ذی رد.	2
9.2.4	اگ ر ص ادر ک ن ن ده ت وک ن از ک ل ی د خ ص وص ی م ش اب ه ی ب رای ه ای audience م ت ف اوت اس ت ف اده م ی ک ن د، ت وک ن ه ای ت ول ی د ش ده دارای م ح دودی ت م خ اط ب ی ب اش ن د ک ه ب ط ور م ن ح ص ر ب ه ف ردی م خ اط ب ی ن م ورد ن ظ ر را م ش خ ص م ی ک ن د. ای ن ام ر از اس ت ف اده م ج دد ت وک ن ت وس ط م خ اط ب ن اخ واس ت ه ج ل وگ ی ری م ی ک ن د. در ص ورت ی ک ه ش ن اس ه م خ اط ب ه ص ورت پ وی ا م ش خ ص ش ده ب اش د، ص ادر ک ن ن ده ت وک ن ب ای د ای ن م خ اط ب ی ن را ب ه م ن ظ ور اط م ی ن ان از ع دم ج ع ل ه وی ت م خ اط ب م ورد اع ت ب ارس ن ج ی ق رار ده د.	2

References

ب رای اط لاع ات ب ی ش ت ر، ه م چ ن ی ن ب ه م ن اب ع زی ر م راج ع ه ک ن ی د:

- Sheet Cheat Token Web JSON OWASP

OIDC and OAuth V10

ه دف

OAuth2 (ک ه در ای ن ف ص ل ب ا ع ن وان OAuth از آن ی اد م ی ش ود) ی ک چ ارچ وب اس ت ان دارد در ص ن ع ت ب رای واگ ذاری م ج وز دس ت رس ی(authorization delegated) اس ت. ب رای م ث ال، ب ا اس ت ف اده از OAuth ی ک ب رن ام ه ی ک ارب ری Client) (Application م ی ت وان د ب ه ن م ای ن د گ ی از ک ارب ر، ب ه ه اAPI (م ن اب ع س رور) دس ت رس ی پ ی دا ک ن د، م ش روط ب ر ای ن ک ه ک ارب ر، دس ت رس ی م ورد ن ی از را ب ه آن ب رن ام ه اع ط ا ک رده ب اش د.

ب ه ت ن ه ای ی، OAuth ب رای اح راز ه وی ت ک ارب ر ط راح ی ن ش ده اس ت. چ ارچ وب Connect OpenID (OIDC) ب ا اف زودن ی ک ل ای ه ی ه وی ت ک ارب ر ب ر روی OAuth، آن را گ س ت رش م ی ده د. ام ک ان ات ی OIDC م ان ن د اط لاع ات اس ت ان دارد ه وی ت ک ارب ر، ورود ی ک پ ارچ ه Single) Sign-On - (SSO و م دی ری ت ن ش س ت Session) (Management را پ ش ت ی ب ان ی م ی ک ن د.از آن ج ا ک ه OIDC ی ک اف زون ه ی OAuth م ح س وب م ی ش ود، ال زام ات م رب وط ب ه OAuth در ای ن ف ص ل، ش ام ل OIDC ن ی ز م ی گ ردد.

ن ق ش ه ای زی ر در OAuth ت ع ری ف ش ده ان د:

- م ش ت ری OAuth OAuth) (Client ب رن ام ه ای اس ت ک ه ت ل اش م ی ک ن د ب ه م ن اب ع س رور دس ت رس ی پ ی دا ک ن د (ب رای م ث ال، ب ا ف راخ وان ی ی ک API ب ه ک م ک ت وک ن دس ت رس ی ص ادرش ده) م ش ت ری OAuth اغ ل ب ی ک ب رن ام ه ی س م ت س رور (Server-side Application) اس ت.
  - ی ک Client Confidential ن وع ی Client OAuth اس ت ک ه ت وان ای ی ح ف ظ م ح رم ان گ ی اع ت ب ارن ام ه-ه ای ی (Credentials) را دارد ک ه ب رای اح راز ه وی ت خ ود در ب راب ر س رور م ج وز Server) (Authorization اس ت ف اده م ی ک ن د.

- ی‌ک Client Public تواناییی حفظ محرمانگیی اعتبارنامه‌ها (Credentials) برای احراز هویت در برابر Server Authorization را ندارد. بنابراین، به جای احراز هویت خود (برای مثال با استفاده از پارامترهای client_id و client_secret)، صرفاً خودش را شناساییی می‌کند (با استفاده از پارامتر client_id)

- Server Resource OAuth (RS) سروری است که از طریق API، منابع را در اختیار Clients OAuth قرار می‌دهد.
- Server Authorization OAuth (AS) ی‌ک برنامه‌ی سرور است که به Clients OAuth توکن‌های دسترسی Access) (Tokens صادر می‌کند. این توکن‌ها به Clients OAuth امکان می‌دهند تا به منابع موجود در RS دسترسی پیدا کنند، یا به نمایندگیی از کاربر نهایی، (End-User) یا به نمایندگیی از خود Client. OAuth معمولاً AS ی‌ک برنامه‌ی مجزا است، اما در صورت لزوم می‌توانند در ی‌ک RS مناسب نیز ادغام شود.
- Owner Resource (RO) همان کاربر نهایی (End-User) است که به Clients OAuth اجازه می‌دهد تا به نمایندگیی از او، دسترسی محدودی به منابع موجود روی Server Resource داشته باشند. Resource Owner با تعامل با Authorization Server، رضایت خود را برای این واگذاری مجوز دسترسی (Del-egated Authorization) اعلام می‌کند.

نقش‌های زیر در OIDC تعریف شده‌اند:

- Relying Party (RP) برنامه‌ی کاربری Client) (Application است که از طریق Provider OpenID درخواست احراز هویت کاربر نهایی (End-User) را می‌دهد. این نقش در واقع همان نقش ی‌ک Client OAuth را بر عهده دارد.
- Provider OpenID (OP) ی‌ک AS OAuth است که توانایی احراز هویت کاربر نهایی (End-User) را دارد و اطلاعات هویتی OIDC) (Claims را در اختیار RP قرار می‌دهد.OP می‌توانند همان Provider Identity (IdP) باشد، اما در سناریوهای فدراسیونی Federated)، (OP Scenarios و Provider Identity (جایی که کاربر نهایی احراز هویت می‌شود) ممکن است دو برنامه‌ی سرور جداگانه باشند.

OAuth و OIDC در ابتدا برای برنامه‌های سوم‌شخص Third-Party) (Applications طراحی شده بودند. امروزه، این پروتکل‌ها به‌طور گسترده در برنامه‌های اول‌شخص First-Party) (Applications نیز مورد استفاده قرار می‌گیرند. با این حال، هنگام استفاده در سناریوهای اول‌شخص مانند احراز هویت (Authentication) و مدیریت نشست Session) (Management این پروتکل‌ها پیچیدگی‌های را به همراه می‌آورند که ممکن است چالش‌های امنیتی جدیدی ایجاد کنند.

OAuth وOIDC را می‌توان در انواع مختلف برنامه‌ها به کار برد، اما تمرکز در ASVS و همچنین الزامات مطرح‌شده در این فصل، بر روی برنامه‌های وب Web) (Applications و رابط‌های برنامه‌نویسی کاربردی (APIs) است.

از آنجاکهOAuth وOIDC را می‌توان به‌عنوان لایه‌ای منطقی بر بستر فناوری‌های وب در نظر گرفت، الزامات عمومی مطرح‌شده در فصل‌های دیگر همواره در اینجا نیز کاربرد دارند. بنابراین، این فصل را نمی‌توان به‌صورت جدا از بقیه‌ی محتوا در نظر گرفت.

این فصل به بهترین شیوه‌های جاری Current) (Best Practices برای OAuth2 و OIDC می‌پردازد که با مشخصات منتشرشده در نشانی‌های https://oauth.net/2/ و https://openid.net/developers/specs/ همسو هستند. حتی اگرچه RFCها به بلوغ رسیده محسوب می‌شوند، اما به‌طور مداوم به‌روزرسانی می‌شوند.

بنابراین، هنگام به کارگیری الزامات این فصل، همسویی با آخرین نسخه‌ها بسیار اهمیت دارد. برای جزئیات بیشتر به بخش مراجع (References) مراجعه کنید.

با توجه به پیچیدگی این حوزه، برای داشتن یک راه کار امن مبتنی بر OAuth یا OIDC بسیار ضروری است که از Authorization های Server شناخته‌شده و استاندارد در صنعت استفاده شود و پیکربندی‌های امنیتی توصیه‌شده به کار گرفته شوند.

اصطلاحات به کاررفته در این فصل با هایOAuth RFC و مشخصات OIDC همسو هستند. با این حال، توجه داشته باشید که اصطلاحات OIDC تنها در مواردی استفاده می‌شوند که مربوط به الزامات خاص OIDC باشند؛ درغیر این صورت، از اصطلاحات OAuth استفاده خواهد شد.

در زمینه‌ی OAuth و ،OIDC اصطلاح توکن(Token) در این فصل اشاره دارد به:

- Access ،Tokens که فقط برای توسط RS مصرف شوند و می‌توانند یاTokens Reference باشند که با استفاده از Introspection اعتبارسنجی می‌شوند، یا Tokens Self-contained باشند که با استفاده از کلید رمزنگاری (Key Material) اعتبارسنجی می‌شوند.
- Refresh ،Tokens که فقط برای توسط Authorization ایServer مصرف شوند که توکن را صادر کرده است.
- ID OIDC ،Tokens که فقط برای توسط ایClient مصرف شوند که جریان احراز مجوز (Authorization Flow) را آغاز کرده است.

سطوح ریسک برای برخی از الزامات این فصل به این بستگی دارد که آیا Client یک Confidential Client است یا به‌عنوان یک Client Public در نظر گرفته می‌شود. از آنجا که استفاده از احراز هویت قوی Client بسیاری از برداره‌ای حمله را کاهش می‌دهد، برخی از الزامات ممکن است در هنگام استفاده از یک Client Confidential برای برنامه‌های L1 آسان‌تر در نظر گرفته شوند.

Security OIDC and OAuth Generic V10.1

این بخش الزامات عمومی را پوشش می‌دهد که برای همه‌ی برنامه‌هایی که ازOAuth یا OIDC استفاده می‌کنند، اعمال می‌شوند.

#	Description	Level
10.1.1	توکن‌ها باید فقط به مؤلفه‌های ارسال شوند که به‌طور دقیق به آن‌ها نیاز دارند. برای مثال، هنگام استفاده از الگوی Backend-for-Frontend برای برنامه‌های JavaScript مبتنی بر مرورگر، Tokens Access و Tokens Refresh باید فقط برای Backend قابل دسترس باشند.	2

#	Description	Level
10.1.2	Client باید فقط مقادیری را از Server Authorization بپذیرد (مانند Code Authorization یا Token ID (که این مقادیر حاصل از یک Flow Authorization باشند که توسط همان نشست (Session) و تراکنش Agent User آغاز شده است. این موضوع مستلزم آن است که هایSecret تولیدشده توسط کلاینت مانند code_verifier در PKCE، یا مقادیر state و nonce در OIDC قابل حدس زدن نباشند، مخصوص همان تراکنش باشند، و به‌صورت امن هم به کلاینت و هم به نشست (Session) مرورگری که تراکنش در آن شروع شده، متصل شده باشند.	2

Client OAuth V10.2

این الزامات مسئولیت‌هایی را که بر عهده برنامه‌های کلاینتِ OAuth است مشخص می‌کنند. کلاینت می‌تواند مثلاً یک بک‌اندِ وب‌سرور باشد (که اغلب به‌عنوان Frontend For Backend یا BFF عمل می‌کند) یک سرویس بک‌اندِ یک‌پارچه‌ساز، یا یک برنامه فرانت‌اند تک‌صفحه‌ای (SPA) یا همان برنامه مبتنی بر مرورگر باشد.

به‌طور کلی، Clients Backend به‌عنوان Clients Confidential و Clients Frontend به‌عنوان Clients Public در نظر گرفته می‌شوند. با این حال، برنامه‌های Native که روی دستگاه کاربر نهایی اجرا می‌شوند می‌توانند در صورتی که از Registration Client Dynamic OAuth استفاده کنند، به‌عنوان Confidential در نظر گرفته شوند.

#	Description	Level
10.2.1	در Code، Flow یا Client OAuth در برابر حملات Forgery Request Browser-based که معمولاً با عنوان Forgery Request Cross-Site (CSRF) شناخته می‌شوند و درخواست‌های توکن را ایجاد می‌کنند، محافظت داشته باشد. این محافظت باید با استفاده از قابلیت PKCE یا با بررسی پارامترstate که در درخواست احراز مجوز ارسال شده است.	2
10.2.2	اگر Client OAuth بتواند با بیش از یک Server Authorization تعامل داشته باشد، باید دارای سازوکاری برای دفاع در برابر Attacks Mix-up باشد. برای مثال، می‌تواند الزام کند که Server Authorization مقدار پارامتر 'iss' را برگرداند و این مقدار هم درResponse Authorization و هم درResponse Token اعتبارسنجی شود.	2
10.2.3	Client OAuth باید فقط Scopes (یا سایر پارامترهای مجوزدهی) مورد نیاز را در درخواست‌ها به Server Authorization درخواست کند.	3

Server Resource OAuth V10.3

در زمی‌نه‌ی ASVS و ای‌ن ف‌ص‌ل، Server Resource ی‌ ک API اس‌ت. ب‌رای ف‌راه‌م ک‌ردن دس‌ت‌رس‌ی ای‌م‌ن، Resource Server ب‌ای‌د:

- Token Access را م‌طاب‌ق ب‌ا ف‌رم‌ت ت‌وک‌ن و م‌ش‌خ‌ص‌ات پ‌روت‌ک‌ل م‌رب‌وط‌ه اع‌ت‌ب‌ارس‌نج‌ی ک‌ن‌د، ب‌رای م‌ث‌ال ب‌ا اس‌ت‌ف‌اده از JWT-validation ی‌ا Introspection. Token OAuth
- اگ‌ر Token Access م‌ع‌ت‌ب‌ر ب‌اش‌د، ت‌ص‌م‌ی‌م‌ات م‌ج‌وزه‌ی (Authorization Decisions) را ب‌ر اس‌اس اط‌لاع‌ات م‌وج‌ود در ت‌وک‌ن و دس‌ت‌رس‌ی‌ه‌ای اع‌طا ش‌ده اع‌م‌ال ن‌م‌ای‌د. ب‌رای م‌ث‌ال، Server Resource ب‌ای‌د ب‌ررس‌ی ک‌ن‌د ک‌ه آی‌ا Client (ک‌ه ب‌ه ن‌م‌ای‌ن‌د‌گ‌ی از RO ع‌م‌ل م‌ی ک‌ن‌د) اج‌ازه‌ی دس‌ت‌رس‌ی ب‌ه Resource درخ‌واس‌ت‌ی را دارد ی‌ا خ‌ی‌ر.

ب‌ن‌اب‌رای‌ن، ال‌زام‌ات ذک‌رش‌ده در ای‌ن‌ج‌ا م‌خ‌ت‌ص OAuth ی‌ا OIDC ه‌س‌ت‌ن‌د و ب‌ای‌د پ‌س از اع‌ت‌ب‌ارس‌نج‌ی ت‌وک‌ن و پ‌ی‌ش از اع‌م‌ال ت‌ص‌م‌ی‌م‌ات م‌ج‌وزه‌ی ب‌ر اس‌اس اط‌لاع‌ات م‌وج‌ود در ت‌وک‌ن ان‌ج‌ام ش‌ون‌د.

#	Description	Level
10.3.1	Server Resource ب‌ای‌د ف‌ق‌ط Access ه‌ای‌ی‌Token را ب‌پ‌ذی‌رد ک‌ه ب‌رای اس‌ت‌ف‌اده ب‌ا ه‌م‌ان س‌روی‌س در ن‌ظ‌ر گ‌رف‌ت‌ه ش‌ده‌ان‌د(Audience). Audience م‌ی‌ت‌وان‌د در ی‌ ک Token Access س‌اخ‌ت‌اری‌اف‌ت‌ه (م‌ان‌ن‌د م‌ق‌دار aud در (JWT درج ش‌ده ب‌اش‌د، ی‌ا از ط‌ری‌ق Endpoint Introspection Token ب‌ررس‌ی ش‌ود.	2
10.3.2	Server Resource ب‌ای‌د ت‌ص‌م‌ی‌م‌ات م‌ج‌وزه‌ی (Authorization Decisions) را ب‌ر اس‌اس Claims م‌وج‌ود در Token Access ک‌ه واگ‌ذاری م‌ج‌وز (Delegated Authorization) را ت‌ع‌ری‌ف م‌ی ک‌ن‌ن‌د، اع‌م‌ال ک‌ن‌د. اگ‌ر ه‌ای‌ی‌Claims م‌ان‌ن‌د ،scope sub و authorization_details م‌وج‌ود ب‌اش‌ن‌د، ب‌ای‌د ج‌زو ف‌رآی‌ن‌د ت‌ص‌م‌ی‌م‌گ‌ی‌ری ق‌رار گ‌ی‌رن‌د.	2
10.3.3	اگ‌ر ب‌رای گ‌رف‌ت‌ن ی‌ ک ت‌ص‌م‌ی‌م ک‌نت‌رل دس‌ت‌رس‌ی، ل‌ازم اس‌ت ی‌ ک ک‌ارب‌رِ ی‌ ک‌ت‌ا از داخ‌ل Token Access (چ‌ه JWT و چ‌ه پ‌اس‌خ Introspection Token (ش‌ن‌اس‌ای‌ی ش‌ود، س‌رور م‌ن‌ب‌ع Resource) (Server ک‌ارب‌ر را از روی ه‌ای‌ی‌Claim ش‌ن‌اس‌ای‌ی ک‌ن‌د ک‌ه ق‌اب‌ل اخ‌ت‌ص‌اص‌دادن ب‌ه ک‌ارب‌ران دی‌ گ‌ر ن‌ی‌س‌ت‌ن‌د. م‌ع‌م‌ولاً ای‌ن ی‌ع‌ن‌ی اس‌ت‌ف‌اده از ت‌رک‌ی‌ب دو Claim ی‌ع‌ن‌ی ’iss‘ (ص‌ادرک‌ن‌ن‌ده ت‌وک‌ن) و ’sub‘ (ش‌ن‌اس‌ه ی‌ ک‌ت‌ای ک‌ارب‌ر)	2
10.3.4	اگ‌ر Server Resource ن‌ی‌ازم‌ن‌د ق‌درت، روش ی‌ا ت‌ازگ‌ی خ‌اص اح‌راز ه‌وی‌ت ب‌اش‌د، ب‌ررس‌ی ک‌ن‌د ک‌ه Token Access ارائ‌ه‌ش‌ده ای‌ن م‌ح‌دودی‌ت‌ه‌ا را ب‌رآورده م‌ی ک‌ن‌د. ب‌رای م‌ث‌ال، در ص‌ورت وج‌ود، از ه‌ای‌ی‌OIDC Claims م‌ان‌ن‌د ،amr acr و auth_time ب‌ه ت‌رت‌ی‌ب اس‌ت‌ف‌اده ش‌ود.	2
10.3.5	ت‌أی‌ی‌د ک‌ن‌ی‌د ک‌ه Server Resource از اس‌ت‌ف‌اده از Access ه‌ای‌ی‌Token س‌رق‌ت‌ش‌ده ی‌ا Replay ت‌وک‌ن‌ه‌ا (ت‌وس‌ط اف‌راد غ‌ی‌رم‌ج‌از) ج‌ل‌وگ‌ی‌ری ک‌ن‌د، ب‌ا ال‌زام اس‌ت‌ف‌اده از Sender-Constrained Tokens، م‌ان‌ن‌د TLS Mutual ب‌رای OAuth 2 ی‌ا OAuth2 (DPoP). Possession of Proof of Demonstration	3

Server Authorization OAuth V10.4

ای‌ن الزام‌ات، م‌س‌ئول‌ی‌ت‌ه‌ای م‌رب‌وط ب‌ه Authorization OAuth ،Servers ش‌ام‌ل Providers OpenID را ت‌ش‌ری‌ح م‌ی ک‌ن‌ن‌د.

ب‌رای Client ،Authentication روش 'self_signed_tls_client_auth' م‌ج‌از اس‌ت، ه‌م‌راه ب‌ا پ‌ی‌ش‌ن‌ی‌ازه‌ای‌ی ک‌ه در ب‌خ‌ش 2.2 از RFC 8705 م‌ش‌خ‌ص ش‌ده‌ان‌د.

#	Description	Level
10.4.1	س‌رور اح‌راز ه‌وی‌ت ب‌ای‌د آدرس‌ه‌ای ب‌ازگ‌ش‌ت‌ی (Redirect URI) را ب‌ر اس‌اس ف‌ه‌رس‌ت م‌ج‌از (Allowlist) از ه‌ایURI از پ‌ی‌ش‌ث‌ب‌ت‌ش‌ده و م‌خ‌ص‌وص ه‌ر ک‌ل‌ای‌ن‌ت، ب‌ا اس‌ت‌ف‌اده از م‌ق‌ای‌س‌ه دق‌ی‌قِ رش‌ت‌ه‌ای (String (Exact Comparison اع‌ت‌ب‌ارس‌ن‌ج‌ی م‌ی ک‌ن‌د.	1
10.4.2	اگ‌ر Server Authorization ک‌د اح‌راز م‌ج‌وز (Authorization Code) را در Authorization Response ب‌رم‌ی گ‌ردان‌د، ای‌ن ک‌د ف‌ق‌ط ی ک‌ب‌ار ب‌رای درخ‌واس‌ت ت‌وک‌ن ب‌ای‌د ق‌اب‌ل اس‌ت‌ف‌اده ب‌اش‌د. ب‌رای دوم‌ی‌ن درخ‌واس‌ت م‌ع‌ت‌ب‌ر ب‌ا ی ک Authorization Code ک‌ه ق‌ب‌لاً ب‌رای ص‌دور Token Access اس‌ت‌ف‌اده ش‌ده اس‌ت، Authorization Server ب‌ای‌د درخ‌واس‌ت ت‌وک‌ن را رد ک‌ن‌د و ه‌ر ت‌وک‌ن ص‌ادرش‌ده‌ی م‌رت‌ب‌ط ب‌ا آن Code Authorization را ب‌اط‌ل ن‌م‌ای‌د.	1
10.4.3	ت‌أی‌ی‌د ک‌ن‌ی‌د ک‌ه Code Authorization دارای م‌دت زم‌ان م‌ع‌ت‌ب‌ر ب‌ودن م‌ح‌دود ب‌اش‌د. ح‌داک‌ث‌ر ط‌ول ع‌م‌ر م‌ی‌ت‌وان‌د ب‌رای ب‌رن‌ام‌ه‌ه‌ای ک‌ارب‌ردی در س‌ط‌وح L1 و L2 ت‌ا ۱۰ دق‌ی‌ق‌ه و ب‌رای ب‌رن‌ام‌ه‌ه‌ای ک‌ارب‌ردی در س‌ط‌ح L3 ت‌ا ۱ دق‌ی‌ق‌ه ب‌اش‌د.	1
10.4.4	ب‌رای ی ک Client م‌ش‌خ‌ص، Server Authorization ف‌ق‌ط اس‌ت‌ف‌اده از ه‌ای‌یGrant را م‌ج‌از ب‌دان‌د ک‌ه آن Client ب‌ه اس‌ت‌ف‌اده از آن‌ه‌ا ن‌ی‌از دارد. ت‌وج‌ه داش‌ت‌ه ب‌اش‌ی‌د ک‌ه ه‌ایGrant 'token' Implicit) (Flow و 'password' Credentials Password Owner (Resource Flow) دی گ‌ر ن‌ب‌ای‌د اس‌ت‌ف‌اده ش‌ون‌د.	1
10.4.5	Server Authorization ب‌ای‌د ح‌م‌لات Replay Token Refresh را ب‌رای Clientاه Public ک‌اه‌ش ده‌د، ت‌رج‌ی‌حاً ب‌ا اس‌ت‌ف‌اده از Refresh Sender-Constrained ،Tokens ی‌ع‌نی Tokens Access Certificate-Bound ی‌ا (DPoP) Possession of Proof Demonstrating ب‌ا اس‌ت‌ف‌اده از TLS Mutual. (mTLS) ب‌رای ب‌رن‌ام‌ه‌ه‌ای L1 و ،L2 م‌ی‌ت‌وان از Refresh Rotation Token اس‌ت‌ف‌اده ک‌رد. اگ‌ر Rotation Token Refresh ب‌ه ک‌ار گ‌رف‌ت‌ه ش‌ود، Server Authorization ب‌ای‌د پ‌س از اس‌ت‌ف‌اده، Token Refresh را ب‌اط‌ل ک‌ن‌د و اگ‌ر ی ک Token Refresh ک‌ه ق‌ب‌لاً اس‌ت‌ف‌اده و ب‌اط‌ل ش‌ده ارائ‌ه ش‌ود، ت‌م‌ام Refresh ه‌ایToken م‌رب‌وط ب‌ه آن م‌ج‌وز را اب‌ط‌ال ن‌م‌ای‌د.	1

#	Description	Level
10.4.6	اگر از Grant Code استفاده شود، Server Authorization باید حملات Interception Code Authorization را با الزام به استفاده از Code for Key Proof Exchange (PKCE) کاهش دهد. برای Authorization، هاServer Authorization Request باید یک مقدار مرتبر برای ’code_challenge‘ الزام کند و نباید مقدار ’code_challenge_method‘ از نوع ’plain‘ را بپذیرد. برای Token، Request باید اعتبارسنجی پارامتر ’code_verifier‘ الزامی باشد.	2
10.4.7	اگر Server Authorization از Registration Client Dynamic Unauthenticated پشتیبانی می‌کند، ریسک مربوط به Client هایApplication مخرب را باید کاهش دهد. این کار باید شامل اعتبارسنجی Metadata Client (مانند هر URI)، Registered اطمینان از رضایت کاربر، و هشدار به کاربر پیش از پردازش یک Request Authorization با یک Application Client غیرقابل اعتماد باشد.	2
10.4.8	Refresh هاToken باید دارای یک انقضای مطلق (Absolute Expiration) باشند، حتی اگر از Expiration Token Refresh Sliding استفاده شود.	2
10.4.9	Refresh هاToken و Access Reference هاToken باید توسط کاربر مجاز از طریق Server Authorization Interface User قابل ابطال باشند، تا ریسک هایClient مخرب یا توکن‌های سرقت‌شده کاهش یابد.	2
10.4.10	Client Confidential باید برای درخواست‌های Backchannel بین Client و Server Authorization، مانند Token Requests، Pushed Requests Authorization (PAR) و Revocation Token Requests، احراز هویت شود.	2
10.4.11	پیکربندی Server Authorization باید فقط Scopes موردنیاز را به OAuth Client اختصاص دهد.	2
10.4.12	برای یک Client مشخص، Server Authorization فقط مقدار ’response_mode‘ را که این Client نیاز دارد، مجاز بداند. برای مثال، با اعتبارسنجی این مقدار توسط Server Authorization در برابر مقادیر مورد انتظار یا با استفاده از Request Authorization Pushed (PAR) یا Request Authorization JWT-secured (JAR).	3
10.4.13	Grant Type ’code‘ همواره همراه با Pushed Requests Authorization (PAR) باید استفاده شود.	3
10.4.14	Server Authorization باید فقط توکن‌های دسترسی از نوع وابسته به ارسال کننده (Proof-of-Possession) صادر می‌کند؛ چه به‌صورت توکن‌های دسترسی مبتنی بر گواهی از طریق TLS دوسویه (mTLS) و چه به‌صورت توکن‌های دسترسی وابسته به DPoP (Demonstration of Proof of Possession).	3

#	Description	Level
10.4.15	برای ی ک ک‌لای‌نت س‌مت‌س‌رور (ک‌ه روی دس‌ت‌گ‌اه ک‌اربر نه‌ای‌ی اج‌را نم‌ی‌ش‌ود)، س‌رور اح‌راز ه‌وی‌ت اط‌م‌ی‌نان ح‌اص‌ل م‌ی ک‌ن‌د ک‌ه م‌ق‌دار پ‌ارام‌ت‌رِ authorization_details از ب‌ک‌اند ک‌لای‌نت ارس‌ال ش‌ده و ک‌اربر در آن دس‌ت‌ک‌اری ن‌ک‌رده اس‌ت. به‌ع‌نوان م‌ث‌ال، با ال‌زام به اس‌ت‌ف‌اده از درخ‌واس‌ت اح‌راز ه‌وی‌ت پ‌وش‌ش‌ده (PAR) ی‌ا درخ‌واس‌ت اح‌راز ه‌وی‌ت ای‌م‌ن‌ش‌ده با JWT .(JAR)	3
10.4.16	ک‌لای‌نت با‌ی‌د از ن‌وع Client Confidential با‌ش‌د و س‌رور اح‌راز ه‌وی‌ت اس‌ت‌ف‌اده از روش‌ه‌ای ق‌درت‌م‌ند اح‌راز ه‌وی‌ت ک‌لای‌نت ـ م‌بت‌نی ب‌ر رم‌زن‌گ‌اری ک‌لی‌د ع‌م‌وم‌ی و م‌ق‌اوم در ب‌راب‌ر ح‌م‌لات attacks replay ـ را ال‌زام‌ی ک‌ن‌د؛ م‌انند TLS دوس‌وی‌ه (tls_client_auth) ، self_signed_tls_client_auth ی‌ا JWT م‌بت‌نی ب‌ر ک‌لی‌د خ‌ص‌وص‌ی .(private_key_jwt)	3

Client OIDC V10.5

از آن‌ج‌ا ک‌ه Party Relying در OIDC ن‌ق‌ش ی ک ک‌لای‌نت OAuth را ه‌م ای‌ف‌ا م‌ی ک‌ن‌د، ال‌زام‌ات ب‌خ‌ش «OAuth Client» ن‌ی‌ز در ای‌ن‌ج‌ا ق‌اب‌ل اع‌م‌ال ه‌س‌ت‌ن‌د.

ه‌م‌چ‌ن‌ی‌ن ت‌وج‌ه داش‌ت‌ه با‌ش‌ی‌د ک‌ه ب‌خ‌ش «Authentication with an Identity Provider» در ف‌ص‌ل «Authentication» ن‌ی‌ز ش‌ام‌ل ال‌زام‌ات ع‌م‌وم‌ی م‌رت‌ب‌ط و م‌ه‌م‌ی اس‌ت.

#	Description	Level
10.5.1	Client به‌ع‌نوان Relying با‌ی‌دParty در ب‌راب‌ر ح‌م‌لات باز‌پ‌خ‌ش (Replay) ت‌وک‌ن ID Token در nonce دق‌ی‌قاً با م‌ق‌دار **nonce**ای ک‌ه در درخ‌واس‌ت اح‌راز ه‌وی‌ت به Provider OpenID ارس‌ال ش‌ده، ی ک‌س‌ان با‌ش‌د(ک‌ه در OAuth 2 به آن authorization request ارس‌ال‌ی به server authorization گ‌ف‌ت‌ه م‌ی‌ش‌ود).	2
10.5.2	Client با‌ی‌د ک‌اربر را به‌ص‌ورت ی ک‌ت‌ا از Claims Token ID ش‌ن‌اس‌ای‌ی ک‌ن‌د، م‌ع‌م‌ولاً از ‘sub’ Claim ، ک‌ه ق‌اب‌ل ان‌ت‌س‌اب م‌ج‌دد به ک‌اربران دی‌گ‌ر ن‌ی‌س‌ت (در ح‌دوده‌ی ه‌م‌ان Provider). Identity	2
10.5.3	Client با‌ی‌د ت‌لاش‌ه‌ای ی ک Server Authorization م‌خ‌رب ب‌رای ج‌ا زدن خ‌ود به‌ج‌ای ی ک Server Authorization دی‌گ‌ر از ط‌ری‌ق م‌ت‌ادی‌ت‌ای Server Authorization را رد م‌ی ک‌ن‌د. ک‌لای‌نت با‌ی‌د م‌ت‌ادی‌ت‌ای Server Authorization را رد ک‌ن‌د اگ‌ر م‌ق‌دار URL issuer م‌وج‌ود در م‌ت‌ادی‌ت‌ا دق‌ی‌قاً با URL issuer از پ‌ی‌ش پ‌ی ک‌رب‌ن‌دی‌ش‌ده و م‌ورد ان‌ت‌ظ‌ار ک‌لای‌نت ی ک‌س‌ان ن‌با‌ش‌د.	2
10.5.4	Client با‌ی‌د اع‌ت‌ب‌ارس‌نج‌ی ک‌ن‌د Token ID ب‌رای اس‌ت‌ف‌اده ت‌وس‌ط ه‌م‌ان Client در ن‌ظ‌ر گ‌رف‌ت‌ه ش‌ده اس‌ت ،(Audience) با ب‌ررس‌ی ای‌ن‌ک‌ه Claim ‘aud’ در ت‌وک‌ن ب‌راب‌ر با م‌ق‌دار ‘client_id’ م‌رب‌وط به Client با‌ش‌د.	2

#	Description	Level
10.5.5	هنگام استفاده از Back-Channel OIDC، Service of Denial از Party Relying Logout از طریق Logout Forced و Confusion Cross-JWT در جریان Logout باید جلوگیری کند. Client باید بررسی کند که Token Logout به درستی با مقدار typ آن برابر با logout+jwt باشد ، شامل Claim ‘event’ با نام عضو صحیح باشد و شامل Claim ‘nonce’ نباشد. همچنین توصیه می‌شود Expiration کوتاه باشد (مثلاً ۲ دقیقه).	2

Provider OpenID V10.6

از آنجا که OpenID Providerها نقش Server Authorization در OAuth را نیز ایفا می‌کنند، الزامات بخش «OAuth Authorization Server» در اینجا نیز قابل اعمال هستند.

توجه شود در صورتی که از Flow Token ID و نه Flow Code استفاده شود، Access ایTokenصادر نمی‌شود و در نتیجه بسیاری از الزامات مربوط به Server Authorization OAuth قابل اعمال نخواهند بود.

#	Description	Level
10.6.1	Provider OpenID باید فقط مقادیر ‘code’، ‘ciba’، ‘id_token’ یا ‘id_token code’ را برای Mode Response مجاز بداند. توجه داشته باشید که ‘code’ نسبت به ‘id_token code’ (که Flow Hybrid OIDC است) ترجیح داده می‌شود و ‘token’ (در Flow Implicit) نباید استفاده شود.	2
10.6.2	Provider OpenID از Service of Denial از طریق Logout Forced جلوگیری کند. این کار با دریافت تأیید صریح از کاربر نهایی یا در صورت وجود، اعتبارسنجی پارامترها در Request Logout (که توسط Party Relying آغاز شده است)، مانند ‘id_token_hint’، انجام می‌شود.	2

Management Consent V10.7

این الزامات، فرآیند تأیید رضایت (Consent) کاربر توسط Server Authorization را پوشش می‌دهند.در صورت نبودِ تأیید صحیح رضایت کاربر، یک مهاجم می‌تواند از طریق جعل (Spoofing) یا مهندسی اجتماعی Social) (Engineering به‌جای کاربر مجوزها (Permissions) را به دست آورد.

#	Description	Level
10.7.1	Server Authorization بایـد تـضـمـیـن کـنـد کـاربـر بـرای هـر درخـواسـت مـجـوز (Authorization) (Request رضـایـت خـود را اعـلـام کـرده اسـت. در صـورتـی کـه هـویـت کـلـایـنـت قـابـل اطـمـیـنـان نـبـاشـد، Server Authorization بایـد در هـمـه مـوارد کـاربـر را بـه‌صـورت صـریـح بـرای اعـلـام رضـایـت (Consent) راهـنـمـایـی و از او تـأیـیـد بـگـیـرد.	2
10.7.2	زمـانـی کـه Server Authorization از کـاربـر درخـواسـت رضـایـت (Consent) مـی کـنـد بـایـد اطـلـاعـات کـافـی و شـفـافـی دربـاره آنـچـه کـاربـر در حـال تـأیـیـد آن اسـت ارائـه دهـد. در صـورت لـزوم، ایـن اطـلـاعـات بـایـد شـامـل ایـن مـوارد بـاشـد: مـاهـیـت مـجـوزهـای درخـواسـتـی)مـعـمـولاً بـر اسـاس server resource scope، و جـزئـیـات مـجـوز در Requests Authorization Rich – ،(RAR هـویـت بـرنـامـه یـا اپـلـیـکـیـشـن دریـافـت‌کـنـنـده مـجـوز و مـدت اعـتـبـار ایـن مـجـوزهـا.	2
10.7.3	کـاربـر بـایـد بـتـوانـد رضـایـت‌هـایـی (Consents) را کـه از طـریـق Authorization Server صـادر کـرده اسـت، مـشـاهـده، ویـرایـش و لـغـو (Revoke) کـنـد.	2

References

بـرای اطـلـاعـات بـیـشـتـر دربـارهٔ OAuth، لـطـفـاً مـشـاهـده کـنـیـد:

- oauth.net
- Sheet Cheat Protocol 2.0 OAuth OWASP

بـرای الـزامـات مـرتـبـط بـا OAuth در ASVS، از هـایRFC مـنـتـشـر شـده و در وضـعـیـت پـیـشـنـویـس زیـر اسـتـفـاده مـی‌شـود:

- Framework Authorization 2.0 OAuth The RFC6749
- Usage Token Bearer Framework: Authorization 2.0 OAuth The RFC6750
- Considerations Security and Model Threat 2.0 OAuth RFC6819
- Clients Public OAuth by Exchange Code for Key Proof RFC7636
- Protocol Registration Client Dynamic 2.0 OAuth RFC7591
- Grant Authorization Device 2.0 OAuth RFC8628
- 2.0 OAuth for Indicators Resource RFC8707
- Tokens Access 2.0 OAuth for Profile (JWT) Token Web JSON RFC9068
- Requests Authorization Pushed 2.0 OAuth RFC9126
- Identification Issuer Server Authorization 2.0 OAuth RFC9207
- Requests Authorization Rich 2.0 OAuth RFC9396
- (DPoP) Possession of Proof Demonstrating 2.0 OAuth RFC9449
- Security 2.0 OAuth for Practice Current Best RFC9700
- Applications Browser-Based for 2.0 OAuth draft
- Framework Authorization 2.1 OAuth The draft

برای اطلاعات بیشتر در مورد OpenID ،Connect لطفاً به بخش زیر مراجعه کنید:

- OpenID Connect Core 1.0
- FAPI 2.0 Security Profile

Cryptography V11

هدف

هدف این فصل تعریف بهترین رویه‌ها برای استفاده عمومی از رمزنگاری است. همچنین به دنبال آن است که درک بنیادی از اصول رمزنگاری ایجاد کرده و تغییری به سمت روی کرده‌ای مقاوم‌تر و مدرن‌تر را ترغیب کند. این فصل این موارد را تشویق(پیشنهاد) می کند:

- پیاده‌سازی سیستم‌های رمزنگاری مقاوم که به‌طور ایمن دچار خطا شوند، با تهدیدات در حال تکامل سازگار شوند و آینده‌نگر باشند.
- به کارگیری سازوکارهای رمزنگاری که هم ایمن باشند و هم با بهترین رویه‌های صنعت همسو باشند.
- حفظ یک سیستم مدیریت کلیدهای رمزنگاری امن، همراه با کنترل‌های دسترسی مناسب و قابلیت ممیزی.
- ارزیابی منظم چشم‌انداز رمزنگاری به‌منظور شناسایی خطرات جدید و تطبیق الگوریتم‌ها بر اساس آن‌ها.
- کشف و مدیریت موارد استفاده‌ی رمزنگاری در طول چرخه‌ی عمر برنامه، به‌منظور اطمینان از ثبت و حفاظت تمامی دارایی‌های رمزنگاری.

علاوه بر تشریح اصول عمومی و بهترین شیوه‌ها، این سند اطلاعات فنی عمیق‌تری درباره الزامات در پیوست C استاندارده‌ای رمزنگاری ارائه می‌دهد. شامل الگوریتم‌ها و حالت‌هایی که برای اهداف الزامات این فصل «تأییدشده» محسوب می‌شوند.

الزامات استفاده کننده از رمزنگاری برای حل مسائل دیگر، مانند مدیریت secrets یا امنیت ارتباطات ، در بخش‌های دیگر استاندارد بررسی خواهند شد.

Documentation and Inventory Cryptographic V11.1

برنامه‌ها باید با معماری رمزنگاری قدرتمند طراحی شوند تا از دارایی‌های داده مطابق با طبقه‌بندی آن‌ها محافظت شود. رمزگذاری همه‌چیز کاری پرهزینه و بی‌هوده است؛ درحالی‌که رمزگذاری نکردن هیچ-چیز، از نظر قانونی سهلانگاری محسوب می‌شود. باید تعادلی برقرار شود، معمولاً در مرحله معماری یا طراحی سطح بالا، اسپریتهای طراحی یا آزمایش‌های معماری (architectural spikes). طراحی رمزنگاری به صورت لحظه‌ای یا اضافه کردن آن به سیستم پس از طراحی، به مراتب پرهزینه‌تر و دشوارتر از لحاظ امنیتی خواهد بود نسبت به حالتی که از ابتدا در طراحی لحاظ شده باشد.

مهم است که اطمینان حاصل شود تمامی دارایی‌های رمزنگاری به‌طور منظم شناسایی، فهرست‌بندی و ارزیابی شوند. لطفاً برای کسب اطلاعات بیشتر درباره نحوه انجام این کار به پیوست مراجعه کنید.

نی‌از به آی‌نده‌نگ‌ری در برابر ظهور اجت‌ناب‌ناپ‌ذی‌ر رای‌انش ک‌وانت‌ومی برای مقاوم‌سازی س‌ی‌س‌ت‌م‌-های رمزنگ‌اری نی‌ز ح‌ی‌ات‌ی است. رمزنگ‌اری پ‌س‌اک‌وانت‌ومی (Post-Quantum Cryptography) یا (PQC به ال‌گ‌وری‌ت‌م‌های رمزنگ‌اری‌ای اشاره دارد که برای مقاومت در برابر ح‌م‌لات رای‌انه‌ای ک‌وانت‌ومی طراح‌ی ش‌ده‌اند؛ رای‌انه‌ای‌ی که انت‌ظار می‌رود ال‌گ‌وری‌ت‌م‌های پرک‌اربردی همچون RSA و رمزنگ‌اری منح‌نی ب‌ی‌ض‌وی (ECC) را ب‌ش‌ک‌نند.

ل‌طفاً برای دری‌افت راهنمای‌ی‌های ک‌نونی درباره اب‌ت‌دای‌ی‌ات و اس‌ت‌اندارده‌ای ت‌أی‌ی‌دش‌ده در زمی‌نه رمزنگ‌اری پ‌س‌اک‌وانت‌ومی ،(PQC) به ض‌م‌ی‌مه مراجع‌ه ک‌نی‌د.

#	Description	Level
11.1.1	اطمی‌نان ح‌اص‌ل ک‌نی‌د که ی‌ک س‌ی‌است م‌س‌ت‌ند برای م‌دی‌ری‌ت ک‌ل‌ی‌ده‌ای رمزنگ‌اری و چ‌رخ‌ه‌ع‌م‌ر ک‌ل‌ی‌ده‌ای رمزنگ‌اری وجود دارد که از ی‌ک اس‌ت‌اندارد م‌دی‌ری‌ت ک‌ل‌ی‌د مانند NIST SP 57-800 پی‌روی می‌ک‌ند. ای‌ن ب‌ای‌د ش‌امل اطمی‌نان از ای‌ن موضوع ب‌اش‌د که ک‌ل‌ی‌دها ب‌ی‌ش از ح‌د به اش‌ت‌راک گ‌ذاش‌ته ن‌ش‌وند (برای مث‌ال، در مورد Secrets مش‌ت‌رک با ب‌ی‌ش از دو موج‌ودی‌ت و در مورد ک‌ل‌ی‌ده‌ای خ‌ص‌وص‌ی با ب‌ی‌ش از ی‌ک موج‌ودی‌ت).	2
11.1.2	فه‌رست اج‌زاء رمزنگ‌اری ب‌ای‌د ته‌ی‌ه و نگ‌ه‌داری ش‌ود و به‌ص‌ورت منظم به‌روزرس‌انی گ‌ردد و ش‌امل ت‌مام ک‌ل‌ی‌ده‌ای رمزنگ‌اری، ال‌گ‌وری‌ت‌م‌ها و گ‌واه‌ی‌های دی‌ج‌ی‌ت‌ال مورد اس‌ت‌فاده در برنامه باش‌د. ای‌ن فه‌رست همچ‌ن‌ی‌ن ب‌ای‌د مش‌خ‌ص کند که ک‌ل‌ی‌دها در کدام بخ‌ش‌های س‌ی‌س‌ت‌م مجاز یا غ‌ی‌رمجاز به اس‌ت‌فاده هستند و چه نوع داده‌ای‌ی می‌توانند یا نمی‌توانند با ای‌ن ک‌ل‌ی‌دها مح‌اف‌ظت ش‌ون‌د.	2
11.1.3	م‌کانی‌زم‌های ک‌ش‌ف رمزنگ‌اری برای ش‌ناس‌ای‌ی ت‌مام موارد اس‌ت‌فاده از رمزنگ‌اری در س‌ی‌س‌ت‌م ب‌ای‌د اس‌ت‌فاده ش‌ود؛ از ج‌م‌له رمزنگ‌اری ،(encryption) هش‌کردن (hashing) و ع‌م‌ل‌ی‌ات امض‌ای دی‌ج‌ی‌ت‌ال .(signing)	3
11.1.4	فه‌رست اج‌زاء رمزنگ‌اری ب‌ای‌د ته‌ی‌ه ش‌ود. ای‌ن فه‌رست ب‌ای‌د ش‌امل ی‌ک برنامه م‌س‌ت‌ند باش‌د که م‌س‌ی‌ر مهاجرت به اس‌ت‌اندارده‌ای ج‌دید رمزنگ‌اری (مانند رمزنگ‌اری پ‌س‌اک‌وانت‌ومی) را م‌ش‌خ‌ص می‌ک‌ند تا امکان واکنش من‌اس‌ب به ته‌دی‌دات آی‌نده فراهم ش‌ود.	3

Implementation Cryptography Secure V11.2

ای‌ن ب‌خ‌ش الزامات مربوط به انت‌خاب، پی‌اده‌س‌ازی و م‌دی‌ری‌ت م‌س‌ت‌م‌ر ال‌گ‌وری‌ت‌م‌های اص‌ل‌ی رمزنگ‌اری برای ی‌ک برنامه را ت‌ع‌ری‌ف می‌ک‌ند. هدف ای‌ن اس‌ت که تنها اب‌ت‌دای‌ی‌ات رمزنگ‌اری (primitives) قدرت‌مند و مورد پذی‌رش ص‌نع‌ت، مطابق با اس‌ت‌اندارده‌ای ف‌ع‌ل‌ی (مانند NIST و ISO/IEC و به‌ت‌ری‌ن روی‌ه‌ها به کار گ‌رف‌ته ش‌ون‌د. س‌ازمان‌ها ب‌ای‌د اطمی‌نان ح‌اص‌ل کنند که هر جزء رمزنگ‌اری بر اساس ش‌واهد داوری‌ش‌ده توسط م‌ت‌خ‌ص‌ص‌ان (peer-reviewed) و آزمای‌ش‌های ع‌م‌ل‌ی امنی‌ت‌ی انت‌خاب ش‌ده اس‌ت.

#	Description	Level
11.2.1	برای عملیات رمزنگاری بایـد از پیادهسازیهای مورد تأیید (شامل کتابخانهها و پیادهسازیهای سختافزاری) استفاده شود.	2
11.2.2	برنامه با انعطافپذیری رمزنگاری (crypto agility) بایـد طراحی شده باشد، بهطوری که الگوریتمهای تولید اعداد تصادفی، رمزنگاری احراز هویت شده، MAC یا هش، طول کلیدها، تعداد دورها، رمزها و حالتها بتوانند در هر زمان مجدداً پیکربندی، ارتقاء یا تعویض شوند تا در برابر شکستهای رمزنگاری محافظت شوند. به همین ترتیب، بایـد امکان جایگزینی کلیدها و رمزهای عبور و رمزگذاری مجدد دادهها نیز وجود داشته باشد. این امکان ارتقاء بدون وقفه به رمزنگاری پساکوانتومی (PQC) را فراهم میکند، زمانی که پیادهسازیهای با اطمینان بالا از طرحها یا استانداردهای تأییدشده PQC بهطور گستردهتر در دسترس قرار گیرند.	2
11.2.3	تمام بدویات رمزنگاری (cryptographic primitives) بر اساس الگوریتم، اندازه کلید و پیکربندی، حداقل ۱۲۸ بیت سطح امنیتی را فراهم میکنند(2128)، برای مثال، یک کلید ECC با طول ۲۵۶ بیت تقریباً ۱۲۸ بیت امنیت ارائه میدهد، در حالیکه برای رسیدن به همین سطح امنیت، الگوریتم RSA به کلید ۳۰۷۲ بیتی نیاز دارد.	2
11.2.4	تأیید کنید که تمامی عملیات رمزنگاری زمان ثابت (constant-time) باشند و هیچ عملیات «کوتاهشده» (short-circuit) در مقایسهها، محاسبات یا بازگشتها وجود نداشته باشد تا از نشت اطلاعات جلوگیری شود.(مهاجم میتواند از همین تفاوتهای زمانی، از طریق Side-Channel Timing Attack، اطلاعات حساس را استخراج کند.)	3
11.2.5	تأیید کنید که تمامی ماژولهای رمزنگاری بهصورت امن دچار خطا (fail securely) شوند و خطاها به گونهای مدیریت شوند که ایجاد آسیبپذیریهایی مانند حملات Oracle Padding را ممکن نکنند.	3

Algorithms Encryption V11.3

الگوریتمهای رمزنگاری احراز هویتشده (Authenticated Encryption) مبتنی بر AES و CHACHA20، زیربنای عملکردهای رمزنگاری مدرن را تشکیل میدهند.

#	Description	Level
11.3.1	از مدهای بلاک ناامن (مانند ECB) و روشهای Padding ضعیف (مانند PKCS#1 v1.5) نباید استفاده شود.	1
11.3.2	تنها رمزها و مدهای تأییدشده، مانند AES با GCM بایـد استفاده شوند.	1

#	Description	Level
11.3.3	داده‌های رمزنگاری‌شده باید با استفاده از ترجیحاً یک روش رمزنگاری احراز هویت‌شده تأییدشده یا با ترکیب یک روش رمزنگاری تأییدشده با یک الگوریتم MAC تأییدشده در برابر تغییرات غیرمجاز محافظت شوند.	2
11.3.4	تأییدکنندهٔ Initialization Nonce و Vector استفاده‌شده برای بیش از یک جفت کلید رمزنگاری و عنصر داده استفاده نشوند. روش تولید آن‌ها باید متناسب با الگوریتم مورد استفاده باشد.	3
11.3.5	تأییدکنندهٔ هر ترکیبی از یک الگوریتم رمزنگاری و یک الگوریتم MAC در حالت Encrypt-then-MAC عمل کند.	3

Functions Hash-based and Hashing V11.4

توابع هش در انواع گسترده‌ای از پروتکل‌های رمزنگاری استفاده می‌شوند، مانند امضای دیجیتال، HMAC، توابع مشتق‌سازی کلید (KDF)، تولید بیت تصادفی و ذخیره‌سازی پسورد. امنیت سیستم رمزنگاری تنها به اندازه‌ی امنیت توابع هش پایه‌ای است که استفاده می‌شوند. این بخش الزامات استفاده از توابع هش امن در عملیات رمزنگاری را بیان می‌کند.

برای ذخیره‌سازی رمزعبور، علاوه بر پیوست رمزنگاری، OWASP Password Storage Cheat Sheet نیز زمینه و راهنمایی مفیدی ارائه می‌دهد.

#	Description	Level
11.4.1	تأییدکنندهٔ تنها توابع هش تأییدشده برای موارد استفاده عمومی رمزنگاری، از جمله امضاهای دیجیتال، HMAC، KDF و تولید بیت تصادفی استفاده شوند. توابع هش غیرمجاز، مانند MD5، نباید برای هیچ هدف رمزنگاری به کار گرفته شوند.	1
11.4.2	رمزعبورها با استفاده از یک تابع مشتق‌سازی کلید تأییدشده و پره‌زینه محاسباتی (که به آن «تابع هش رمزعبور» نیز گفته می‌شود) ذخیره شوند، و تنظیمات پارامترها بر اساس راهنمایی‌های کنونی پیکربندی شده باشد. این تنظیمات باید تعادل بین امنیت و عملکرد برقرار کنند تا حملات Brute-force برای سطح امنیت مورد نیاز به‌طور کافی دشوار باشد.	2
11.4.3	توابع هش استفاده‌شده در امضاهای دیجیتال، باید به‌عنوان بخشی از احراز هویت داده یا یکپارچگی داده، در برابر collision مقاوم بوده و طول بیت متناسب داشته باشند. اگر مقاومت در برابر collision لازم باشد، طول خروجی باید حداقل 256 بیت باشد. اگر تنها مقاومت در برابر حملات Second Pre-image لازم باشد، طول خروجی باید حداقل 128 بیت باشد.	2

#	Description	Level
11.4.4	برنامه‌ای که از توابع مشتق‌سازی کلید (KDF) تأییدشده با پارامترهای Stretching Key استفاده می‌کند. پارامترهای مورد استفاده باید تعادلی بین امنیت و عملکرد برقرار کنند تا از نفوذ حملات brute-force و به خطر افتادن کلید رمزنگاری تولیدشده جلوگیری شود.	2

Values Random V11.5

تولید اعداد شبه‌تصادفی امن از نظر رمزنگاری (CSPRNG) بسیار دشوار است. به‌طور کلی، منابع خوب انتروپی در یک سیستم اگر بیش از حد استفاده شوند، سریعاً تخلیه می‌شوند، اما منابع با تصادفی‌بودن کمتر می‌توانند منجر به ایجاد کلیدها و secrets قابل پیش‌بینی شوند.

#	Description	Level
11.5.1	اعداد و رشته‌های تصادفی که قرار است قابل حدس نباشند، باید با استفاده از یک تولیدکننده اعداد شبه‌تصادفی امن رمزنگاری‌شده (CSPRNG) تولید شوند و حداقل 128 بیت انتروپی داشته باشند. توجه داشته باشید که UUIDها این شرط را رعایت نمی‌کنند.	2
11.5.2	مکانیزم تولید اعداد تصادفی مورد استفاده به گونه‌ای طراحی شده باشد که حتی تحت بار سنگین نیز به‌طور امن عمل کند.	3

Cryptography Key Public V11.6

رمزنگاری کلید عمومی (Public Cryptography) Key زمانی استفاده می‌شود که امکان یا تمایل به اشتراک‌گذاری کلید مخفی (secret key) بین چندین طرف وجود نداشته باشد.

به‌عنوان بخشی از این موضوع، نیاز به مکانیزم‌های تبادل کلید تأییدشده وجود دارد، مانند Diffie-Hellman و Diffie-Hellman Curve Elliptic، (ECDH) تا اطمینان حاصل شود که سیستم رمزنگاری در برابر ته‌دیدات مدرن امن باقی می‌ماند. فصل "ارتباط امن" الزامات مربوط به TLS را ارائه می‌دهد، بنابراین الزامات این بخش برای موقعیتی در نظر گرفته شده است که رمزنگاری کلید عمومی در موارد استفاده‌ای به غیر از TLS به کار گرفته شود.

#	Description	Level
11.6.1	فقط الگوریتم‌های رمزنگاری و مدهای عملیاتی تأییدشده برای تولید کلید و مقداردهی اولیه، و همچنین برای تولید و تأیید امضاهای دیجیتال باید استفاده می‌شوند. الگوریتم‌های تولید کلید نباید کلیدهای ناامن تولید کنند که در برابر حملات شناخته‌شده آسیب‌پذیر باشند؛ به‌عنوان مثال، کلیدهای RSA که در برابر factorization Fermat آسیب‌پذیر هستند.	2
11.6.2	برای تبادل کلید از الگوریتم‌های رمزنگاری تأییدشده (مانند Diffie-Hellman) استفاده می‌شود و تمرکز بر این است که مکانیزم‌های تبادل کلید از پارامترهای امن به‌ره ببرند. این کار از حملات بر فرآیند برقراری کلید جلوگیری می‌کند و مانع حملات مرد میانی (MITM) یا شکست‌های رمزنگاری می‌شود.	3

Cryptography Data In-Use V11.7

حفاظت از داده‌ها در حین پردازش اهمیت بالایی دارد. توصیه می‌شود از تکنیک‌هایی مانند رمزنگاری کامل حافظه، رمزنگاری داده‌ها در حال انتقال و اطمینان از رمزنگاری سریع داده‌ها پس از استفاده به‌ره گرفته شود.

#	Description	Level
11.7.1	رمزنگاری کامل حافظه (Full Memory Encryption) باید فعال باشد تا داده‌های حساس هنگام استفاده محافظت شوند و دسترسی کاربران یا فرآیندهای غیرمجاز به آن‌ها جلوگیری شود.	3
11.7.2	کاهش داده‌ها (data minimization) تضمین می‌کند که حداقل مقدار داده در حین پردازش افشا شود، و اطمینان حاصل شود که داده‌ها بلافاصله پس از استفاده یا در اولین فرصت ممکن رمزنگاری شوند.	3

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- OWASP Web Security Testing Guide: Weak Cryptography for Testing
- OWASP Cheat Sheet Storage Cryptographic
- FIPS 140-3
- NIST SP 800-57

Communication Secure V12

هدف

این فصل شامل الزامات مربوط به مکانیزم‌های خاصی است که باید برای محافظت از داده‌ها در حین انتقال برقرار باشند، هم بین کلاینت کاربر نهایی و سرویس باکند و هم بین سرویس‌های داخلی و باکند.

مفاهیم کلیدی که در این فصل تروج می‌شوند عبارتند از:

- اطمینان از اینکه ارتباطات به صورت خارجی رمزگذاری شده‌اند و در ایده‌آل حالت، به صورت داخلی نیز رمزگذاری شوند.
- پیکربندی مکانیزم‌های رمزگذاری با استفاده از آخرین دستورالعمل‌ها، شامل الگوریتم‌ها و رمزهای ترجیحی.
- استفاده از گواهی‌نامه‌های امضا شده برای اطمینان از اینکه ارتباطات توسط افراد غیرمجاز رهگیری نمی‌شوند.

علاوه بر ارائه اصول کلی و بهترین شیوه‌ها، ASVS اطلاعات فنی عمیق‌تری درباره قدرت رمزنگاری نیز در ضمیمه C – استانداردهای رمزنگاری ارائه می‌دهد.

Guidance Security TLS General V12.1

این بخش راهنمایی اولیه در مورد نحوه‌ی ایمن‌سازی ارتباطات TLS را ارائه می‌دهد. ابزارهای به‌روز باید برای بازبینی پیکربندی TLS به‌صورت مستمر استفاده شوند.

اگرچه استفاده از TLS wildcard ذاتاً ناامن نیست، اما در صورتی که یک گواهی که در تمامی محیط‌های test، staging development و production به‌کار رفته است به خطر بیفتد، ممکن است وضعیت امنیتی تمامی برنامه‌های استفاده‌کننده از آن گواهی نیز دچار آسیب شود. در صورت امکان، باید از حفاظت مناسب، مدیریت صحیح و همچنین استفاده از گواهی‌های TLS مجزا در محیط‌های مختلف بهره گرفته شود.

#	Description	Level
12.1.1	نسخه‌های پیش‌فرض پروتکل TLS فعال باشند، مانند TLS 1.2 و TLS 1.3 نسخه‌ی جدیدتر پروتکل TLS باید گزینه‌ی ترجیحی باشد.	1
12.1.2	suiteهای cipher پیش‌فرض فعال باشند و قوی‌ترین suiteهای cipher به‌عنوان گزینه‌ی ترجیحی تنظیم شده باشند. برنامه‌های L3 باید تنها از suiteهای cipher پشتیبانی کنند که Secrecy Forward را فراهم می‌کنند.	2
12.1.3	برنامه باید پیش از استفاده از هویت گواهی برای احراز هویت یا مجوزدهی، اعتبار و مورد اعتماد بودن گواهی‌های کلاینت در mTLS را بررسی و تأیید کند.	2

#	Description	Level
12.1.4	لغو صحی گواهی‌ها، مانند OCSP ، باید فعال و به‌درستی پیکربندی شده باشد.	3
12.1.5	باید در تنظیمات TLS برنامه فعال باشد تا از (ECH) Hello Client Encrypted افشای متادیتای حساس، مانند Indication Name Server ،(SNI) در طول فرآیند TLS Handshake جلوگیری شود.	3

Services Facing External with Communication HTTPS V12.2

تمام ترافیک HTTP به سمت سرویس‌های برون‌سازمانی (external-facing) که برنامه ارائه می‌دهد، به‌صورت رمزنگاری‌شده و با استفاده از گواهی‌های عمومیِ مورد اعتماد ارسال می‌شود.

#	Description	Level
12.2.1	برای تمام ارتباطات بین کلاینت و سرویس‌های مبتنی بر HTTP که در معرض دسترسی خارجی هستند، از TLS باید استفاده شود و هیچ‌گونه بازگشت (fallback) به ارتباطات ناامن یا بدون رمزنگاری انجام نگیرد.	1
12.2.2	سرویس‌هایی که در معرض دسترسی خارجی قرار دارند از گواهی‌های TLS عمومی و مورد اعتماد استفاده می‌کنند.	1

Security Communication Service to Service General V12.3

ارتباطات سرور (چه داخلی و چه خارجی) تنها شامل HTTP نمی‌باشد. ارتباطات به و از سایر سیستم‌ها نیز باید امن باشند، ترجیحاً با استفاده از TLS.

#	Description	Level
12.3.1	یک پروتکل رمزنگاری‌شده مانند TLS باید برای تمامی ارتباطات ورودی و خروجی به و از برنامه استفاده شود، از جمله سیستم‌های مانیتورینگ، ابزارهای مدیریت، دسترسی از راه دور و SSH، پایگاه‌های داده، mainframes، سیستم‌های partner یا APIهای خارجی. سرور نباید به پروتکل‌های ناامن یا بدون رمزگذاری بازگردد.	2
12.3.2	کلاینت‌های TLS باید قبل از برقراری ارتباط با سرور ،TLS گواهی‌های دریافتی را اعتبارسنجی کنند.	2
12.3.3	TLS یا دیگر مکانیزم‌های مناسب رمزگذاری انتقال باید برای تمامی ارتباطات بین سرویس‌های داخلی مبتنی بر HTTP درون برنامه استفاده شود و ارتباط به حالت‌های ناامن یا بدون رمزگذاری بازنگردد.	2

#	Description	Level
12.3.4	ارتباطات TLS بین سرویس‌های داخلی باید از گواهی‌های معتبر استفاده کنند. در صورتی که از گواهی‌های داخلی تولیدشده یا Self-Signed استفاده شود، سرویس مصرف‌کننده باید به گونه‌ای پیکربندی شود که تنها به هایCA داخلی مشخص و گواهی‌های Self-Signed خاص اعتماد کند.	2
12.3.5	سرویس‌هایی که درون یک سیستم با یکدیگر ارتباط دارند (ارتباطات درون‌سرویسی)، باید از احراز هویت قوی استفاده کنند تا هر نقطه انتهایی (endpoint) تأیید شود. روش‌های احراز هویت قوی، مانند احراز هویت کلاینت TLS، باید به‌کار گرفته شوند تا هویت تضمین شود (با استفاده از زیرساخت کلید عمومی (PKI) و مکانیزم‌هایی که در برابر حملات تکرار (replay attacks) مقاوم هستند). برای معماری‌های میکروسرویس، استفاده از سرویس مش برای ساده‌سازی مدیریت گواهی‌ها و افزایش امنیت در نظر گرفته شود	3

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- Sheet Cheat Security Layer Transport - OWASP
- guide configuration TLS Side Server Mozilla's
- .configurations TLS good known generate to tool Mozilla's
- configuration TLS validate to Project OWASP - O-Saft

Configuration V13

هدف

پیکربندی پیش‌فرض برنامه برای استفاده در اینترنت باید امن باشد.

این فصل راهنمایی‌های در مورد پیکربندی‌های مختلف لازم برای دستیابی به این هدف را ارائه می‌دهد، از جمله پیکربندی‌های که در طول توسعه، ساخت و استقرار اعمال می‌شوند.

موضوعات پوشش داده‌شده شامل جلوگیری از نشت داده‌ها، مدیریت امن ارتباط بین اجزا و حفاظت از secrets است.

Documentation Configuration V13.1

این بخش الزامات مستندسازی را برای نحوه‌ی ارتباط برنامه با سرویس‌های داخلی و خارجی، و همچنین تکنیک‌های برای جلوگیری از کاهش دسترسی به دلیل عدم دسترسی به سرویس ارائه می‌دهد. همچنین به مستندسازی مرتبط با secrets نیز پرداخته می‌شود.

#	Description	Level
13.1.1	تمامی نیازهای ارتباطی برنامه باید به‌طور کامل مستندسازی شده باشند. این مستندسازی شامل سرویس‌های خارجی که برنامه به آن‌ها وابسته است و همچنین مواردی که کاربر نهایی جهت اتصال به سرویس خارجی مشخص می‌کند باید باشد.	2
13.1.2	برای هر سرویسی که برنامه استفاده می‌کند، مستندسازی باید شامل حداکثر تعداد ارتباطات همزمان (مثلاً محدودیت‌های Connection Pool) و نحوه‌ی رفتار برنامه هنگام رسیدن به این حد باشد، از جمله هر مکانیزم بازیابی یا جایگزین، تا از بروز شرایط Service of Denial جلوگیری شود.	3
13.1.3	مستندات برنامه باید استراتژی‌های مدیریت منابع را برای هر سیستم یا سرویس خارجی که استفاده می‌کند مشخص کرده باشد (مثلاً پایگاه‌های داده، هندل‌های فایل، رشته‌ها، اتصالات HTTP). این مستندسازی باید شامل این موارد باشد: روی‌های آزادسازی منابع، تنظیمات تایم‌اوت، مدیریت خطاها، جایی که منطق Retry اعمال می‌شود، شامل محدودیت تعداد Retry، تأخیرها و الگوریتم‌های Back-off. برای عملیات همزمان درخواست-پاسخ HTTP (Synchronous)، مستندات باید تایم‌اوت کوتاه را الزام کند و یا Retry را غیرفعال کند یا به‌طور سخت‌گیرانه محدود کند تا از تاخیرهای زنجیره‌ای و هدررفت منابع جلوگیری شود.	3
13.1.4	مستندسازی برنامه باید شامل secretهای حیاتی برای امنیت برنامه و همچنین برنامه‌ای برای چرخش آن‌ها باشد(بر اساس مدل تهدید سازمان و نیازهای کسب‌وکار).	3

Configuration Communication Backend V13.2

برنامه‌ها با چندین سرویس از جمله APIها، پایگاه‌های داده یا سایر اجزا تعامل دارند. این سرویس-ها ممکن است نسبت به برنامه اجزای داخلی محسوب شوند اما در مکانیزم‌های کنترل دسترسی استاندارد برنامه گنجانده نشده باشند، یا کاملاً خارجی باشند. در هر صورت، لازم است برنامه برای تعامل امن با این اجزا پیکربندی شود و در صورت نیاز، این پیکربندی نیز محافظت گردد.

توجه: فصل Secure “Communication” راهنمایی‌های برای رمزگذاری در حین انتقال را ارائه می‌دهد.

#	Description	Level
13.2.1	رت‌باطات بی‌ن اجزای ب ک‌اند برنامه ک‌ه از م ک‌انی‌زم اس‌ت‌اندارد نش‌س‌ت ک‌اربران برنامه پ‌ش‌ت‌ی‌بانی نم‌ی ک‌ن‌ند، از ج‌م‌له ،ه‌APIا م‌ی‌انافزاره‌ا و ل‌ای‌ه‌ه‌ای داده، ب‌ای‌د اح‌راز ه‌وی‌ت ش‌ده ب‌اش‌ند. اح‌راز ه‌وی‌ت ب‌ای‌د ب‌ا اس‌ت‌ف‌اده از ح‌س‌اب‌ه‌ای س‌روی‌س ج‌داگ‌انه، ت‌وک‌ن‌ه‌ای ک‌وت‌اه‌م‌دت ی‌ا اح‌راز ه‌وی‌ت م‌ب‌ت‌نی ب‌ر گ‌واه‌ی انج‌ام ش‌ود و ن‌ب‌ای‌د از اع‌ت‌ب‌ارنام‌ه‌ه‌ای ث‌اب‌ت م‌انند رم‌ز ع‌ب‌ور، ک‌ل‌ی‌ده‌ای API ی‌ا ح‌س‌اب‌ه‌ای م‌ش‌ت‌رک ب‌ا دس‌ت‌رس‌ی‌ه‌ای س‌طح ب‌الا اس‌ت‌ف‌اده ش‌ود.	2
13.2.2	ارت‌ب‌اطات ب‌ی‌ن اجزای ب ک‌اند، از ج‌م‌له س‌روی‌س‌ه‌ای م‌ح‌لی ی‌ا س‌ی‌س‌ت‌م‌ع‌ام‌ل، ،ه‌APIا م‌ی‌انافزاره‌ا و ل‌ای‌ه‌ه‌ای داده، ب‌ا ح‌س‌اب‌ه‌ای‌ی ب‌ای‌د انج‌ام ش‌ود ک‌ه ک‌م‌ت‌ری‌ن س‌طح دس‌ت‌رس‌ی لازم را دارند.	2
13.2.3	اگ‌ر اع‌ت‌ب‌ارنام‌ه‌ای ب‌رای اح‌راز ه‌وی‌ت س‌روی‌س اس‌ت‌ف‌اده م‌ی‌ش‌ود، اع‌ت‌ب‌ارنام‌ه‌ای ک‌ه ت‌وس‌ط م‌ص‌رف ک‌ن‌ن‌ده اس‌ت‌ف‌اده م‌ی‌ش‌ود، اع‌ت‌ب‌ارنام‌ه پ‌ی‌ش‌ف‌رض ن‌ب‌اش‌د (م‌ث‌لاً root/root ی‌ا admin/admin).	2
13.2.4	ی‌ک allowlist ب‌رای ت‌ع‌ی‌ی‌ن م‌ن‌اب‌ع ی‌ا س‌ی‌س‌ت‌م‌ه‌ای خ‌ارج‌ی ک‌ه ب‌رنام‌ه م‌ج‌از ب‌ه ارت‌ب‌اط ب‌ا آن‌ه‌ا اس‌ت ب‌ای‌د وج‌ود داش‌ت‌ه ب‌اش‌د (م‌ث‌لاً ب‌رای درخ‌واس‌ت‌ه‌ای خ‌روج‌ی، ب‌ارگ‌ذاری داده ی‌ا دس‌ت‌رس‌ی ب‌ه ف‌ای‌ل). ای‌ن allowlist م‌ی‌ت‌وان‌د در ل‌ای‌ه ب‌رنام‌ه، وب‌س‌رور، ف‌ای‌روال ی‌ا ت‌رک‌ی‌ب‌ی از ل‌ای‌ه‌ه‌ای م‌خ‌ت‌ل‌ف پ‌ی‌اده‌س‌ازی ش‌ود.	2
13.2.5	وب‌س‌رور ی‌ا س‌رور ب‌رنام‌ه ب‌ا ی‌ک allowlist از م‌ن‌اب‌ع ی‌ا س‌ی‌س‌ت‌م‌ه‌ای‌ی ک‌ه س‌رور م‌ی‌ت‌وان‌د ب‌ه آن‌ه‌ا درخ‌واس‌ت ارس‌ال ک‌ن‌د ی‌ا داده‌ه‌ا و ف‌ای‌ل‌ه‌ا را ب‌ارگ‌ذاری ک‌ن‌د پ‌ی‌ک‌ربن‌دی ش‌ده ب‌اش‌د.	2
13.2.6	در م‌واق‌ع‌ی ک‌ه ب‌رنام‌ه ب‌ه س‌روی‌س‌ه‌ای ج‌داگ‌انه م‌ت‌ص‌ل م‌ی‌ش‌ود، پ‌ی‌ک‌ربن‌دی م‌س‌ت‌ن‌دس‌ازی‌ش‌ده ب‌رای ه‌ر ات‌ص‌ال رع‌ای‌ت ش‌ود، از ج‌م‌له ح‌داک‌ث‌ر ارت‌ب‌اطات ه‌م‌زمان، رف‌ت‌ار ه‌ن‌گ‌ام رس‌ی‌دن ب‌ه ح‌داک‌ث‌ر ارت‌ب‌اط م‌ج‌از، زمان‌ه‌ای Timeout ات‌ص‌ال و اس‌ت‌رات‌ژی‌ه‌ای Retry.	3

Management Secret V13.3

م‌دی‌ری‌ت secret ی‌ک وظی‌ف‌ه پ‌ی‌ک‌ربن‌دی ح‌ی‌ات‌ی اس‌ت ت‌ا از ح‌ف‌اظت داده‌ه‌ای م‌ورد اس‌ت‌ف‌اده در ب‌رنام‌ه اط‌م‌ی‌نان ح‌اص‌ل ش‌ود. ال‌زام‌ات خ‌اص م‌رب‌وط ب‌ه رم‌زن‌گ‌اری در ف‌ص‌ل "Cryptography" ق‌اب‌ل دس‌ت‌رس‌ی اس‌ت، ام‌ا ای‌ن ب‌خ‌ش ب‌ر م‌دی‌ری‌ت و ن‌ح‌وه‌ی ب‌رخ‌ورد ب‌ا secret ت‌م‌رک‌ز دارد.

#	Description	Level
13.3.1	ی ک راه ک ار م دی ری ت ،secret م انن د Vault ،Key ب رای ای ج اد ام ن، ذخ ی ره، ک نت رل دس ت رس ی و از ب ی ن ب ردن secret ب ک ان د اس ت ف اده ش ود. ای ن secret م ی ت وان د ش ام ل رمزعب ورها، داده ای رمز ن گ اری، اط لاع ات ح س اس م رب وط ب ه ات ص ال ب ه پ ای گ اه داده و س ی س ت م ه ای ش خ ص ث الث، ک ل ی ده ا و ه ایseed ت وک ن ه ای زمان م ح ور، س ای ر ه ایsecret داخ ل ی و ک ل ی ده ای API ب اش د. Secret ن ب ای د در ک د م نب ع ب رنام ه ی ا در artifacts build ق رار گ ی رد. ب رای ب رنام ه ه ای ،L3 ای ن ب ای د ش ام ل راه ک ار ی م ب ت ن ی ب ر س خ ت اف زار م انن د HSM ب اش د.	2
13.3.2	دس ت رس ی ب ه دارای ی ه ای secret ب ر اس اس اص ل ح داق ل دس ت رس ی (Least Privilege) رع ای ت ش ود.	2
13.3.3	ت م ام ع م ل ی ات رمزن گ اری ب ای د ب ا اس ت ف اده از ی ک م اژول ام ن ی ت ی ای زوله (م انن د Vault ی ا Security Hardware (Module انج ام ش ود ت ا م واد ک ل ی دی ب ه ط ور ام ن م دی ری ت و م ح اف ظ ت ش ده و از اف ش ای خ ارج از م اژول ام ن ی ت ی ج لوگ ی ری ش ود.	3
13.3.4	ه اsecret ب ر اس اس م س ت ن دس ازی ب رنام ه ط وری پ ی ک ربن دی ش ون د ک ه م ن ق ض ی ش ده و چ رخ ش داده ش ون د.	3

Leakage Information Unintended V13.4

پ ی ک ربن دی ه ای production ب ای د ب ه گ ون ه ای ام ن ش ون د ک ه از اف ش ای داده ه ای غ ی رض رور ی ج لوگ ی ری ش ود. ب س ی اری از ای ن م س ائ ل ب ه ن درت ب ه ع ن وان ری س ک ه ای م ه م ارزی اب ی م ی ش ون د، ام ا اغ ل ب ب ا س ای ر آس ی ب پ ذی ری ه ا زنج ی ره ای م ی ش ون د. اگ ر ای ن م س ائ ل ب ه ص ورت پ ی ش ف رض وج ود ن داش ت ه ب اش ن د، س ط ح دش واری ح م ل ه ب ه ب رنام ه اف زای ش م ی اب د.

ب ه ع ن وان م ث ال، م خ ف ی ک ردن ن س خ ه ی اج زای س رور ب اع ث ح ذف ن ی از ب ه ب ه روزرس ان ی ت م ام اج زا ن م ی ش ود، و غ ی رف ع ال ک ردن ن م ای ش ف ه رس ت پ وش ه ها ن ی از ب ه اس ت ف اده از ک ن ت رل ه ای دس ت رس ی ی ا ن گ ه داری ف ای ل ها دور از پ وش ه ع م وم ی را از ب ی ن ن م ی ب رد، ام ا س ط ح دش واری ح م ل ه را اف زای ش م ی ده د.

#	Description	Level
13.4.1	ب رنام ه ب ای د ب ه گ ون ه ای م س ت ق ر ش ود ک ه ه ی چ گ ون ه م ت ادی ت ای ک ن ت رل ن س خ ه، از ج م ل ه پ وش ه ه ای git. ی ا ،svn. در دس ت رس ن ب اش د ی ا ب ه ش ک ل ی ب اش د ک ه ای ن پ وش ه ها ن ه از ب ی رون و ن ه ت وس ط خ ود ب رنام ه ق اب ل دس ت رس ی ن ب اش ن د.	1
13.4.2	ح ال ت ه ای Debug ب رای ت م ام اج زا در م ح ی ط ه ای production ب ای د غ ی رف ع ال ش ده ب اش ن د ت ا از اف ش ای ق اب ل ی ت ه ای دی ب اگ و ن ش ت اط لاع ات ج لوگ ی ری ش ود.	2
13.4.3	وب س رورها ف ه رس ت ب ن دی دای ر ک ت وری ه ا را ب ه ک ارب ر ن ه ای ی ن ب ای د ن م ای ش ده ند م گ ر ای ن ک ه ب ه ط ور ص ری ح م ورد ن ظ ر ب اش د.	2
13.4.4	از م ت د TRACE HTTP در م ح ی ط ه ای production ن ب ای د پ ش ت ی ب ان ی ش ود ت ا از اح ت م ال ن ش ت اط لاع ات ج لوگ ی ری ش ود.	2

#	Description	Level
13.4.5	مس‌تندس‌ازی‌ها (مانند مس‌تندات های‌API داخ‌لی) و نق‌اط پ‌ای‌ش Monitoring) (Endpoints در دس‌ترس نب‌اش‌ند م‌گ‌ر ای‌نک‌ه به‌طور ص‌ری‌ح م‌ورد نظر ب‌اش‌د.	2
13.4.6	ت‌أی‌ی‌د ک‌نی‌د ک‌ه برنام‌ه اط‌لاع‌ات نس‌خه دق‌ی‌ق اج‌زای backend را اف‌ش‌ا ن‌ک‌ن‌د.	3
13.4.7	ل‌ای‌ه وب ب‌ای‌د به‌گ‌ون‌ه‌ای پ‌ی‌ک‌ربن‌دی ش‌ده ب‌اش‌د ک‌ه ف‌ق‌ط ف‌ای‌ل‌ه‌ای‌ی ب‌ا پ‌س‌ون‌ده‌ای م‌ش‌خ‌ص را س‌رو ک‌ن‌د ت‌ا از اف‌ش‌ای ت‌ص‌ادف‌ی اط‌لاع‌ات، پ‌ی‌ک‌ربن‌دی و ک‌د م‌نبع ج‌لوگ‌ی‌ری ش‌ود.	3

References

ب‌رای اط‌لاع‌ات ب‌ی‌ش‌تر، ه‌مچ‌ن‌ی‌ن به م‌نابع زی‌ر م‌راجع‌ه ک‌نی‌د:

- Testing Management Deployment and Configuration Guide: Testing Security Web OWASP

Protection Data V14

ه‌دف

برنام‌ه‌ها نم‌ی‌ت‌وانند ت‌م‌ام ال‌گ‌وه‌ای اس‌ت‌ف‌اده و رف‌ت‌اره‌ای ک‌اربران را پ‌ی‌ش‌ب‌ی‌نی ک‌نند، بن‌اب‌رای‌ن ب‌ای‌د ک‌نت‌رل‌ه‌ای‌ی را پ‌ی‌اده‌س‌ازی ک‌نند ت‌ا از دس‌ت‌رس‌ی غ‌ی‌رمج‌از به داده‌ه‌ای ح‌س‌اس روی دس‌ت‌گ‌اه‌ه‌ای ک‌اربر ج‌لوگ‌ی‌ری ش‌ود.

ای‌ن ف‌ص‌ل ش‌ام‌ل ال‌زام‌ات‌ی اس‌ت ک‌ه چ‌ه داده‌ه‌ای‌ی ب‌ای‌د م‌ح‌اف‌ظت ش‌ون‌د، چ‌گ‌ون‌ه ب‌ای‌د م‌ح‌اف‌ظت ش‌ون‌د، و ه‌مچ‌ن‌ی‌ن م‌ک‌ان‌ی‌زم‌ه‌ای خ‌اص‌ی ک‌ه ب‌ای‌د پ‌ی‌اده‌س‌ازی ش‌ون‌د ی‌ا اش‌ت‌ب‌اه‌ات‌ی ک‌ه ب‌ای‌د از آن‌ه‌ا اج‌ت‌ن‌اب ش‌ود.

ی‌ک‌ی دی‌گ‌راز م‌واردی ک‌ه ب‌ای‌د در ح‌ف‌اظت از داده‌ه‌ا در ن‌ظر گ‌رفت، اس‌ت‌خ‌راج ع‌م‌ده، ت‌غ‌ی‌ی‌ر ی‌ا اس‌ت‌ف‌اده ب‌ی‌ش از ح‌د از داده‌ه‌ا اس‌ت. ال‌زام‌ات ه‌ر س‌ی‌س‌ت‌م اح‌ت‌م‌الاً ب‌س‌ی‌ار م‌ت‌ف‌اوت خ‌واه‌ند ب‌ود، بن‌اب‌رای‌ن ت‌ع‌ی‌ی‌ن ای‌نک‌ه چ‌ه چ‌ی‌زی «غ‌ی‌رع‌ادی» م‌ح‌س‌وب م‌ی‌ش‌ود ب‌ای‌د ب‌ر اس‌اس م‌دل ت‌ه‌دی‌د و ری‌س‌ک ک‌س‌ب‌وک‌ار انج‌ام گ‌ی‌رد. از دی‌دگ‌اه ASVS، ش‌ن‌اس‌ای‌ی ای‌ن م‌س‌ائ‌ل در ف‌ص‌ل «Security Error and Logging» Handling ب‌ررس‌ی م‌ی‌ش‌ود و ت‌ع‌ی‌ی‌ن م‌ح‌دودی‌ت‌ه‌ا در ف‌ص‌ل «Validation Business and» Logic م‌ط‌رح ش‌ده اس‌ت.

Documentation Protection Data V14.1

ی‌ک‌ی از پ‌ی‌ش‌ن‌ی‌ازه‌ای اص‌ل‌ی ب‌رای ح‌ف‌اظت از داده‌ه‌ا، دس‌ته‌ب‌ن‌دی داده‌ه‌ای‌ی اس‌ت ک‌ه ب‌ای‌د به‌ع‌ن‌وان داده ح‌س‌اس در ن‌ظر گ‌رفت‌ه ش‌ون‌د. به‌اح‌ت‌م‌ال زی‌اد چ‌ند س‌ط‌ح م‌ت‌ف‌اوت از ح‌س‌اس‌ی‌ت وج‌ود خ‌واه‌د داش‌ت و ب‌رای ه‌ر س‌ط‌ح، ک‌نت‌رل‌ه‌ای ل‌ازم ج‌ه‌ت ح‌ف‌اظت از داده‌ه‌ا م‌ت‌ف‌اوت خ‌واه‌د ب‌ود.

م‌ق‌ررات و ق‌وان‌ی‌ن م‌خ‌ت‌ل‌ف‌ی در ح‌وزه ح‌ری‌م خ‌ص‌وص‌ی وج‌ود دارند ک‌ه ب‌ر نح‌وه ذخ‌ی‌ره‌س‌ازی، اس‌ت‌ف‌اده و ان‌ت‌ق‌ال داده‌ه‌ای ش‌خ‌ص‌ی ح‌س‌اس ت‌وس‌ط برنام‌ه‌ها ت‌أث‌ی‌ر م‌ی‌گ‌ذارند. ای‌ن ب‌خ‌ش دی‌گ‌ر ت‌ل‌اش‌ی ب‌رای

ت‌کرار چ‌نی‌ن قوانی‌ن ی‌ا م‌قررات‌ی در زم‌ین‌ه ح‌فاظت از داده ی‌ا ح‌ری‌م خ‌ص‌وص‌ی ن‌م‌ی‌ک‌ن‌د، ب‌ل‌ک‌ه ت‌م‌رک‌ز آن ب‌ر م‌لاح‌ظات ف‌ن‌ی ک‌ل‌ی‌دی ب‌رای ح‌فاظت از داده‌ای ح‌س‌اس اس‌ت. ل‌طف‌اً قوانی‌ن و م‌قررات م‌ح‌ل‌ی را ب‌ررس‌ی ک‌رده و در ص‌ورت نی‌از ب‌ا ی‌ک م‌تخ‌ص‌ص ح‌ری‌م خ‌ص‌وص‌ی ی‌ا وک‌ی‌ل واجد ش‌رای‌ط م‌ش‌ورت ک‌نی‌د.

#	Description	Level
14.1.1	ت‌م‌ام‌ی داده‌ه‌ای ح‌س‌اس ای‌جادش‌ده و پ‌ردازش‌ش‌ده ت‌وس‌ط ب‌رن‌ام‌ه ب‌ای‌د ش‌ن‌اس‌ای‌ی ش‌ده و ب‌ر اس‌اس س‌طوح ح‌فاظت‌ی ط‌ب‌ق‌ه‌ب‌ن‌دی ش‌ده‌ان‌د. ای‌ن م‌وض‌وع ش‌ام‌ل داده‌ه‌ای‌ی م‌ی‌ش‌ود ک‌ه ص‌رف‌اً ک‌ُدگ‌ذاری ش‌ده‌ان‌د و ب‌ه‌راح‌ت‌ی ق‌اب‌ل ب‌ازی‌اب‌ی ه‌س‌ت‌ن‌د، م‌ان‌ن‌د رش‌ت‌ه‌ه‌ای Base64 ی‌ا م‌ح‌ت‌وای م‌ت‌نی (plaintext) داخ‌ل ی‌ک .JWT س‌طوح ح‌فاظت‌ی ب‌ای‌د ال‌زام‌ات قوانی‌ن و اس‌ت‌ان‌دارده‌ای ح‌فاظت از داده و ح‌ری‌م خ‌ص‌وص‌ی ک‌ه ب‌رن‌ام‌ه م‌لزم ب‌ه رع‌ای‌ت آن‌ه‌اس‌ت را در ن‌ظر ب‌گ‌ی‌رن‌د.	2
14.1.2	ب‌رای ت‌م‌ام‌ی س‌طوح ح‌فاظت از داده‌ه‌ای ح‌س‌اس، م‌ج‌م‌وع‌ه‌ای م‌س‌ت‌ن‌د از ال‌زام‌ات ح‌فاظت‌ی ت‌ع‌ری‌ف ش‌ده ب‌اش‌د. ای‌ن ال‌زام‌ات ب‌ای‌د ش‌ام‌ل (ام‌ا م‌ح‌دود ب‌ه آن ن‌ب‌اش‌د) م‌وارد زی‌ر ب‌اش‌ن‌د: ال‌زام‌ات م‌رت‌ب‌ط ب‌ا رم‌زن‌گ‌اری ک‌ل‌ی، ب‌ررس‌ی ص‌ح‌ت و ی‌ک‌پ‌ارچ‌گ‌ی، دوره‌ه‌ای ن‌گ‌ه‌داری داده، ن‌ح‌وه ث‌ب‌ت داده‌ه‌ا در ل‌اگ، ک‌ن‌ت‌رل‌ه‌ای دس‌ت‌رس‌ی ب‌ه داده‌ه‌ای ح‌س‌اس در ل‌اگ‌ه‌ا، رم‌زن‌گ‌اری در س‌طح پ‌ای‌گ‌اه داده، ال‌زام‌ات م‌رب‌وط ب‌ه ح‌ری‌م خ‌ص‌وص‌ی و ف‌ن‌اوری‌ه‌ای ت‌ق‌وی‌ت ک‌ن‌ن‌ده ح‌ری‌م خ‌ص‌وص‌ی م‌ورد اس‌ت‌ف‌اده، و س‌ای‌ر ال‌زام‌ات م‌رت‌ب‌ط ب‌ا م‌ح‌رم‌ان‌گ‌ی.	2

Protection Data General V14.2

ای‌ن ب‌خ‌ش ش‌ام‌ل م‌ج‌م‌وع‌ه‌ای از ال‌زام‌ات ع‌م‌ل‌ی ب‌رای ح‌فاظت از داده‌ه‌ا م‌ی‌ب‌اش‌د. ب‌ی‌ش‌ت‌ر ای‌ن ال‌زام‌ات ب‌ه م‌س‌ائ‌ل خ‌اص‌ی م‌ان‌ن‌د ن‌ش‌ت ن‌اخ‌واس‌ت‌ه داده‌ه‌ا م‌رب‌وط م‌ی‌ش‌ون‌د، ام‌ا ی‌ک ال‌زام ک‌ل‌ی ن‌ی‌ز وج‌ود دارد ک‌ه ب‌ر پ‌ی‌اده‌س‌ازی ک‌ن‌ت‌رل‌ه‌ای ح‌فاظت‌ی ب‌ر اس‌اس س‌طح ح‌فاظت م‌وردن‌ی‌از ب‌رای ه‌ر داده ت‌أک‌ی‌د دارد.

#	Description	Level
14.2.1	داده‌ه‌ای ح‌س‌اس ب‌ای‌د ف‌ق‌ط در ب‌دن‌ه پ‌ی‌ام HTTP ی‌ا ف‌ی‌ل‌ده‌ای ه‌در ب‌ه س‌رور ارس‌ال ش‌ون‌د، و ای‌ن‌ک‌ه URL و string query ش‌ام‌ل اط‌لاع‌ات ح‌س‌اس (م‌ان‌ن‌د key API ی‌ا session token) ن‌ب‌اش‌ن‌د.	1
14.2.2	ب‌رن‌ام‌ه ب‌ای‌د از cache ش‌دن داده‌ه‌ای ح‌س‌اس در اج‌زای س‌رور م‌ان‌ن‌د Load Balancer و Cache Application ج‌ل‌وگ‌ی‌ری ک‌ن‌د، ی‌ا اط‌م‌ی‌ن‌ان ح‌اص‌ل ش‌ود ک‌ه داده‌ه‌ا پ‌س از اس‌ت‌ف‌اده ب‌ه‌ط‌ور ای‌م‌ن پ‌اک‌س‌ازی م‌ی‌ش‌ون‌د.	2
14.2.3	داده‌ه‌ای ح‌س‌اس ت‌ع‌ری‌ف‌ش‌ده ب‌ه ط‌رف‌ه‌ای غ‌ی‌رق‌اب‌ل اع‌ت‌م‌اد (م‌ان‌ن‌د User (Trackers ن‌ب‌ای‌د ارس‌ال ش‌ون‌د ت‌ا از ج‌م‌ع‌آوری ن‌اخ‌واس‌ت‌ه داده‌ه‌ا خ‌ارج از ک‌ن‌ت‌رل ب‌رن‌ام‌ه ج‌ل‌وگ‌ی‌ری ش‌ود.	2

#	Description	Level
14.2.4	کنترل‌های مرتبط با داده‌های حساس شامل رمزنگاری، بررسی صحت و یکپارچگی، نگه‌داری، نحوه ثبت داده‌ها در لاگ، کنترل‌های دسترسی به داده‌های حساس در لاگ‌ها، حریم خصوصی و فناوری‌های مربوط به حریم خصوصی، مطابق با آنچه در مستندات برای سطح حفاظت مشخص هر داده تعریف شده است، پیاده‌سازی شوند.	2
14.2.5	مکانیزم‌های cache باید طوری پیکربندی شده باشند که تنها پاسخ‌های با نوع محتوای مورد انتظار برای آن منبع cache شوند و شامل محتوای حساس یا پویا نباشند. وب‌سرور باید هنگام دسترسی به فایل ناموجود، پاسخ 404 یا 302 برگرداند و نه فایل معتبر دیگر، تا از حملات Cache Web Deception جلوگیری شود.	3
14.2.6	برنامه باید تنها حداقل داده‌های حساس مورد نیاز برای عملکرد برنامه را بازگرداند. برای مثال، تنها برخی از ارقام شماره کارت اعتباری بازگردانده شود و نه شماره کامل. در صورتی که داده کامل لازم باشد، باید در رابط کاربری masked شود مگر اینکه کاربر به‌طور مشخص آن را مشاهده کند.	3
14.2.7	اطلاعات حساس باید تحت طبقه‌بندی دوره‌ای نگه‌داری داده قرار گرفته باشند، به‌گونه‌ای که داده‌های قدیمی یا غیرضروری به‌طور خودکار، در یک برنامه زمان‌بندی‌شده مشخص، یا براساس نیاز حذف شوند.	3
14.2.8	اطلاعات حساس باید از متادیتای فایل‌های ارسال‌شده توسط کاربر حذف شود، مگر اینکه ذخیره‌سازی آن با رضایت کاربر انجام شود.	3

Protection Data Client-side V14.3

این بخش شامل الزامات جلوگیری از نشت داده‌ها به روش‌های خاص در سمت کلاینت یا سمت User Agent برنامه است.

#	Description	Level
14.3.1	داده‌های احراز هویت‌شده از حافظه کلاینت، مانند DOM مرورگر، پس از خروج کلاینت یا Session پاک شوند. فیلد هدر Clear-Site-Data در پاسخ سرور می‌تواند در این زمینه مفید باشد، اما کلاینت باید بتواند داده‌ها را حتی زمانی که اتصال به سرور در دسترس نیست در زمان پایان Session (خروج از آن) پاک کند.	1
14.3.2	برنامه باید هدرهای پاسخ anti-cach HTTP، مناسب (مانند :Cache-Control no-store) را تنظیم کند تا داده‌های حساس در مرورگرها cache نشوند.	2
14.3.3	برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:	2

References

also: see information, more For

- fields header anti-caching and security check to website Headers Security the using Consider
- Mozilla by headers anti-caching about Documentation
- project Headers Secure OWASP
- Project Risks Privacy OWASP
- Sheet Cheat Protection Privacy User OWASP
- information personal of Security - 11 Principle Privacy Australian
- overview (GDPR) Regulation Protection Data General Union European
- Network Engineering Privacy Internet - Supervisor Protection Data Union European
- header “Clear-Site-Data” the on Information
- Deception Cache Web on paper White

Architecture and Coding Secure V15

Objective Control

بس‌یاری از الزامات ASVS یا به ی ک حوزه خاص امن‌یت‌ی مانند احراز هویت یا مجوزده‌ی و ی‌ا به ی ک نوع خاص از کارک‌رده‌ای نرم‌افزار مانند ثبت رخداده‌ا ی‌ا مدی‌ری‌ت فای‌ل مرتبط می‌باشند.

ای‌ن ف‌ص‌ل الزامات ک‌ل‌ی امن‌یت‌ی ک‌ه با‌ی‌د ه‌نگام طراح‌ی و ت‌وس‌عه نرم‌افزاره‌ا در نظر گرفت‌ه ش‌وند را ارائه می‌ده‌د. ای‌ن الزامات نه ت‌نه‌ا بر مع‌ماری ت‌می‌ز و ک‌ی‌ف‌ی‌ت ک‌دت‌م‌رک‌زدارند، بل‌ک‌ه ش‌امل ش‌ی‌وه‌ه‌ای خاص مع‌ماری و ک‌دنوی‌س‌ی نی‌ز می‌ش‌وند ک‌ه برای امن‌یت نرم‌افزار ض‌روری ه‌س‌ت‌ند.

Documentation Architecture and Coding Secure V15.1

بس‌یاری از الزامات مربوط به ای‌جاد ی‌ک مع‌ماری امن و قابل دفاع، به م‌س‌ت‌ندس‌ازی ش‌فاف ت‌ص‌می‌مات‌ی بس‌ت‌گ‌ی دارند ک‌ه در مورد پ‌ی‌اده‌س‌ازی ک‌نت‌رله‌ای امن‌یت‌ی م‌شخص و م‌ؤلف‌ه‌ه‌ای اس‌ت‌فاده‌ش‌ده در نرم‌افزار ات‌خاذ می‌ش‌وند.

ای‌ن ب‌خ‌ش، الزامات م‌س‌ت‌ندس‌ازی را ش‌رح می‌ده‌د، از ج‌مله ش‌ناس‌ای‌ی م‌ؤلف‌ه‌ه‌ای‌ی ک‌ه دارای «ع‌م‌ل ک‌رد خ‌طرناک» در نظر گرفت‌ه می‌ش‌وند ی‌ا به ع‌نوان «م‌ؤلف‌ه‌ه‌ای پ‌ررس‌ک» ش‌ناخت‌ه می‌ش‌وند.

ی‌ک م‌ؤلف‌ه با «ع‌م‌ل ک‌رد خ‌طرناک» م‌م‌ک‌ن اس‌ت ی‌ک م‌ؤلف‌ه ت‌وس‌ع‌ه‌ی‌اف‌ت‌ه داخ‌ل‌ی ی‌ا ش‌خص ث‌الث ب‌اش‌د ک‌ه ع‌م‌ل‌ی‌ات‌ه‌ای‌ی مانند deserialization داده‌ای غ‌ی‌رقابل‌اع‌ت‌م‌اد، پ‌ردازش داده‌ای خام ی‌ا با‌ی‌نری، اج‌رای ک‌د به‌ص‌ورت پ‌وی‌ا، ی‌ا دس‌ت‌ک‌اری م‌س‌ت‌ق‌ی‌م ح‌اف‌ظه را انج‌ام می‌ده‌د. آس‌ی‌ب‌پ‌ذی‌ری‌ه‌ا در ای‌ن نوع ع‌م‌ل‌ی‌ات‌ه‌ا ری‌س‌ک ب‌الا‌ی‌ی برای به خ‌طر انداخ‌ت‌ن برنامه و اح‌ت‌م‌الاً اف‌ش‌ای زی‌رس‌اخت زی‌ربنا‌ی‌ی آن ای‌جاد می‌ک‌ن‌ند.

ی‌ک «م‌ؤلف‌ه پ‌ررس‌ک» ی‌ک ک‌ت‌اب‌خانه ش‌خص ث‌الث اس‌ت (ی‌عن‌ی ت‌وس‌ع‌ه‌ی‌اف‌ت‌ه داخ‌ل‌ی نی‌س‌ت) ک‌ه ک‌نت‌رله‌ای امن‌یت‌ی در فرآی‌ند ت‌وس‌ع‌ه ی‌ا ع‌م‌ل ک‌رد آن وج‌ود ن‌دارد ی‌ا ض‌ع‌ی‌ف پ‌ی‌اده‌س‌ازی ش‌ده‌اند.

نمونه‌ها شامل مؤلفه‌هایی هستند که به‌خوبی نگه‌داری نمی‌شوند، پشتیبانی نمی‌شوند، در مرحله end-of-life قرار دارند، یا سابقه‌ای از آسیب‌پذیری‌های جدی دارند.

این بخش همچنین بر اهمیت تعیین بازه‌های زمانی مناسب برای رسیدگی به آسیب‌پذیری‌ها در مؤلفه‌های شخص ثالث تأکید می‌کند.

#	Description	Level
15.1.1	مستندات برنامه باید بازه‌های زمانی جهت برطرف سازی آسیب‌پذیری نسخه‌های مؤلفه شخص ثالث (بر اساس ریسک) و همچنین به‌روزرسانی کتابخانه‌ها را به طور کلی تعریف کرده باشد تا ریسک ناشی از این مؤلفه‌ها به حداقل برسد.	1
15.1.2	یک کاتالوگ دارایی مانند Materials of Bill Software (SBOM) باید برای تمامی کتابخانه‌های شخص ثالث مورد استفاده نگه‌داری شود. شامل تاییدیه این که مؤلفه‌ها از مخازن از پیش تعیین‌شده، قابل اعتماد و به‌طور مستمر نگه‌داری‌شده تهیه شده‌اند.	2
15.1.3	مستندات برنامه باید شامل عملکردهایی که زمان‌بر یا پرمصرف(منابع سیستمی) هستند نیز باشد. این مورد باید شامل روش‌هایی برای جلوگیری از دست‌رفتن دسترس‌پذیری به دلیل استفاده بیش از حد از این عملکردها و همچنین جلوگیری از وضعیتی باشد که پردازش یک پاسخ طولانی‌تر از زمان انتظار مصرف‌کننده شود. تدابیر احتمالی می‌توانند شامل پردازش غیرهمزمان، استفاده از صف‌ها و محدود کردن فرآیندهای موازی برای هر کاربر و هر برنامه باشد.	2
15.1.4	مستندات برنامه باید کتابخانه‌های شخص ثالثی را که به‌عنوان «کامپوننت‌های پرخطر» شناخته می‌شوند، مشخص کرده باشد.	3
15.1.5	مستندات برنامه باید بخش‌هایی از برنامه را که به‌عنوان «عملکرد خطرناک» استفاده می‌شود، مشخص کرده باشد.	3

Dependencies and Architecture Security V15.2

این بخش شامل الزامات مربوط به مدیریت وابستگی‌ها و کامپوننت‌ها می‌باشد تا اجزای پرخطر، قدیمی یا ناامن به‌طور مؤثر شناسایی، کنترل و اداره شوند.

همچنین شامل استفاده از تکنیک‌های سطح معماری مانند containerization encapsulation، sandboxing و ایزوله‌سازی شبکه می‌باشد تا تأثیر استفاده از «عملیات خطرناک» (Dangerous operations) یا «کامپوننت‌های پرخطر» (dangerous operations) (همانطور که در بخش قبلی تعریف شد) کاهش یابد و از کاهش دسترسی به دلیل استفاده بیش از حد از عملکردهای پرمصرف منابع جلوگیری شود.

#	Description	Level
15.2.1	برنامه بایدتنها شامل کامپونتهایی باشدکه چارچوبهای زمانی مستندشده برای بهروزرسانی و رفع آسیبپذیریها را نقض نکردهباشند.	1
15.2.2	برنامه بایدبر اساس تصمیمات و استراتژیهای امنیتی مستندسازیشده، تدابیری برای جلوگیری از کاهش دسترسپذیری ناشی از عملکردهایی که زمانبر یا پرمصرف منابع هستند، پیادهسازی کرده باشد.	2
15.2.3	محیط production تنها شامل عملکردهایی میباشدکه برای اجرای برنامه ضروری هستند و هیچ قابلیت اضافی مانند کدهای تست، نمونه کدها و عملکردهای توسعهای در دسترس نمیباشد.	2
15.2.4	کامپونتهای شخص ثالث و تمام وابستگیهای انتقالی آنها از مخزن مورد انتظار بایدد دریافت شوند، چه داخلی و چه منبع خارجی، و ریسک حملهی confusion dependency مدیریت شود.	3
15.2.5	برنامه بایدمحافظتهای اضافی را در بخشهایی از برنامه کهبهعنوان «عملکرد خطرناک» مستند شدهاند یا از کتابخانههای شخص ثالثی کهبهعنوان «کامپونتهای پرریسک» شناختهمیشوند، پیادهسازی میکنند. این میتواند شامل تکنیکهایی مانند sandboxing، encapsulation یا containerization جداسازی در سطح شبکهباشد تا حملهکنندگان پس از نفوذ بهیک بخش از برنامه، نتوانند به بخشهای دیگربرنامه منتقل شوند و زمان لازم برای پیشروی آنها افزایش یابد.	3

Coding Defensive V15.3

این بخش انواع آسیبپذیریها را پوشش میدهد، از جمله type pollution prototype juggling، و سایر مواردی که ناشی استفاده از الگوهای ناامن برنامهنویسی در یک زبان خاص هستند. برخی از این آسیب-پذیریها ممکن است برای همه زبانها مرتبط نباشند، در حالی که برخی دیگر راهحلهای خاص زبان دارند یا به نحوه مدیریت ویژگیهایی مانند پارامترهای HTTP توسط یک زبان یا فریمورک خاص مربوط میشوند. همچنین، این بخش به خطرعدم اعتبارسنجی)رمزنگاری شده(بهروزرسانیهای برنامه نیز میپردازد.

این بخش همچنین خطرات مرتبط با استفاده از Objects برای نمایش دادهها و پذیرش و بازگرداندن آنها از طریق هایAPI خارجی را مورد بررسی قرار میدهد. در این حالت، برنامه بایداطمینان حاصل کند که فیلدهای دادهای کهنبایدقابل ویرایش باشند توسط ورودی کاربر تغییر نمیکنند mass) (assignment و API بهصورت انتخابی مشخص کندکه کدام فیلدهای داده بازگردانده شوند. هر جایی که دسترسی به فیلدها به مجوزهای کاربر وابسته باشد، این موضوع بایدد در چارچوب الزامات کنترل دسترسی در سطح فیلدها در فصل Authorization در نظر گرفته شود.

#	Description	Level
15.3.1	برنامه بایدت نه‌ا زیرمجموعه‌ای از فیلده‌ای مورد نیاز از یک object data را بازگرداند. به‌عنوان مثال، نبایدت کل object data بازگردانده شود، زیرا برخی فیلده‌ای منفرد نبایدت برای کاربران قابل دسترسی باشند.	1
15.3.2	درجایی که بکاند برنامه به هایURL خارجی فراخوانی میفرستد، طوری بایدت پیکربندی شده باشد که تنه‌ا در صورت نیاز و منظور مشخص، از تغییر مسیره‌ا (redirects) پیروی کند.	2
15.3.3	برنامه بایدت دارای تدابیر مقابله‌ای برای محافظت در برابر حملات mass assignment باشد، به‌طوری که فیلده‌ای مجاز برای هر کنترلر و اکشن محدود شده باشند؛ به عنوان مثال، نبایدت بتوان مقداری برای فیلدی وارد یا به‌روزرسانی کرد که قرار نبوده بخشی از آن اکشن باشد.	2
15.3.4	تمام اجزای proxying و middleware بایدت آدرس IP اصلی کاربر را به‌درستی منتقل کنند، با استفاده از فیلده‌ای داده معتبر که توسط کاربر نه‌ای قابل دستکاری نباشند، و برنامه و وبسرور از این مقدار صحیح برای ثبت لاگ و تصمیم‌گیری‌ه‌ای امنیتی مانند limiting rate استفاده کنند، با در نظر گرفتن اینکه حتی آدرس IP اصلی ممکن است به دلیل هایIP پویا، هVPN یا فایروال‌ه‌ای سازمانی قابل اعتماد نباشد.	2
15.3.5	برنامه بایدت به‌طور صریح اطمینان حاصل کند که variables از نوع صحیح هستند و عملیات‌ه‌ای مقایسه و comparator به‌صورت دقیق (strict) انجام میشوند. این اقدام برای جلوگیری از آسیب‌پذیری‌ه‌ای juggling type یا type confusion است که ممکن است به دلیل فرضیات نادرست برنامه درباره نوع یک متغیر ایجاد شود.	2
15.3.6	کدJavaScript بایدت به گونه‌ای نوشته شده باشد که از pollution prototype جلوگیری کند، برای مثال با استفاده از Set() یا Map() به جای object literals.	2
15.3.7	برنامه بایدت دارای تدابیر محافظتی در برابر pollution parameter HTTP باشد، به‌ویژه اگر چارچوب برنامه تفاوتی بین منابع پارامتره‌ای درخواست (رشته‌ه‌ای query، پارامتره‌ای body، کوکی‌ه یا فیلده‌ای هدر) قائل نشود.	2

Concurrency Safe V15.4

مسائل همزمانی مانند race condition، آسیب‌پذیری‌ه‌ای time-of-use to time-of-check (TOCTOU)، deadlock، livelock، starvation thread و هم گامسازی نادرست میتوانند منجر به رفتار غیرقابل پیش‌بینی و خطرات امنیتی شوند. این بخش شامل تکنیک‌ها و استراتژی‌ه‌ای مختلفی است که به کاهش این ریسک‌ها کمک می‌کنند.

#	Description	Level
15.4.1	objects shared در ک دmulti-threaded (م انن د ،هcache ف ای ل ه ا، ی ا اش ی ائ ی ک ه ت وس ط threads multiple دس ت رس ی پ ی دا م ی ک ن ن د) ب ای د ب ه ص ورت ای م ن م ورد اس ت ف اده ق رار ب گ ی رن د، ب ا اس ت ف اده از ن وع ه ای thread-safe و م ک ان ی زم ه ای ه م گ ام س ازی م انن د lock ی ا semaphore ت ا از condition race و ت خ ری ب داده ج ل وگ ی ری ش ود.	3
15.4.2	ب ررس ی وض ع ی ت ی ک ،resource م انن د وج ود آن ی ا دس ت رس ی ه ا،و اق دام ات ی ک ه ب ه ای ن وض ع ی ت واب س ت ه ان د، ب ه ص ورت ی ک ع م ل ی ات واح د انج ام ش ون د ت ا از ن وع condition race time-of-use to time-of-check (TOCTOU) ج ل وگ ی ری ش ود. ب ری ای م ث ال، ب ررس ی ای ن ک ه ی ک ف ای ل وج ود دارد ق ب ل از ب از ک ردن آن، ی ا ت أی ی د دس ت رس ی ی ک ک ارب ر ق ب ل از اع ط ای آن.	3
15.4.3	ب ای د از ق ف ل ه ا (Locks) ب ه ط ور ی ک ن واخ ت اس ت ف اده ش ود ت ا از گ ی ر ک ردن (Threads) ج ل وگ ی ری ش ود، چ ه ب ا ان ت ظ ار ب ری ای ک ی گ ر و چ ه ب ا ت ل اش ب ی پ ای ان، و ه م چ ن ی ن م ن ط ق ق ف ل گ ذاری ب ای د در ه م ان ک ی ب اق ی ب م ان د ک ه م س ئ ول م دی ری ت م ن ب ع اس ت؛ ای ن ک ار ت ض م ی ن م ی ک ن د ک ه ق ف ل ه ا ن م ی ت وان ن د ب ه ص ورت ن اخ واس ت ه ی ا خ راب ک ارانه ت وس ط ک ل اس ه ا ی ا ک ه ای ب ی رون ی ت غ ی ی ر داده ش ون د.	3
15.4.4	ت أی ی د ک ن ی د ک ه س ی اس ت ه ای ت خ ص ی ص starvation thread از resource ج ل وگ ی ری م ی ک ن ن د، ب ا اط م ی ن ان از دس ت رس ی ع ادلان ه ب ه م ن اب ع، م انن د اس ت ف اده از pools thread و اج ازه دادن ب ه threads ب ا اول وی ت پ ای ی ن ت ر ت ا در ب ازه زم ان ی م ن ط ق ی پ ی ش رف ت ک ن ن د.	3

References

ب رای اط لاع ات ب ی ش ت ر، ه م چ ن ی ن ب ه م ن اب ع زی ر م راج ع ه ک ن ی د:

- Sheet Cheat Prevention Pollution Prototype OWASP
- Sheet Cheat Prevention Assignment Mass OWASP
- Specification Materials of Bill CycloneDX OWASP
- Pollution Parameter HTTP for Testing Guide: Testing Security Web OWASP

Handling Error and Logging Security V16

ه دف

ل اگ ه ای ام ن ی ت ی ب ا ل اگ ه ای خ ط ا ی ا ل اگ ه ای ع م ل ک رد م ت ف اوت ه س ت ن د و ب رای ث ب ت روی داده ای م رت ب ط ب ا ام ن ی ت اس ت ف اده م ی ش ون د؛ م انن د ت ص م ی م ه ای م رب وط ب ه اح راز ه وی ت، ک ن ت رل دس ت رس ی، و ت ل اش ه ا ب رای دور زدن ک ن ت رل ه ای ام ن ی ت ی (م انن د اع ت ب ارس ن ج ی ورودی ی ا اع ت ب ارس ن ج ی م ن ط ق ت ج اری).ه دف

آن‌ها پشتیبانی از تشخیص، پاسخ و بررسی است، از طریق ارائه داده‌های ساختاریافته و با کیفیت بالا برای ابزارهای تحلیلی مانند SIEM.

لاگ‌ها نباید شامل داده‌های شخصی حساس باشند مگر در مواردی که قانون الزام کند. هر داده‌ای که لاگ می‌شود باید به‌عنوان یک دارایی بسیار باارزش محافظت شود. لاگ‌برداری نباید باعث به خطر افتادن حریم خصوصی یا امنیت سیستم شود. همچنین برنامه باید در شرایط خطا به‌صورت ایمن عمل کند و از افشای غیرضروری اطلاعات یا ایجاد اختلال جلوگیری کند.

برای راهنمایی دقیق در مورد پیاده‌سازی، به OWASP Cheat Sheets در بخش منابع مراجعه کنید.

Documentation Logging Security V16.1

این بخش تضمین می‌کند که یک دارایی (Inventory) شفاف و کامل از لاگ‌گیری در سراسر stack برنامه وجود داشته باشد. این کار برای نظارت امنیتی مؤثر، پاسخ به حوادث و انطباق (Compliance) ضروری است.

#	Description	Level
16.1.1	فهرستی باید وجود داشته باشد که در آن ثبت وقایع (Logging) انجام‌شده در هر لایه از stack فناوری برنامه، رویدادهای ثبت‌شده، فرمت‌های لاگ، محل ذخیره‌سازی، نحوه استفاده، نحوه کنترل دسترسی به آن‌ها و مدت زمان نگه‌داری لاگ‌ها مستند شده است.	2

Logging General V16.2

این بخش الزامات لازم را ارائه می‌دهد تا اطمینان حاصل شود که لاگ‌های امنیتی به‌صورت یک‌پارچه ساختاردهی شده‌اند و متادیتا مورد انتظار را درخود دارند. هدف این است که لاگ‌ها قابل‌خواندن توسط ماشین باشند و بتوان آن‌ها را در سیستم‌ها و ابزارهای توزیع‌شده تحلیل کرد.

به‌طور طبیعی، رویدادهای امنیتی اغلب شامل داده‌های حساس هستند. اگر چنین داده‌ای بدون ملاحظه در لاگ‌ها ثبت شود، خود لاگ‌ها به‌عنوان داده‌ای طبقه‌بندی‌شده محسوب می‌شوند و بنابراین مشمول الزامات رمزنگاری، سیاست‌های سخت‌گیرانه‌تر نگه‌داری و همچنین احتمال افشا در طول ممیزی‌ها خواهند بود.

بنابراین، بسیار مهم است که فقط موارد ضروری در لاگ‌ها ثبت شوند و داده‌ای لاگ با همان دقت و مراقبتی که برای سایر دارایی‌های حساس به کار می‌رود، مورد توجه قرار گیرند.

الزامات زیر، نیازمندی‌های پایه‌ای مربوط به متادیتا در لاگ‌ها، مکانیسم‌سازی، فرمت و کنترل را مشخص می‌کنند.

#	Description	Level
16.2.1	هر ورودی لاگ بایـد شامل متادیتای لازم (مانند زمان، مکان، چه کسی و چه چیزی) باشد تا امکان بررسی دقیق خط زمانی هنگام وقوع یک رویداد فراهم شود.	2
16.2.2	منابع زمانی برای تمام مؤلفه‌های لاگ با هم هماهنگ‌سازی شده‌اند و هر زمان (timestamp) در متادیتای رویدادهای امنیتی از UTC استفاده کند یا شامل یک اختلاف‌زمان (time zone offset) صریح باشد. استفاده از UTC توصیه می‌شود تا یک پارچگی در سراسر سیستم‌های توزیع‌شده تضمین شود و از بروز سردرگمی در زمان تغییر ساعت تابستانی جلوگیری گردد.	2
16.2.3	برنامه تنها لاگ‌ها را در فایل‌ها و سرویس‌های ذخیره یا ارسال می‌کند که در فهرست مستند لاگ‌ها ثبت شده‌اند.	2
16.2.4	لاگ‌ها بایـد توسط پردازش گر لاگی که در حال استفاده است خوانده و هم‌بسته شوند، و ترجیحاً با استفاده از یک فرمت لاگ مشترک این کار انجام گیرد.	2
16.2.5	هنگام لاگ گیری از داده‌های حساس، برنامه بایـد لاگ گیری را بر اساس سطح حفاظت داده اعمال کند. برای مثال، ممکن است لاگ کردن برخی داده‌ها مانند اطلاعات ورود یا جزئیات پرداخت مجاز نباشد. داده‌های دیگر، مانند session ،token تنها در صورتی بایـد لاگ شوند که به‌صورت hash یا masked، چه به‌طور کامل یا جزئی، ثبت شوند.	2

Events Security V16.3

این بخش الزامات مربوط به لاگ‌برداری از رویدادهای مرتبط با امنیت در داخل برنامه را تعریف می‌کند. ثبت این رویدادها برای شناسایی رفتارهای مشکوک، پشتیبانی از تحقیقات، و انجام تعهدات مربوط به انطباق است.

این بخش انواع رویدادهایی که بایـد لاگ شوند را مشخص می‌کند، اما سعی ندارد جزئیات کامل و جامعی ارائه دهد. هر برنامه دارای عوامل ریسک و زمینه عملیاتی منحصربه‌فرد خود است.

توجه داشته باشید ASVS در حالی شامل لاگ گیری رویدادهای امنیتی در محدوده خود می‌شود که Alerting و Correlation (مثلاً قوانین SIEM یا زیرساخت‌های مانیتورینگ) خارج از محدوده در نظر گرفته شده و توسط سیستم‌های عملیاتی و نظارتی مدیریت می‌شوند.

#	Description	Level
16.3.1	تمام عملیات احراز هویت بایـد لاگ گیری شوند، از جمله تلاش‌های موفق و ناموفق. همچنین بایـد متادیتای اضافی، مانند نوع احراز هویت یا عوامل استفاده‌شده، جمع‌آوری شود.	2

#	Description	Level
16.3.2	تلاش‌های ناموفق برای مجوزدهی (authorization) باید لاگ‌گیری شوند. برای برنامه‌های L3، این باید شامل لاگ‌گیری تمام تصمیمات مجوزدهی باشد، از جمله ثبت زمانی که داده‌های حساس دسترسی پیدا می‌کنند، بدون آنکه خود داده‌های حساس ثبت شوند.	2
16.3.3	برنامه باید رویدادهای امنیتی تعریف‌شده در مستندات (ابتدای بخش) را لاگ نماید و همچنین تلاش‌ها برای دور زدن کنترل‌های امنیتی، مانند اعتبارسنجی ورودی، منطق کسب‌وکار و ضدخودکارسازی، را نیز ثبت کند.	2
16.3.4	برنامه باید خطاهای غیرمنتظره و شکست‌های کنترل‌های امنیتی، مانند شکست‌های TLS در بک اند را لاگ کند.	2

Protection Log V16.4

لاگ‌ها به عنوان آثار ارزشمند forensic محسوب می‌شوند و باید محافظت شوند. اگرلاگ‌ها به‌سادگی قابل تغییر یا حذف باشند، یکپارچگی خود را از دست می‌دهند و برای تحقیقات حادثه یا پرونده‌های حقوقی غیرقابل اعتماد می‌شوند. همچنین، لاگ‌ها ممکن است رفتار داخلی برنامه یا متادیتای حساس را فاش کنند و این موضوع آن‌ها را به هدف جذابی برای مهاجمان تبدیل می‌کند.

این بخش الزامات را برای اطمینان از حفاظت لاگ‌ها در برابر دسترسی غیرمجاز، دستکاری و افشا تعریف می‌کند و همچنین تضمین می‌کند که لاگ‌ها به‌صورت ایمن مدیریت و در سیستم‌های امن و ایزوله ذخیره شوند.

#	Description	Level
16.4.1	تمام مؤلفه‌های لاگ‌گیری باید داده‌ها را به‌طور مناسب رمزگذاری کنند تا از حملات injection log جلوگیری شود.	2
16.4.2	لاگ‌ها باید در برابر دسترسی غیرمجاز محافظت شده و امکان تغییر آن‌ها وجود نداشته باشد.	2
16.4.3	لاگ‌ها به‌صورت امن باید به یک سیستم مدیریت جداگانه برای تحلیل، تشخیص، هشدار و ارجاع مدیریت شوند. هدف این است که در صورت نفوذ به برنامه، لاگ‌ها به خطر نیفتند.	2

Handling Error V16.5

این بخش الزامات لازم را برای اطمینان از این که برنامه‌ها به‌صورت امن و بدون افشای جزئیات حساس داخلی دچار خطا می‌شوند، تعریف می‌کند.

#	Description	Level
16.5.1	هنگام بروز خطاهای غیرمنتظره یا حساس به امنیت، پیامی عمومی به کاربر بایـد بازگردانده شود، به گونه‌ای که هیچ گونه اطلاعات حساس داخلی سیستم مانند stack ،trace کوئری‌ها، کلی‌دها و توکن‌های محرمانه افشا نشود.	2
16.5.2	برنامه بایـد هنگام بروز خطا در دسترسی به منابع خارجی همچنان به‌صورت امن عمل نمایـد، برای مثال با استفاده از الگوهایی مانند breaker circuit یا کاهش تدریجی عملکرد (graceful degradation).	2
16.5.3	برنامه بایـد به‌صورت امن و کنترل‌شده دچار خطا شود، حتی هنگام وقوع استثنا، و از شرایط fail-open جلوگیری نمایـد؛ برای مثال، از پردازش تراکنش در صورت بروز خطا در منطق اعتبارسنجی جلوگیری شود.	2
16.5.4	یک « last resort» بایـد تعریف شده باشد که تمامی exception unhandled را مدیریت کند. این کار هم برای جلوگیری از از دست رفتن جزئیات خطا که بایـد در فایل‌های لاگ ثبت شوند و هم برای اطمینان از این است که خطا باعث از کار افتادن کل فرآیند برنامه و در نتیجه از دست رفتن دسترسی نشود، ضروری است.	3

توجه: برخی زبان‌ها (از جمله Swift و Go و همچنین بسیاری از زبان‌های تابعی بر اساس رویه‌های متداول طراحی) از exceptions یا resort last پشتیبانی نمی‌کنند. در این موارد، معماران و توسعه‌دهندگان بایـد از یک الگو، زبان، یا روش سازگار با چارچوب کاری استفاده کنند تا اطمینان حاصل شود که برنامه‌ها می‌توانند روی‌داده‌ای استثنائی، غیرمنتظره یا مرتبط با امنیت را به‌صورت امن مدیریت کنند.

References

برای اطلاعات بیشتر، همچنین به منابع زیر مراجعه کنید:

- Handling Error for Testing Guide: Testing Security Web OWASP
- messages error about section Sheet Cheat Authentication OWASP
- Sheet Cheat Logging OWASP
- Sheet Cheat Vocabulary Logging Application OWASP

WebRTC V17

هدف

Web Real-Time Communication (WebRTC) امکان تبادل صوت، تصویر و داده به‌صورت لحظه‌ای در برنامه‌های مدرن را فراهم می‌کند. با افزایش پذیرش این فناوری، تأمین امنیت زیرساخت WebRTC

اه‌ی‌ت ح‌ی‌ا‌ت‌ی پ‌ی‌دا م‌ی ک‌ن‌د. ای‌ن ب‌خ‌ش ال‌زام‌ات ام‌ن‌ی‌ت‌ی را ب‌را‌ی ذی‌ن‌ف‌ع‌ان‌ی ارا‌ئ‌ه م‌ی‌ده‌د ک‌ه س‌ی‌س‌ت‌م-ه‌ا‌ی WebRTC را ت‌وس‌ع‌ه، م‌ی‌زب‌ان‌ی ی‌ا ی ک‌پ‌ارچ‌ه م‌ی ک‌ن‌ن‌د

ص‌ن‌ع‌ت WebRTC را م‌ی‌ت‌وان ب‌ه‌ط‌ور ک‌ل‌ی ب‌ه س‌ه ب‌خ‌ش ت‌ق‌س‌ی‌م ک‌رد:

1. ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان م‌ح‌ص‌ول: ف‌روش‌ن‌د‌گ‌ان اخ‌ت‌ص‌اص‌ی و م‌ت‌ن‌ب‌از ک‌ه م‌ح‌ص‌ول‌ات و راه‌ح‌ل‌ه‌ا‌ی WebRTC را ای‌ج‌اد و ع‌رض‌ه م‌ی ک‌ن‌ن‌د. ت‌م‌رک‌ز آن‌ه‌ا ب‌ر ت‌وس‌ع‌ه ف‌ن‌اوری‌ه‌ا‌ی ق‌وی و ام‌ن WebRTC اس‌ت ک‌ه ت‌وس‌ط دی‌گ‌ران ق‌اب‌ل اس‌ت‌ف‌اده ب‌اش‌ن‌د.
2. ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان خ‌دم‌ات: س‌ازم‌ان‌ه‌ا‌ی‌ی ک‌ه از م‌ح‌ص‌ول‌ات ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان ی‌ا ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان CPaaS اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د ی‌ا راه‌ک‌اره‌ا‌ی WebRTC خ‌ود را ت‌وس‌ع‌ه م‌ی‌ده‌ن‌د. آن‌ه‌ا ب‌رن‌ام‌ه‌ه‌ا‌ی‌ی را ب‌را‌ی ک‌ن‌ف‌ران‌س آن‌ل‌ا‌ی‌ن، س‌ل‌ام‌ت، آم‌وزش ال‌ک‌ت‌رون‌ی‌ک‌ی و س‌ای‌ر ح‌وزه‌ه‌ا‌ی‌ی ک‌ه در آن‌ه‌ا ارت‌ب‌اط ب‌ل‌ادرن‌گ ح‌ی‌ا‌ت‌ی اس‌ت، ای‌ج‌اد و پ‌ی‌اده‌س‌ازی م‌ی ک‌ن‌ن‌د.
3. ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان خ‌دم‌ات: س‌ازم‌ان‌ه‌ا‌ی‌ی ک‌ه از م‌ح‌ص‌ول‌ات ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان ی‌ا ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان CPaaS اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د ی‌ا خ‌ود راه‌ک‌اره‌ا‌ی WebRTC خ‌ود را ت‌وس‌ع‌ه م‌ی‌ده‌ن‌د. آن‌ه‌ا ب‌رن‌ام‌ه‌ه‌ا‌ی‌ی ب‌را‌ی ک‌ن‌ف‌ران‌س‌ه‌ا‌ی آن‌ل‌ا‌ی‌ن، ح‌وزه س‌ل‌ام‌ت، آم‌وزش ال‌ک‌ت‌رون‌ی‌ک‌ی و س‌ای‌ر زم‌ی‌ن‌ه‌ه‌ا‌ی‌ی ک‌ه ارت‌ب‌اط ب‌ل‌ادرن‌گ ح‌ی‌ا‌ت‌ی اس‌ت، ای‌ج‌اد و پ‌ی‌اده‌س‌ازی م‌ی ک‌ن‌ن‌د.

ن‌ی‌ازم‌ن‌دی‌ه‌ا‌ی ام‌ن‌ی‌ت‌ی م‌ط‌رح ش‌ده در ای‌ن‌ج‌ا ع‌م‌دت‌اً ب‌ر ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان م‌ح‌ص‌ول، ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان CPaaS و ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان خ‌دم‌ات م‌ت‌م‌رک‌ز اس‌ت ک‌ه:

- از راه‌ح‌ل‌ه‌ا‌ی م‌ت‌ن‌ب‌از ب‌را‌ی س‌اخ‌ت ب‌رن‌ام‌ه‌ه‌ا‌ی WebRTC خ‌ود اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د.
- از م‌ح‌ص‌ول‌ات ت‌ج‌ا‌ری WebRTC ب‌ه‌ع‌ن‌وان ب‌خ‌ش‌ی از ز‌ی‌رس‌اخ‌ت خ‌ود اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د.
- از راه‌ح‌ل‌ه‌ا‌ی WebRTC ک‌ه ب‌ه‌ص‌ورت داخ‌ل‌ی ت‌وس‌ع‌ه داده‌ان‌د اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د ی‌ا اج‌زا‌ی م‌خ‌ت‌ل‌ف را در ی ک س‌روی‌س ی ک‌پ‌ارچ‌ه ت‌رک‌ی‌ب م‌ی ک‌ن‌ن‌د.

ق‌اب‌ل ت‌وج‌ه اس‌ت ک‌ه ای‌ن ال‌زام‌ات ام‌ن‌ی‌ت‌ی ش‌ام‌ل ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان‌ی ن‌م‌ی‌ش‌ود ک‌ه ص‌رف‌اً از ه‌ا‌یSDK و ه‌ا‌یAPI ارا‌ئ‌ه‌ش‌ده ت‌وس‌ط ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان CPaaS اس‌ت‌ف‌اده م‌ی ک‌ن‌ن‌د. ب‌را‌ی چ‌ن‌ی‌ن ت‌وس‌ع‌ه‌ده‌ن‌د‌گ‌ان‌ی، م‌س‌ئ‌ول‌ی‌ت ب‌ی‌ش‌ت‌ر م‌س‌ائ‌ل ام‌ن‌ی‌ت‌ی ز‌ی‌رس‌اخ‌ت‌ی م‌ع‌م‌ولاً ب‌ر ع‌ه‌ده ارا‌ئ‌ه‌ده‌ن‌د‌گ‌ان CPaaS اس‌ت و اس‌ت‌ان‌دارد ام‌ن‌ی‌ت‌ی ع‌م‌وم‌ی م‌ان‌ن‌د ASVS م‌م‌ک‌ن اس‌ت ب‌ه‌ط‌ور ک‌ام‌ل ن‌ی‌ازه‌ا‌ی آن‌ه‌ا را پ‌وش‌ش ن‌ده‌د.

Server TURN V17.1

ای‌ن ب‌خ‌ش ال‌زام‌ات ام‌ن‌ی‌ت‌ی را ب‌را‌ی س‌ی‌س‌ت‌م‌ه‌ا‌ی‌ی ک‌ه س‌رور‌ه‌ا‌ی around Relays Using (Traversal TURN (NAT خ‌ود را راه‌ان‌دازی م‌ی ک‌ن‌ن‌د، ت‌ع‌ری‌ف م‌ی ک‌ن‌د. س‌رور‌ه‌ا‌ی TURN در ه‌دا‌ی‌ت Media در م‌ح‌ی‌ط‌ه‌ا‌ی ش‌ب‌ک‌ه-ا‌ی م‌ح‌دود ک‌م‌ک م‌ی ک‌ن‌ن‌د، ام‌ا در ص‌ورت پ‌ی ک‌ر‌ب‌ن‌دی ن‌ادرس‌ت م‌ی‌ت‌وان‌ن‌د خ‌ط‌رات‌ی ای‌ج‌اد ک‌ن‌ن‌د. ای‌ن ک‌ن‌ت‌رل‌ه‌ا ب‌ر ف‌ی‌ل‌ت‌ر ک‌ردن ام‌ن آدرس‌ه‌ا و ج‌ل‌وگ‌ی‌ری از ت‌م‌ام ش‌دن م‌ن‌اب‌ع س‌ی‌س‌ت‌م (resource exhaustion) ت‌م‌رک‌ز دارن‌د.

#	Description	Level
17.1.1	سرویس NAT around Relays Using Traversal (TURN) برای دتنها به آدرس‌های IP دست‌رسی ده‌دک‌ه برای اه‌داف ویژه رزرو نش‌ده‌اند (م‌ثلاً ش‌بک‌ه‌های داخ‌لی، broadcast، loopback). توجه داشته باش‌یدک‌ه این مورد هم برای آدرس‌های IPv4 و هم برای IPv6 صدق می‌ک‌ند.	2
17.1.2	سرویس NAT around Relays Using Traversal (TURN)، نبرای د به resource exhaustion آس‌یب‌پذیر باش‌د، حتی زمانی‌ک‌ه ک‌اربران قانونی تلاش ک‌ننند تع‌داد زیادی پورت روی سرور TURN باز ک‌ننند.	3

Media V17.2

این الزامات فقط به سی‌ستم‌های اعمال می‌شود ک‌ه سرورهای رسانه‌ای WebRTC خود را می‌زبانی می‌ک‌ننند، مانند Units Forwarding Selective (SFU)، Units Control Multipoint (MCU)، سرورهای Recording یا سرورهای Gateway. سرورهای رسانه(Media) وظیفه پردازش و توزیع جریان‌های رسانه‌ای را برعهده دارند و امنیت آن‌ها برای محافظت از ارتباطات بین همتاها حیاتی است. حفاظت از جریان‌های رسانه‌ای در برنامه‌های WebRTC از اهمیت بالایی برخوردار است تا از شنود، دست‌کاری و حملات محروم‌سازی از سرویس(denial-of-service) جلوگیری شود ک‌ه می‌توانند حریم خصوصی ک‌اربران و ک‌یفیت ارتباط را به خطر بیندازد.

به‌ویژه، لازم است تدابیری برای محافظت در برابر حملات flood مانند rate limiting، اعتبارسنجی timestamps، استفاده از ساعت‌های همگام برای تطبیق بازه‌های زمانی واقعی و مدیریت بافرها به‌منظور جلوگیری از overflow و حفظ زمان‌بندی مناسب، اعمال شود. اگر بسته‌های مربوط به یک جلسه رسانه‌ای خاص خیلی سریع برسند، بسته‌های اضافی باید حذف شوند. همچنین محافظت از سیستم در برابر بسته‌های خراب یا مخرب اهمیت دارد ک‌ه با اعمال اعتبارسنجی ورودی، مدیریت ایمن سرریز عدد صحیح، جلوگیری از overflows buffer و استفاده از سایر تک‌نیک‌های مقاوم در برابر خطا، حاصل می‌شود.

سی‌ستم‌های ک‌ه صرفاً بر ارتباط رسانه‌ای همتابه‌همتا بین مرورگرهای وب متک‌ی هستند و سرورهای میانی رسانه‌ای در آن‌ها دخالتی ندارند، از این الزامات امنیتی خاص مرتبط با رسانه مستثنی هستند.

این بخش به استفاده از Datagram Security Layer Transport (DTLS) در زمینه WebRTC اشاره دارد. الزامی مربوط به داشتن سیاست مستند برای مدیریت کلیدهای رمزنگاری در فصل «Cryptography» قابل یافت است. اطلاعات مربوط به روش‌های رمزنگاری تأییدشده را می‌توان یا در پیوست Cryptography استاندارد ASVS یا در استنادی مانند NIST SP 800-52 Rev. 2 و BSI TR-02102-2 (نسخه 2025-01) پیدا کرد.

#	Description	Level
17.2.1	کل‌ی‌د م‌رب‌وط ب‌ه گ‌واه‌ی Security Layer Transport Datagram (DTLS) ب‌ر اس‌اس س‌ی‌اس‌ت م‌س‌ت‌ن‌د م‌دی‌ری‌ت کل‌ی‌ده‌ای رم‌زن‌گ‌اری م‌دی‌ری‌ت و م‌ح‌اف‌ظ‌ت م‌ی‌ش‌ود.	2
17.2.2	س‌رور Media ط‌وری پ‌ی‌ک‌ربن‌دی ش‌ده ب‌اش‌د ک‌ه از م‌ج‌م‌وع‌ه‌ه‌ای رم‌زن‌گ‌اری ت‌ای‌ی‌دش‌ده Security Layer Transport Datagram (DTLS) اس‌ت‌ف‌اده ک‌ن‌د و از ی‌ک پ‌روف‌ای‌ل م‌ح‌اف‌ظ‌ت‌ی ام‌ن ب‌رای گ‌س‌ت‌رش DTLS ب‌ه م‌ن‌ظ‌ور ای‌ج‌اد کل‌ی‌ده‌ا ب‌رای پ‌روت‌ک‌ل Protocol Transport Real-time Secure (DTLS-SRTP) پ‌ش‌ت‌ی‌ب‌ان‌ی ن‌م‌ای‌د.	2
17.2.3	اح‌راز ه‌وی‌ت Protocol Transport Real-time Secure (SRTP) در س‌رور Media ب‌ررس‌ی ش‌ود ت‌ا از ح‌م‌لات ت‌زری‌ق Protocol Transport Real-time (RTP) ج‌لوگ‌ی‌ری ش‌ده و ای‌ن ح‌م‌لات ب‌اع‌ث ب‌روز ش‌رای‌ط Service of Denial ی‌ا وارد ش‌دن م‌ح‌ت‌وای ص‌وت‌ی ی‌ا ت‌ص‌وی‌ری ن‌اخ‌واس‌ت‌ه ب‌ه ج‌ری‌ان‌ه‌ای رس‌ان‌ه‌ای ن‌ش‌ون‌د.	2
17.2.4	س‌رور Media ب‌ای‌د ق‌ادر ب‌اش‌د پ‌ردازش ت‌راف‌ی‌ک رس‌ان‌ه‌ای ورودی را ح‌ت‌ی ه‌ن‌گ‌ام م‌واج‌ه‌ه ب‌ا ب‌س‌ت‌ه‌ه‌ای Protocol Transport Real-time Secure (SRTP) ن‌اق‌ص ی‌ا خ‌راب ادام‌ه ده‌د.	2
17.2.5	س‌رور Media ب‌ای‌د ق‌ادر ب‌اش‌د پ‌ردازش ت‌راف‌ی‌ک رس‌ان‌ه‌ای ورودی را ح‌ت‌ی در ه‌ن‌گ‌ام دری‌اف‌ت س‌ی‌ل‌ی(flood) از ب‌س‌ت‌ه‌ه‌ای Protocol Transport Real-time Secure (SRTP) از ک‌ارب‌ران ق‌ان‌ون‌ی ادام‌ه ده‌د.	3
17.2.6	س‌رور Media ن‌س‌ب‌ت ب‌ه آس‌ی‌ب‌پ‌ذی‌ری Race “ClientHello Condition” در Datagram Security Layer Transport (DTLS) ن‌ب‌ای‌د آس‌ی‌ب‌پ‌ذی‌ر ن‌ب‌اش‌د، ای‌ن ک‌ار م‌ی‌ت‌وان‌د ب‌ا ب‌ررس‌ی ای‌ن‌ک‌ه آی‌ا س‌رور رس‌ان‌ه ب‌ه‌ص‌ورت ع‌م‌وم‌ی ب‌ه ع‌ن‌وان آس‌ی‌ب‌پ‌ذی‌ر ش‌ن‌اخ‌ت‌ه ش‌ده اس‌ت ی‌ا ب‌ا ان‌ج‌ام آزم‌ون Condition Race ان‌ج‌ام ش‌ود.	3
17.2.7	م‌ک‌ان‌ی‌زم‌ه‌ای ض‌ب‌ط ص‌دا ی‌ا ت‌ص‌وی‌ر م‌رت‌ب‌ط ب‌ا س‌رور رس‌ان‌ه در ه‌ن‌گ‌ام ط‌وف‌ان ب‌س‌ت‌ه‌ای (Flood) از پ‌روت‌ک‌ل ان‌ت‌ق‌ال ب‌لادرن‌گ ام‌ن (SRTP) ت‌وس‌ط ک‌ارب‌ران م‌ج‌از، ب‌ای‌د ق‌ادر ب‌ه ادام‌ه پ‌ردازش ت‌راف‌ی‌ک رس‌ان‌ه ورودی اس‌ت.	3
17.2.8	گ‌واه‌ی‌ن‌ام‌ه ام‌ن‌ی‌ت ل‌ای‌ه ان‌ت‌ق‌ال دی‌ت‌اگ‌رام (DTLS) ب‌ای‌د ب‌ا وی‌ژگ‌ی اث‌ر ان‌گ‌ش‌ت (Fingerprint) پ‌روت‌ک‌ل ت‌وص‌ی‌ف ن‌ش‌س‌ت (SDP) ب‌ررس‌ی م‌ی‌ش‌ود و در ص‌ورت ش‌ک‌س‌ت در ب‌ررس‌ی، ج‌ری‌ان رس‌ان‌ه ق‌ط‌ع م‌ی‌ش‌ود ت‌ا اص‌الت ج‌ری‌ان رس‌ان‌ه ت‌ض‌م‌ی‌ن گ‌ردد.	3

Signaling V17.3

ای‌ن ب‌خ‌ش ال‌زام‌ات س‌ی‌س‌ت‌م‌ه‌ای‌ی را ت‌ع‌ری‌ف م‌ی‌ک‌ن‌د ک‌ه س‌رور‌ه‌ای س‌ی‌گ‌ن‌ال‌ی‌ن‌گ WebRTC خ‌ود را اداره م‌ی‌ک‌ن‌ن‌د. س‌ی‌گ‌ن‌ال‌ی‌ن‌گ وظ‌ی‌ف‌ه م‌ه‌ان‌گ‌ی ارت‌ب‌اط peer-to-peer را دارد و ب‌ای‌د در ب‌راب‌ر ح‌م‌لات‌ی ک‌ه م‌ی‌ت‌وان‌ن‌د ب‌ر ای‌ج‌اد ی‌ا ک‌ن‌ت‌رل ج‌ل‌س‌ات ت‌أث‌ی‌ر ب‌گ‌ذارن‌د م‌ق‌اوم ب‌اش‌د.

ب‌رای اط‌م‌ی‌ن‌ان از س‌ی‌گ‌ن‌ال‌ی‌ن‌گ ای‌م‌ن، س‌ی‌س‌ت‌م‌ه‌ا ب‌ای‌د ورودی‌ه‌ای ن‌اق‌ص ی‌ا م‌خ‌دوش را ب‌ه‌ص‌ورت ام‌ن م‌دی‌ری‌ت ک‌ن‌ن‌د و ح‌ت‌ی ت‌ح‌ت ب‌ار زی‌اد ن‌ی‌ز در دس‌ت‌رس ب‌اق‌ی ب‌م‌ان‌ن‌د.

#	Description	Level
17.3.1	س‌رور س‌ی‌گ‌نال‌ی‌ن‌گ ب‌ای‌د ق‌ادر ب‌اش‌د ح‌ت‌ی در ج‌ری‌ان flood، attack پ‌ی‌ام‌ه‌ای س‌ی‌گ‌نال‌ی‌ن‌گ ورودی م‌ش‌روع را پ‌ردازش ک‌ن‌د. ای‌ن ب‌ای‌د ب‌ا اع‌م‌ال م‌ح‌دودی‌ت ن‌رخ (rate limiting) در س‌طح س‌ی‌گ‌نال‌ی‌ن‌گ م‌ح‌ق‌ق ش‌ود.	2
17.3.2	س‌رور س‌ی‌گ‌نال‌ی‌ن‌گ ب‌ای‌د ق‌ادر ب‌اش‌د پ‌ی‌ام‌ه‌ای س‌ی‌گ‌نال‌ی‌ن‌گ م‌ش‌روع را ح‌ت‌ی در م‌واج‌ه‌ه ب‌ا پ‌ی‌ام‌ه‌ای س‌ی‌گ‌نال‌ی‌ن‌گ ن‌اق‌ص ی‌ا م‌خ‌رب ک‌ه م‌ی‌ت‌وان‌ن‌د ب‌اع‌ث ای‌ج‌اد ش‌رای‌ط ع‌دم دس‌ت‌رس‌ی (Denial of Service) ش‌ون‌د، پ‌ردازش ک‌ن‌د. ای‌ن م‌ی‌ت‌وان‌د ش‌ام‌ل اع‌م‌ال اع‌ت‌ب‌ارس‌نج‌ی ورودی، م‌دی‌ری‌ت ای‌من س‌رری‌ز ع‌دد ص‌ح‌ی‌ح (integer overflow)، ج‌ل‌وگ‌ی‌ری از س‌رری‌ز ب‌اف‌ر (buffer overflow) و اس‌ت‌ف‌اده از دی‌گ‌ر ت‌ک‌ن‌ی‌ک‌ه‌ای م‌ق‌اوم م‌دی‌ری‌ت خ‌ط‌ا ب‌اش‌د.	2

References

ب‌رای اط‌لاع‌ات ب‌ی‌ش‌تر، ه‌م‌چ‌ن‌ی‌ن ب‌ه م‌ن‌اب‌ع زی‌ر م‌راج‌ع‌ه ک‌ن‌ی‌د:

- security at aimed post blog Security's Enable at documented best is DoS ClientHello DTLS WebRTC The developers WebRTC at aimed paper white associated the and professionals
- Applications Real-Time for Protocol Transport A RTP: - 3550 RFC
- (SRTP) Protocol Transport Real-time Secure The - 3711 RFC
- Real- Secure the for Keys Establish to Extension (DTLS) Security Layer Transport Datagram - 5764 RFC (SRTP)) Protocol Transport time
- Applications Browser-Based for Protocols Real-Time Overview: - 8825 RFC
- WebRTC for Considerations Security - 8826 RFC
- Architecture Security WebRTC - 8827 RFC
- Profiles Protection DTLS-SRTP

Glossary A: Appendix

- **Lifetime Session Maximum Absolute** – ک‌ه ت‌وس‌ط NIST ب‌ا ع‌ن‌وان «م‌ه‌ل‌ت زم‌ان‌ی ک‌ل‌ی (Overall Timeout)» ن‌ی‌ز ش‌ن‌اخ‌ت‌ه م‌ی‌ش‌ود، ح‌داک‌ث‌ر م‌دت زم‌ان‌ی اس‌ت ک‌ه ی‌ک ن‌ش‌س‌ت پ‌س از اح‌راز ه‌وی‌ت م‌ی‌ت‌وان‌د ف‌ع‌ال ب‌اق‌ی ب‌م‌ان‌د، ص‌رف‌ن‌ظر از ه‌ر گ‌ون‌ه ت‌ع‌ام‌ل ک‌ارب‌ر. ای‌ن م‌ف‌ه‌وم ی‌ک‌ی از م‌ؤل‌ف‌ه‌ه‌ای ان‌ق‌ض‌ای ن‌ش‌س‌ت (Session Expiration) م‌ح‌س‌وب م‌ی‌ش‌ود.
- **Allowlist** – ف‌ه‌رس‌ت‌ی از داده‌ه‌ا ی‌ا ع‌م‌ل‌ی‌ات م‌ج‌از؛ ب‌رای م‌ث‌ال، ف‌ه‌رس‌ت‌ی از ک‌ارا ک‌ت‌ره‌ای‌ی ک‌ه ان‌ج‌ام اع‌ت‌ب‌ارس‌نج‌ی ورودی (Input Validation) ب‌ر اس‌اس آن‌ه‌ا م‌ج‌از اس‌ت.
- **token Anti-forgery** – م‌ک‌ان‌ی‌زم‌ی ک‌ه در آن ی‌ک ی‌ا چ‌ن‌د ت‌وک‌ن ه‌م‌راه ب‌ا درخ‌واس‌ت ارس‌ال ش‌ده و ت‌وس‌ط س‌رور ب‌رن‌ام‌ه اع‌ت‌ب‌ارس‌نج‌ی م‌ی‌ش‌ون‌د ت‌ا اط‌م‌ی‌ن‌ان ح‌اص‌ل ش‌ود درخ‌واس‌ت از ی‌ک ن‌ق‌ط‌ه ان‌ت‌ه‌ای‌ی (Endpoint) م‌ورد ان‌ت‌ظ‌ار ارس‌ال ش‌ده اس‌ت.
- **Security Application** – ام‌ن‌ی‌ت در س‌طح ب‌رن‌ام‌ه ب‌ر ت‌ح‌ل‌ی‌ل م‌ؤل‌ف‌ه‌ه‌ای‌ی ت‌م‌رک‌ز دارد ک‌ه ل‌ای‌ه ک‌ارب‌ردی در م‌دل م‌رج‌ع ات‌ص‌ال س‌ی‌س‌ت‌م‌ه‌ای ب‌از (OSI) را ت‌ش‌ک‌ی‌ل م‌ی‌ده‌ن‌د، ن‌ه ب‌ر اج‌زای زی‌رب‌ن‌ای‌ی

مانند سیستم عامل یا شبکه‌ای متصل.

- **Verification Security Application** – ارزیابی فنی یک برنامه کاربردی بر اساس استاندارد OWASP ASVS.
- **Report Verification Security Application** – گزارشی که نتایج کلی و تحلیل‌های پشتیبان تهیه‌شده توسط ارزیاب (Verifier) را برای یک برنامه کاربردی مشخص مستند می‌کند.
- **Authentication** – فرایند تأیید هویت ادعاشده کاربر یک برنامه کاربردی.
- **Verification Automated** – استفاده از ابزاره‌ای خودکار (شامل ابزاره‌ای تحلیل پویا، ابزاره‌ای تحلیل ایستا، یا هر دو) که با تکیه بر امضاهای آسیب‌پذیری برای شناسایی مشکلات به کار می‌روند.
- **testing box Black** – روشی از آزمون نرم‌افزار که عملکرد یک برنامه را بررسی می‌کند بدون آنکه به ساختارها یا عملکرد داخلی آن نگاه کند.
- **Enumeration Weakness Common** (CWE) – فهرستی که توسط جامعه توسعه‌دهندگان ایجاد شده و شامل نقاط ضعف رایج امنیت نرم‌افزار است. این فهرست به‌عنوان زبان مشترک، معیاری برای ابزاره‌ای امنیت نرم‌افزار، و پایه‌ای برای شناسایی، کاهش و پیشگیری از نقاط ضعف عمل می‌کند.
- **Component** – یک واحد مستقل از کد است که دارای رابطه‌ای مرتبط با دیسک و شبکه می‌باشد و با سایر مولفه‌ها ارتباط برقرار می‌کند.
- **Provider Service Credential** (CSP) – که به آن ارائه‌دهنده هویت (Identity Provider - IdP) نیز گفته می‌شود، منبعی از داده‌های کاربری است که می‌تواند به‌عنوان منبع احراز هویت توسط سایر برنامه‌ها استفاده شود.
- **Inclusion Script Cross-Site** (XSSI) - گونه‌ای از حمله اسکریپت‌نویسی بین‌سایتی (XSS) که در آن یک برنامه وب کدمخرب را از یک منبع خارجی دریافت کرده و آن کدرا به‌عنوان بخشی از محتوای خود وارد می‌کند.
- **Scripting Cross-Site** (XSS) – یک آسیب‌پذیری امنیتی معمول در برنامه‌های وب که امکان تزریق اسکریپت‌های سمت کاربر (Client-Side Scripts) به محتوا را فراهم می‌کند.
- **module Cryptographic** – سخت‌افزار، نرم‌افزار و/یا فریم‌ورکی که الگوریتم‌های رمزنگاری را اجرا کرده و/یا کلیدهای رمزنگاری تولید می‌کند.
- **generator number pseudo-random secure Cryptographically** (CSPRNG) - یک تولیدکننده اعداد شبه‌تصادفی با ویژگی‌هایی که آن را مناسب برای استفاده در رمزنگاری می‌کند؛ که گاهی به آن تولیدکننده اعداد تصادفی رمزنگاری (Cryptographic Random Number Generator - CRNG) نیز گفته می‌شود.
- **Security Layer Transport Datagram** (DTLS) – یک پروتکل رمزنگاری که امنیت ارتباطی را بر روی اتصال شبکه فراهم می‌کند. این پروتکل بر اساس TLS ساخته شده اما برای محافظت از پروتکل‌های مبتنی بر دیتاگرام (معمولاً روی UDP تطبیق داده شده است. نسخه DTLS 1.3 در RFC 9147 تعریف شده است.
- **Transport Real-time Secure the for Keys Establish to Extension Security Layer Transport Datagram Protocol** (DTLS-SRTP) –مکانیزمی که از Handshake DTLS برای ایجاد مواد کلیدی (Key Material) جهت یک جلسه SRTP استفاده می‌کند. این افزونه در RFC 5764 تعریف شده است.
- **Verification Design** – ارزیابی فنی معماری امنیتی یک برنامه کاربردی.
- **Testing Security Application Dynamic** (DAST) – فناوری‌ای که برای شناسایی شرایطی که نشان‌دهنده آسیب‌پذیری امنیتی در یک برنامه در حال اجرا هستند طراحی شده‌اند.

- **Verification Dynamic** – استفاده از ابزارهای خودکار که با تکیه بر امضاهای آسیب‌پذیری به شناسایی مشکلات در حین اجرای برنامه می‌پردازند.
- **Online IDentity Fast** (FIDO) – مجموعه‌ای از استانداردهای احراز هویت که امکان استفاده از روش‌های مختلف احراز هویت از جمله بیومتریک، ماژول‌های پلتفرم مورد اعتماد (TPM)، توکن‌های امنیتی USB و غیره را فراهم می‌کند.
- **Module Security Hardware** (HSM) – یک جزء سخت‌افزاری که کلیدهای رمزنگاری و سایر اسرار را به‌صورت محافظت‌شده ذخیره می‌کند.
- **Language Query Hibernate** (HQL) – یک زبان پرس‌وجو که از نظر ظاهری شبیه SQL است و توسط کتابخانه ORM Hibernate استفاده می‌شود.
- **Security Transport Strict HTTP** (HSTS) – سیاستی که مرورگر را مجبور می‌کند فقط از طریق TLS به دامنه‌ای که هدر HSTS را ارسال می‌کند متصل شود و تنها زمانی که گواهی‌نامه معتبر ارائه شده باشد. این سیاست با فیلد هدر پاسخ Strict-Transport-Security فعال می‌شود.
- **Protocol Transfer HyperText** (HTTP) – یک پروتکل برنامه‌ای برای سیستم‌های اطلاعاتی توزیع‌شده، مشارکتی و ابررسانه‌ای است. HTTP پایه و اساس ارتباط داده‌ها در شبکه جهانی وب محسوب می‌شود.
- **SSL/TLS over Protocol Transfer HyperText** (HTTPS) – روشی برای امن‌سازی ارتباط HTTP از طریق رمزنگاری آن با استفاده از TLS (Transport Layer Security).
- **Provider Identity** (IdP) – که در منابع NIST گاهی به آن ارائه‌دهنده خدمات اعتبارنامه (Credential Service Provider - CSP) نیز گفته می‌شود، موجودیتی است که منبع احراز هویت را برای سایر برنامه‌ها فراهم می‌کند.
- **Timeout Inactivity** – مدتی است که یک نشست می‌تواند در صورت عدم تعامل کاربر با برنامه فعال باقی بماند. این معیار یکی از مؤلفه‌های انقضای نشست (Session Expiration) است.
- **Validation Input** – استانداردسازی (Canonicalization) و اعتبارسنجی ورودی‌های کاربر غیرقابل اعتماد.
- **Token Web JSON** (JWT) – RFC 7519 یک استاندارد برای یک شیء داده JSON تعریف می‌کند که از یک بخش هدر تشکیل شده که نحوه اعتبارسنجی شیء را توضیح می‌دهد، یک بخش بدنه که شامل مجموعه‌ای از ادعاها است، و یک بخش امضا که شامل امضای دیجیتال است و می‌توان از آن برای اعتبارسنجی محتوای بخش بدنه استفاده کرد. این نوعی توکن خودکفا (self-contained token) است.
- **Inclusion File Local** (LFI) - حمله‌ای که از رویه‌های آسیب‌پذیر درج فایل در یک برنامه سوءاستفاده می‌کند و منجر به درج فایل‌های محلیِ موجود روی سرور می‌شود.
- **Code Malicious** – کدی که در طول توسعه یک برنامه بدون اطلاع مالک برنامه وارد شده و سیاست امنیتی مورد نظر برنامه را دور می‌زند. این با بدافزارهای مانند ویروس یا کرم یکسان نیست!
- **Malware** – کدهای که در حین اجرای برنامه و بدون اطلاع کاربر یا مدیر برنامه وارد می‌شود.
- **code authentication Message** (MAC) - یک چکسام رمزنگاری‌شده بر داده‌ها است که توسط الگوریتم تولید MAC محاسبه می‌شود و برای اطمینان از صحت و اصالت داده‌ها استفاده می‌شود.
- **authentication Multi-factor** (MFA) – احراز هویتی که شامل دو یا چند عامل از عوامل احراز هویت تکی است.

- **TLS Mutual** (mTLS) – مراجعه کنید به احراز هویت کلاینت TLS Client (Authentication).
- **Mapping Object-relational** (ORM) – سیستمی که امکان ارجاع و پرس‌وجوی پایگاه داده‌ای رابطه‌ای/جدولی را در یک برنامه کاربردی با استفاده از مدل شیءمحور سازگار با برنامه فراهم می‌کند.
- **Password One-time** (OTP) – رمزی که به‌صورت منحصر به فرد تولید شده و فقط برای یک بار استفاده کاربرد دارد.
- **Project Security Application Worldwide Open** (OWASP) – یک جامعه جهانی، رایگان و باز است که بر به‌بود امنیت نرم‌افزاره‌ای کاربردی تمرکز دارد. مأموریت آن این است که امنیت برنامه-های کاربردی را «قابل مشاهده» کند تا افراد و سازمان‌ها بتوانند تصمیمات آگاهانه‌ای در مورد ریسک‌های امنیتی برنامه‌های کاربردی بگیرند. برای اطلاعات بیشتر مشاهده شود : https://www.owasp.org/.
- **Password-Based Key Derivation Function 2** (PBKDF2) – یک الگوریتم یک‌طرفه ویژه است که برای ایجاد یک کلید رمزنگاری قوی از یک متن ورودی (مانند گذرواژه) و یک مقدار salt تصادفی اضافی استفاده می‌شود و بنابراین می‌توان از آن برای سخت‌تر کردن شکست‌تن گذرواژه به‌صورت آفلاین استفاده کرد، اگر مقدار حاصل به‌جای گذرواژه اصلی ذخیره شود.
- **Public Key Infrastructure** (PKI) – ساختاری که کلیدهای عمومی را با هویت‌های مربوط به موجودیت‌ها پیوند می‌دهد. این پیوند از طریق فرآیند ثبت و صدور گواهی‌نامه توسط یک مرجع صدور گواهی (Certificate Authority) - (CA برقرار می‌شود.
- **Public Switched Telephone Network** (PSTN) – شبکه تلفن سنتی که شامل تلفن‌های خط ثابت و تلفن‌همراه می‌شود.
- **Real-time Transport Protocol** (RTP) and **Real-time Transport Control Protocol** (RTCP) – دو پروتکل که به‌صورت ترکیبی برای انتقال جریان‌های چندرسانه‌ای استفاده می‌شوند. این پروتکل‌ها توسط پشته WebRTC استفاده می‌شوند و در RFC 3550 تعریف شده‌اند.
- **Token Reference** – نوعی توکن که به‌عنوان اشاره‌گر یا شناسه‌ای برای وضعیت یا متادادهٔ ذخیره‌شده روی سرورعمل می‌کند و گاهی به آن توکن‌های تصادفی (Random Tokens) یا توکن-های مات (Opaque Tokens) نیز گفته می‌شود. برخلاف توکن‌های خودکفا (Self-Contained Tokens) که بخشی از داده‌های مرتبط خود را درون توکن جای می‌دهند، توکن‌های مرجع هیچ اطلاعات ذاتی-ای ندارند و برای دریافت زمینه (Context) به سرور واسته هستند. توکن مرجع یا یک شناسه نشست (Session Identifier) است یا شامل آن می‌باشد.
- **Relying Party** (RP) – معمولاً یک برنامه کاربردی است که بر احراز هویت کاربر توسط یک ارائه‌دهنده احراز هویت جداگانه متکی است. این برنامه بر نوعی توکن یا مجموعه‌ای از ادعاهای امضا شده ارائه‌شده توسط آن ارائه‌دهنده اعتماد می‌کند تا مطمئن شود کاربر همان کسی است که ادعا می‌کند.
- **Remote File Inclusion** (RFI) - حمله‌ای که از رویه‌های آسیب‌پذیر درج فایل در برنامه سوءاستفاده می‌کند و منجر به درج فایل‌های راه‌دور (Remote) می‌شود.
- **Scalable Vector Graphics** (SVG) – یک زبان نشانه‌گذاری مبتنی بر XML برای توصیف گرافیکی‌های برداری دوبعدی.
- **Real-time Transport Protocol Secure** and (SRTP) **Real-time Transport Control Protocol Secure** (SRTCP) – یک پروفایل از پروتکل‌های RTP و RTCP که پشتیبانی از رمزنگاری پیام، احراز هویت و محافظت از صحت داده‌ها را فراهم می‌کند. این پروتکل‌ها در RFC 3711 تعریف شده‌اند.

- **Architecture Security** – یک انتزاع از طراحی برنامه کاربردی است که محل و نحوه استفاده از کنترل‌های امنیتی را شناسایی و توصیف می‌کند و همچنین مکان و حساسیت داده‌های کاربر و برنامه را مشخص می‌نماید.
- **Language Markup Assertion Security** (SAML) – یک استاندارد باز برای احراز هویت Sign-On Single است که بر اساس انتقال ادعاهای امضا شده (معمولاً اشیاء (XML بین ارائه‌دهنده هویت (Identity Provider) و Party Relying عمل می‌کند.
- **Configuration Security** – پیکربندی زمان اجرا یک برنامه که نحوه استفاده از کنترل‌های امنیتی را تحت تأثیر قرار می‌دهد.
- **Control Security** – یک عمل کرد یا مؤلفه که یک بررسی امنیتی انجام می‌دهد (مثلاً بررسی دسترسی) یا هنگام فراخوانی منجر به اثر امنیتی می‌شود (مثلاً تولید یک رکورد حسابرسی).
- **management event and information Security** (SIEM) - سیستمی برای شناسایی ته‌دیدات، انطباق با مقررات و مدیریت رخدادهای امنیتی از طریق جمع‌آوری و تحلیل داده‌های مرتبط با امنیت از منابع مختلف در زیرساخت فناوری اطلاعات یک سازمان.
- **Token Self-Contained** – توکنی که یک یا چند ویژگی را در خود جای می‌دهد و به وضعیت سمت سرور یا سایر ذخیره‌سازی‌های خارجی متکی نیست. این توکن‌ها اصالت و صحت ویژگی‌های درون خود را تضمین می‌کنند و امکان تبادل امن و بدون حالت (Stateless) اطلاعات بین سیستم‌ها را فراهم می‌سازند. توکن‌های خودکفا معمولاً با تکنیک‌های رمزنگاری مانند امضاهای دیجیتال یا کدهای تأیید پیام (MAC) ایمن می‌شوند تا اصالت، صحت و در برخی موارد محرمانگی داده‌ها تضمین گردد. نمونه‌های رایج شامل ادعاهای SAML SAML) (Assertions و JWTها هستند.
- **Forgery Request Server-side** (SSRF) – حمله‌ای که از قابلیت‌های سرور برای خواندن یا به‌روزرسانی منابع داخلی سوءاستفاده می‌کند. مهاجم یک URL را ارائه یا تغییر می‌دهد که کدی که روی سرور اجرا می‌شود آن را خوانده یا داده‌ای به آن ارسال می‌کند.
- **Protocol Description Session** (SDP) – یک قالب پیام برای راه‌اندازی نشست‌های چندرسانه‌ای (به‌عنوان مثال در WebRTC استفاده می‌شود). این پروتکل در RFC 4566 تعریف شده است.
- **ID Session** or **Identifier Session** – یک کلید که یک نشست stateful ذخیره‌شده در سمت سرور را شناسایی می‌کند. این شناسه به‌صورت مستقیم یا درون یک «توکن مرجع» (Reference Token) بین سرور و کلاینت منتقل می‌شود.
- **Token Session** – اصطلاحی کلی که در این استاندارد برای اشاره به توکن یا مقدار مورد استفاده در مکانیزم‌های نشست stateless (که از توکن استفاده‌شدهself-contained می‌کنند) یا مکانیزم‌های نشست stateful (که از توکن مرجع استفاده می‌کنند) به کار می‌رود.
- **NAT for Utilities Traversal Session** (STUN) – یک پروتکل که برای کمک به عبور از NAT به منظور برقراری ارتباط‌های همتا به همتا (Peer-to-Peer) استفاده می‌شود. این پروتکل در RFC 3489 تعریف شده است.
- **authenticator Single-factor** – مکانیزمی برای بررسی احراز هویت کاربر که بایدیکی از موارد زیر باشد: چیزی که می‌دانید (رمزهای عبور، عبارات عبور، PIN)، چیزی که هستید (بیومتریک، اثر انگشت، اسکن چهره) یا چیزی که در اختیار دارید (توکن‌های OTP، دست‌گاه رمزنگاری مانند کارت هوشمند).
- **Authentication Sign-on Single** (SSO) – زمانی رخ می‌دهد که کاربر وارد یک برنامه می‌شود و به-

صورت خودکار به برنامه‌های دیگر نیز وارد می‌شود بدون نیاز به احراز هویت مجدد. به‌عنوان مثال، وقتی کاربر وارد Google می‌شود، به‌طور خودکار وارد سایر سرویس‌های Google مانند YouTube، Docs Google و Gmail نیز می‌گردد.

- **Software Bill of Materials** (SBOM) - یک فهرست ساختاریافته و جامع از تمام مؤلفه‌ها، ماژول‌ها، کتابخانه‌ها، فریم‌ورک‌ها و سایر منابع مورد نیاز برای ساخت یا مونتاژ یک برنامه نرم‌افزاری است.
- **Software Composition Analysis** (SCA) – مجموعه‌ای از فناوری‌ها که برای تحلیل ترکیب برنامه، وابستگی‌ها، کتابخانه‌ها و بسته‌ها به‌منظور شناسایی آسیب‌پذیری‌های امنیتی نسخه‌های خاص مؤلفه‌های مورد استفاده طراحی شده است. این مفهوم با تحلیل کد منبع (SAST) اشتباه گرفته نشود.
- **Software Development Lifecycle** (SDLC) – فرایند گام‌به‌گام توسعه نرم‌افزار که از نیازمندی‌های اولیه تا استقرار و نگه‌داری پیش می‌رود.
- **SQL Injection** (SQLi) – یک تکنیک تزریق کد که برای حمله به برنامه‌های مبتنی بر داده استفاده می‌شود و در آن دستورات SQL مخرب به یک نقطه ورودی تزریق می‌گردند.
- **Stateful Session Mechanism** – در این مکانیزم، برنامه وضعیت نشست را در سمت سرور نگه می‌دارد که معمولاً با توکن نشست مطابقت دارد و این توکن با استفاده از تولید کننده اعداد شبه‌تصادفی امن رمزنگاری (CSPRNG) ایجاد و به کاربر نهایی ارائه می‌شود.
- **Stateless Session Mechanism** – یک مکانیزم نشست stateless از یک token self-contained استفاده می‌کند که به کلاینت‌ها منتقل می‌شود و شامل اطلاعات نشست است که لزوماً در سرویس دریافت‌کننده ذخیره نمی‌شود و سپس آن سرویس توکن را اعتبارسنجی می‌کند. در عمل، یک سرویس نیاز دارد به دسترسی به برخی اطلاعات نشست (مانند فهرست لغو (JWT تا بتواند کنترل‌های امنیتی مورد نیاز را اعمال کند.
- **Static Application Security Testing** (SAST) – مجموعه‌ای از فناوری‌ها که برای تحلیل کد منبع، بایت‌کد و باینری‌های برنامه به‌منظور شناسایی شرایط برنامه‌نویسی و طراحی که نشان‌دهنده آسیب‌پذیری‌های امنیتی هستند طراحی شده‌اند. راه‌کاره‌ای SAST برنامه را از داخل به خارج و در حالت غیر اجرایی تحلیل می‌کنند.
- **Threat Modeling** – یک تکنیک که شامل توسعه معماری‌های امنیتی به‌طور پیوسته و دقیق‌تر برای شناسایی عاملان تهدید، مناطق امنیتی، کنترل‌های امنیتی و دارایی‌های فنی و تجاری مهم است.
- **Time-of-Check to Time-of-use** (TOCTOU) – وضعیتی که در آن یک برنامه وضعیت یک منبع را قبل از استفاده از آن بررسی می‌کند، اما وضعیت منبع می‌تواند بین زمان بررسی و استفاده تغییر کند. این می‌تواند نتایج بررسی را نامعتبر کند و باعث شود برنامه به دلیل عدم تطابق وضعیت اقدامات نامعتبر انجام دهد.
- **Time-based One-time Passwords** (TOTPs) - روشی برای تولید OTP که در آن زمان فعلی بخشی از الگوریتم تولید رمز عبور محسوب می‌شود.
- **TLS Mutual** called also ,**TLS client authentication** (mTLS) – در یک اتصال استاندارد، TLS کلاینت می‌تواند از گواهی ارائه‌شده توسط سرور برای اعتبارسنجی هویت سرور استفاده کند. زمانی که احراز هویت کلاینت TLS استفاده می‌شود، کلاینت نیز از کلید خصوصی و گواهی خود استفاده می‌کند تا سرور بتواند هویت کلاینت را اعتبارسنجی کند.
- **Transport Layer Security** (TLS) – پروتکل‌های رمزنگاری که امنیت ارتباطات را بر روی اتصال شبکه فراهم می‌کنند.

- **NAT around Relays Using Traversal** (TURN) – ی ک اف زونه از پ روت ک ل STUN ک ه از ی ک س رور TURN ب ه ع نوان رل ه اس ت ف اده م ی ک ند زم انی ک ه ات ص ال م س ت ق ی م ه م ت ا ب ه ه م ت ا ق ابل ب رق راری ن ی س ت. ای ن پ روت ک ل در RFC 8656 ت ع ری ف ش ده اس ت.
- **environment execution Trusted** (TEE) - ی ک م ح ی ط پ ردازش ی ای زول ه ک ه در آن ب رن ام ه ه ا م ی ت وان ند ب ه ط ور ام ن اج را ش ون د، ب دون ت وج ه ب ه ب اق ی س ی س ت م.
- **Module Platform Trusted** (TPM) – ن وع ی HSM ک ه م ع م ولاً ب ه ی ک ج زء س خ ت اف زاری ب زرگ ت ر م ان ند م ادرب ورد م ت ص ل اس ت و ب ه ع ن وان ری ش ه اع ت م اد (Root of Trust) ب رای آن س ی س ت م ع م ل م ی ک ند.
- **Layer Service Trusted** – ه ر ن ق ط ه اج رای ک ن ت رل م ورد اع ت م اد، م ان ند ی ک م ی ک روس روی س، API ب دون س رور (Serverless API)، س م ت س رور، ی ک API م ورد اع ت م اد روی دس ت گ اه ک ل ای ن ت ک ه ب وت ام ن دارد، ه ای API ش رک اء ی ا خ ارج ی و غ ی ره. م ورد اع ت م اد ب ه ای ن م ع ن اس ت ک ه ن گ ران ی وج ود ن دارد ک ه ی ک ک ارب ر غ ی رم ورد اع ت م اد ب ت وان د ل ای ه ی ا ک ن ت رل ه ای پ ی اده س ازی ش ده در آن ل ای ه را دور ب زن د ی ا ن ادی ده ب گ ی رد.
- **Identifier Resource Uniform** -(URI) ی ک رش ت ه ی ی ک ت ا از ک اراک ت ره ا ک ه ی ک م نب ع را ش ن اس ای ی م ی ک ند، م ان ند ی ک ص ف ح ه وب، آدرس ای م ی ل ی ا م ک ان ه ا.
- **Locator Resource Uniform** (URL) – رش ت ه ای ک ه م ک ان ی ک م نب ع در ای ن ت رن ت را م ش خ ص م ی ک ند.
- **Identifier Unique Universally** (UUID) – ی ک ش م اره م رج ع ی ک ت ا ک ه ب ه ع ن وان ش ن اس ه در ن رم اف زار اس ت ف اده م ی ش ود.
- **Verifier** – ف رد ی ا ت ی م ی ک ه ی ک ب رن ام ه را ب ر اس اس ال زام ات ASVS OWASP ب ررس ی م ی ک ند.
- **Communication Real-Time Web** (WebRTC) – ی ک پ ش ت ه پ روت ک ل و API وب م رت ب ط ک ه ب رای ان ت ق ال ج ری ان ه ای چ ن درس ان ه ای در ب رن ام ه ه ای وب اس ت ف اده م ی ش ود، م ع م ولاً در زم ی ن ه ک ن ف ران س ه ای وی دی وی ی. ای ن پ ش ت ه ب ر اس اس SRTP، SRTCP، SDP DTLS و STUN/TURN س اخ ت ه ش ده اس ت.
- **TLS over WebSocket** (WSS) – روش ی ب رای ام ن س ازی ارت ب اط وب س وک ت از ط ری ق ق رار دادن وب-س وک ت ب ر روی پ روت ک ل TLS.
- **Get You What Is See You What** (WYSIWYG) – ن وع ی وی رای ش گ رم ح ت وای غ ن ی ک ه ن ش ان م ی ده د م ح ت وا ه ن گ ام ن م ای ش چ گ ون ه ب ه ن ظ ر م ی رس د، ب ه ج ای آن ک ه ک ه ای ی ک ه ب رای ن م ای ش م ح ت وا اس ت ف اده م ی ش ون د را ن ش ان ده د.
- **Certificate X.509** – ی ک گ واه ی دی ج ی ت ال اس ت ک ه از اس ت ان دارد ب ی ن ال م ل ل ی پ ذی رف ت ه ش ده X.509 در زی رس اخ ت ک ل ی د ع م وم ی (PKI) اس ت ف اده م ی ک ند ت ا ت أ ی ی د ک ند ک ل ی د ع م وم ی م ت ع ل ق ب ه ه وی ت ک ارب ر، ک ام پ ی وت ر ی ا س روی س اس ت ک ه در گ واه ی ذ ک ر ش ده اس ت.
- **Entity eXternal XML** (XXE) – ن وع ی م وج ودی ت XML ک ه م ی ت وان د از ط ری ق ش ن اس ه س ی س ت م اع ل ام-ش ده ب ه م ح ت وای م ح ل ی ی ا راه دور دس ت رس ی پ ی دا ک ند. ای ن م ی ت وان د م ن ج ر ب ه ان واع ح م ل ات ت زری ق ی ش ود.

References B: Appendix

پ روژه ه ای زی ر از OWASP ب ه اح ت م ال زی اد ب رای ک ارب ران و اس ت ف اده ک ن ن د گ ان ای ن اس ت ان دارد م ف ی د خ واه ند ب ود:

Projects Core OWASP

1. https://owasp.org/www-project-top-ten/ Project: 10 Top OWASP
2. https://owasp.org/www-project-web-security-testing-guide/ Guide: Testing Security Web OWASP
3. https://owasp.org/www-project-proactive-controls/ Controls: Proactive OWASP
4. https://owasp.org/www-project-samm/ (SAMM): Model Maturity Assurance Software OWASP
5. https://owasp.org/www-project-secure-headers/ Project: Headers Secure OWASP

project Series Sheet Cheat OWASP

ای‌ن پ‌روژه دارای چ‌ندی‌ن ب‌رگ‌ه راه‌نم‌ا (Cheat Sheet) م‌ی‌ب‌اش‌د ک‌ه ب‌رای م‌وض‌وع‌ات م‌خ‌ت‌ل‌ف در ASVS م‌رت‌ب‌ط و ک‌ارب‌ردی خ‌واه‌ن‌د ب‌ود.

ن‌گ‌اش‌ت‌ی ب‌ه ASVS وج‌ود دارد ک‌ه م‌ی‌ت‌وان آن را در ای‌ن‌ج‌ا پ‌ی‌دا ک‌رد: https://cheatsheetseries.owasp.org/IndexASVS.html

Projects Related Security Mobile

1. https://owasp.org/www-project-mobile-security/ Project: Security Mobile OWASP
2. https://owasp.org/www-project-mobile-top-10/ Risks: 10 Top Mobile OWASP
3. https: Standard: Verification Security Application Mobile and Guide Testing Security Mobile OWASP //owasp.org/www-project-mobile-security-testing-guide/

projects related Things of Internet OWASP

1. https://owasp.org/www-project-internet-of-things/ Project: Things of Internet OWASP

projects Serverless OWASP

1. https://owasp.org/www-project-serverless-top-10/ Project: Serverless OWASP

Others

ب‌ه‌ط‌ور م‌ش‌اب‌ه، وب‌س‌ای‌ت‌ه‌ای زی‌ر ب‌ه‌اح‌ت‌م‌ال زی‌اد ب‌رای ک‌ارب‌ران و اس‌ت‌ف‌اده ک‌ن‌ن‌د گ‌ان ای‌ن اس‌ت‌ان‌دارد م‌ف‌ی‌د خ‌واه‌ن‌د ب‌ود.

1. https://github.com/danielmiessler/SecLists Github: SecLists
2. https://cwe.mitre.org/ Enumeration: Weakness Common MITRE
3. https://www.pcisecuritystandards.org/standards/ Standards: Security PCI

Standards Cryptography C: Appendix

فصل «رمزنگاری» فراتر از ارائه‌ی ساده‌ی به‌تری‌ن روی‌ه‌ا عمل می‌کند. این فصل با هدف افزای‌ش درک اصول رمزنگاری و تشوی‌ق به به‌کارگی‌ری روش‌های امنی‌تی مدرن‌تر و مقاوم‌تر تدوی‌ن شده است. این پی‌وست، اطلاعات فنی تفصی‌لی مربوط به هر ی‌ک از الزامات را ارائه می‌دهد و استانداردهای کلی مطرح‌شده در فصل «رمزنگاری» را تکمی‌ل می‌کند.

این پی‌وست سطح تأیی‌د را برای مکانی‌زم‌های مختلف رمزنگاری تعری‌ف می‌کند:

- مکانی‌زم‌های تأیی‌دشده (A) می‌توانند در برنام‌ه‌ها استفاده شوند.
- مکانی‌زم‌های قدیمی (L) نبای‌د در برنام‌ه‌ها استفاده شوند، اما ممکن است فقط برای سازگاری با برنام‌ه‌ها یا کدهای قدیمی موجود به کار روند. اگرچه استفاده از این مکانی‌زم‌ها در حال حاضر به خودی خود آسی‌ب‌پذی‌ری محسوب نمی‌شود، اما بای‌د هرچه سری‌عتر با مکانی‌زم‌های امنتر و آی‌نده‌نگرجای‌گزی‌ن شوند.
- مکانی‌زم‌های غی‌رمجاز (D) نبای‌د استفاده شوند زی‌را در حال حاضر شکست‌ه محسوب می‌شوند یا امنی‌ت کافی ارائه نمی‌کنند.

این فهرست ممکن است در زمی‌نه ی‌ک برنامه خاص به دلای‌ل مختلف لغو شود، از جمله:

- تحولات جدی‌د در حوزه رمزنگاری؛
- رعای‌ت مقررات و قوانی‌ن.

Documentation and Inventory Cryptographic

این بخش اطلاعات تکمی‌لی را برای V11.1 موجودی و مستندسازی رمزنگاری ارائه می‌دهد.

مهم است که تمام دارای‌ی‌های رمزنگاری، مانند الگوری‌تم‌ه‌ا، کلی‌دها و گواه‌ی‌نام‌ه‌ها، به‌طور منظم شناسای‌ی، فهرست‌بندی و ارزیاب‌ی شوند. برای سطح 3، این بای‌د شامل استفاده از اسکن ای‌ستا و پویا برای شناسای‌ی استفاده از رمزنگاری در ی‌ک برنامه باشد. ابزاره‌ای‌ی مانند SAST و DAST می‌توانند در این زمی‌نه کمک کنند، اما ممکن است ابزاره‌ای اختصاصی‌ی برای پوشش جامع‌تر مورد نیاز باشند. نمونه‌های رای‌گان از این ابزاره‌ا عبارتند از:

- python in written eBPF, using - Monitor Cryptography Network - CryptoMon
- Outputs CodeQL from CBOMs Comprehensive Generating Tool: Forge Cryptobom

Parameters Cryptographic of Strengths Equivalent

قدرته‌ای امنی‌تی نسبی برای سی‌ستم‌ه‌ای مختلف رمزنگاری در این جدول آمده است (از SP NIST 800-57 Part 1, صفحه71):

Strength Security	Key Symmetric Algorithms	Field Finite	Integer Factorization	Curve Elliptic
80 <=	2TDEA	160 = N 1024 = L	1024 = k	160-223 = f

Strength Security	Key Symmetric Algorithms	Field Finite	Integer Factorization	Curve Elliptic
112	3TDEA	224 = N 2048 = L	2048 = k	224-255 = f
128	AES-128	256 = N 3072 = L	3072 = k	256-383 = f
192	AES-192	384 = N 7680 = L	7680 = k	384-511 = f
256	AES-256	512 = N 15360 = L	15360 = k	512+ = f

نمونه‌ای از برنامه‌ها:

- رمزنگاری می‌دان محدود (Finite Field): Cryptography، DSA، FFDH MQV
- رمزنگاری تجزیه عدد صحیح (Integer Factorization): Cryptography RSA
- رمزنگاری منحنی بیضوی (Elliptic Curve): Cryptography، ECDSA، EdDSA، ECDH MQV

توجه: این بخش فرض می‌کند که هیچ کامپیوتر کوانتومی وجود ندارد؛ اگر چنین کامپیوتری وجود داشته باشد، برآورده‌ای سه ستون آخر دیگر معتبر نخواهند بود.

Values Random

این بخش اطلاعات تکمیلی برای Values Random 5 را ارائه می‌دهد.

Name	Version/Reference	Notes	Status
`/dev/random`	Linux 4.8+ (Oct 2016), also found in Linux-based other on Based systems. operating POSIX RFC7539	Utilizing ChaCha20 stream. Found in iOS and `SecRandomCopyBytes` `Random Secure` Android with correct the settings each. to provided	A
`/dev/urandom`	Linux's special file for kernel providing random data	Provides high-quality, entropy hardware from sources randomness	A
`AES-CTR-DRBG`	NIST SP800-90A	As used in common implementations, such as CNG Windows API by set `BCryptGenRandom` `.BCRYPT_RNG_ALGORITHM`	A
`HMAC-DRBG`	NIST SP800-90A		A
`Hash-DRBG`	NIST SP800-90A		A

Name	Version/Reference	Notes	Status
`getentropy()`	Linux in available ,OpenBSD macOS and 2.25+ glibc 10.12+	bytes random secure Provides kernel's the from directly a with source entropy minimal and straightforward and modern more It's API. with associated pitfalls avoids APIs. older	A

تابع هش زیربنایی که در HMAC-DRBG یا Hash-DRBG استفاده می‌شود، باید برای این کاربرد تأیید شده باشد.

Algorithms Cipher

این بخش اطلاعات تکمیلی برای الگوریتم‌های رمزنگاری را ارائه می‌دهد.

الگوریتم‌های رمزنگاری تأیید شده به ترتیب اولویت فهرست شده‌اند.

Algorithms Key Symmetric	Reference	Status
AES-256	197 FIPS	A
Salsa20	specification 20 Salsa	A
XChaCha20	Draft XChaCha20	A
XSalsa20	nonce Salsa20 the Extending	A
ChaCha20	8439 RFC	A
AES-192	197 FIPS	A
AES-128	197 FIPS	L
2TDEA		D
(3DES/3DEA) TDEA		D
IDEA		D
RC4		D
Blowfish		D
ARC4		D
DES		D

Modes Cipher AES

رمزنگاری‌های بلوکی، مانند AES، می‌توانند با حالت‌های مختلف عملیاتی استفاده شوند. بسیاری از حالت‌های عملیاتی، مانند Codebook Electronic (ECB)، نامن هستند و نباید استفاده شوند. حالت‌های عملیاتی Mode Galois/Counter (GCM) و Message Chaining Block Cipher with Counter Code Authentication (CCM) رمزنگاری تأیید شده (Authenticated Encryption) ارائه می‌دهند و باید در برنامه‌های مدرن استفاده شوند.

حالت‌های تأیید شده به ترتیب اولویت فهرست شده‌اند.

Mode	Authenticated	Reference	Status	Restriction
GCM	Yes	SP NIST 800-38D	A	
CCM	Yes	SP NIST 800-38C	A	
CBC	No	SP NIST 800-38A	L	
CCM-8	Yes		D	
ECB	No		D	
CFB	No		D	
OFB	No		D	
CTR	No		D	

یادداشت‌ها:

- تمام پیام‌های رمزنگاری‌شده باید احراز هویت شوند. برای هر استفاده‌ای از حالت CBC، حتماً باید یک الگوریتم هش MAC مرتبط برای اعتبارسنجی پیام وجود داشته باشد. به طور کلی، این باید با روش Encrypt-Then-Hash اعمال شود (اما TLS 1.2 به جای آن از روش Hash-Then-Encrypt استفاده می‌کند). اگر این تضمین امکان‌پذیر نباشد، نباید از CBC استفاده شود. تنها کاربردی که در آن رمزنگاری بدون الگوریتم MAC مجاز است، رمزنگاری دیسک است.
- اگر از حالت CBC استفاده شود، باید تضمین شود که بررسی پدینگ (Padding) در زمان ثابت انجام می‌شود.
- هنگام استفاده از CCM-8، برچسب MAC تنها ۶۴ بیت امنیت ارائه می‌دهد. این با الزامات بند ۶.۲.۹ که حداقل ۱۲۸ بیت امنیت را نیاز دارد، مطابقت ندارد.
- رمزنگاری دیسک خارج از محدوده ASVS در نظر گرفته شده است. بنابراین، این ضمیمه هیچ روش تأیید شده‌ای برای رمزنگاری دیسک فهرست نمی‌کند. برای این کاربرد، معمولاً رمزنگاری بدون احراز هویت پذیرفته می‌شود و حالت‌های XEX XTS، و LRW معمولاً استفاده می‌شوند.

Wrapping Key

بس‌ته‌بن‌دی کل‌ی‌د رمزن‌گ‌اری (و ب‌از ک‌ردن ب‌س‌ت‌ه‌ی م‌رب‌وط‌ه) روش‌ی ب‌رای م‌ح‌اف‌ظ‌ت از ی‌ک ک‌ل‌ی‌د م‌وج‌ود اس‌ت ک‌ه ب‌ا م‌ح‌ص‌ور ک‌ردن (ی‌ع‌ن‌ی ب‌س‌ت‌ه‌ب‌ن‌دی) آن و اس‌ت‌ف‌اده از ی‌ک م‌ک‌ان‌ی‌زم رمزن‌گ‌اری اض‌اف‌ی ان‌ج‌ام م‌ی‌ش‌ود ت‌ا ک‌ل‌ی‌د اص‌ل‌ی ب‌ه‌ط‌ور آش‌ک‌ار در م‌ع‌رض دی‌د ق‌رار ن‌گ‌ی‌رد، م‌ث‌لاً ه‌ن‌گ‌ام ان‌ت‌ق‌ال. ک‌ل‌ی‌د اض‌اف‌ی ک‌ه ب‌رای م‌ح‌اف‌ظ‌ت از ک‌ل‌ی‌د اص‌ل‌ی اس‌ت‌ف‌اده م‌ی‌ش‌ود، ک‌ل‌ی‌د ب‌س‌ت‌ه‌ب‌ن‌دی (wrap key) ن‌ام‌ی‌ده م‌ی‌ش‌ود.

ای‌ن ع‌م‌ل‌ی‌ات م‌م‌ک‌ن اس‌ت زم‌ان‌ی ان‌ج‌ام ش‌ود ک‌ه ب‌خ‌واه‌ی‌م ک‌ل‌ی‌ده‌ا را در م‌ک‌ان‌ه‌ای‌ی ک‌ه ق‌اب‌ل اع‌ت‌م‌اد ن‌ی‌س‌ت‌ن‌د م‌ح‌اف‌ظ‌ت ک‌ن‌ی‌م، ی‌ا ک‌ل‌ی‌ده‌ای ح‌س‌اس را از ط‌ری‌ق ش‌ب‌ک‌ه‌ه‌ای غ‌ی‌رق‌اب‌ل اع‌ت‌م‌اد ی‌ا درون ب‌رن‌ام‌ه‌ه‌ا ارس‌ال ک‌ن‌ی‌م. ب‌ا ای‌ن ح‌ال، ب‌ای‌د ب‌ا دق‌ت ب‌ه م‌اه‌ی‌ت ک‌ل‌ی‌د اص‌ل‌ی (م‌ان‌ن‌د ه‌وی‌ت و ه‌دف آن) ق‌ب‌ل از ان‌ج‌ام ف‌رآی‌ن‌د ب‌س‌ت‌ه‌ب‌ن‌دی/ب‌ازک‌ردن ب‌س‌ت‌ه ت‌وج‌ه ش‌ود، زی‌را ای‌ن م‌ی‌ت‌وان‌د ب‌رای س‌ی‌س‌ت‌م‌ه‌ا ی‌ا ب‌رن‌ام‌ه‌ه‌ای م‌ب‌دأ و م‌ق‌ص‌د پ‌ی‌ام‌ده‌ای‌ی در زم‌ی‌نه ام‌ن‌ی‌ت و ب‌ه وی‌ژه ت‌ط‌اب‌ق ق‌ان‌ون‌ی داش‌ت‌ه ب‌اش‌د، ک‌ه م‌م‌ک‌ن اس‌ت ش‌ام‌ل م‌س‌ی‌ره‌ای ح‌س‌اب‌رس‌ی ع‌م‌ل ک‌رد ک‌ل‌ی‌د (م‌ان‌ن‌د ام‌ض‌ا) و ه‌م‌چ‌ن‌ی‌ن ذخ‌ی‌ره‌س‌ازی م‌ن‌اس‌ب ک‌ل‌ی‌د ب‌اش‌د.

ب‌ه‌ط‌ور م‌ش‌خ‌ص، ب‌رای ب‌س‌ت‌ه‌ب‌ن‌دی ک‌ل‌ی‌د ب‌ای‌د از AES-256 اس‌ت‌ف‌اده ش‌ود، م‌ط‌اب‌ق ب‌ا SP NIST 800-38F و ب‌ا در ن‌ظ‌ر گ‌رف‌ت‌ن ت‌م‌ه‌ی‌دات آی‌ن‌ده‌ن‌گ‌ر در ب‌راب‌ر ت‌ه‌دی‌د ک‌وان‌ت‌وم‌ی. ح‌ال‌ت‌ه‌ای رمزن‌گ‌اری اس‌ت‌ف‌اده‌ش‌ده ب‌ا AES ب‌ه ت‌رت‌ی‌ب اول‌وی‌ت ب‌ه ش‌رح زی‌ر ه‌س‌ت‌ن‌د:

Wrapping Key	Reference	Status
KW	800-38F SP NIST	A
KWP	800-38F SP NIST	A

در ص‌ورت‌ی ک‌ه م‌ورد اس‌ت‌ف‌اده ن‌ی‌از داش‌ت‌ه ب‌اش‌د، م‌ی‌ت‌وان از AES-192 و AES-128 ن‌ی‌ز اس‌ت‌ف‌اده ک‌رد، ام‌ا دل‌ی‌ل اس‌ت‌ف‌اده از آن‌ه‌ا ب‌ای‌د در ف‌ه‌رس‌ت رمزن‌گ‌اری م‌وج‌ود در س‌ازم‌ان م‌س‌ت‌ن‌دس‌ازی ش‌ود.

Encryption Authenticated

ب‌ه اس‌ت‌ث‌ن‌ای رمزن‌گ‌اری د‌ی‌س‌ک، داده‌ه‌ای رمزن‌گ‌اری‌ش‌ده ب‌ای‌د در ب‌راب‌ر ت‌غ‌ی‌ی‌رات غ‌ی‌رم‌ج‌از ب‌ا اس‌ت‌ف‌اده از ن‌وع‌ی از ط‌رح رمزن‌گ‌اری اح‌راز ه‌وی‌ت‌ش‌ده (AE) م‌ح‌اف‌ظ‌ت ش‌ون‌د، ک‌ه م‌ع‌م‌ولاً از ط‌رح رمزن‌گ‌اری اح‌راز ه‌وی‌ت‌ش‌ده ب‌ا داده‌ه‌ای م‌رت‌ب‌ط (AEAD) اس‌ت‌ف‌اده م‌ی‌ش‌ود.

ب‌ه‌ت‌ر اس‌ت ب‌رن‌ام‌ه از ی‌ک ط‌رح AEAD ت‌أی‌ی‌د ش‌ده اس‌ت‌ف‌اده ک‌ن‌د. ب‌ه ط‌ور ج‌ای‌گ‌زی‌ن، م‌ی‌ت‌وان‌د ی‌ک ط‌رح رمزن‌گ‌اری ت‌أی‌ی‌د ش‌ده و ی‌ک ال‌گ‌وری‌ت‌م MAC ت‌أی‌ی‌د ش‌ده را ب‌ا س‌اخ‌ت‌ار Encrypt-then-MAC ت‌رک‌ی‌ب ک‌ن‌د.

روش MAC-then-encrypt ه‌م‌چ‌ن‌ان ب‌رای س‌ازگ‌اری ب‌ا ب‌رن‌ام‌ه‌ه‌ای ق‌دی‌م‌ی م‌ج‌از اس‌ت. ای‌ن روش در TLS ن‌س‌خ‌ه ۱.۲ ب‌ا م‌ج‌م‌وع‌ه‌ای رمزن‌گ‌اری ق‌دی‌م‌ی اس‌ت‌ف‌اده م‌ی‌ش‌ود.

mechanism AEAD	Reference	Status
AES-GCM	800-38D SP	A
AES-CCM	800-38C SP	A
ChaCha-Poly1305	7539 RFC	A
AEGIS-256	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	A
AEGIS-128	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	A
AEGIS-128L	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	A
Encrypt-then-MAC		A
MAC-then-encrypt		L

Functions Hash

ای‌ن بخ‌ش اط‌لاع‌ات ت‌ک‌م‌ی‌ل‌ی در م‌ورد ه‌ش ک‌ردن و ت‌وابع م‌بت‌نی ب‌ر ه‌ش را ارائ‌ه م‌ی‌ده‌د.

Cases Use General for Functions Hash

ج‌دول زی‌ر ت‌وابع ه‌ش ت‌أی‌ی‌د ش‌ده ب‌رای ک‌اربرده‌ای ع‌م‌ومی رم‌زن‌گ‌اری، م‌انند ام‌ض‌اه‌ای دی‌ج‌ی‌ت‌ال، را ف‌ه‌رس‌ت م‌ی‌ک‌ن‌د:

- ت‌وابع ه‌ش ت‌أی‌ی‌د ش‌ده م‌ق‌اوم‌ت ب‌ال‌ای‌ی در ب‌راب‌ر ب‌رخ‌ورد (collision) دارن‌د و ب‌رای ب‌رن‌ام‌ه‌ای ب‌ا ام‌ن‌ی‌ت ب‌ال‌ا م‌ن‌اس‌ب ه‌س‌ت‌ن‌د.
- ب‌رخ‌ی از ای‌ن ال‌گ‌وری‌ت‌م‌ه‌ا وق‌ت‌ی ه‌م‌راه ب‌ا م‌دی‌ری‌ت ص‌ح‌ی‌ح ک‌ل‌ی‌ده‌ای رم‌زن‌گ‌اری اس‌ت‌ف‌اده ش‌ون‌د، م‌ق‌اوم‌ت ب‌ال‌ای‌ی در ب‌راب‌ر ح‌م‌لات ارائ‌ه م‌ی‌ده‌ند و ب‌ن‌اب‌رای‌ن ب‌رای ت‌وابع ،KDF HMAC و RBG ن‌ی‌ز ت‌أی‌ی‌د ش‌ده‌ان‌د.
- ت‌وابع ه‌ش ب‌ا خ‌روج‌ی ک‌م‌ت‌ر از ۲۵۴ ب‌ی‌ت م‌ق‌اوم‌ت ک‌اف‌ی در ب‌راب‌ر ب‌رخ‌ورد (collision) ن‌دارن‌د و ن‌ب‌ای‌د ب‌رای ام‌ض‌اه‌ای دی‌ج‌ی‌ت‌ال ی‌ا س‌ای‌ر ک‌اربرده‌ای‌ی ک‌ه ن‌ی‌از ب‌ه م‌ق‌اوم‌ت در ب‌راب‌ر ب‌رخ‌ورد دارن‌د، اس‌ت‌ف‌اده ش‌ون‌د. ب‌رای س‌ای‌ر ک‌اربرده‌ا، م‌م‌ک‌ن اس‌ت ت‌ن‌ه‌ا ب‌رای س‌ازگ‌اری و اع‌ت‌ب‌ارس‌نج‌ی ب‌ا س‌ی‌س‌ت‌م‌ه‌ای ق‌دی‌م‌ی اس‌ت‌ف‌اده ش‌ون‌د، ام‌ا ن‌ب‌ای‌د در ط‌راح‌ی‌ه‌ای ج‌دی‌د ب‌ه ک‌ار رون‌د.

function Hash	Reference	Status	Restrictions
SHA3-512	202 FIPS	A	
SHA-512	180-4 FIPS	A	
SHA3-384	202 FIPS	A	
SHA-384	180-4 FIPS	A	
SHA3-256	202 FIPS	A	

function Hash	Reference	Status	Restrictions
SHA-512/256	180-4 FIPS	A	
SHA-256	180-4 FIPS	A	
SHAKE256	202 FIPS	A	
BLAKE2s	as fast smaller, simpler, BLAKE2: MD5	A	
BLAKE2b	as fast smaller, simpler, BLAKE2: MD5	A	
BLAKE3	fast function, one BLAKE3 everywhere	A	
SHA-224	180-4 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA-512/224	180-4 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA3-224	202 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA-1	6194 RFC & 3174 RFC	L	KDF, HMAC, for suitable Not signatures digital RBG,
length) (any CRC		D	
MD4	1320 RFC	D	
MD5	1321 RFC	D	

Storage Password for Functions Hash

برای هش کردن امن گذرواژه‌ها، باید از توابع هش مخصوص استفاده شود. این الگوریتم‌های هش کند، با افزایش سختی محاسباتی شکستن گذرواژه، حملات جست‌وجوی فراگیر (brute-force) و دیکشنری را کاهش می‌دهند.

KDF	Reference	Parameters Required	Status
argon2id	9106 RFC	1 = p MiB), (46 47104 □ m 1: = t	A
		1 = p MiB), (19 19456 □ m 2: = t	A
		1 = p MiB), (12 12288 □ m 3: □ t	A
scrypt	7914 RFC	8 = r MiB), (128 2^17 □ N 1: = p	A
		8 = r MiB), (64 2^16 □ N 2: = p	A

KDF	Reference	Parameters Required	Status
		8 = r MiB), (32 2^15 □ N 3: □ p	A
bcrypt	Future-Adaptable A Scheme Password	10 □ cost	A
PBKDF2-HMAC-SHA-512	FIPS ,800-132 SP NIST 180-4	000 210, □ iterations	A
PBKDF2-HMAC-SHA-256	FIPS ,800-132 SP NIST 180-4	000 600, □ iterations	A
PBKDF2-HMAC-SHA-1	FIPS ,800-132 SP NIST 180-4	000 300, 1, □ iterations	L

توابع استخراج کلید مبتنی بر گذرواژه Functions) Derivation Key (Password-Based تأیید شده می‌توانند برای ذخیره‌سازی گذرواژه استفاده شوند.

(KDFs) Functions Derivation Key

Functions Derivation Key General

KDF	Reference	Status
HKDF	5869 RFC	A
PRF 1.2 TLS	5248 RFC	L
KDFs MD5-based	1321 RFC	D
KDFs SHA-1-based	6194 RFC & 3174 RFC	D

Functions Derivation Key Password-based

KDF	Reference	Parameters Required	Status
argon2id	9106 RFC	1 = p MiB), (46 47104 □ m 1: = t	A
		1 = p MiB), (19 19456 □ m 2: = t	A
scrypt	7914 RFC	8 = r MiB), (128 2^17 □ N 1: = p	A
		8 = r MiB), (64 2^16 □ N 2: = p	A
		8 = r MiB), (32 2^15 □ N 3: □ p	A

KDF	Reference	Parameters Required	Status
PBKDF2-HMAC-SHA-512	FIPS ,800-132 SP NIST 180-4	000 210, □ iterations	A
PBKDF2-HMAC-SHA-256	FIPS ,800-132 SP NIST 180-4	000 600, □ iterations	A
PBKDF2-HMAC-SHA-1	FIPS ,800-132 SP NIST 180-4	000 300, 1, □ iterations	L

Mechanisms Exchange Key

ای‌ن ب‌خ‌ش اط‌لاع‌ات ت‌ک‌م‌ی‌لی رم‌زن‌گ‌اری ک‌لی‌د ع‌م‌وم‌ی را ارائ‌ه م‌ی‌ده‌د.

Schemes KEX

ب‌رای ه‌م‌ه ط‌رح‌ه‌ای ت‌ب‌ادل ک‌لی‌د ب‌ای‌د ق‌درت ام‌ن‌ی‌ت‌ی ۱۱۲ ب‌ی‌ت ی‌ا ب‌ی‌ش‌ت‌ر ت‌ض‌م‌ی‌ن ش‌ود و پ‌ی‌اده‌-س‌ازی آن‌ه‌ا ب‌ای‌د از ان‌ت‌خ‌اب پ‌ارام‌ت‌ره‌ای م‌وج‌ود در ج‌دول زی‌ر پ‌ی‌روی ک‌ن‌د.

Scheme	Domain Parameters	Forward Secrecy	Status
Finite Field Diffie-Hellman (FFDH)	L >= 3072 & N >= 256	Yes	A
Elliptic Curve Diffie-Hellman (ECDH)	f >= 256-383	Yes	A
Encrypted key transport with RSA-PKCS#1 v1.5		No	D

ک‌ه پ‌ارام‌ت‌ره‌ای زی‌ر ع‌ب‌ارت‌ن‌د از:

- k ان‌دازه ک‌لی‌د ب‌رای ک‌لی‌ده‌ای RSA اس‌ت.
- L ان‌دازه ک‌لی‌د ع‌م‌وم‌ی و N ان‌دازه ک‌لی‌د خ‌ص‌وص‌ی ب‌رای رم‌زن‌گ‌اری ب‌ر م‌ب‌ن‌ای م‌ی‌دان م‌ح‌دود اس‌ت.
- f م‌ح‌دوده ان‌دازه‌ه‌ای ک‌لی‌د ب‌رای ECC اس‌ت.

ه‌ی‌چ پ‌ی‌اده‌س‌ازی ج‌دی‌دی ن‌ب‌ای‌د از ط‌رح‌ی اس‌ت‌ف‌اده ک‌ن‌د ک‌ه ب‌ا اس‌ت‌ان‌دارده‌ای NIST SP 800-56A & B و NIST SP 800-77 م‌ط‌اب‌ق‌ت ن‌داش‌ت‌ه ب‌اش‌د. ب‌ه ط‌ور م‌ش‌خ‌ص، IKEv1 ن‌ب‌ای‌د در م‌ح‌ی‌ط‌ه‌ای ت‌ول‌ی‌دی اس‌ت‌ف‌اده ش‌ود.

groups Diffie-Hellman

گ‌روه‌ه‌ای زی‌ر ب‌رای پ‌ی‌اده‌س‌ازی Diffie-Hellman ت‌أی‌ی‌د ش‌ده‌ان‌د. ق‌درت‌ه‌ای ام‌ن‌ی‌ت‌ی در ض‌م‌ی‌م‌ه D اس‌ت‌ان‌دارد NIST SP 800-56A و ب‌خ‌ش 1 ن‌س‌خ‌ه 5 اس‌ت‌ان‌دارد NIST SP 800-57 م‌س‌ت‌ن‌د ش‌ده‌ان‌د.

Group	Status
P-224, secp224r1	A
P-256, secp256r1	A
P-384, secp384r1	A
P-521, secp521r1	A
K-233, sect233k1	A
K-283, sect283k1	A
K-409, sect409k1	A
K-571, sect571k1	A
B-233, sect233r1	A
B-283, sect283r1	A
B-409, sect409r1	A
B-571, sect571r1	A
Curve448	A
Curve25519	A
MODP-2048	A
MODP-3072	A
MODP-4096	A
MODP-6144	A
MODP-8192	A
ffdhe2048	A
ffdhe3072	A
ffdhe4096	A
ffdhe6144	A
ffdhe8192	A

(MAC) Codes Authentication Message

کدهای احراز هویت پیام (MAC) سازه‌ای رمزنگاری هستند که برای بررسی صحت و اصالت یک پیام استفاده می‌شوند. یک MAC یک پیام و یک کلید مخفی را به عنوان ورودی می‌گیرد و یک برچسب با اندازه ثابت (مقدار MAC تولید می‌کند. هاMAC به طور گسترده در پروتکل‌های ارتباطی امن (مانند TLS/SSL استفاده می‌شوند تا اطمینان حاصل شود که پیام‌های تبادل‌شده بین طرفین معتبر و دستنخورده هستند.

Algorithm MAC	Reference	Status
HMAC-SHA-256	198-1 FIPS & 2104 RFC	A
HMAC-SHA-384	198-1 FIPS & 2104 RFC	A
HMAC-SHA-512	198-1 FIPS & 2104 RFC	A
KMAC128	800-185 SP NIST	A
KMAC256	800-185 SP NIST	A
mode) (keyed_hash BLAKE3	everywhere fast function, one BLAKE3	A
AES-CMAC	800-38B SP NIST & 4493 RFC	A
AES-GMAC	800-38D SP NIST	A
Poly1305-AES	code message-authentication Poly1305-AES The	A
HMAC-SHA-1	198-1 FIPS & 2104 RFC	L
HMAC-MD5	1321 RFC	D

Signatures Digital

طرح‌های امضا بایـد از اندازه‌ها و پارامترهای کلیـد تأییـد شده مطابق با 800-57 SP NIST بخش 1 استفاده کنند.

Algorithm Signature	Reference	Status
Ed448) (Ed25519, EdDSA	8032 RFC	A
Curve448) (Curve25519, XEdDSA	XEdDSA	A
P-521) P-384, (P-256, ECDSA	186-4 FIPS	A
RSA-RSSA-PSS	8017 RFC	A
v1.5 RSA-SSA-PKCS#1	8017 RFC	D
size) key (any DSA	186-4 FIPS	D

Standards Encryption Post-Quantum

پیاده‌سازی‌های رمزنگاری پساکوانتومی (PQC) بایـد از استانداردهای FIPS-203، FIPS-204 و FIPS-205 پیروی کنند. در حال حاضر، نمونه‌های کدمقاوم یا پیاده‌سازی‌های مرجع زیادی برای این استانداردها در دسترس نیست. برای جزئیات بیشتر، به اعلامیه NIST درباره سه استاندارد نهایی‌شده رمزنگاری پساکوانتومی (اوت ۲۰۲۴) مراجعه کنید.

روش پیش‌نهادی mlkem768x25519 برای توافق کلیـد هیبریدی TLS پساکوانتومی توسط مرورگرهای اصلی مانند Firefox نسخه ۱۳۲ و Chrome نسخه ۱۳۱ پشتیبانی می‌شود. این روش

می‌توانند در محیط‌های آزمایشی رمزنگاری یا زمانی که در کتابخانه‌های تأیید شده توسط صنعت یا دولت در دسترس است، استفاده شود.

Recommendations D: Appendix

Introduction

در حین آماده‌سازی نسخه ۵.۰ استاندارد اعتبارسنجی امنیت برنامه‌ها (ASVS)، مشخص شد که تعدادی از موارد موجود و همچنین موارد پیشنهادی جدید وجود دارند که نباید به‌عنوان الزام در نسخه ۵.۰ گنجانده شوند. این موضوع یا به این دلیل بود که مطابق تعریف نسخه ۵.۰ در محدوده ASVS قرار نمی‌گرفتند، یا به این خاطر که هرچند ایده‌های خوبی بودند، اما امکان الزام‌آور کردن آن‌ها وجود نداشت.

برای اینکه همه‌ی این موارد به‌طور کامل از دست نروند، برخی از آن‌ها در این پیوست ثبت شده‌اند.

mechanisms in-scope Recommended,

موارد زیر در محدوده ASVS قرار دارند. این موارد نباید الزام‌آور شوند، اما قویاً توصیه می‌شود که به‌عنوان بخشی از یک برنامه‌ی امن مورد توجه قرار گیرند.

- باید ابزاری برای نمایش می‌زان قوی یا ضعیف بودن گذرواژه در اختیار کاربران قرار داده شود تا به آن‌ها در انتخاب یک گذرواژه امنتر کمک کند.
- یک فایل security.txt عمومی در ریشه سایت یا پوشه well-known. برنامه ایجاد کنید که به‌وضوح یک لینک یا آدرس ایمیل برای تماس افراد با مالکین در مورد مسائل امنیتی را مشخص کند.
- اعتبارسنجی ورودی‌ها در سمت کاربر باید علاوه بر اعتبارسنجی در لایه سرویس مورد اعتماد اعمال شود، زیرا این کار فرصت خوبی برای شناسایی زمانی فراهم می‌کند که کسی تلاش کرده است با عبور از کنترل‌های سمت کاربر به برنامه حمله کند.
- جلوگیری از دسترسی تصادفی و نمایش صفحات حساس در موتورهای جستجو با استفاده از فایل robots.txt، در پاسخ X-Robots-Tag یا تگ متای HTML robots.
- هنگام استفاده از GraphQL، منطق احراز هویت را در لایه منطق کسب‌وکار پیاده‌سازی کنید، نه در لایه GraphQL یا resolver، تا نیازی به مدیریت احراز هویت در هر رابط جداگانه نباشد.

مرجع:

- More information on Security.txt including a link to the RFC

Software Security principles

موارد زیر قبلاً در ASVS ذکر شده بودند، اما در واقع الزام نیستند. درعوض، این‌ها اصولی هستند که هنگام پیاده‌سازی کنترل‌های امنیتی باید در نظر گرفته شوند و رعایت آن‌ها منجر به کنترل‌های مقاوم‌تر می‌شود. این موارد شامل:

- کنترل‌های امنیتی بایدتمرکز، ساده (اقتصادی در طراحی)، قابل‌اعتبارسنجی و قابل استفاده مجدد باشند. این روی‌کرد باید از تکراری، ناقص یا ناکارآمد بودن کنترل‌ها جلوگیری کند.
- هرجا ممکن است، به‌جای پیاده‌سازی کنترل‌ها از ابتدا، از پیاده‌سازی‌های قبلاً نوشته شده و به‌خوبی بررسی‌شده کنترل‌های امنیتی استفاده کنید.
- به‌طور ایده‌آل، باید از یک مکانیزم کنترل دسترسی واحد برای دسترسی به داده‌ها و منابع محافظت‌شده استفاده شود. تمام درخواست‌ها باید از طریق همین مکانیزم واحد عبور کنند تا از مسیره‌های جایگزین ناامن یا کپی و چسب‌اندن جلوگیری شود.
- کنترل دسترسی مبتنی بر ویژگی یا صفت، یک الگوی پیش‌نهادی است که در آن کد مجوز کاربر را برای یک ویژگی یا مورد داده بررسی می‌کند، نه صرفاً نقش او. با این حال، تخصیص دسترسی‌ها همچنان باید از طریق نقش‌ها انجام شود.

processes Security Software

تعدادی از فرآیندهای امنیتی وجود دارند که از ASVS نسخه ۵.۰ حذف شده‌اند اما همچنان ایده خوبی هستند. پروژه SAMM OWASP می‌تواند منبع مناسبی برای نحوه پیاده‌سازی مؤثر این فرآیندها باشد. مواردی که قبلاً در ASVS گنجانده شده بودند، شامل:

- استفاده از چرخه عمر توسعه نرم‌افزار امن را که امنیت را در تمامی مراحل توسعه در نظر می‌گیرد، تأیید کنید.
- استفاده از مدل‌سازی تهدید برای هر تغییر طراحی یا برنامه‌ریزی اسپرینت را تأیید کنید تا تهدیدها شناسایی شوند، برنامه‌ای برای مقابله با آن‌ها تدوین شود، پاسخ‌های مناسب به ریسک تست‌های گردد و تست‌های امنیتی هدایت شوند.
- تأیید کنید که تمام داستان‌های کاربری و ویژگی‌ها شامل محدودیت‌های عملکردی امنیتی باشند، مانند: «به‌عنوان یک کاربر، باید قادر باشم پروفایل خود را مشاهده و ویرایش کنم. نباید قادر باشم پروفایل سایر کاربران را مشاهده یا ویرایش کنم.
- اطمینان حاصل کنید که یک چک‌لیست برنامه‌نویسی امن، الزامات امنیتی، راهنما یا سیاست امنیتی در دسترس تمام توسعه‌دهندگان و تست‌کنندگان قرار دارد.
- اطمینان حاصل کنید که یک فرآیند مستمر برای بررسی وجود دارد تا کد منبع برنامه عاری از درب‌های پشتی، کدهای مخرب (مثلاً حملات سال‌امی، بمب‌های منطقی، بمب‌های زمانی) و ویژگی‌های مستندسازی نشده یا مخفی (مثلاً Easter eggها، ابزارهای اشکال‌زدایی ناامن) باشد. رعایت این بخش بدون دسترسی کامل به کد منبع، شامل کتابخانه‌های شخص ثالث، امکان‌پذیر نیست و بنابراین احتمالاً فقط برای برنامه‌های مناسب است که به بالاترین سطوح امنیت نیاز دارند.
- اطمینان حاصل کنید که مکانیزم‌های برای شناسایی و پاسخ به تغییرات ناخواسته پیکربندی در محیط‌های مستقر شده وجود دارد. این مکانیزم شامل استفاده از زیرساخت غیرقابل تغییر، بازاستقرار خودکار از یک پایه امن، یا ابزارهای شناسایی تغییر که وضعیت فعلی را با پیکربندی‌های تأیید شده مقایسه می‌کنند، باشد.
- اطمینان حاصل کنید که امن‌سازی پیکربندی روی تمام محصولات، کتابخانه‌ها، فریم‌ورک‌ها و سرویس‌های شخص ثالث طبق توصیه‌های هر یک انجام شده باشد.

مراجع:

- Sheet Cheat Modeling Threat OWASP
- modeling Threat OWASP
- Project Model Maturity Assurance Software OWASP
- SDL Microsoft

Contributors - E Appendix

ما با سپاس گزاری از مشارکت افراد زیر که از زمان انتشار نسخه ۴.۰.۰ ASVS نظر داده‌اند یا درخواست-های ادغام (Pull Request) باز کرده‌اند، قدردانی می کنیم.

اگر از وجود هرگونه خطای آگاه هستید یا ترجیح می‌دهید نام شما به شکلی متفاوت نمایش داده شود، لطفاً به ما اطلاع دهید.

Oleksii Dovy-d-kov (oleksiidov)	)lfservin(servin luis	Johan Sydseter (sydseter)
kkshitish	)ThunderSon(Saad Eli	James Sulinski (jsulinski)
Michael Gargiulo (mgargiulo)	)Bankde(Eakasit Bankde	M Rick (kingthorin)
Joerg Bruen-ner (JoergBruenner)	inaz0	Kohl Cesar (cesarkohl)
Matteo Pace (M4tteoP)	)jimfenton(Fenton Jim	John Carroll (yosignals)
craig-shony	)jeremychoi(Choi Bonghwan Jeremy	van Steven Baan der (vdbaan)
Masahiro IZUKA (maizuka)	Andrew A9 van der Stock (vanderaj)	Raphael Dunant (Rlater)
David Deather-age (dave-security)	Sebastien gio-ria (SPoint42)	Riccardo Sirigu (ricsirigu)

Tomasz Wrobel)tw2as(	)belalena(Dubeshko Alena	Rafael Green)RafaelGreen1(	mjang-cobalt
clallier94	)kwwall(Wall W. Kevin	Jordan Sher-man jsherm-fwdsec /)deleterepo	Ingo Rauner ingo-( )rauner
Dirk Wetter)drwetter(	)moshe-apiiro(Zioni Moshe	Patrick Dwyer)coderpatrick	David Clarke davidclarke-( )au
Takaharu Ogasa)takaharuogasa(	)arkid15r(Yakovets Arkadii	Motoyasu Saburi motoyasu-( )saburi	seirn
wet-certitude	timhemel	RL Thorn-ton)thornshadow99(	Thomas Bandt)aspnetde(
Roel Storms)roelstorms(	)commjoen(Willemsen Jeroen	anonymous-31	Kaus-ran Sai-ful-lah)deFr0ggy(
Steve Springett)stevespringett(	)northdpole(Spyros	Hans Her-rera)hansphp(	Marx314
CarlosAllendes	)yruss972(Russ Yonah	Sander Mai-jers sanmai-)NL	Luboš Bretschnei-der)bretik(

Eva Sarafianou)esarafianou(	ataseren	Steve Thomas)Sc00bz(	Dominique RIGHETTO)righettod(
van Steven Baan der)svdb-ncc(	)Aif4thah(Vacarella Michael	Tonimir Kisas-ondi)tkisasondi(	Stefan Streichs-bier)streichsbaer(
hi-unc1e	)starbuck3000(sb3k	mario-platt	Devdatta Akhawe)devd(
Michael Gissing)scolytus(	)thatsjet(Anderson Jet	Dave Wich-ers)davewichers(	Jonny Schnittger)JonnySchnittger(
Väli Silvia)silviavali(	jackgates73	1songb1rd	Timur)timurozkul(
Gareth Heyes)hackvertor(	appills	suvikaarttinals	)chaals(
DanielPharos)AtlasHackert(	)willfarrell(Farrell will	Alina Vasil-jeva)avasiljeva(	Paul Mc-Cann)vanmisepaul(
Sage)SajjadPourali(	rbsec	Benedikt Bauer)mastachata(	James Jar-dine)jamesjardine(
Mark Burnett)m8urnett(	dschwarz91	Cyber-AppSec Cyber-AppSec)(	Tib3rius
BitnessWise)bitnesswise(	)damienbod(damienbod	Jared Meit)jmeit-fwdsec(	Stefan Seel-mann)sseelmann(

Brendan O'Connor)ussjoin(	)andrettv(Titov Andrei	Hans-Petter Fjeld)atluxity(	markehack
Neil Madden)NeilMadden(	)mgeramb(Geramb Michael	Osama El-nag-gar ossie-( )git	mackowski
Balla Ravi)raviballa(	)hazanasec(Hazana	David Means)dmeans82(	Alexander Stein)ch4(
BaeSenseii)baesenseii(	)VincentDS(Schutter De Vincent	S Bani)sbani(	Mitsuaki Akiyama)mak1yama(
Christopher Loessl)hashier(	victorxm	Michal Rada)michalrada(	Veeresh De-vidadd)drveresh(
MaknaSEO	darkzero2022	Liam)LiamDobbelaere(	Frank nis)jedisct1(
Sulin Otto)ottosulin(	carllaw6885	Anders Jo-han Holme-fjord)aholmis(	Richard Fritsch)rfricz(
mesutgungor	)ScottHelme(Helme Scott	Carlo Reg-giani)carloreggiani(	Suyash Sri-vas-gaya)suyash5053(
Mark Potter)markonweb(	)alamers(Lamers Arjan	Gøran Breivik)gobrtg(	flo-blg

Guillaume Déflache guillaume-( )d	)toufik-airane(Airane Toufik	Keith Hoodlet)securingdev(	Sinner)SoftwareSinner(
iloving	)TheDauntless(Beckers Jeroen	Joubin Jab-bari)joubin(	yu fu-jioka)fujiokayu(
execjosh)execjosh(	)tomato42(Kario Alicja	Sidney Ribeiro)srjsoftware(	Gabriel Mar-quez)Gby56(
Drew Schulz)drschulz(	bedirhan	muralito	Ronnie Flathers)ropnop(
Philippe Ryck De)philippederyck(	)mal33(Malte	MazeOfAlmonds	Andreas Falk)andifalk(
Javi)javixeneize(	)averell23(Hahn Daniel	borislavc	Robin Wood)digininja(
miro2ns	)jandockx(Dockx Jan	vipinsaini	priyanshukumar3
Nat Sakimura)sakimura(	)BenjaminHae(Häublein Benjamin	unknown user-from	Ali Ra-mazan TAŞDE-LEN)alitasdln(
Pedro Escaleira)oEscal(	)josh-hemphill(Josh	Tim Würtele)SECtim(	AviD)avidouglen(

SheHacksPurple)shehackspurple(	fcerullo-cycubix	Hector Eryx Paredes Camacho)heryxpc(	Irene Michlin)irene221b(
Y-M Jonah TG-( )Techie	)bahroos(Bahroos Dhiraj	Jef Meijvis)jefmeijvis(	IzmaDoesItbeta
Abdessamad TEMMAR)TmmmmmR(	sectroyer	Soh Satoh)sohsatoh(	regoravalaz
james-t james-( )bitherder	)aramhovsepyan(Hovsepyan Aram	JaimeGomezGat01	YaleGat01aSan
iwatachan)ishowta(	)VinodAnandan(Anandan Vinod	Kevin Kien)KevinKwok(	paul-williamson-sw(op
endergzr	)Rado0z(Alshamamri Radhwan	Grant Ongers)rewtd(	Cure53)cure53(
AliR2Linux	)GangGreenTemperTatum(Dawson Ads	Williamgabe Reyor)BillReyor(	)gcrow(
mascotter	luissaiz	Suren Manukyan vx-( )sec	Piotr Gliźniewicz)pglizniewicz(
Tadeusz Wachowski)tadeuszwachowski(	)andesec(Nate aka Nasir	settantasette	Lars Haulin)LarsH(

Terence Eden)edent(	JasmineScholz	Arun Sivadasan)teavanish(	Yusuf GÜR)yusuffgur(
Troy Marshall)troymarshall(	)tprynn(Prynn Tanner	Nick K.)nickific(	raoul361
Azeem Ilyas)TheAxZim(	)avioli(Stamatov Evo	Tim Pot-ter)timpotter87(	Gavin Ray)GavinRay97(
monis)demideus(	)MarcinHoppe(Hoppe Marcin	Grambuly)ramshazak(	Jordan Liggitt)computersarebad(
Jason Rogers jason-( )invision	)benbhall(Hall Ben	JamesPoppyck)jamesly(	WhiteHackLabs)whitehacklabs(
Alex Gaynor)alex(	)filipvanlaenen(Laenen van Filip	jeurgen	GraoMelo
Andreas Kurtz)ay-kay(	)TomTervoort(Tervoort Tom	old man)deveras(	Marco Schnüriger)marcortw(
stiiin	)teaminfoseclearn(infoseclearn	hljupkij	Noe)nmarher(
Lyz)lyz-code(	)mrtnrdl(Riedel Martin	KIM Jae-suck)tcaesvk(	Barbara Schachner)bschach(
René Reuter)AresSec(	carhackpils	Tyler)tyler2cp(	Hugo)hasousa(
Wouter Bloeyaert)Someniak(	)markderijkinfosec(Rijk de Mark	Ramin)picohub(	Philip D. Turner)philipdturner(

Will Chatham)willc(